The Institute of Chartered Accountants of Bangladesh (ICAB)

IT Governance



Workbook
For CA Professional Level Exams

CA BANGLADESH

THE INSTITUTE OF CHARTERED ACCOUNTANTS OF BANGLADESH

www.icab.org.bd

The Institute of Chartered Accountants of Bangladesh (ICAB)

IT Governance

Workbook

Professional Level

CA™ BANGLADESH | THE INSTITUTE OF CHARTERED ACCOUNTANTS OF BANGLADESH

www.icab.org.bd

IT Governance

The Institute of Chartered Accountants of Bangladesh

First edition 2026

All rights reserved. No part of this publication may be reproduced, stored in a retrieval system or transmitted in any form or by any means, graphic, electronic or mechanical including photocopying, recording, scanning or otherwise, without the prior written permission of the publisher.

The content of this publication is intended to prepare students of the ICAB examinations, and should not be used as professional advice.

Disclaimer: To the extent permitted by applicable law, ICAB expressly disclaims all liability, howsoever arising from this publication or any translation thereof whether in contract or otherwise (including, but not limited to, liability for any negligent act or omission) to any person in respect of any claims or losses of any nature including direct, indirect, incidental or consequential loss, punitive damages, penalties or costs.

While every effort is made to ensure the accuracy and completeness of the information provided, unintentional errors or omissions may occur. The content is provided "as is" without warranties of any kind. We appreciate the understanding of all readers and encourage to notify us of any inaccuracies so that they can be corrected in future editions.

Contents

IT Governance iv
Key resources v
Professional skills required by the ACA qualification vi
Sustainability in the ACA Qualification vii
ACA and Technology xvi

1 Information Technology Policies and Laws 1
2 Management Information Systems and Developments in Technology 119
3 IT Governance, Organization and Strategy 191
4 Information Systems Security 213
5 Information Systems Auditing 283

Questions within the Workbook should be treated as preparation questions, providing you with a firm foundation before you attempt the exam-standard questions.

**** Italic denotes changes***

IT Governance

Module aim

This course provides an overview of key policies, laws, and technologies shaping modern information systems. Topics include national IT policies, legal and ethical issues, decision support, and data analytics. Students will explore emerging technologies like AI, blockchain, fintech, and big data along with IT governance, risk management, and performance monitoring. The course also covers security frameworks, access control, forensics, and IS auditing aligned with ISACA standards.

This course equips students with a solid understanding of the legal, ethical, and technological foundations of modern information systems. It prepares them to navigate and manage emerging digital tools and frameworks, ensuring they can make informed decisions in areas like cyber security, data analytics, and IT governance.

- Explain the implementation of the various legal, ethical and social issues and policies regarding Information Systems;
- Demonstrate how MIS, DSS, EIS, expert systems, AI and big data can be applied to deci sion-making situations faced by business managers and professionals;
- Understand IT governance, management and control frameworks, standards, and strategic alignment of IT with business goals;
- Identify the threats and defenses for business information systems and understand protection of sensitive data through access control, encryption, and policies;
- Demonstrate knowledge necessary to audit information systems in accordance with IS audit standards to assist organisations in protecting and controlling IS.

Method of assessment

IT Governance exam is 4 hours long. The exam consists of 150 questions worth one marks each, covering the areas of the syllabus in accordance with the weightings set out in the specification grid. The questions are presented in the form of multiple choice, or multiple response.

Ethics and professional scepticism

Ethical thinking will be required across all areas of the syllabus. A specific weighting is given in the syllabus area 'Key issues for the accountancy profession and business' which includes ethics and business ethics, in the table below. The policies and procedures necessary to promote an ethical culture will be emphasised. Students will be expected to apply professional scepticism. Additionally, under the syllabus area 'The external environment of business', students must demonstrate an awareness of the needs of different stakeholders, and in the 'Technology and data analysis' area they must be able to identify types of data bias, their causes and effects.

Sustainability

Knowledge of core sustainability concepts is a requirement for the professional accountant. Students will be expected to understand the overarching concept of sustainability and why people and planet are strategically important to business. Understanding how the ICAB chartered accoun tant can contribute to and help manage sustainability risks, opportunities and regulations (particular ly in terms of information flows) is fundamental to understanding the context of the ACA sustainabili ty content.

Whilst climate is the predominant issue of our time, with this often representing a key area of risk (and opportunity) for business, students will be introduced to sustainability topics beyond climate that can also prove financially material for companies.

Specification grid

This grid shows the relative weightings of subjects within this module and should guide the relative study time spent on each. Over time the marks available in the assessment will equate to the weightings below, while slight variations may occur in individual assessments to enable suitably rigorous questions to be set.

	Weighting (%)
1 Information Technology Policies and Laws	15
2 Management Information Systems and Developments in Technology	15
3 IT Governance, Organization and Strategy	20
4 Information Systems Security	25
5 Information Systems Auditing	25
Total	100

Key resources

Whether you're studying the ICAB, ACA qualification with an employer, at university, independently, or as part of an apprenticeship, we provide a wide range of resources and services to help you in your studies.

ACA students, you can access dedicated exam resources, guidance and information for the ACA qualification via your dashboard at icaew.com/dashboard.

ACA students, you can access dedicated exam resources, guidance and information for the ACA qualification at https://www.icab.org.bd Syllabus and technical knowledge grids

The syllabus presents the learning outcomes for each exam and should be read in conjunction with the relevant technical knowledge grids.

Exam support

A variety of exam resources and support have been developed to help you through your studies and each exam. This includes expert guides, sample exams, hints and tips, marks plans, and more.

Student support team

Our student support team is here to help and advise you, so do not hesitate to get in ICAB education team or do visit ICAB website: www.icab.org.bd

Professional skills required by the ACA qualification

The following professional skills areas are present throughout the ACA qualification.

Skill area	Overall objective
Assimilating and using information	Understand a business or accounting situation, prioritise by determining key drivers, issues and requirements and identify any relevant information.
Structuring problems and solutions	Structure information from various sources into suitable formats for analysis and provide creative and pragmatic solutions in a business environment.
Applying judgement	Apply professional scepticism and critical thinking to identify faults, gaps, inconsistencies and interactions from a range of relevant information sources and relate issues to a business environment.
Concluding, recommending and communicating	Apply technical knowledge, skills and experience to support reasoning and conclusion and formulate opinions, advice, plans, solutions, options and reservations based on valid evidence and communicate clearly in a manner suitable for the recipient.

The level of skill required to pass each exam increases as ACA trainees progress upwards through each Level of the ACA qualification. The skills progression embedded throughout the ACA qualification ensures ACA trainees develop the knowledge and professional skills necessary to successfully operate in the modern workplace which are expected by today's forward-thinking employers.

At Certificate Level, the ACA professional skills which you are expected to demonstrate in the exam are summarised as follows:

Assimilating and using information

- Understanding the situation and the requirements.
- Identifying and using relevant information.
- Identifying and prioritising key issues.

Structuring problems and solutions

- Structuring data.
- Developing solutions.

Applying judgement

- Applying professional scepticism and critical thinking.
- Relating issues to the broader business environment, including ethical issues.

Concluding, recommending and communicating

- Concluding and recommending.
- Communicating.

To help you develop your ability to demonstrate competency in each professional skills area, each chapter of this Workbook includes up to four professional skills guidance points.

Each professional skills guidance point focuses on one of the four ACA professional skills areas and explains how to demonstrate a particular aspect of that professional skill relevant to the topic being studied. It is advised you refer back to the professional skills guidance points while revisiting specific topics and during question practice.

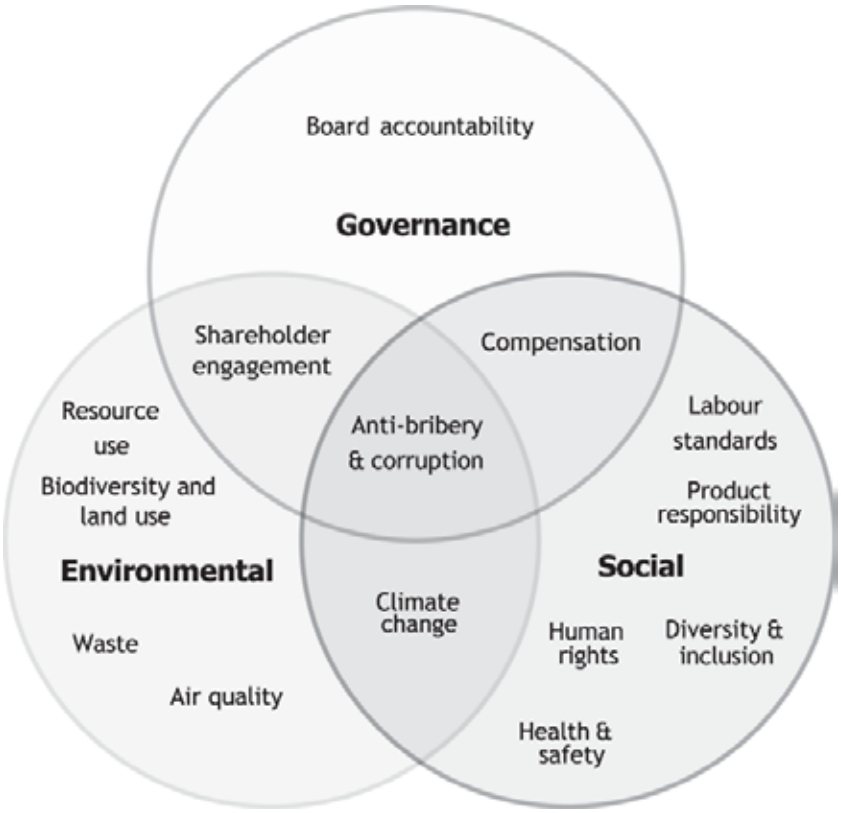
Sustainability in the ACA Qualification

The sustainability landscape has developed at a rapid pace in recent years, with a marked shift from voluntary frameworks and guidance to more mandatory reporting and risk management requirements.

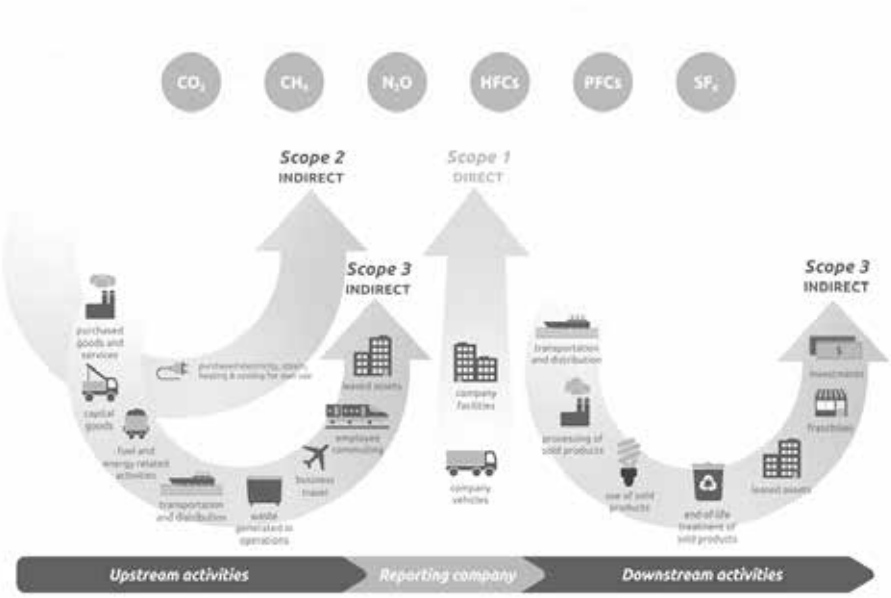
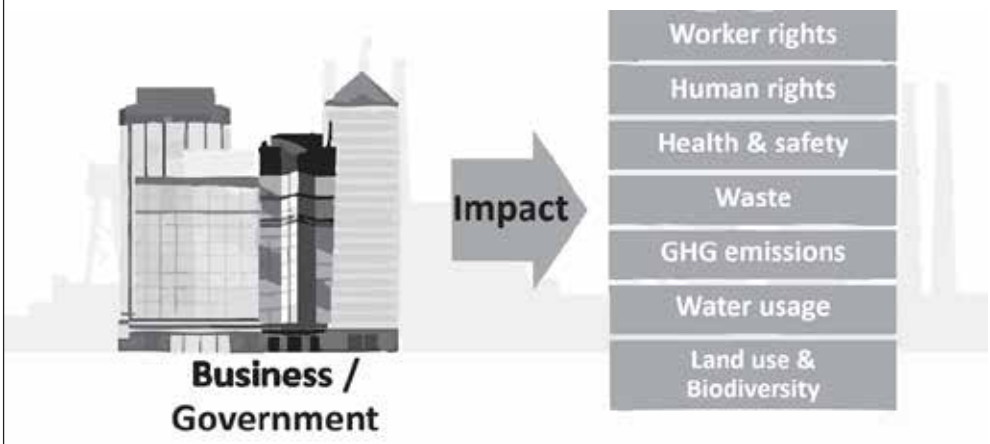
The relevance of sustainability to the role of accountants is growing, with the skillset provided by the CA becoming increasingly valuable to respond to the tide of incoming regulations and increasing investor and broader stakeholder requirements.

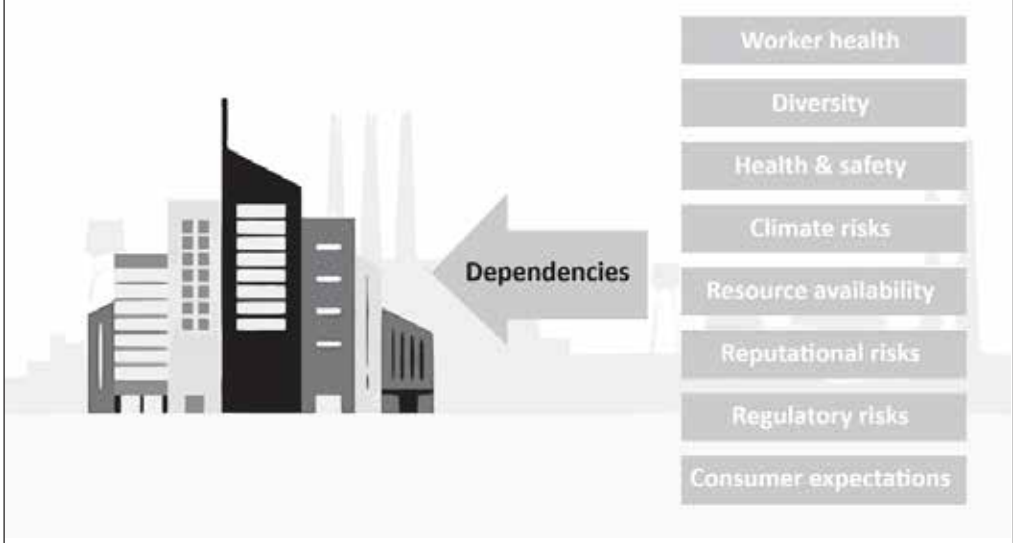
The taxonomy and language around sustainability and its related areas is varied and may as yet be unfamiliar and so there is a need for consistency of sustainability language and underlying concepts. ICAB has created this glossary to provide support for greater consistency and concepts across the ACA exams.

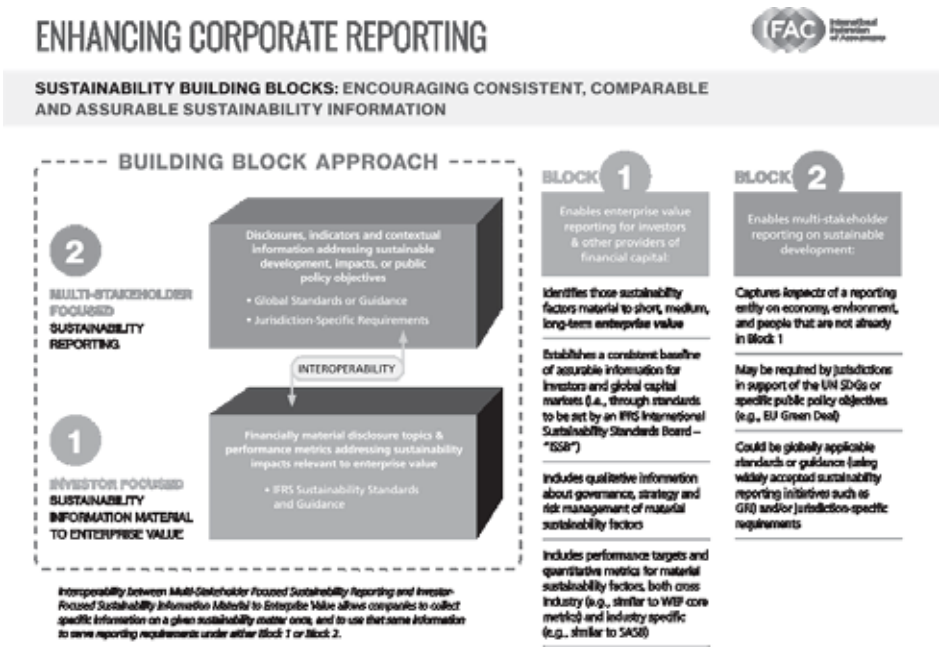
Term	Definition or description
Climate scenario analysis	Environmental issues such as climate change are giving rise to significant risks for businesses. These may arise from physical climate events or the transition to a net-zero carbon economy. Scenario analysis is key to better understanding and managing future risks today, as well as supporting the transition to a net-zero carbon economy. Forward-looking assessments using scenario analysis is recommended by the TCFD to test strategic resilience to future climate shocks. It is not about providing profit forecasts or predicting the future but assures investors that the organisation is prepared for plausible future outcomes.
Companies Act 1994	Under the Companies Act, 1994 of Bangladesh, the Board of Directors is required to place before the company at every Annual General Meeting the balance sheet together with the profit and loss account, and a Board's Report must be attached to every balance sheet laid before the company in general meeting. The Board's Report must address, among other matters, the state of the company's affairs, and, so far as is material for the appreciation of the company's affairs by its members, it must also explain any changes that occurred during the financial year in the nature of the company's business, in its subsidiaries, or in the classes of business in which the company has an interest. In addition, the Board is required to provide the fullest information and explanations regarding any reservation, qualification, or adverse remark contained in the auditors' report.
Corporate Social Responsibility	Corporate Social Responsibility (CSR) is a management concept whereby companies integrate social and environmental concerns in their business operations and interactions with their stakeholders. CSR is generally understood as being the way through which a company achieves a balance of economic, environmental and social imperatives ('Triple-Bottom-Line-Approach'), while at the same time addressing the expectations of shareholders and stakeholders. The term CSR is still occasionally used but ESG is now the more common term. See Chapter 1. (UN Industrial Development Organisation: https://www.unido.org/our-focus/advancing-economic-competitiveness/competitive-trade-capacities-and-corporate-responsibility/corporate-social-responsibility-market-integration/what-csr) This term is used less often in recent times, following a swathe of articles exposing greenwashing practices associated with the movement. 'Sustainability' and 'ESG' tend to be more favoured.

Term	Definition or description
Corporate Sustainability Reporting Directive (CSRD)	In tandem with the development of standards by the ISSB, the EU has adopted the Corporate Sustainability Reporting Directive (CSRD). The CSRD introduces detailed sustainability reporting requirements for large and listed companies and paves the way for mandatory sustainability assurance. The CSRD incorporates the concept of 'double materiality'. This means that companies have to report not only on how sustainability issues might create financial risks for the company (financial materiality), but also on the company's own impacts on people and the environment (impact materiality). This diverges from the ISSB concept of materiality, which remains aligned with financial materiality.
Double materiality	Double materiality means considering not only the sustainability issues that might create financial risks for the company (financial materiality), but also those sustainability issues where a company's activities materially impact on people and the environment (impact materiality). This concept is fundamental to the CSRD.
ESG	Environmental, social and governance (ESG) approaches sustainability-related issues from the perspective of the business itself and considers the impact of these risks on business and enterprise values (rather than on society more broadly). It is a frequently used terminology in corporate and investment communities. At a high level, it is another characterisation of sustainability, providing the 3 lenses of environment, social and corporate governance to use when exploring relevant sustainability factors: 

Term	Definition or description
	When looked at in more detail, however, ESG is distinct from sustainability. It does not include consideration of planetary limits and a social foundation, together considered the 'safe operating space' within which companies, governments and individuals can sustainably operate. According to the Principles for Responsible Investment (PRI) (a United Nations-supported international network of investors) ESG issues faced by organisations can be defined as follows: Environmental: Issues relating to the quality and functioning of the natural environment and natural systems. These include: biodiversity loss; greenhouse gas (GHG) emissions; climate change; renewable energy; energy efficiency; air, water or resource depletion or pollution; waste management; stratospheric ozone depletion; changes in land use; ocean acidification; and changes to the nitrogen and phosphorus cycles. Social: Issues relating to the rights, well-being and interests of people and communities. These include: human rights; labour standards in the supply chain; child, slave and bonded labour; workplace health and safety; freedom of association and freedom of expression; human capital management and employee relations; diversity; relations with local communities; activities in conflict zones; health and access to medicine; HIV/AIDS; consumer protection; and controversial weapons. Governance: Issues relating to the governance of companies and other investee entities. In the listed equity context these include: board structure, size, diversity, skills and independence, executive pay, shareholder rights, stakeholder interaction, disclosure of information, business ethics, bribery and corruption, internal controls and risk management, and, in general, issues dealing with the relationship between a company's management, its board, its shareholders and its other stakeholders. This category may also include matters of business strategy, encompassing both the implications of business strategy for environmental and social issues, and how the strategy is to be implemented. (Source: https://www.unpri.org/Uploads/i/m/n/maindefinitionstoprireportingframewor k_127272_949397.pdf)
ESG vs Sustainability	Sustainability describes a world of thriving economies and just societies based on what nature can afford. It incorporates consideration of both the impacts and dependencies of an organisation and so includes those factors that are material both to the organisation but also to society. Environmental, social and governance (ESG) approaches this issue through the perspective of the business itself and considers only how these risks and opportunities affect a business and its enterprise value. Whilst sustainability includes the concept of environmental and social limits (planetary limits and a social foundation) within which there is a safe operating space, ESG focusses on enterprise value and so does not incorporate considerations of a safe operating space.
GHG emissions – scope 1, 2 & 3	Scope 1, 2 and 3 is a way of categorising different kinds of Greenhouse Gas (GHG) emissions. Scope 1: The GHG emissions that an entity makes directly by eg, running boilers and vehicles. Scope 2: The GHG emissions it makes indirectly by eg, purchasing electricity or energy that is produced on its behalf. Scope 3: All the GHG emissions the entity is indirectly responsible for, up and down its value chain eg, by buying products from its suppliers, and from its products when customers use them.

Term	Definition or description
	 (Source: GHG Protocol Corporate Standard)
Impacts and dependencies	There are two fundamental aspects to sustainability: one is organisations considering how their business positively or negatively affects environmental, societal and governance issues ('impacts');  (Source: ifac.org) the other is considering how environmental, social and governance issues can affect the organisation's ability to create and maintain value ('dependencies').

Term	Definition or description
	 (Source: ifac.org) Information on dependencies is generally more useful for investors, who want to assess how well a company is managing its exposure to long-term ESG risks, and hence assess the value of the company to inform investment decisions. This relates to financial materiality. In this context, investor-useful information comprises financially material disclosure topics & performance metrics addressing sustainability dependencies (and impacts) relevant to enterprise value. Impact information is generally useful for broader stakeholders, including consumers, civil society and employees. The decisions they make are more attuned to information on how an organisation is impacting, for example, livelihoods; deforestation; equality and health. In this context information useful for broader stakeholders includes disclosures, indicators and contextual information addressing sustainable development, impacts, or public policy objectives. Reporting impact information alongside dependencies is aligned with the concept of double materiality. However, a company's impacts can also be financially material due to reputational impacts affecting consumer demand, license to operate etc. These concepts are usefully visualised by the International Federation of Accountants here: https://www.ifac.org/_flysystem/azure- private/publications/files/IFAC-enhancing-corporate-reporting-sustainability-building-blocks.pdf

Term	Definition or description
	 (Source: ifac.org)
Mitigation and adaptation	In the face of increasing climate-related risks, organisations need to focus on both mitigation and adaptation activities. Climate change mitigation means avoiding and reducing emissions of greenhouse gases into the atmosphere to prevent the planet from warming to more extreme temperatures. This involves a transition away from fossil fuels to clean, renewable energy; halting deforestation; and restoring natural habitats to reach net zero emissions. Climate change adaptation refers to adjustments of strategies and actions in response to the effects and future risks of climate change. These risks may be linked to the physical impacts of climate change; but also, the economic impact of a transition towards net zero. Identifying, managing and adapting to these risks is key for the development of a resilient business that can survive, and even thrive in the unprecedented physical and transitional changes ahead.
Paris Agreement and Net Zero	The Paris Agreement is an international treaty on climate change that was signed by nearly 200 countries in 2015 at the United Nations Framework Convention on Climate Change's 21st Conference of Parties, known as COP21. This agreement is generally regarded as the framework for international action towards mitigating climate change and its impacts. The Paris Agreement set the ambition to a maximum of 2°C global temperature change, with the preferred goal of 1.5°C above pre-industrial levels. The term 'net zero' refers to the global reduction of greenhouse gas emissions to net zero by 2050 and is the action required to limit temperature rise to 1.5 degrees Celsius.

Term	Definition or description
Physical and Transition Risks	The risks business and the public sector will face due to climate change can be categorised into two areas: Physical risks, which arise from the physical effects of climate change such as storms, extreme temperatures, wildfires, flooding. Transition risks, which relate to social and economic shifts to a low-carbon economy such as changes to policy, regulation, technology and market.
Stranded assets	'Stranded assets' are assets that are economically stranded, having suffered from 'unanticipated or premature write-downs, devaluations or conversion to liabilities' (Smith School of Enterprise and the Environment, 2014). Stranded assets can be caused by a range of environmental-related risks including: climate change new regulations evolving social norms litigation
Sustainability	Sustainability is a broad term that encompasses an environmental and social focus to improve people's lives and improve the planet for the long-term. The technical definition of sustainability comes from the 1987 Brundtland report, and is defined as development that 'meets the needs of the present without compromising the ability of future generations to meet their own needs'. Frameworks, goals or categories for sustainability can help to break it down for practical application. This is where characterisations such as environmental, social and governance (ESG) or environmental, social and economic factors can be useful. Sustainability is not limited to the environment. Interpretations of the scope of sustainable development have developed from a narrow interpretation which focused on 'green issues' to broader interpretations which include concerns such as: Increasing extremes of poverty and wealth Population growth Biodiversity loss Deteriorating air and water quality Climate change Human rights Bribery and corruption
Sustainable Development Goals (SDGs)	The United Nation's Sustainable Development Goals are a set of 17 goals based on the key environmental, social and economic factors required for peace and prosperity for people and planet. They frame sustainability through the lens of environmental, social and economic characterisations, with a healthy environment underpinning a healthy society, which underpins a healthy economy.
WEF Global Risks Report	The World Economic Forum's annual Global Risks Report explores some of the most severe risks the world may face over the next decade. It is underpinned by their annual Global Risks Perception Survey, bringing together leading insights from over 1,200 experts across the World Economic Forum's diverse network. In 2024, perceptions of the most severe risks on a global scale over the next 2 and 10 years were as follows:

Term	Definition or description
	
WEF IBC metrics	The World Economic Forum (WEF) International Business Council (IBC) metrics provide a useful starting point when considering what sustainability metrics may be relevant for an organisation. The WEF paper 'Measuring Stakeholder Capitalism' was written with the aim of developing a core set of common metrics and disclosures on non-financial factors, for sustainable value creation. It highlights the key themes significant to the planet, society and business and was produced in collaboration with Deloitte, EY, KPMG and PwC in 2020.
	The metrics are categorised into four pillars: Principles of Governance, Planet, People and Prosperity and aligned with their relevant SDGs.

Sustainability and the role of ACA professionals

ICAB Chartered Accountants ('ACA Professionals') recognise that sustainability is at the core of what they do and are capable of actively using their business skills to analyse how to make the new sustainable economy work for their business.

The relevance of sustainability to the role of accountants is growing, with the skillset provided by the ACA becoming increasingly valuable to respond to incoming regulations and increasing investor and broader stakeholder requirements.

Finance and accounting professionals need to move beyond simply measuring and reporting the impact of climate change, environmental regulation, supply chain pressure and rising energy costs.

ACA Professionals need to focus on understanding those implications and integrating them into financial management and business planning by integrating knowledge and understanding the broader implications of environmental, social and governance issues.

Sustainability and decision making

Integrating sustainability to strategic decision making and operational processes is closely related to the skills and experience of ACA Professionals. Examples include:

- Identification and management of risks.
- Compliance with laws, regulations and code of corporate governance.
- Design and operation of management control systems.
- Measurement of environmental, social and governance (ESG) related liabilities and impaired assets, financial instruments and new forms of taxation, such as renewable energy reliefs or carbon emission tariffs and any assurance required thereon.

Where the technical issues extend beyond the accountant's reach then the accountant will work with sustainability experts and other relevant experts when required, which is good practice.

Reporting

The role of ACA Professionals includes the preparation and issuance of reported sustainability information with related activities which include:

- Identifying and evaluating sustainability-related risks and opportunities and advising on solutions to mitigate impacts and risks.
- Considering how current and future sustainability-related risks and opportunities affect an organisation's strategy, operations, financial reporting, regulatory and legal compliance and sustainability reporting requirements.
- Advising on an organisation's specific sustainability metrics to monitor and report.
- Developing methods and solutions to measure sustainability metrics.
- Developing processes and controls to produce and verify the information.
- Preparing sustainability reports and advising on the sufficiency of current sustainability reporting disclosures.
- Providing assurance over mandatory and voluntary sustainability reported information.
- Providing sustainability information that is relevant to strategic and operational decision making.
- Influencing others in positions of power to take appropriate action to safeguard or improve an organisation's sustainability performance.

Applying sustainability related learning in ACA

ACA students can develop these skills by applying a common set of sustainability principles across every ACA module in this complex and fast changing area.

These core principles include, but are not limited to:

- Consider an organisation's sustainability-related dependencies alongside its sustainability-related impacts.
- Clarify that climate change is only one aspect of environmental concerns.
- Consider sustainability-related opportunities alongside risk.
- Consider physical risks as well as transition risks and opportunities.
- Confirm that climate and other environmental issues are considered against the broader context of sustainability.
- Apply a principles-based approach of identifying, evaluating and mitigating sustainability-related risks and opportunities where the su

stainability landscape is complex and lacks a global/mandatory standard.

This can be aided by the application of the following ACA Professional Skills to specific sustainability-related situations:

- Assimilating and using information
- Structuring problems and solutions
- Applying judgement
- Concluding, recommending and communicating

ACA and Technology

Changes in technology have automated many routine aspects of accountancy. However, with these changes in technology also come complexity and risk. Accountants need to adapt and develop new skills to manage the change resulting from the emergence of new technologies.

These and other innovations in technology are likely to have a significant impact on the way that accountants access information, transact and manage business finances. Technology tools can provide information more quickly and often more accurately than humans, but they cannot replicate human intelligence and quality decision-making, or effectively communicate the output of analysis.

Therefore, ACA professionals hold key roles such as validating the source of the data, interpreting, and analysing the outputs, and ensuring the tools support effective management of the organisation. Additionally, as routine and compliance work reduces, the ACA provides a focus on the development of skills that equip ACA professionals to work with the outputs of automated processes, with other specialists, and in a changing world.

While there are many new technology capabilities that have broad application across the business and consumer environment, ICAB has identified seven trends that have the greatest potential to transform the accountancy profession: Artificial Intelligence, Automation, Blockchain, Cybersecurity, Cloud computing, Data and Digital Transformation. These technologies are explored across relevant ACA modules and are supported by the following definitions.

Term	Definition
Artificial Intelligence (AI)	Artificial Intelligence involves the creation and use of advanced computer systems to perform tasks that traditionally require human intelligence. This includes learning from data, reasoning and problem-solving, sensory understanding, language processing, and recognising patterns. AI systems are characterised by their ability to adapt to new information or environments, operate with a degree of autonomy, and make informed decisions. AI often, but not always, involves the use of Machine Learning.
Augmented Reality (AR)	Augmented Reality is a technology that overlays digital information – such as images, text or effects – onto the real world as seen through a device, such as a smartphone or AR glasses.
Automation	Automation is the creation and application of technology to monitor and control the production and delivery of products and services. (Source: The International Society of Automation, 2018) (current BST definition)
Big Data	Big Data is the term that describes those 'datasets whose size is beyond the ability of typical database software to capture, store, manage and analyse.' (Source: McKinsey Global Institute, Big data: The next frontier for innovation, competition and productivity)
Blockchain	Blockchain is a specific form of distributed ledger technology that records data in a decentralised and immutable manner across multiple nodes. This structure makes records tamper-proof and enhances security by removing single points of failure. Blockchains are often public, allowing anyone to verify the data, though private configurations exist for tailored organisational needs. This technology supports cryptocurrencies and has many other applications, including supply chain oversight, digital identity and secure voting.
Chatbot	A chatbot is a software application designed to simulate conversation with human users. It uses natural language processing to understand and respond to user queries.
Cloud accounting	Cloud accounting refers to performing accounting tasks using cloud computing software, often delivered in a software-as-a-service (SaaS) model.
Cloud computing	Cloud computing is on-demand access, via the internet, to computing resources – applications, servers (physical servers and virtual servers), data storage, development tools, networking capabilities and more – hosted at a remote data centre managed by a cloud services provider (or CSP). (Source: https://www.ibm.com/topics/cloud- computing#:~:text=-Cloud%20computing%20is%20on,or%20CSP)

Term	Definition
Cryptocurrency	Cryptocurrency is a digital asset that is designed to function as a medium of exchange and store of value. It operates through a decentralised computer network independent of any central authority, such as a central bank, which does not issue or regulate it. Cryptocurrencies use blockchain technology to achieve decentralisation, transparency and immutability, distinguishing them from traditional monetary systems and financial assets. While they perform roles similar to currency, under IFRS® Accounting Standards they are not recognised as cash or financial instruments but may be accounted for as intangible assets or inventory depending on the circumstances.
Cyber-attack	A cyber-attack is an attempt by individuals or groups to breach the cybersecurity of a specific organisation or individual. This includes any unauthorised access, manipulation or damage to computers, networks, digital systems or data. Cyber-attacks are carried out to steal, alter or destroy information, or to disrupt the operation of systems and services. Common forms of cyber-attacks include phishing, malware, ransomware, denial of service (DoS) and advanced persistent threats (APTs).
Cyber security	Cyber security is the collection of tools, policies, security concepts, security safeguards, guidelines, risk management approaches, actions, training, best practices, assurance and technologies that can be used to protect an organisation's and user's assets against cyber-attack.
Data analytics	Data analytics is the process of collecting, organising and analysing large sets of data to discover patterns and other information which an organisation can use for its future business decisions. (Current MI & BTF)
Data bias	Data is biased when it is not representative of the population that is being analysed. Bias can be inherent in the data collected or it can be introduced by those analysing the data.
Data mining	Data mining is the process of analysing large datasets to discover patterns, relationships and insights. It employs AI and statistical algorithms to identify correlations and trends that transform raw data into actionable information.
Distributed ledger technology (DLT)	Distributed ledger technology (DLT) encompasses a range of decentralised database systems where transactions are recorded and validated across multiple sites. Unlike traditional ledgers, DLT does not rely on a central authority, enhancing transparency and reducing the need for audits. While blockchain is a well-known type of DLT noted for its chained data structure, other forms of DLT may organize data differently and offer varying levels of access and privacy.

Term	Definition
Generative AI	Generative AI refers to a type of artificial intelligence that is designed to generate new content, such as images, text, audio or video, based on patterns learned from a training dataset. Unlike predictive models that focus on making predictions or classifications based on existing data, generative AI models create entirely new data instances that mimic the characteristics of the training data.
Infrastructure-as-a-service (IaaS)	Infrastructure-as-a-service, or IaaS, provides virtual computing resources over the internet. It allows businesses to rent servers, storage space and networking capabilities without needing to own physical infrastructure. Users can manage operating systems, storage and deployed applications while the service provider handles the physical hardware.
Machine Learning	Machine Learning is the capability of computer systems to learn from and make predictions or decisions based on large volumes of training data, without being explicitly programmed to do so. It involves two primary methods: supervised and unsupervised learning. In supervised learning, the model is trained on labelled data, meaning it learns to predict outcomes from input data that has an associated correct answer. Unsupervised learning involves training on data without labelled responses, allowing the model to identify patterns and relationships in the data independently.
Natural Language Processing (NLP)	Natural Language Processing is a branch of artificial intelligence that enables computers to understand, interpret, and generate human language in a way that is both meaningful and useful. By employing techniques from linguistics and computer science, NLP helps machines process and analyse large amounts of natural language data, facilitating tasks such as translation, sentiment analysis, voice-activated services and chatbot responses.
Platform-as-a- service (PaaS)	Platform-as-a-service, or PaaS, offers a development and deployment environment delivered over the internet, allowing users to build, test and deploy applications without the complexity of managing the underlying infrastructure. Providers supply a framework that developers can build upon, including support for software development kits, databases and development tools. PaaS is designed for developers who want to create applications without worrying about hardware, software updates or storage.
Robot	A robot is a programmable machine capable of carrying out complex actions autonomously or semi-autonomously. Typically equipped with sensors and actuators, robots are used in various industries for tasks that require precision and endurance or involve hazardous conditions.

Term	Definition
Process Automation	Robotic Process Automation is a software solution that replicates a business process, designed to do a task that would otherwise be performed manually. It is programmed to follow 'if this, then that' instructions. It runs with other applications rather than replacing them.
Software-as-a- service (SaaS)	Software-as-a-service, or SaaS, is a delivery model that allows users to access software applications over the internet. These applications are hosted and maintained by external providers, offering convenience and reduced IT overhead for users. SaaS solutions are typically subscription-based, with common applications including email, customer relationship management (CRM) and collaboration tools.
Virtual Reality (VR)	Virtual Reality (VR) is a digital technology that creates a simulated environment, immersing users in a three-dimensional space. Users can interact with virtual objects and experience scenarios that mimic real life or imaginative worlds.
Cloud accounting	Cloud accounting refers to performing accounting tasks using cloud computing software, often delivered in a software-as-a-service (SaaS) model.

Information Technology Policies and Laws

Identify the purpose of IT policies, standards and procedures for an organization and the essential elements of each.

Identify the relevant laws, regulations and industry standards affecting the organization

Demonstrate the impact of Ethical and social issues in information systems

Discuss the different provisions of National IT Policy 2018, Information and communication Technology Act 2009.

Management information systems and developments in technology

Identify the changes taking place in the form and use of decision support in business.

Identify the role and reporting alternatives of management information systems.

Describe how online analytical processing can meet key information needs of managers.

Understand the concepts, tools, and applications of Big Data to analyze large datasets, generate business insights, and support informed decision-making in accounting and finance contexts.

Explain the decision support system concept and how it differs from traditional management information systems.

Explain how the following information systems can support the information needs of executives, managers, and business professionals:

Executive information systems

Enterprise information portals

Knowledge management systems

Identify how neural networks, fuzzy logic, genetic algorithms, virtual reality, and intelligent agents can be used in business.

Illustrate the ways expert systems can be used in business decision-making situations.

Understand Big Data as a distributed technology framework that offers scalable, resilient platforms for storing and processing massive datasets, enabling organizations to remotely analyze and leverage data for strategic decision-making.

IT governance, organization and strategy

Evaluate the effectiveness of the IT governance structure to determine whether IT decisions, directions and performance support the organization's strategies and objectives.

Demonstrate various IT governance frameworks such as COBIT (Control Objectives for Information and Related Technologies), ITIL (Information Technology Infrastructure Library), and others and explain how these frameworks help organizations align their IT strategies with business objectives, manage risks, and ensure compliance.

Evaluate the IT strategy, including the IT direction, and the processes for the strategy's development, approval, implementation and maintenance for alignment with the organization's strategies and objectives.

Explain the organization's technology direction and IT architecture and their implications for setting long-term strategic directions.

Cover aspects like the creation, implementation, and enforcement of policies to ensure security, compliance, and effective IT operations.

Identify risk assessment methodologies and the establishment of controls to mitigate identified risks.

Explore the efficient use of IT resources, including human resources, technology, and infrastructure.

Evaluate methods for evaluating IT performance, including metrics, key performance indicators (KPIs), and continuous monitoring.

Information systems security

Identify the components of an organizational framework for security and control.

Demonstrate the most important tools and technologies for safeguarding information resources.

Evaluate the information security and privacy policies, standards and procedures for completeness, alignment with generally accepted practices and compliance with applicable external requirements.

Discuss encryption techniques and their application in protecting data both at rest and during transmission.

Evaluate the design, implementation, maintenance, monitoring and reporting of physical and environmental controls to determine whether information assets are adequately safeguarded.

Information systems auditing

Execute a risk-based IS audit strategy in compliance with IS audit standards to ensure that key risk areas are audited.

Plan specific audits to determine whether information systems are protected, controlled and provide value to the organization.

Conduct audits in accordance with IS audit standards to achieve planned audit objectives.

Communicate audit results and make recommendations to key stakeholders through meetings and audit reports to promote change when necessary.

Conduct audit follow-ups to determine whether appropriate actions have been taken by management in a timely manner.

Chapter 1
Information Technology Policies and Laws

Introduction

Lerning topics

1. Preliminary
2. National ICT policy 2009
3. Social equity
4. Understanding ethical & social issues related to systems

Practice questions and answers with explanations



Introduction

National IT Policy

Bangladesh National Parliament
Dhaka, 23 Ashwin, 1413/8 October, 2006

The following Act undertaken by the Parliament received approval from the President on 23 Ashwin, 1413 corresponding to 8 October 2006 and thus published for the public: -

Act No. 39 of the year 2006

Act prepared to provide legal recognition and security of Information and Communication Technology and rules of relevant subjects

Since it is plausible and necessary to provide legal recognition and security of Information & Communication Technology and prepare rules of relevant subjects;
Thus hereby the following Act has been created:--

1. Preliminary

1. Short Title, extent and commencement.

(i) This Act may be called the Information & Communication Technology Act, 2006.

(ii) It shall extend to the whole of Bangladesh.

2. Definitions.-- In this Act, unless the context otherwise requires,--

(1)" digital signature" means data in an electronic form, which--

(a) is related with any other electronic data directly or logically; and

(b) is able to satisfy the following conditions for validating the digital signature--

(i) affixing with the signatory uniquely;

(ii) capable to identify the signatory;

(iii) created in safe manner or using a means under the sole control of the signatory; and

(iv) related with the attached data in such a manner that is capable to identify any alteration made in the data thereafter.

(2)" digital signature certificate" means a certificate issued under section 36;

(3)" electronic" means electrical, digital, magnetic, wireless, optical, electromagnetic or any technology having equivalent such capability;

(4)" electronic data interchange" means transferring data from one computer to another computer electronically by following a standard for the purpose of organizing information;

(5)" electronic form" with reference to information means any information generated, sent, received or stored in media, magnetic, optical, computer memory, microfilm, computer generated microfiche or similar device or technology;

(6)" electronic gazette" means the official gazette published in the electronic form in addition to official printed & published gazette;

(7)" electronic record" means data, record or data generated, image or sound stored, received or sent in an electronic form or microfilm or computer generated microfiche;

(8)" internet" means such an international computer network by which users of computer, cellular phone or any other electronic system around the globe can communicate with one another and interchange information and can browse the information presented in the websites;

(9)" electronic mail" means information generated electronically and transmitted using internet;

(10)" data" means a representation of information, knowledge, facts, concepts or instructions which are being prepared or have been prepared in a formalized manner, and is intended to be processed, is being processed, or has been processed in a computer system or computer network, and may be in any form including computer printouts, magnetic or optical storage media, punch cards, punched tapes or stored internally in the memory of the computer;

(11)" data message" means electronic, electronic data interchange including optical, electronic mail, telegram, telex, fax, telecopy, short message or created something similar, sent, received or stored information;

(12)" website" means document and information stored in computer and web server which can be browsed or seen by the user through internet;

(13)" computer" means any electronic, magnetic, optical or other high-speed data processing device or system which performs logical, arithmetical and memory functions by manipulations of electronic, magnetic or optical impulses, and includes all input, output, processing, storage, computer software or communication facilities which are connected or related to the computer in a computer system or computer network;

(14)" computer network" means the interconnection of one or more computers through the use of satellite, microwave, terrestrial line, wireless equipment, wide area network, local area network, infrared, WiFi, bluetooth or other communication media; and terminals or a complex consisting of two or more interconnected computers whether or not the interconnection is continuously maintained;

(15)" subscriber" means a person in whose name the Digital Signature Certificate is issued;

(16)" chairman" means a chairman appointed under cyber appeal tribunal of section 82 of this Act;

(17) " civil procedure" means Code of Civil Procedure, 1908 (Act V 0f 1908);

(18) " penal code" means Penal Code, 1860 (Act XLV of 1860);

(19) " prescribed" means prescribed by rules;

(20)" secure signature generating machine or technology" means any signature generating machine or technology subject to the conditions illustrated under section 17;

(21)" addressee" with reference to data message means a person who is intended by the originator to receive the electronic record but does not include any intermediary;

(22)" verification" means such procedure used to identify signatory or authentication of data message;

(23)" originator" with reference to data message means a person who sends or prepares data message before preservation or causes any date message to be sent, generated, stored or transmitted but does not include an intermediary;

(24)" regulation" means regulation prepared under this Act;

(25)" criminal procedure" means Code of Criminal Procedure, 1898 (Act V of 1898);

(26)" person" relates to unique person having any natural entity, partnership business, union, company, body corporate, cooperatives;

(27)" adjudicating officer" means an adjudicating officer of cyber tribunal constituted under section 68 of this Act;

(28)" rule" means rule prepared under this Act;

(29)" medium" means any person sending, receiving, advancing or saving any data message or any service rendering on this data message on behalf of any other person for a particular data message;

(30)" licence" means a licence granted under section 22 of this Act;

(31)" authentication service provider" means certificate issuing authority or any person rendering service related to digital signature.

(32)" certifying authority" means a person or authority who has been granted a licence under section 18 to be read with section 22 of this Act to issue a Digital Signature Certificate:

(33)" certification practice and description of procedure" means certification practice and description of procedure defined by the regulation where practices and procedures are written for issuing Digital Signature Certificate;

(34)" member" means a member of cyber appeal tribunal constituted under section 82 of this Act;

(35)" signatory" means a person providing signature generated through signature generating machine or procedure;

(36)" signature verification machine" means software or hardware used for verifying signature;

(37)" signature generating machine" means software or hardware used generating data for creating signature;

(38)" cyber tribunal" or "tribunal" means a cyber tribunal constituted under section 82 of this Act;

(39)" cyber appeal tribunal" means a cyber appeal tribunal constituted under section 82 of this Act.

3. Domination of the Act. Where any law provides whatever anything it contained, the rules of this Act shall be in force;
4. Inter-state application of the Act.
   (1) If any person commits offence or contravention under this Act outside of Bangladesh which is punishable under this Act if he commits it in Bangladesh, then this Act shall apply as such he commits offence or contravention in Bangladesh;
   (2) If any person commits offence or contravention in Bangladesh under this Act from outside Bangladesh using a computer, computer system or computer network located in Bangladesh, then this Act shall apply as such the entire process of the offence or contravention took place in Bangladesh;
   (3) If any person from within Bangladesh commits offence or contravention outside of Bangladesh under this Act, then this Act shall apply against him as such the entire process of the offence or contravention took place in Bangladesh;

1.1 Digital Signature & Electronic Records

5. Authentication of electronic records by digital signature - (1) Subject to the provision of sub-section (2) of this section, any subscriber may authenticate an electronic record by affixing his digital signature.
   (2) The authentication of electronic record shall be effected by the use of technology neutral system or standard authentic signature generating machine or strategy.
6. Legal recognition of electronic records - Where any law provides that information or any other matter shall be in writing or in the typewritten or printed form, then, notwithstanding anything contained in such law, such information or matter is rendered or made available in an electronic form:
   Provided that such information or matter is accessible so as to be usable for a subsequent reference.
7. Legal recognition of digital signatures - Where any law provides that--
   (a) any information or any other matter shall be authenticated by affixing the signature; or
   (b) any document shall be authenticated by signature or bear the signature of any person;
   then, notwithstanding anything contained in such law, such information or matter is authenticated by means of digital signature affixed in defined manner or so is the case of any document.
8. Use of electronic records and electronic signatures in Government and its agencies -
   (1) Where any law provides for-
      (a) the filing of any form, application or any other document with any office, authority, body or agency owned or controlled by the appropriate Government in a particular manner;
      (b) the issue or grant of any licence, permit, sanction, approval or order by whatever name called in a particular manner;
      (c) the receipt or payment of money in a particular manner;
      then, notwithstanding anything contained in such law, filing, issue, grant of the document and receipt and payment of money, as the case may be, is effected by means of prescribed electronic form.
   (2) The manner and format in which such electronic records shall be filed, created or issued and the manner or methods of payment of any fee or charges for creation and filing shall be fixed by the rules for fulfilling the purposes of this section.

9. Retention of electronic records -

(1) Where any law provides that any document, record or information shall be retained for any specific period, then such requirement shall be deemed to have been satisfied if such documents, records or information, as the case may be, are retained in the electronic form if the following conditions are satisfied-

(a) the information contained therein remains accessible so as to be usable for a subsequent reference;

(b) the electronic record is retained in the format in which it was originally generated, sent or received, or in a format which can be demonstrated to represent accurately the information originally generated, sent or received;

(c) such information, if any, as enables the identification of the origin and destination of an electronic record and the date and time when it was sent or received, is retained:

Provided that this sub-clause does not apply to any information which is automatically generated solely for the purpose of enabling and electronic record to be dispatched or received.

(2) A person may satisfy the requirements referred to in sub-section (1) of this section by using the services of any other person, if the conditions in clauses (a) to (c) of that sub-section are complied with.

(3) Nothing in this section shall apply to any law that expressly provides for the retention of documents, records or information.

10. Electronic gazette - Where any law requires that any law, rule, regulation, order, bye-law, notification or any other matter shall be published in the Official Gazette, then, such requirement shall be deemed to have been satisfied if such law, rule, regulation, order, bye-law, notification or any other matter is published in the Official Gazette or Electronic Gazette:

Provided that where any law, rule, regulation, order, bye-law, notification or any other matter is published in the Official Gazette or the Electronic Gazette, the date of publication shall be deemed to be the date of the Gazette which was first published in any form.

11. No liability on Government to accept documents in electronic form - Nothing contained in this Act shall by itself compel any Ministry or Department of the Government or any authority or body established by or under any law or controlled or funded by the Government to accept, issue, create, retain and preserve any document in the form of electronic records or effect any monetary transaction in the electronic form.

12. Power of Government to make rules in respect of digital signatures - The Government may, by notification in the Official Gazette and in additionally optionally in the Electronic Gazette, make the following rules (all or any of them) to prescribe for the purposes of this Act-

(a) the type of digital signature;

(b) the manner and format in which the digital signature shall be affixed;

(c) the manner and procedure which facilitates identification of the person affixing the digital signature;

(d) the control processes and procedures to ensure adequate integrity, security and confidentiality of electronic records and payments; and

(e) any other matter which is necessary to give legal effect to digital signatures.

1.2 Attribution, acknowledgement and despatch of electronic records

13. Attribution -

(1) An electronic record shall be that of the originator it was sent by the originator himself.

(2) As between the originator and the addressee, an electronic record shall be deemed to be that of the originator if it was sent-

(a) by a person who had the authority to act on behalf of the originator in respect of that electronic record; or

(b) by an information system programmed by or on behalf of the originator to operate automatically.

(3) As between the originator and the addressee, an addressee shall be entitled to regard an electronic record as being that of the originator and to act on that assumption if--

(a) in order to ascertain whether the electronic record was that of the originator, the addressee properly applied a procedure previously agreed to by the originator for that purpose; or

(b) the information as received by the addressee resulted from the actions of a person whose relationship with the originator or with any agent of the originator enabled that person to gain access to a method used by the originator to identify the electronic records as its own.

(4) Sub-section (3) of this section shall not apply--

(a) from the time when the addressee has received notice from the originator that the electronic record is not that of the originator, and had reasonable time to act accordingly;

(b) in such case as in clause (b) of section (3) of this section, at any time when the addressee knew or ought to have known, after using reasonable care or using agreed procedure, that the electronic record was not that of the originator;

(c) if, in all circumstances of the case, it is unconscionable for the addressee to regard the electronic record as being that of the originator or to act on that assumption.

(5) Where an electronic record is that of the originator or is deemed to be that of the originator, or the addressee is entitled to act on that assumption, then, as between the originator and the addressee, the addressee shall be entitled to regard the electronic record received as being what the originator intended to send, and to act on that assumption.

(6) Whatever is there in sub-section (5) of this section, the addressee shall not be so entitled when the addressee knew or should have known, after exercising reasonable care or using any agreed procedure, that the transmission resulted in any error in the electronic record as received.

(7) The addressee shall be entitled to regard each electronic record received as separate electronic record and to act on that assumption; however, it shall not be applicable for the following electronic records--

(a) duplicates of other electronic records created by the addressee; and

(b) the addressee knew or should have known, after exercising reasonable care or using any agreed procedure, that the electronic record was a duplicate.

14. Acknowledgement of receipt -

(1) Sub-sections (2), (3) & (4) of this section shall apply where, on or before sending an electronic record, or by means of that electronic record, the originator has requested or has agreed with the addressee that receipt of the electronic record be acknowledged.

(2) Where the originator has not agreed with the addressee that the acknowledgement be given in a particular form or by a particular method, an acknowledgement may be given by-

(a) any communication by the addressee, automated or otherwise; or

(b) any conduct of the addressee, sufficient to indicate to the originator that the electronic record has been received.

(3) Where the originator has stipulated that the electronic record shall be conditional on receipt of the acknowledgement, then, until the acknowledgement has been received, the electronic record shall be deemed to have been never sent by the originator.

(4) Where the originator has not stipulated that the electronic record shall be conditional on receipt of the acknowledgement, and the acknowledgement has not been received by the originator within the time specified or agreed or, if no time has been specified or agreed, within a reasonable time, the originator -

(a) may give notice to the addressee stating that no acknowledgement has been received and specifying a reasonable time by which the acknowledgement must be received; and

(b) if no acknowledgement is received within the time specified in clause (a) of this sub-section, may, after giving notice to the addressee, treat the electronic record as though it has never been sent.

(5) Where the originator receives the addressee's acknowledgement of receipt, it shall be presumed that the related electronic record was received by the addressee, but that presumption shall not imply that the content of the electronic record corresponds to the content of the record received.

(6) Where the received acknowledgement states that the related electronic record met technical requirements, either agreed upon or set forth in applicable standards, it shall be presumed that those requirements have been met.

15. Time and place of dispatch and receipt of electronic record -

(1) Save as otherwise agreed to between the originator and the addressee -

(a) the time of dispatch of an electronic record shall be determined when it enters a computer or electronic machine or resource out side the control of the originator;

(b) the time of receipt of an electronic record shall be determined as follows, namely:-

(i) if the addressee has designated an electronic device or resource for the purpose of receiving electronic records, receipt occurs,-

(a) at the time when the electronic record enters the designated electronic device or resource;

(b) if the electronic record is sent to an electronic device or resource of the addressee that is not designated electronic device or resource, at the time when the electronic record is retrieved by addressee;

(ii) if the addressee has not designated an electronic device or resource along with the specified timings, if any, receipt occurs when the electronic record enters the electronic device or resource.

(c) An electronic record is deemed to be dispatched at the place where the originator has his place of business, and is deemed to be received at the place where the addressee has his place of business.

(2) The provision of sub-section (1) (b) of this section shall apply notwithstanding that the place where the computer resource is located may be different from the place where the electronic record is deemed to have been received under sub-section (1) (c) of this section.

(3) For the purposes of this section-

(a) if the originator or the addressee has more than one place of business, the principal place of business shall be the place of business;

(b) if the originator or the addressee does not have a place of business, his usual place of residence shall be deemed to be the place of business;

Explanation- "principal place of business" or "usual place of residence" in relation to a body corporate or body incorporated means the place where it is registered.

1.3 Secure electronic records & digital signatures

16. Secure electronic record- Where any security procedure has been applied to an electronic record at a specific point of time, then such record shall be deemed to a secure electronic record from such point of time to the time of verification.

17. Secure digital signature.

(1) If, by application of a security procedure agreed to by the parties concerned, it can be verified that a digital signature, at the time it was affixed, was-

(a) unique to the person affixing it;

(b) capable of identifying the person affixing it; and

(c) created in manner or using a means under the sole control of the person affixing; then such digital signature shall be deemed to be a secure digital signature as per sub-section (2).

(2) Despite the fact of sub-section (1), the digital signature would be invalidated if the electronic record was altered relating to this very digital signature.

1.4 Controller & certifying authorities

18. Certifying Authorities Controller and other officers-

(1) For the purpose of this Act, the Government may, by notification in the Official Gazette and additionally optionally in Electronic Gazette, appoint a Controller and such number of Deputy Controller(s) and Assistant Controller(s) as it deems fit within 90 days of the enactment of this law.

(2) The Controller shall discharge such functions as are vested in him under this Act under the general superintendence and control of the Government.

(3) The Deputy Controllers and the Assistant Controllers shall perform such functions as are assigned to them by the Controller under the general superintendence and control of the Controller.

(4) The qualifications, experience and terms & conditions of service of Controller, Deputy Controllers and Assistant Controllers shall be such as may be prescribed by the Service Code.

(5) The Head Office of the Controller shall be located at Dhaka and as the Government may think fit may establish Branch Offices at such places for fixed time duration or permanently.

(6) There shall be a seal of the office of the controller, which will be used in places approved by the Government and other defined areas.

(7) For the purpose of preserving all electronic records under this Act there shall be a room in the Office of Controller which will be named as "electronic records repository room."

19. Functions of the Controller- The Controller may perform all or any of the following functions, namely:-

(a) exercising supervision over the activities of the Certifying Authorities;

(b) laying down the standards to be maintained by the Certifying Authorities;

(c) specifying the qualifications and experience which employees of the Certifying Authorities should possess;

(d) specifying the conditions subject to which the Certifying Authorities shall conduct their business;

(e) specifying the contents of written, printed or visual materials and advertisements that may be used in respect of a Digital Signature Certifying;
(f) specifying the form and content of a Digital Signature Certificate;
(g) specifying the form and manner in which accounts shall be maintained by the Certifying Authorities;
(h) specifying the terms and conditions subject to which auditors may be appointed and the remuneration to be paid to them for auditing the Certifying Authorities;
(i) facilitatining the establishment of any electronic system by a Certifying Authority either solely or jointly with other Certifying Authorities and regulation of such systems;
(j) specifying the manner in which the Certifying Authorities shall conduct their dealings with the subscribers;
(k) resolving any conflict of interests between the Certifying Authorities and the subscribers;
(l) laying down the duties and responsibilities of the Certifying Authorities;
(m) maintaining computer based databases, which--
(i) contain the disclosure record of every Certifying Authority containing such particulars as may be specified by regulations; and
(ii) shall be accessible to the member of the public;
(n) perform any other function under this Act or Codes prepared under this Act.

20. Recognition of foreign Certifying Authorities.
(1) Subject to such conditions and restrictions as may be specified by regulations, the Controller may, with the previous approval of the Government, and by notification in the Official Gazette and additionally optionally in Electronic Gazette, recognize any foreign Certifying Authority as a Certifying Authority for the purposes of this Act.
(2) Where any Certifying Authority is recognized under sub-section (1) of this section, the Digital Signature Certificate issued by such Certifying Authority shall be valid for the purposes of this Act.
(3) The Controller may, if he is satisfied that any Certifying Authority has contravened any of the conditions and restrictions subject to which it was granted recognition under sub-section (1) of this section, for reasons to be recorded in writing, by notification in the Official Gazette and additionally optionally in Electronic Gazette, revoke such recognition.

21. Controller to act as repository-
(1) The Controller shall be the repository of all Digital Signature Certificates issued under this Act.
(2) The Controller shall ensure that the secrecy and security of the digital signature are assured and in order to do so shall make use of hardware, software and procedures that are secure from intrusion and misuse and follow such standards as may be prescribed.

22. Licence to issue Digital Signature Certificate.
(1) Subject to the provision of sub- section (2) of this section, any person may make an application to the Controller for a licence to issue Digital Signature Certificates.
(2) No licences shall be issued under sub-section (1) of this section unless the applicant fulfills such requirements with respect to qualification, expertise, manpower, financial resources and other infrastructure facilities which are necessary to issue Digital Signature Certificates.
(3) A licence granted under sub-section (1) of this section-
(a) shall be valid for certain period;
(b) shall be delivered subject to fulfilling defined terms and conditions; and
(c) shall not be transferable or heritable.

23. Application for licence
(1) Every application for issue of a licence shall be submitted in a prescribed form.
(2) Every application of sub-section (1) of this section shall be accompanied by-

(a) a certification practice statement;
(b) necessary documents with respect to identification of the applicant;
(c) evidence of payment of defined fees;
(d) such other documents as may be prescribed.

24. Renewal of licence.—Licence issued under this Act shall be renewed automatically for a certain period subject to paying fees in a prescribed procedure.

25. Procedure for grant or rejection of licence.—The Controller may, on receipt an application under sub-section (1) of section 22 of this Act, after considering the documents accompanying the application and such other factors as he deems fit, grant the licence or reject the application:
Provided that no application shall be rejected under this section unless the applicant has been given a reasonable opportunity of presenting his case.

26. Revocation and suspension of licence.
(1) The Controller may suspend or revoke any licence under this Act, if he is satisfied after making such inquiry, as he may think fit, that a Certifying Authority has—
(a) made statement in, or in relation to, the application for the issue or renewal of the licence, which is incorrect or false in material particulars;
(b) failed to comply with the terms and conditions subject to which the licence was granted;
(c) failed to main the standards specified under section 21 (2) of this Act;
(d) contravened any provisions of this Act, rules, regulations or orders made thereunder.
(2) No licence shall be revoked unless the Certifying Authority has been given reasonable opportunity of showing cause against the proposed revocation under sub-section (1) of this section.
(3) The Controller may, if he has reasonable cause to believe that there is any ground for revoking a licence under sub-section (1) of this section, by or, suspend such licence temporarily pending the completion of any enquiry ordered by him.
(4) No licence shall be suspended for a period exceeding 14 (fourteen) days unless the Certifying Authority has been given a reasonable opportunity of showing cause against the propose suspension under sub-section (3) of this section;
(5) A Certifying Authority whose licence has been suspended temporarily shall not issue any Digital Signature Certificate during the period of such suspension.

27. Notice of revocation or suspension of licence.
(1) Where the licence of a Certifying Authority is revoked or suspended temporarily, the Controller shall publish notice of such revocation or suspension, as the case may be, in the database maintained by him.
(2) Where one or more repositories are specified, the Controller shall publish notices of such temporarily revocation or suspension, as the case may be, in all such repositories:
Provided that the database containing the temporarily notice of such revocation or suspension, as the case may be, shall be made available electronically including website or any other medium which shall be accessible round the clock.

28. Power to delegate.—The Controller may, in writing, authorize the Deputy Controller, Assistant Controller or any other officer to exercise any of the power of the Controller under this Act.

29. Power to investigate contraventions.
(1) The Controller or any officer authorized by him in this behalf shall take up for investigation any contravention of the provisions of this Act, rules or regulations made thereunder.
(2) The Controller or any officer authorized by him in this behalf shall, for the purposes of sub-section (1) of this section, have the same power as are vested in a Civil Court under the Code of Civil Procedure, when trying a suit in respect of the following matters, namely:-

(a) discovery and inspection;
(b) enforcing the attendance of any person and examining him on oath or affirmation;
(c) compelling the production of any document; and
(d) issuing commissions for the examination of witness.

30. Access to computers and data.
(1) Without prejudice to the provisions of section 45 of this Act the Controller or any officer authorized by him shall, if he has reasonable cause to suspect that any contravention of the provisions of this Act or rules and regulations made thereunder has been committed, have access to any computer system, any apparatus, data or any other material connected with such system, for the purpose of searching or causing a search to be made for obtaining any information or data contained in or available to such computer system.
(2) For the purpose of sub-section (1) of this section the Controller or any officer authorized by him may, by order, direct any person in charge of, or otherwise concerned with the operation of, the computer system, data apparatus or material, to provide him with such reasonable technical and other assistance as he may consider necessary.
(3) If authorization has been given to a person, the authorized person shall oblige to assist as instructed under sub-section (1) of this section.

31. Certifying Authority to follow certain procedures.—Every Certifying Authority shall—
(a) make use of hardware, software and procedures that are secure from intrusion and misuse;
(b) provide a reasonable level of reliability in its services which are reasonable suited to the performance of intended function under this Act;
(c) adhere to security procedures to ensure that the secrecy and privacy of digital signatures are assured; and
(d) observe such other standards as may be specified by regulations.

32. Certifying Authority to ensure compliance of the Act, rules, regulations, etc.—Every Certifying Authority shall ensure that every person employed or otherwise engaged by it complies, in the course of his employment or engagement, with the provisions of this Act, rules, regulations or orders made thereunder.

33. Display of licence.—Every Certifying Authority shall display its licence at a conspicuous place of the premises in which it carries on its business.

34. Surrender of licence.—Every Certifying Authority whose licence is revoked or suspended, as the case may be, shall immediately after such revocation or suspension, as the case may be, surrender the licence to the Controller.

35. Disclosures.
(1) Every Certifying Authority shall disclose in the manner specified by regulations—
(a) Digital Signature Certificate used by the Certifying Authority to digitally sign another Digital Signature Certificate;
(b) any certification practice statement relevant thereto;
(c) notice of the revocation or suspension of its Certifying Authority certificate, if any; and
(d) any other fact the materially and adversely affects either the reliability of a Digital Signature Certificate, which the Certifying Authority has issued, or the Certifying Authority's ability to perform its service.
(2) Where in the opinion of the Certifying Authority any event has occurred or any situation has arisen which may materially and adversely affect the integrity of its computer system or the conditions subject to which a Digital Signature Certificate was granted, then the Certifying Authority shall use reasonable efforts to notify any person who is likely to affected by the occurrence, or act in accordance with the procedure specified in its certification practice statement to deal with such event or situation.

36. Issue of certificate.

The Certifying Authority may issue a certificate to a prospective subscriber only after the Certifying Authority–

(a) has received an application in the prescribed form requesting for issuance of a certificate from the prospective subscriber;

(b) if it has a certification practice statement, complied with all of the practices and procedures set forth in such certification practice

(c) if the prospective subscriber is the person to be listed in the certificate to be issued;

(d) if all information in the certificate to be issued is correct; and

(e) whether the prospective subscriber paid such fees as may be prescribed for issuance of certificate.

37. Representations upon issuance of certificate.

(1) By issuing a certificate, the Certifying Authority represents to any person who reasonably relies on the certificate or digital signature described in the certificate that the Certifying Authority has issued the certificate in accordance with any applicable certification practice statement incorporated by reference in the certificate, or of which the relying person has notice.

(2) In the absence of such certification practice statement mentioned in sub-section (1) of this section, the Certifying Authority represents that it has confirmed that–

(a) the Certifying Authority has complied with all applicable requirements of this Act and the rule and regulations made thereunder in issuing the certificate, and if the Certifying Authority has published the certificate or otherwise made it available to such relying person, that the subscriber listed in the certificate has accepted it;

(b) all information in the certificate is accurate, unless the Certifying Authority has stated in the certificate or incorporated by reference in the certificate a statement that the accuracy of specified information is not confirmed;

(c) the Certifying Authority has no knowledge of any material fact which if it had been included in the certificate would adversely effect the reliability of the representations in clauses (a) and (b) of this sub-section.

(3) Where there is an applicable certification practice statement which has been incorporated by reference in the certificate, or of which the relying person has notice, sub-section (2) of this section shall apply to the extent that the representations are not inconsistent with the certification practice statement.

38. Revocation of Digital Signature Certificate.

(1) A Certifying Authority shall revoke a Digital Signature Certificate issued by it–

(a) where the subscriber or any person authorized by him makes a request to that effect; or

(b) upon the death of the subscriber; or

(c) where the subscriber is a firm or a company, if it has been dissolved or wound up or has otherwise ceased to exist.

(2) Subject to the provisions of sub-section (3) of this section and without prejudice to the provisions of sub-section (1) of this section, a Certifying Authority may revoke a Digital Signature Certificate which has been issued by it at any time if it is of opinion that–

(a) a material fact represented in the Digital Signature Certificate is false or has been concealed;

(b) a requirement for issuance of the Digital Signature Certificate was not satisfied;

(c) the Certifying Authority's identification/security system was compromised in a manner materially or as a whole affecting the Digital Signature Certificate's reliability;

(d) the subscriber has been declared insolvent by a competent court or authority.

(3) A Digital Signature Certificate shall not be revoked unless the subscriber has been given an opportunity of being heard in the matter.

(4) On revocation of a Digital Signature Certificate under this section, the Certifying Authority shall communicate the same to the subscriber.

39. Suspension of Digital Signature Certificate.

(1) Subject to the provisions of sub-section of this section, the Certifying Authority which has issued a Digital Signature Certificate may suspend such Digital Signature Certificate–

(a) on receipt of a request to that effect from the subscriber listed in the Digital Signature certificate or any person duly authorized to act on behalf of that subscriber;

(b) if it is opinion that the Digital Signature Certificate should be suspended in public interest.

(2) A Digital Signature Certificate shall not be suspended for a period exceeding 30 (thirty) days without giving the subscriber a notice under sub-section 1 (b) of this section.

(3) Certifying Authority can suspend the Digital Signature Certificate, if the Authority is satisfied on the ground that the explanation given by the subscriber in response to the notice of sub-section of this section is not acceptable.

(4) On suspension of a Digital Signature Certificate under this section, the Certifying Authority shall communicate the same to the subscriber.

40. Notice of revocation or suspension.

(1) Where a Digital Signature Certificate is revoked under section 38 of this Act or suspended under section 39 of this Act, the Certifying Authority shall publish a notice of such revocation or suspension, as the case may be, in the repository specified in the Digital Signature Certificate for publication of such notice.

(2) Where one or more repositories are specified, the Certifying Authority shall publish notices of such revocation or suspension, as the case may be, in all such repositories.

1.5 Duties of subscribers

41. Application of security procedure- The subscriber shall apply required security procedure to ensure the purity of Digital Signature Certificate issued by a Certifying Authority.

42. Acceptance of Digital Signature Certificate

(1) A subscriber shall be deemed to have accepted a Digital Signature Certificate if he publishes or authorizes the publication of a Digital Signature Certificate to one or more persons or in a repository.

(2) By accepting Digital Signature Certificate the subscriber certifies to all who reasonably rely on the information contained in the Digital Signature Certificate that-

(a) all representations made by the subscriber to the Certifying Authority and all materials relevant to the information contained in the Digital Certificate are true; and

(b) all information in the Digital Signature Certificate that is within the knowledge of the subscriber is true.

43. Presumption of represented information of obtaining Digital Signature Certificate. All material representations made by the subscriber to a Certifying Authority for purposes of obtaining a certificate, including all information known to the subscriber and represented in the Digital Signature Certificate, shall be accurate and complete to the best of the subscriber's knowledge and belief, regardless of whether such representations are confirmed by the Certifying Authority.

44. Control of safety measure of subscriber

(1) Every subscriber shall exercise reasonable care to retain control of using of Digital Signature Certificate and take all steps to prevent its disclosure to a person not authorized to affix the digital signature of the subscriber.

(2) If the security of Digital Signature Certificate has been compromised by disobeying the rules in sub-section (1) of this section, the subscriber shall communicate the same without any delay to the Certifying Authority who has issued the Digital Signature Certificate in an agreed manner.

1.6 Breaching rules, prevention, penalties etc.

45. Power of Controller to give directions.—The Controller may, by order, direct a Certifying Authority or any employee of such a Certifying Authority to take such measure or cease carrying on such activities as specified in the order if those are necessary to ensure compliance with the provisions of this Act, or rules and regulations made thereunder.

46. Power of Controller to give directions in emergency.

(1) If the Controller is satisfied that it is necessary or expedient so to do in the interest of the sovereignty, integrity, or security of Bangladesh, friendly relations of Bangladesh with other States, public order or for preventing incitement to commission of any cognizable offence, for reasons to be recorded in writing, by order, direct any agency of the Government to intercept any information to be transmitted through any computer resource.

(2) The subscriber or any person in charge of a computer resource shall, when called upon by any agency to which direction has been issued under sub-section (1) of this section, extend all facilities and technical assistance to decrypt the information.

47. Power to announce protected systems.

(1) The Controller may, by notification in the Official Gazette or in Electronic Gazette, declare any computer, computer system or computer network to be a protected system.

(2) The Controller, by order in writing, authorize the persons who are authorized to secure access to protected systems notified under sub-section (1) of this section.

48. Penalty for failure to furnish document, return and report.—If any person fails to submit given document, return and report under the provisions of this Act, or rules and regulations made thereunder to the Controller or Certifying Authority, the Controller or any officer of the Government authorized by the Government by special order, as the case may be, can fine the person which may extend to Taka ten thousands mentioning reasons in written by administrative order.

49. Penalty for failure to file return, information, book etc.—If any person fails to deliver any information, books or any other documents under the provisions of this Act, or rules and regulations made thereunder within stipulated time, the Controller or any officer of the Government authorized by the Government by special order, as the case may be, can fine the person which may extend to Taka ten thousand mentioning reasons in written by administrative order.

50. Penalty for failure to maintain books of accounts or record.—If any person fails to maintain books of accounts or records which is supposed to be preserved under the provisions of this Act, or rules and regulations made thereunder, the Controller or any officer of the Government authorized by the Government by special order, as the case may be, can fine the person which may extend to Taka two lakhs mentioning reasons in written by administrative order.

51. Residuary penalty.—If any person contravenes any rules of this Act for which the provision of penalties has not been fixed separately under the provisions of this Act, or rules and regulations made thereunder, the Controller or any officer of the Government authorized by the Government by special order, as the case may be, can fine the person for breaching the very rule which may extend to Taka twenty five thousands mentioning reasons in written by administrative order.

52. Power of Controller to issue prohibition of possible breaching of rules.

(1) If the Controller is in the opinion that, any person has attempted or is attempting to do such activities which is breaching or may breach the provisions of this Act, rules, regulations made thereunder, or conditions or any order of the Controller then the Controller shall issue a notice within the stipulated time limit ordering the person to present his statement in written why he should not refrain himself from doing such activity and if such statement is presented then the Controller shall issue an order to refrain him from doing such activity or any other instruction about the activity sthat deems fit to him.

(2) If the Controller is satisfied that, the nature of breaching or possible breaching under sub-section (1) of this section is such that to prevent the person from that activity immediately, then the Controller shall issue an interim order which deems fit to him during the time of issuing a notice under that sub-section.

(3) If any instruction under sub-sections (1) and (2) of this section is given to anyone, he shall be bound to obey it.

(4) If any person breaches the given instructions of this section, the Controller can fine the person which may extend to Taka ten thousand.

53. Penalties.

(1) The Controller can impose penalties for breaching other rules under this Act defined by the rules as an addition to imposable penalties under this Act.

(2) No penalty shall be imposed under this Act for breaching this Act or any rules of this Act without giving reasonable opportunity to the offender on hearing.

(3) The accused person can lodge an application to the Controller for auditing the decision of imposing penalties by the Controller within seven days from the date the decision is made and if any such application is lodged, the Controller shall give opportunity to the Applicant for hearing and dissolve it within fifteen days.

Unless the penalties are paid under this Act which is due, is collectable as a Government demand under the Public Demands Recovery Act, 1913 (Ben. Act III of 1913).

Part-1

1.7 Offences, investigation, adjudication, penalties etc.

Offences & Penalties

54. Penalty for damage to computer, computer system, etc.

(1) If any person, without permission of the owner or any person who is in charge of a computer, computer system or computer network,

(a) accesses or secure access to such computer, computer system or computer networks for the purpose of destroying information or retrieving or collecting information or assists other to do so;

(b) downloads, copies or extracts any data, computer database or information from such computer, computer system or computer network including information or data held or stored in any removable storage medium;

(c) introduces or causes to be introduced any computer contaminant or computer virus into any computer, computer system or computer network;

(d) damages or causes to be damaged willingly in any computer, computer system or computer network, data, computer database or any other programmes residing in such computer, computer system or computer network;

(e) disrupts or causes disruption of any computer, computer system or computer network;

(f) denies of causes the denial of access to any person authorized to access any computer, computer system or computer network by any means;

(g) provides any assistance to any person to facilitate access to a computer, computer system or computer network, in contravention of the provisions of this Act, rules or regulations made thereunder;

(h) for the purpose of advertisement of goods and services, generates or causes generation of spams or sends unwanted electronic mails without any permission of the originator or subscriber;

(i) charges the services availed of by a person to the account of another person by tampering with or manipulating any computer, computer system or computer network; then the above said activities shall be treated as offences of the said person.

(2) If any person commits offence under sub-section (1) of this section, he shall be punishable with imprisonment for a term which may extend to not more than fourteen years and not less than seven years, or with fine which may extend to Taka ten lakhs, or with both.

Explanation- For the purpose of this section-

(i)" computer contaminant" means any set of computer instructions that are designed-

(a) to modify, destroy record, transmit data or program residing within a computer, computer system or computer network; or

(b) by any means to usurp the normal operation of the computer, computer system or computer network;

(ii)" computer database" means a representation information, knowledge, facts, concepts or instructions in the form of text, image, audio or video that--

(a) are being prepared or have been prepared in a formalized manner by a computer, computer system or computer network; and

(b) are intended for use in a computer, computer system or computer network;

"computer virus" means such computer instruction, information, data or program,

(iii) that--

(a) destroys, damages, degrades or adversely affects the performance of a computer resource; or

(b) attaches itself to another computer resource and operates when a program, data or instruction is executed or some other event takes place in that computer;

(iv)"damage" means to destroy, alter, delete, add, modify or rearrange any computer resource by any means.

55. Punishment for tampering with computer source code-

(1) Whoever intentionally or knowingly conceals, destroys or alters or intentionally or knowingly causes other person to conceal, destroy or alter any computer source code used for a computer, computer program, computer system or computer network, when the computer source code is required to be kept or maintained by any law for time being in force, then this activity of his will be regarded as offence.

(2) Whoever commits offence under sub-section (1) of this section he shall be punishable with imprisonment for a term which may extend to three years, or with fine which may extend to Taka three lakhs, or with both.

Explanation- For the purpose of this section, "computer source code" means the listing of programs, computer commands, design and layout and program analysis of computer resources in any form.

56. Punishment for hacking with computer system

(1) If any person-

(a) with the intent to cause or knowing that he is likely to cause wrongful loss or damage to the public or any person, does any act and thereby destroys, deletes or alters any information residing in a computer resource or diminishes its value or utility or affects it injuriously by any means;

(b) damage through illegal access to any such computer, computer network or any other electronic system which do not belong to him;
then such activity shall be treated as hacking offence.

(2) Whoever commits hacking offence under sub-section (1) of this section he shall be punishable with imprisonment for a term which may extend to not more than fourteen years and not less than seven years, or with fine which may extend to Taka one crore, or with both.

57. Punishment for publishing fake, obscene or defaming information in electronic form-

(1) If any person deliberately publishes or transmits or causes to be published or transmitted in the website or in electronic form any material which is fake and obscene or its effect is such as to tend to deprave and corrupt persons who are likely, having regard to all relevant circumstances, to read, see or hear the matter contained or embodied in it, or causes to deteriorate or creates possibility to deteriorate law and order, prejudice the image of the State or person or causes to hurt or may hurt religious belief or instigate against any person or organization, then this activity of his will be regarded as an offence.

(2) Whoever commits offence under sub-section (1) of this section he shall be punishable with imprisonment for a term which may extend to not more than fourteen years and not less than seven years and with fine which may extend to Taka one crore.

58. Punishment for failure to surrender licence

(1) Where any Certifying Authority fails to surrender a licence under section 34 of this Act, the person in whose favour the licence is issued, the failure of the person shall be an offence.

(2) Whoever commits offence under sub-section (1) of this section he shall be punishable with imprisonment for a term which may extend to six months, or with fine which may extend to Taka ten thousands, or with both.

59. Punishment for failure to comply with order

(1) Any person who fails to comply with any order made under section 45 of this Act, then this activity of his will be regarded as an offence.

(2) Whoever commits offence under sub-section (1) of this section he shall be punishable with imprisonment for a term which may extend to one year, or with fine which may extend to Taka one lakh, or with both.

60. Punishment for failure to comply with order made by the Controller in emergency -

(1) Any person who fails to comply with any order made under section 46 of this Act, then this activity of his will be regarded as an offence.

(2) Whoever commits offence under sub-section (1) of this section he shall be punishable with imprisonment for a term which may extend to five years, or with fine which may extend to Taka five lakhs, or with both.

61. Punishment for unauthorized access to protected systems

(1) Any person who secures access or attempts to secure access to protected system in contraventions of section 47 of this Act, then this activity of his will be regarded as an offence.

(2) Whoever commits offence under sub-section (1) of this section he shall be punishable with imprisonment for a term which may extend to not more than fourteen years and not less than seven years, or with fine which may extend to Taka ten lakhs, or with both.

62. Punishment for misrepresentation and obscuring information

(1) Whoever makes any misrepresentation to, or suppresses any material fact from the Controller or the Certifying uthority for obtaining any licence or Digital Signature Certificate shall be regarded as an offence.

(2) Whoever commits any offence under sub-section (1) of this section he shall be punishable with imprisonment for a term which may extend to two years, or with fine which may extend to Taka two lakhs, or with both.

63. Punishment for disclosure of confidentiality and privacy

(1) Save as otherwise provided by this Act or any other law for the time being in force, no person who, in pursuance of any of the powers conferred under this Act, or rules and regulations made thereunder, has secured access to any electronic record, book, register, correspondence, information, document or other material shall, without the consent of the person concerned, disclose such electronic record, book, register, correspondence, information, document or other material to any other person shall be regarded as an offence.

(2) Whoever commits any offence under sub-section (1) of this section he shall be punishable with imprisonment for a term which may extend to two years, or with fine which may extend to Taka two lakhs, or with both.

64. Punishment for publishing false Digital Signature Certificate

(1) No person shall publish a Digital Signature Certificate or otherwise make it available to any other person knowing that-

(a) the Certifying Authority listed in the certificate has not issued it; or

(b) the subscriber listed in the certificate has not accepted it; or

(c) the certificate has been revoked or suspended;

unless such publication is for the purpose of verifying a digital signature created prior to such suspension or revocation and by breaching the rules such Digital Signature Certificate is published or otherwise make it available to others shall be regarded as an offence.

(2) Whoever commits any offence under sub-section (1) of this section he shall be punishable with imprisonment for a term which may extend to two years, or with fine which may extend to Taka two lakhs, or with both.

65. Punishment for publishing Digital Signature Certificate for fraudulent purpose etc.

(1) Whosoever knowingly creates and publishes or otherwise makes available a Digital Signature Certificate for any fraudulent or unlawful purpose shall be regarded as an offence.

(2) Whoever commits any offence under sub-section (1) of this section he shall be punishable with imprisonment for a term which may extend to two years, or with fine which may extend to Taka two lakh, or with both.

66. Punishment for using computer for committing an offence

(1) Whosoever knowingly assists committing crimes under this Act, using any computer, e-mail or computer network, resource or system shall be regarded as an offence.

(2) Whoever aids committing any offence under sub-section (1) of this section he shall be punishable with the punishment provided for the core offence.

67. Offences committed by companies etc.- If any offence is committed by a company under this Act, then each director, manager, secretary, partner, officer and staff of the company who has directly involvement in committing the said offence shall be guilty of the offence or the contraventions, as the case may be, unless he proves that the offence or contravention was committed without his knowledge or that he exercised sue diligence in order to prevent commission of such offence or contravention.

Explanation– For the purposes of this section–

(a)" company" means any body corporate and includes commercial firm, partnership business, cooperatives, association, organization or other association of individuals; and

(b)" director" in relation to a commercial firm includes a partner or member of Board of Directors.

Part-2

1.8 Establishment of cyber tribunal, investigation of offences, adjudication, appeal etc.

68. Establishment of Cyber Tribunal.

(1) The Government shall, by notification in the Official Gazette, establish one or more Cyber Tribunals to be known as Tribunal at times for the purposes of speedy and effective trials of offences committed under this Act.

(2) Cyber Tribunal established under sub-section (1) of this section in consultation with the Supreme Court shall be constituted by a Session Judge or an Additional Session Judge appointed by the Government; and similarly appointed a Judge to be known as "Judge, Cyber Tribunal."

(3) Local jurisdiction of entire Bangladesh or jurisdiction of one or more Session Divisions can be given to the Cyber Tribunal established under this Act; and the Tribunal only prosecutes the offences committed under this Act.

(4) The on-going prosecution of any case of any Session Court shall not be suspended or transferred automatically to the Tribunal of local jurisdiction concerned due to tendering of local jurisdiction of entire Bangladesh or parts of jurisdiction constituted by one or more Session Divisions to the Tribunal established by the Government later on, however, the Government by notification in the Official Gazette, transfer the case to the Tribunal having special local jurisdiction.

(5) Any Tribunal, taken decision otherwise, shall not be bound to retaking statement of witness who has already given statement, or taking rehearing or begin again any other activities already undertaken under sub-section (1) of this section, however, the Tribunal shall continue the prosecution from where it stood on the basis of already taken or presented statement from the witness.

(6) The Government, by order, shall define the place and time; accordingly the special Tribunal shall conduct its activities from that place and time.

69. Trial procedure of Cyber Tribunal.

(1) Without written report of a police officer not below the rank of Sub-Inspector or the prior approval of the Controller or any other officer authorized by the Controller the special Tribunal shall not accept any offence trial.

(2) The Tribunal shall follow the rules mentioned in the Chapter 23 of the Code of Criminal Procedure, if they are not inconsistent with the rules of this Act, which is used in Session Court.

(3) Any Tribunal shall not suspend any prosecution without having written reasons and unless it is required for the sake of just adjudication.

(4) If the Tribunal is in the opinion that the accused person has been absconded and for that it is not possible to arrest him and produce him before the Tribunal and there is no possibility to arrest him immediately, in that case the Tribunal can order the accused person to appear before the Tribunal by publishing such order in two mass circulated national Bengali dailies and if the accused person fails to do so, the prosecution shall take place in his absence.

(5) The rules mentioned in sub-section (4) of this section shall not be applicable if the accused person fails to appear before the Tribunal or absconded after getting bail.

(6) The Tribunal can order any police officer, or the Controller, or any officer authorized by the Controller, as the case may be, to reinvestigate the case and submit the report within the stipulated time of its own initiative or any application lodged to the Tribunal,

70. Application of code of criminal procedure in the activities of Tribunal.

(1) Rules of Code of Criminal Procedure, as far as, are not inconsistent with the rules of this Act shall be applicable in the activities of this Tribunal and it will have all the power as exercised by the Session Court.

(2) The person prosecuting the case on behalf of the Government in this tribunal to be known as public prosecutor.

71. Rules relating to bail–

The Judge of Cyber Tribunal shall not bail any person accused in committing crime under this Act, which is punishable, unless-

(a) Hearing opportunity is given to the Government side on similar bail orders;

(b) The Judge is satisfied that,--

(i) There is reasonable cause to believe that the accused person may not be proved guilty in the trial;

(ii) The offence is not severe in relative term and the punishment shall not be tough enough even the guilt is proved.

(c) He writes down the reasons of similar satisfactions.

72. Time limit to deliver verdict.

(1) The Judge of Cyber Tribunal shall give the verdict within ten days from the date of completing of taking evidence or debate, what happened later, unless he extends the time limit no more than ten days with having written reasons.

(2) If the verdict is given by the Cyber Tribunal under sub-section (1) of this section or any appeal is lodged against the verdict to the Cyber Appellate Tribunal then Cyber Tribunal or Cyber Appellate Tribunal concerned shall forward the copy of the verdict of the appeal to the Controller for preserving it in the electronic records repository room established under section 18 (7) of this Act.

73. Prescribed timeframe for dissolving cases by Cyber Tribunal.

(1) The Judge of Cyber Tribunal shall complete the prosecution within six months since the date of filing the charge sheet.

(2) If the Judge of Cyber Tribunal fails to complete the prosecution within the time limit fixed under sub-section (1) of this section can extend the time limit another three months having written the reasons.

(3) If the Judge of Cyber Tribunal fails to complete the prosecution within the timeframe fixed under sub-section (2) of this section can continue the prosecution process having written the reasons and submitted it as a report to the High Court and the Controller.

74. Prosecution of offence by Session Court–

Whatever is contained in the Code of Criminal Procedure, until the special tribunal has not been established, the Session Court shall prosecute any offence committed under this Act.

75. Prosecution procedure followed by the Session Court.

(1) To prosecute any offence committed under this Act which is trialed in Session Court, Session Court shall follow the rules mentioned in section 23 of the Code of Criminal Procedure which is applicable in Session Court trial.

(2) Any Session Court shall not accept any prosecution/trial of any offence committed under this Act without any written report from the police officer not below the rank of Sub-Inspector of the Police and prior approval of the Controller or any officer authorized by the Controller, whatever is contained in the Code of Criminal Procedure.

76. Investigation of crime, etc.

(1) Whatever is contained in the Code of Criminal Procedure, the Controller or any officer authorized by the Controller, or any police officer not below the rank of Sub-Inspector of the Police shall investigate any offence committed under this Act.

(2) Offence committed under this Act shall be non-cognizable offence.

77. Confiscation.

(1) Any computer, computer system, floppies, compact disks (CDs), tape drives or any other accessories related thereto, in respect of which any provision of this Act, rules, orders or regulations made thereunder has been or is being contravened, or in respect of which any offence has been committed, shall be liable to confiscation by an order of the court trying an offence or contravention.

(2) If the court is satisfied, that the computer, computer system, floppies, compact disks (CDs), tape drives or any other accessories belonging to a person or under control of him related thereto, in respect of which any provision of this Act, rules, orders or regulations made thereunder has not been responsible to contravene, or committing an offence, then the computer, computer system, floppies, compact disks (CDs), tape drives or any other accessories shall not be confiscated.

(3) If any legal computer, computer system, floppies, compact disks (CDs), tape drives or any other accessories is found with the computer, computer system, floppies, compact disks (CDs), tape drives or any other accessories which is confiscated under sub-section (1) of this section shall also be confiscated.

(4) Any computer or other relevant accessories belonging to the Government or Body Government Authority is used to commit an offence under sub-section (1) of this section, whatever contained in this section, shall not be confiscated.

78. Penalties or confiscation no bar against other punishments–

No penalty imposed or confiscation made under this Act shall prevent the imposition of any other punishment to which the person affected thereby may be liable under any other law for the time being in force.

79. Network service providers not to be liable in certain cases–

For the removal of doubts, it is hereby declared that no person providing any service as a network service provider shall be liable under this Act, or rules and regulations made thereunder, for any third party information or data made available by him if he proves that the offence or contravention was committed without his knowledge or that he had exercised due diligence to prevent the commission of such offence or contravention.

Explanation–For the purposes of this section-

(a)" network service provider" means an intermediary;

(b)" third party information" means any information dealt with by a network service provider in his capacity as an intermediary.

80. Power of seize or arrest in public place, etc.–

Any investigation taken under this Act, the Controller, or any officer of Government authorized by the Government or any police officer not below the rank of a Sub-Inspector of Police are in opinion that an offence has been committed or being committed or offence which is punishable under this Act has been committed, then having written the reasons, may enter the place and search and seize the germane materials and arrest the concerned person or the offender.

81. Procedure of search, etc.–

The provisions of the Code of Criminal Procedure shall, subject to the provisions of this Act, apply, so far as may be, in relation to all investigations, entry, search and arrest made under this Act.

Part-3

1.9 Establishment of cyber appellate tribunal, etc.

82. Establishment of Cyber Appellate Tribunal.

(1) The Government shall, by notification in the Official Gazette, establish one or more Cyber Appellate Tribunals to be known as Appellate Tribunal.

(2) Cyber tribunal established under sub-section (1) of this section shall consist of one Chairman and two members to be appointed by the Government.

(3) A person shall not be qualified as the Chairman of a Cyber Appellate Tribunal unless he is, or has been, or is qualified to be, a Judge of the Supreme Court and one of the members shall be serving in judicial department or retired District Judge and the other member shall be a person having adequate knowledge and experience in information and communication technology.

(4) Chairman and members shall be retained in the positions since the date of joining between no less than three years and no more than five years and their terms of reference shall be determined by the Government.

83. Procedure and powers of Cyber Appellate Tribunal.-

(1) Cyber Appellate Tribunal shall have the power to hear appeal and dissolving the verdict and order given by Cyber Tribunal and Session Court, as the case may be.

(2) In case of hearing and dissolving the appeal, Cyber Appellate Tribunal shall follow the procedure defined by rules and if the rules do not exist in that case Appellate Tribunal shall maintain the procedure in relation to hearing and dissolving of criminal appeal followed by the High Court Division of the Supreme Court.

(3) Cyber Appellate Tribunal shall have the power to retain, revoke, alter, or rectify the verdict or order made by the Cyber Tribunal.

(4) The decision made by the Appellate Tribunal shall be final.

84. Appeal procedure in case of not establishing Cyber Appellate Tribunal-If the Cyber Appellate Tribunal has not been established, whatever contained in the Code of Criminal Procedure,
appeal shall be lodged in the High Court Division of Supreme Court against the verdict and order given by the Session Court or Cyber Tribunal, as the case may be.

1.10 Miscellaneous

85. Public servants. The Controller, the Deputy Controller, the Assistant Controller or any person empowered under this Act to exercise his power and carrying out the tasks shall be deemed to be public servants within the meaning of section 21 of Penal Code.

86. Protection of action in good faith.--No suit, prosecution or other legal proceedings shall lie against the Government, the Controller, the Deputy Controller, the Assistant Controller or any person acting on his behalf, for anything which is in good faith done or intended to be done in pursuance of this Act or any rule, regulation, order or direction made thereunder.

87. Augmented use of few definitions used in few acts. For the purpose of this Act,--

(a) The definition of "document" in section 29 of Penal Code, 1860 (Act XLV of 1860) also includes the document generated or prepared by electronic machine or technology;

(b) The definition of "document" in section 3 of Evidence Act, 1872 (Act I of 1872) also includes the document generated or prepared by electronic machine or technology;

(c) The definition of "bankers books" in section 2, Clause (3) of Banker's Books Evidence Act, 1891 (Act XVIII of 1891) also includes the books viz. ledgers, day-books, cash-books, account-books and all other books generated or prepared by electronic machine or technology;

88. Power of Government to make rules.

The Government may, by notification in the Official Gazette and in the Electronic Gazette, make for all or any of the following rules for carrying out of this Act:

(a) the manner in which any information or matter may be authenticated or any document may be signed by means of digital signature;

(b) the electronic form in which filing, issue, grant or payment;

(c) the manner and format in which electronic records shall be filed, or issued and the method of payment;

(d) the matters relating to the type of digital signature, manner and format in which it may be affixed;

(e) the qualifications, experience and terms and conditions of service of the Controller, Deputy Controllers and Assistant Controllers;

(f) other standards to be observed by the Controller;

(g) the requirements which an applicant must fulfill;

(h) the period of validity of licence;

(i) the format in which an application may be made;

(j) the amount of fees payable with application for licence;

(k) such other document which shall accompany an application for licence;

(l) the form of application for renewal of a licence and the fee payable;

(m) the form in which application for issue of a Digital Signature Certificate and the amount of fees payable;

(n) the qualifications and experience of Chairman and members of Cyber Appeal Tribunal; the form in which appeal may be filed;

(o) the procedure of investigation;

(p) other such necessary matters.

89. Power of Controller to make regulations. The Controller with prior approval of the Government, by notification in the Official Gazette and in the Electronic Gazette, make for all or any of the following regulations:-

(a) the particulars relating to maintenance of database containing the disclosure record of every Certify Authority;

(b) the conditions and restrictions subject to which the Controller may recognize any foreign Certifying Authority;

(c) the terms and conditions subject to which a licence may be granted;

(d) other standards to be observed by a Certifying Authority;

(e) the manner in which the Certifying Authority shall disclose the particular matters;

(f) the particulars of statement which shall accompany an application.

90. Original script & English script. The original script shall be in Bengali and there shall be a dependable English transcription of it.

Provided that any conflict arises between Bengali & English scripts the Bengali script shall get domination.

Practice questions and answers with explanations

Case: Unauthorized Data Access

1. Rahim accesses a company's computer system without permission and copies confidential files.

Question: Which section applies to Rahim's offence?

A. Section 55

B. Section 54

C. Section 57

D. Section 63

Answer: B. Section 54

Explanation: Unauthorized access and data extraction are offences under Section 54, punishable with imprisonment and/or fine.

Case: Fake News Publication

2. A blogger publishes false and defamatory content online that harms a person's reputation.

Question: Which section is applicable?

A. Section 56

B. Section 57

C. Section 62

D. Section 65

Answer: B. Section 57

Explanation: Publishing fake, obscene, or defamatory content in electronic form is punishable under Section 57.

Case: Digital Signature Misuse

3. A certifying authority issues a digital certificate without verifying the applicant's identity.

Question: Which principle is violated?

A. Authentication of electronic record

B. Certification procedure compliance

C. Data retention rule

D. Attribution rule

Answer: B. Certification procedure compliance

Explanation: Certifying Authorities must verify identity and follow procedures before issuing certificates (Section 36).

Case: Tampering Source Code

4. An employee deliberately alters the source code of a company system that must be preserved by law.

Question: Which section governs this offence?

A. Section 54

B. Section 55

C. Section 56

D. Section 60

Answer: B. Section 55

Explanation: Tampering with computer source code required by law is punishable under Section 55.

Case: Hacking Incident

5. A hacker deletes important data from a government server causing loss.

Question: What is the punishment under ICT Act?

A. Fine only

B. Imprisonment up to 3 years

C. 7–14 years imprisonment

D. No punishment

Answer: C. 7–14 years imprisonment

Explanation: Hacking offences under Section 56 carry severe punishment including imprisonment up to 14 years.

2. National ICT policy 2009

In today's world, Information and Communication Technology (ICT) is considered as the most effective constituent for the development of a nation. In order to decide on the ways to deliver the benefits of ICT to the greater mass of the country, the present Government, in its previous tenure, felt the necessity of an Information and Communication Technology policy. The intention was reflected in measures such as tax waiver from import of computers, connecting Bangladesh with the Information Superhighway and allocation of fund 400 million Taka for promotion of IT sector. Digital Telephony was also introduced during that period. Especially mobile phone business was opened up through removal of monopoly with a view to keep the mobile communication within the reach of the common people. For the development of Information & Communication Technology in the country, the Government formed a committee for formulating a national policy on ICT (vide Circular No: MOST/Sec-09/NCST-1/99/90 Dated: 10-05-1999). Though the policy was approved in 2002, the vision of developing a knowledge-based society in the country within 2006 could not be realized because of sluggishness of the next Government. Needless to say, that we have to go a long way to achieve that level of maturity in ICTs. In view of this, the ICT stakeholders felt the need to revise the current ICT Policy in line with the national goals, objectives and capabilities. Accordingly, the 'National ICT Policy Review Committee' was formed by the Ministry of Science and ICT (vide Circular No. MOSICT/Section-13/IT-7/1999/Part-2/108, Dated: 4-5-2008, published in Bangladesh Gazette in Vol.29: July 17, 2008). The 'National ICT Policy 2009' is the outcome of the work of this committee.

It is expected that the successful implementation of the vision and objectives of the National ICT Policy 2009 will facilitate materialize Digital Bangladesh which the government pledged to build within 2021 by.

2.1 Rationale for a national ICT policy

The constitution of the People's Republic of Bangladesh has edified social equity and ICTs are the best means to propagate that ethos within a framework optimizing the effective utilization of the nation's limited natural and abundant human resources.

The article 19 of the constitution clearly mandates:

19. Equality of opportunity.

(1) The State shall endeavour to ensure equality of opportunity to all citizens.

(2) The State shall adopt effective measures to remove social and economic inequality between man and man and to ensure the equitable distribution of wealth among citizens, and of opportunities in order to attain a uniform level of economic development throughout the Republic."

The policy is intended as a binding guide for all planners and executive officers of the state. It is also meant to be an investment guide for private enterprises, a social mobilization guide for NGOs/civil societies and a benchmark for electronic delivery of citizen services.

2.2 Present context and future trends

Bangladesh has not been able to harness the power of ICTs for economic and social gains to the extent that other countries of the world have done. The promise of ICTs has only become stronger with time and a future without ICTs in any part of the world is unthinkable. As the financial barrier to ICTs is much lower than many other modern technologies, and as the future of human society is inextricably linked with ICTs, Bangladesh as a country must embrace ICTs as a matter of policy and set an aggressive strategy to make up for the current lag and leapfrog into the ranks of top ICT-ready countries.

As a nation, Bangladesh is still classified as a least-developed country (LDC) with a per capita GNP of USD 600 per annum. With more than 1,000 people per square km, the country has the highest population density in the world, aside from city-states. There are few proven natural resources, though there are some in the energy sector that are not sufficient to meet the total energy needs now or in the future. Generally speaking the only abundant resource the country has is its young population.

The national vision is to raise the economic profile of the nation to that of a middle- income country within a decade which would require more than doubling of our current level of per capita GNP. This economic vision must be achieved in a manner that is socially equitable and just.

Optimal resource utilization, certified skills development, efficient communication and quality education delivery are some of the ways in which the above goals can be realized within the specified timeframe by pushing the growth rate to above 7.5% through extensive use of ICTs. By sustaining this level of growth, the country's GNP can be increased twenty-fold from the present level and high-income status can be achieved within 30 years.

2.3 Structure and conventions

The policy document is structured as a hierarchical pyramid with a single vision, 10 broad objectives, 56 strategic themes and 306 action items. The vision and objectives are aligned with the general national goals while the strategic themes are areas within the broad objectives that can readily benefit from the use of ICTs. The action items are generally meant to be implemented either in the

- short term (18 months or less),
- medium term (5 years or less) or
- long term (10 years or less).

However, some action items have been recommended for continuation throughout multiple terms where the scope of the activity gradually expands in the longer terms.

Conventional notions of vision, objective, strategic theme, etc. tend to differ greatly from person to person and from discipline to discipline. Thus, for the purpose of this policy proposal, the following definitions have been adopted for a) Vision, b) Objective c) Strategic Theme, d) Action Item, and e) ICTs.

Definition of Vision: The national aspirations with respect to maximising the use of ICTs for national development

Definition of Objective: A set of related goals to be achieved to realize the Vision

Definition of Strategic Theme: A broad recommendation to guide the development and implementation of specific action items

Definition of Action Item: A particular implementation task under a strategic theme with clearly specified outcomes, time limits and actors

Definition of ICTs: All e-technologies used in creating, storing, processing, communicating and disseminating information of all kinds

2.4 Policy ownership, monitoring and review

The ICT Policy must be owned by all stakeholder groups who will continually seek to have the mandates of the policy adhered to in all spheres of national life. The policy must have a Champion in the highest levels of the Government. Accordingly, the following Policy Ownership arrangement is envisaged.

The National ICT Policy shall be monitored and coordinated by the Minister in charge of ICT while the associated action programmes will be implemented and/or supported by the Bangladesh Computer Council or its successor organisation; all Government agencies and quasi-state bodies will implement ICT Policy in their respective area. Instruction from National ICT Task Force will be taken for any deviation in implementing the Policy.

The action plans under the policy shall be reviewed at least once a year for implementation status checks, necessary reprioritizations and changes in programmes. The strategic themes shall be reviewed every three years along with realignment of specific goals with new developments. The whole policy itself shall be reviewed in totality every six years and long-term goals adjusted according to achievements and failures along the way.

With the aims and objectives of the National ICT Policy 2009 materialized, Bangladesh is expected to become a 'knowledge society' within one generation.

2.5 Vision

Expand and diversify the use of ICTs to establish a transparent, responsive and accountable government; develop skilled human resources; enhance social equity; ensure cost-effective delivery of citizen-services through public-private partnerships; and support the national goal of becoming a middle-income country within 2021 and join the ranks of the developed countries of the world within thirty years.

2.6 Objectives

i Social Equity: Ensure social equity, gender parity, equal opportunity and equitable participation in nation-building through access to ICTs for all, including persons with disabilities and special needs

ii Productivity: Achieve higher productivity across all economic sectors including agriculture and SMME (small, medium and micro enterprises) through the use of ICTs.

iii Integrity: Achieve transparency, accountability, responsiveness and higher efficiency in the delivery of citizen-services.

iv Education and Research: Expand the reach and quality of education to all parts of the country using ICTs, ensure computer literacy at all levels of education and public service and facilitate innovation, creation of intellectual property and adoption of ICTs through appropriate research and development.

v Employment Generation: Enlarge the pool of world-class ICT professionals to cater to the local and overseas employment opportunities.

vi Strengthening Exports: Ensure a thriving software, ITES and IT manufacturing industry to meet domestic and global demands and thereby increase foreign exchange earnings, attract foreign direct investments and reduce dependence on imports.

vii Healthcare: Ensure quality healthcare to all citizens by innovative application of ICTs.

viii Universal Access: Ensure connectivity to all as a public service obligation (PSO).

ix Environment, Climate and Disaster Management: Enhance creation and adoption of environment-friendly green technologies, ensure safe disposal of toxic wastes, minimize disaster response times and enable effective climate- change management programmes through use of ICTs as Bangladesh is facing the dual scourge of environmental pollution due to rising industrial and consumer wastes and also global-warming-induced climate-change due to excessive carbon emissions of the industrialized countries

x Supports to ICTs: Develop appropriate infrastructure including power, and regulatory framework for effective adoption and use of ICTs throughout the country

2.7 Strategic themes

Social Equity:

i Mainstream social advancement opportunities for disadvantaged groups as an immediate priority to minimize economic disparity and bridge the digital divide for (a) lower income groups, (b) ethnic minorities, (c) women, and (d) persons with disabilities and special needs

ii Facilitate citizens' participation in local and national government, and policy making as a broad national agenda

iii Provide incentives to the private sector and NGO/CSO/CBOs to generate and share locally relevant and local language digital content and online services

Develop and preserve content to bolster culture, heritage and religion

iv Bring into focus children's issues, including protection of children from harmful digital content

2.8 Productivity:

i Encourage maximum utilization of ICT services nationwide to boost productivity of small, medium and micro enterprises and agriculture sector, and focus on innovation and competitiveness

ii Ensure dissemination and utilization of latest know-how and market information to increase production capability and supply chain management of agriculture through ICT applications

iii Ensure better monitoring, skills gap determination, appropriate training and modern enterprise operations to enhance productivity of large enterprises by encouraging immediate implementation of end to end applications (ERP)

iv Ensure sustainable productivity in the service sector through increased automation of operations and management information systems

v Encourage e-commerce, e-payments, and e-transactions in general bringing in a new dimension of productivity to the economy at the earliest

2.9 Integrity:

i Ensure the use of Bangla in all ICT activities

ii Reduce harassment, time and cost of the people and ensure transparency and accountability in government service delivery by monitoring citizens' charter and making results of all services delivery public including services related to justice and law & order

iii Establish interconnectivity across government offices for effective data sharing

iv Build capacity of public functionaries and foster leadership for electronic service delivery

v Mandate availability of all public information through electronic means and ensure sustainability of ICT-based citizens' services delivery

vi Introduce ICT-based monitoring of planning, implementation and effectiveness of development projects

2.10 Education and research:

i Assess skills of ICT professionals and meet gaps with targeted training programmes to overcome the short-term skills shortage in the ICT industry and adopt continuing education and professional skills assessment and enhancement programmes

ii Encourage closer collaboration between academia and industry to align curriculum with market needs

iii Establish an ICT Centre of Excellence with necessary long-term funding to teach and conduct research in advanced ICTs

iv Extend the reach of ICT literacy throughout the country by incorporating ICT courses in primary and secondary education and technical and vocational education and training (TVET) programmes

v Enhance the quality and reach of education at all levels with a special focus on Mathematics, Science and English

vi Ensure ICT Literacy for all in public service

vii Boost use of ICT tools in all levels of education including ECDP, mass literacy and lifelong learning

viii Ensure access to education and research for people with disabilities and special needs using ICT tools

ix Ensure that all universities provide global standard ICT education and introduce Postgraduate Programmes in ICT education to encourage research and innovation

2.11 Employment generation:

i Provide incentives for investment in local ICT industry

ii Build institutional capacity for producing greater number of IT professionals in line with domestic and global demands for knowledge workers

iii Standardize skills for local ICT industry

iv Facilitate global employment of skilled ICT workforce

v Provide financial assistance to ICT professionals for skills development

2.12 Strengthening exports:

i Develop strong marketing, promotion and branding for Bangladeshi ICT products and services in global markets

ii Ensure access to finance for promising software and ITES companies

iii Develop and maintain reliable ICT infrastructure

iv Provide incentives to increase export and create industry friendly policy and enabling environment

v Foster innovation through research and development to improve quality, process, technology, domain, value chain and niche markets

2.13 Healthcare:

i Improve management of healthcare delivery system using telemedicine and modern technologies

ii Improve community awareness and access to health care facilities for all including difficult to access areas, with a special emphasis on child, maternal and reproduction health

iii Ensure Quality Assurance of health care services

iv Enhance capacity of National Health Service Delivery System

2.14 Universal access:

i Extend universal connectivity to all citizens as a public service obligation within 5 years

ii Extend internet backbone infrastructure to all district headquarters immediately at the same access cost as in the capital

iii Extend Internet and IP telephony services to all parts of the country within 5 years through providing incentives as stipulated in the national telecom policy

iv Make IP-based telecommunications ubiquitous and affordable by all through aggressive adoption of NGN and license-free regime

2.15 Environment, climate and disaster management:

i Promote entire environmental preservation including land and water resources by adopting environment-friendly green technologies

ii Promote entire environmental protection including land and water resources through the use of ICT tools

iii Protect citizens from natural disasters through ICT-based disaster warning and management technologies

iv Ensure safe disposal of toxic wastes resulting from use of ICTs

v Promote efficient relief management and post disaster activities monitoring

2.16 Supports to ICTs:

i Ensure reliable and cost-effective power

ii Create supportive legal framework for IPR protection, online document sharing, transactions and payments

iii Establish a Government Interoperability Framework to be adhered to by all government ICT projects

iv Promote the use of cost-effective, open source and open architecture solutions

v Build ICT infrastructure facilities in educational institutions

vi Decentralize ICT growth outside the capital

vii Improve education quality in IT, Mathematics and English

viii Improve Internet availability and reliability

2.17 Action plans and funding

The action plans are the tangible dimension of the ICT policy which will ultimately determine the degree of success or failure of the policy itself. At 306 items, the list is comprehensive, but not exhaustive. Some action items are marked with an asterisk (*) to indicate their overarching importance in relation to others under the same objective.

The objectives and strategic themes stated above drive the action plans. The plans are grouped in tables first by the broad objectives and then subdivided under specific strategic themes. The action items have a running serial number across all objectives and tables.

Action items have indicative implementation timeframes, e.g., short-term, mid-term and long-term. Short-term is meant to be 18 months or less, mid term is meant to be longer than 18 months but not more than 5 years while long-term is meant to be longer than 5 years but not more than 10 years.

In the ICT sector, looking ahead even 2 years is a challenge as the industry is continuously evolving at a rapid pace. The short-term action items are the needs of the hour while the mid-term and long-term action items need to be aligned with the ground- realities and developments in ICTs during annual reviews of the action items.

Separate allocations have to be made in the national budget for implementing the action items. A budget line for e-governance should be created in every ministry, department, and autonomous bodies for routine ICT activities. An ICT Development Fund should be created through block grants in the annual budget to be accessed by public sector entities by a process of competition.

3. Social equity

3.1 Objective : Social equity

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
Strategic Theme 1.1: Mainstream social advancement opportunities for disadvantaged groups as an immediate priority to bridge the digital divide and minimize economic disparity for (a) lower income groups, (b) ethnic minorities, (c) women, and (d) persons with disabilities and special needs						
*1	Establish Community e-Centres (telecentres) initiated and operated by the private sector to facilitate access to computers, Internet and e-citizen services. Provide relevant content, pricing structure, and incentive through nominal bandwidth charges for underdeveloped areas and marginalized populations. The govt. may also provide hosting in public and local government facilities by charging nominal rent.	MoSICT, MoEst, BTRC, NGOs, district administrations	Citizens will be able to access critical services from their doorstep with reduced cost, time, and hassle.	All urban locations and upazilas covering 50% of the country's population including at least 20% of the rural communities	75% of the population	100% of the popula tion
*2	Establish Community e-Centres in City Corporations, Upazila Parishads, Pourashavas and Union Parishads (UPs).	MoSICT, BTRC, NGOs, district administrati ons, LGD	Provide access to critical services within easy reach to minimize time, cost, and hassle to citizens.	100% City Corporations 100% Upazila Parishads, 25% Pourashavas 10% UPs	100% pourasha vas, Zila Parishad, 50% UPs	all UPs
*3	Launch Citizens Helpdesk in public organisations. The host is not mandated to be physically located at the relevant public organisation. Telecom operators will have to provide low-toll/toll-free numbers for these call centres	MoSICT, BTRC, NGOs, district administrations LGD	Provide access to critical information through phone to minimize cost, time and hassle to citizens.	All City Corporations Zila Parishad	All utility providers, all Pourashav as and Upazila Parishads	
*4	Provide incentives to create low-cost, affordable Bangla processing tools and software to develop searchable text and voice content from printed material with special	MoSICT, MoEdu, MoSW, UGC, NCTB	These technologies will benefit persons with disabilities and also most of the illiterate	Dictionary, text to speech, IVR	OCR, handwriting recognition machine translation	Voice recognition

	attention to persons with disabilities and specials needs		population who are functionally 'print-disabled'.			
*5	Modify ISP licenses to ensure rural connectivity through extending network and provide a mechanism such as USO fund whereby govt. can provide cash and tax incentives to ISPs providing services in rural areas	MoSICT, MoPT, BTRC	Ensure affordable and reliable rural connectivity.			
*6	Expand the voter ID to National ID platform to be used for all citizens' services such as birth registration, passport, bank account, school enrollment, healthcare, vaccination, VGF/VGD and other social safety net programmes.	ECS, LGD, MoHFW, DPE, MoSW	Ensure that the broad foundation created by the voter ID database is reused for other critical social services, thus lowering cost and time for implementation of these services. Ensure that databases are interoperable so that policy decisions have deeper integration and cross-agency services are more effectively designed.	National ID card with identification of persons with disabilities and special needs, driving license, birth registration, passport, bank accounts, etc.	Vaccination, school enrollment, relief, land records	Other social safety net programmes
*7	Enable all citizens to apply for and receive public grants electronically.	MoSICT, MoRA, MoWCA, MoSW, MoLWA	Ensure overall transparency of grant giving.			

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
*8	Provide access to critical public services related to livelihood and human development through online means from any location in Bangladesh.	All ministries/ divisions, Cabinet Division	Electronic delivery mechanisms will enable citizens to access critical services from their doorstep with lower cost, time, and hassle.	100 public services (2 per ministry/ division)	300 public services	All others
*9	Develop special ICT literacy and training programmes for ethnic minorities	MoCA, MoCHTA, CHT Zila Parishads	Narrow the digital divide between ethnic minorities and the rest of the population.	10% of ethnic minorities	50% of ethnic minorities	100% of ethnic minorities
*10	Develop web and mobile enabled e-commerce platforms indigenous artisans	MoCHTA, MoCommerce CHT Zila Parishads, CHT Unnayan Board	Websites featuring work of remote artisans will enable buyers to contact them or buy products online, thus increasing income earning opportunities, allowing them to form effective cooperatives to market their products, and creating new job opportunities.	e-comme rce site with arts and crafts	Promotion of eco-tourism	

*11	Establish women's e-commerce centre to expand market access to promote women-led micro enterprises	DWA, MoIndustries, MoWCA, private sector	Increase income earning opportunities for women without leaving their localities, enable them to form effective cooperatives to market their products and services, and create new job opportunities.	Divisional HQs	District towns	Upazilas
*12	Launch a Development TV Channel using the under- utilized terrestrial channel of BTV	MoInform ati on, private sector	Broaden and deepen the distance education and awareness capacities of the government	12 hours/day	24 hrs/day	
Strategic Theme 1.2: Facilitate citizens' participation in local and central government, and policy making as a broad national agenda						
*13	Ensure filing of public grievances through electronic means. The government and local government authorities should provide publicly accessible responses to the grievances.	MoSICT, MoPT, BTRC, Cabinet Division, MoEst, LGD	Accepting public grievances through govt. websites and email will promote greater transparency and faster resolution to grievances.	City Corporations, Zila Parishad, Pourashavas, Upazila Parishad	50% Union Parishads	100% Union Parishad
*14	Mandate all new policies to be featured on govt. websites to collect public feedback.	All ministries	Enable greater participation of citizens in policy debates regardless of location and time.		City Corporations Pouras havas, Upazila Parishad	Union Parishad

Strategic Theme 1.3: Provide incentives to the private sector and NGO/CSO/CBOs to generate and share locally relevant and local language digital content and online services						
*15	Provide grants for local language and locally relevant content development. This may include digital content for educational purposes, capacity development, dissemination of vital information relating to life and livelihood, etc.	MoInformation MoSICT, MoCA, MoHFW, MoA, oEdu, MoPME, all relevant ministries	Wide benefits in providing education, training, and vital information to large segments of the population.			
Strategic Theme 1.4: Develop and preserve cultural content to bolster culture, heritage and religion						
*16	Promote archiving and dissemination of multimedia content for indigenous culture, heritage and religion.	MoCA, National Archives, National Museum, MoCHTA, MoRA, UNESCO	Ensure permanent preservation and dissemination of important content related to indigenous culture, heritage and religion.	wiki, websites on cultural content	Computer scripts for indigenous languages (Monipuri, Chakma, etc.)	
Strategic Theme 1.5: Bring to focus children's issues, including protection of children from harmful digital content						
*17	Provide grants for development of content suitable for children. This may include digital content for children's education and awareness development at different levels.	MoWCA, UNESCO UNICEF	The fun and interactive aspect of digital material will promote greater interest for learning and better knowledge retention.	Competition among companies for development of child-friendly content.		
*18	Train parents on how to filter content harmful to children through websites and TV programmes.	MoWCA, MoInform ati on	Help parents be prepared for protecting children from	Websites on how to filter sites	TV programmes	Awareness program mes in schools and CICs

			easily accessible but harmful digital content.			
*19	Train ISPs on how to detect and block sites with content harmful to children.	MoInformation MoSICT, BTRC	Create awareness among ISPs about the type of content to block.	Subscribe to internation al forums that track harmful sites	Database of local and foreign sites	
*20	Create advocacy programmes to create awareness about content harmful to children.	MoInformati on, MoWCA, NGOs	Create awareness among all social actors about harm done by certain digital content and develop protective measures.	Websites with cartoons that help children understand what harmful content is	TV programmes	

3.2 Objective : Social equity

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
Strategic Theme 2.1: Encourage maximum utilization of ICT services nationwide to boost productivity of small, medium and micro enterprises and agriculture sector, and focus on innovation and competitiveness						
*21	Conduct a study to understand the current status of ICT and services availability for business.	MoSICT and relevant trade organisations	Study Report benefit: determine e-readiness	√		
*22	Conduct media campaign to build mass awareness on benefit of ITES and business opportunity.	MoSICT, MoInformation MoA, MoFL, NGOs, BASIS, BCS and media	Road shows, talk shows and relevant communicatio ns through TV, radio, other electronic media, and newspapers, will help people understand the benefit of IT usage.	District level for SMME	Union level for agriculture	
*23	Arrange fairs, exhibitions & targeted workshops for local enterprises. Roadshows and other interactive programmes.	MoCommerce MoInformation FBCCI, SMEF and IBPC	Open up business opportunities with foreign investors			
*24	Explore PPP education & training for developing skilled HR for improving enterprise productivity.	BCC & BSCIC MoEdu & MoSICT	Optimum PPP frame work for productive resource development. Achieve required level of skilled HR to support immediate and future needs of enterprises.			
*25	Implement ICT based model SMME (one for each category) at Dhaka and other divisional HQs.	MoSICT, BASIS, BCS	Building best practice Model in each category in	in Dhaka	in all other divisions	

			each Division. Exhibit role models to inspire other SMME			
*26	Arrange Internet connectivity up to all villages of the country	BTRC & MoPT	Maximise ICT usage	up to Upazila	up to villages	
*27	Develop Agriculture, Food and SMME related content in Bangla.	MoSICT, MoA, MoFin, MoCommerce, MoIndustries, BASIS and BCS	Appropriate Bangla content. Support beneficiaries and provide access to relevant local content.			
*28	Enable e-commerce platforms for SMMEs.	NGOs, private sector, MoCommerce, BB, MoF	PKI & e-payment gateway in operation			
*29	Develop network within communities to share indigenous knowledge and innovations related to pest management, crop preservation, etc.	MoA, MoInformation	Community Radio, telecentres, web based networks.			
Strategic Theme 2.2: Ensure dissemination and utilization of latest know-how & market information to increase production capability and supply chain management of agriculture through ICT applications						
*30	Establish SME resource centre focused on agricultural needs spanning relevant supply chain in the local context.	MoSICT, NGOs, SME Foundation and trade org.	Strategic alliance with local chamber/ telecentre	In all districts, 25% of Upazila Parishads, 5% of Union Parishads	In 100% of Upazila Parishads, 25% of Union Parishads	100% of Union Parishads, selected primary schools at village level
*31	Establish e-governance in all executive layers of the society, community and Government.	MoSICT, LGRD, Youth Development Ministry and PMO	Online service delivery. Increase service delivery for SMME business.	Assessment & Planning	Implementation	

*32	Arrange export fairs, exhibitions, seminars, workshops.	BEPZA, MoCommerce	Sharing of latest knowledge with all target groups and market information	Division level	District level	
*33	Enhance the agricultural supply chain management system through business portals accessible through various electronic channels.	MoCommerce, MoIndustries, BASIS, BCS, private sector	Creation of transparent, knowledge-based trading platforms that will play a major role in reducing/ eliminating rent- seeking middlemen opportunities. A trading and information platform spanning the entire supply chain.			
*34	Arrange targeted workshops with Non Resident Bangladeshis (NRB) and international research organisations for technology & knowledge transfer for productivity in the agriculture sector.	MoSICT, MoCommerce, BASIS, BCS and other Trade org.	Knowledge transfer from more mature economies/industries	Leverage the TEIN3 network.	Establish connectivity and knowledge sharing links with other international research organisations	
35	Provide training of extension workers and farmers on updated technologies, credit schemes, etc. using ICTs.	MoA, MoFL, MoEF	Cost-effective and frequent capacity building of extension workers	√	√	√
36	Provide farmer literacy and education through distance-learning, adjusted to the needs of farmers, for production and agro-processing industry.	MoA, MoFL, MoEF, NGOs, private sector	Capacity building of farmers based on local needs and accommodating seasonal calendars and other local preferences.	√	√	√

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
37	Provide up-to-date demand- supply and market rate information on agri produce at market yards.	DAM, private sectors	Disseminate critical pricing data across the country to assist producers in getting the best possible prices.	Establish centralized-price information-repository with field capability for datacollection.	Expand field capability. Develop analysis capacity at the central locations.	
38	Utilize GIS based soil mapping system to analyze detailed data to provide information relating to crop suitability, land zoning, nutrient status and fertilizer dosage.	SRDI	Reduce wastage and increase yield through the use of agricultural inputs based on specific soil condition.	Pilot in a few selected upazilas with data from Union Parishads	Extend to all Upazilas, 10% Union Parishads	Extend to all Union Parishads
39	Ensure timely access to livestock, poultry and fisheries disease diagnosis and prescription through remote consultation.	MoFL	Reduce business losses for the individual farmer or cooperative.	Pilot in a few district veterinary and fisheries centres with access from Union Parishads	Extend to all district veterinary and fisheries centres.	Extend to all Upazila veterinary and fisheries centres.
40	Provide access to m-banking for farmers and agro-businesses.		Extend the reach of conventional banking in terms of cost-effective disposal of micro-loans and micro-payments without a commensurate expansion of physical facilities and human resources.	Policy decisions. Potentially modificatio n to existing laws, enactment of new laws. Pilot in a few areas.	Mobile phone recharge mechanism or something equally ubiquitous and cost-effective in 50% of the country	m-banking available for farmers in all parts of the country
41	Develop Internet and mobile-based trading platforms for agriculture produce for extended supply chain.	MoA, MoFL, MoCommerce				

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
Strategic Theme 2.3: Ensure better monitoring, skills gap determination, appropriate training and modern enterprise operations to enhance productivity of large enterprises by encouraging immediate implementationof end to end applications (ERP)						
42	Form joint monitoring and review task force up to Upazila level.	MoCommerce, MoSICT, ICT TaskForce				
43	Initiate a pilot project to promote sector based customized ERP.	MoSICT, BCC, BASIS, BCS	Improve management information productivity, and provide effective monitoring and decision support.	Implement 5 pilots in 5 sectors	Implement 10 Pilots	
44	Create strategic management consultancy capacity for productivity improvement.	Private sector, MoIndustries, MoSICT				
45	Create and disseminate e- Learning resources on Energy Efficiency, ISO competencies, Lean Six Sigma, advanced Production System, etc.	MoPEMR, MoCommerce, MoIndustries, MoSICT	Support enterprises to improve quality of services and to comply with standards.			
Strategic Theme 2.4: Ensure sustainable productivity in the service sector through increased automation of operations and management information systems						
46	Implement ICT based automation and MIS model at Division level.	MoSICT, BASIS, BCS	End-to-end applications and content. Improve information management for higher businessgrowth and market competitiveness			

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
47	Initiate a pilot project to promote sector based customized MIS.	MoA, MoFDM, MoHFW, BASIS,and BCS	Develop an Application Services system for enterprises	Implement 3 pilots for Agri, Food & Health sectors	Implement10 pilots	
Strategic Theme 2.5: Encourage e-commerce, e-payments, and e-transactions in general to bring in a new dimension of productivity to the economy at the earliest						
48	Implement ICT Act 2006 and create infrastructure for e-commerce, e-payments, and e-transactions.	MoFin, MoSICT and BB	Facilitate trade & business productivity	Frame rules & regula-tions for ICT Act 2006. Establish legal and infrastructu ral facilities for issuing CA licenses. Generate awareness on alterna-tive options such as PGP which require no CA to operate.		
49	Establish Certifying Authority (CA).	MoSICT, MoFin, and BB	Ensure security in e- commerce applications.	Frame rules & regulationsf or payment gateway. Appoint Controller of Certifying Authority (CCA). Initiate operation and issue license.		
50	Develop capacity development programmes for the judiciary & the law enforcement agencies.		Introduce a separate training curricu-lum in PATC andrespective Academy			

3.3 Objective : Integrity

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
Strategic Theme 3.1: Ensure the use of Bangla in all ICT activities						
51	Promote the use of standard Bangla keyboard and resolve related issues, if any.	BSTI, BCC, Industry Associations	Anyone using Bangla can expect to have a standard keyboard	√		
52	Update Bangla encoding standard to align it with Unicode and ISO	BCC, BSTI, Copyright Office, Industry Associations	Encourage software vendors to use the standard encoding	√		
53	Digitally publish all govt. publications in Bangla using a standard encoding to guarantee document portability.	MoEst	All Bangla documents will be portable across platforms, applications, and time		√	
54	Join the Unicode Consortium as an Institutional Member	BCC, MoSICT	Bangladesh will have a direct voice in Bangla script encoding issues in Unicode		√	
Strategic Theme 3.2: Reduce harassment, time and cost to the public and ensure transparency and accountability in government service delivery by monitoring citizens' charter and making service delivery results public						
*55	Develop national web portal as a "one-stop shop" for delivering e-citizen services	PMO, BCC	Citizens can obtain e- citizen services from one location instead of having to search in multiple electronic locations. Reduce confusion and rent- seeking opportunities.			

*56	Enable payment of utility bills through mobile phones, banks, ATMs or other service centres from any location and at any time of the day	All utility providers	Reduce the monthly hassle, cost, and time spent paying utility bills. Govt. would benefit fromincreased transparency and efficiency in operations, and faster recovery of payments.	√		
*57	Enable online status check of court cases	Supreme Court, MoLaw, Land Appeal Board	Obtaining hearing dates and other information through the web/SMS would reduce time, cost, and hassles to citizens.	Supreme Court (Appellate and High Court Divisions)	District courts	
58	Enable electronic filing of GD and FIR	MoHA	Web and SMS-based filing of GD and FIR.	All police stations of Dhaka metropolitan area	Other metropoli tan cities	all police stations
59	Ensure access to public transport schedules, fares and ticket purchasing through the Internet and mobile phone.	MoCommu-nications	Enable citizens to obtain schedule/fare information without going to the station or waiting in line, thus reducing time, money, and hassle.	Railway, Biman		
60	Allow online registration and work permit for foreign investors	BoI	Increase overall efficiency in foreign inves-tors' registration system, thus increasing foreign invest-ment and elevating the image of the country.	√		

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
*61	Allow online VAT registration	NBR	Reduce time, cost of compliance and hassle to obtain VAT registration for companies/business firms. This will also increases the taxpayers' compliance rate, which will also increase VAT collection.	√		
*62	Allow online Tax filing. Introduce online tax payment system either collectively or successively for a whole financial year	NBR	Allowing citizens to file tax returns at their convenience from the comfort of their home will save citizens time, money and hassle, resulting in high rate of tax filing and collection.	√		
*63	Allow online issuance/renewal of passports	Passport	Minimize or eliminate harassment by middlemen. Citizens will not have to travel long distances to collect forms or for issuing/renewal of passports.	√		
64	Enable registration and ownership transfer of motor vehicles to be done electronically.	BRTA	Save vehicle owners from visiting multiple locations to register their vehicles. Ensure overall transparency of the system, which will authenticate the registration and contribute to reducing accident rates.	√		

*65	Allow online issuance/renewal of driving license	BRTA	Increase efficiency of issuance/renewal system, and ensure authenticity of the document, thus reducing the number of illegal drivers.	√		
*66	Allow online issuance/renewal of trade license	City Corporations	Ensure transparency in the trade license issuance system since there will be no room for bribery or nepotism, thus reducing illegal trades.	√		
*67	Allow citizens to report cases of corruption electronically	ACC	Empower citizens by giving them a voice in fighting corruption, thus helping the govt. fight corruption more effectively.	√		
68	Allow online lodging arrangements, booking of tickets for Hajj	MoRA	Reduce hassles with logistics of Hajj, especially for those who have never beenabroad, and elderly Hajis.	√		
69	Issue property registration certificates online	Dept of Registration	Reduce corruption by giving detailed records of individual property and assets.		√	
70	Register businesses/NGOs online	Registrar of JSC	Reduce timeand paperwork by providing rules, regulations and requirements online.	√		
*71	Ensure quick customs clearance of cargos	NBR		√		
72	Provide e-Assisted Consular attestation	MoFA	Enhance transparency and reliability of the system, thus reducing hassle to clients and eliminating the chance of frauds that can potentially threaten national security.	√		

73	Establish dairy information kiosk at collection centres	RDCD	Ensure faster turn- around time for quality assurance leading to elimination of middlemen and immediate payment to farmers based on more accurate and transparent quality assessment.	√		
74	Modernize bridge toll system	Bridge Division	Increase efficiency of toll collection and save citizens time and hassle.	√		
*75	Launch online job bank	MoEWOE, BMET	Establish easy linkage between graduates of TTC and recruiting agencies. TTCs will be better informed about the demand-supply situation, and be able to plan accordingly.	√		
76	Enable database of freedom fighters	MoLWA	Enable freedom fighters to effectively and efficiently receive various privileges offered by the govt. It will also be a document of national and historic value.	√		
77	Allow SMS/IVR-based allocation for sugar-cane farmers	MoIndustries	Establish a transparent and fair purchase system, which would save cost, time, hassle of the farmers	√		

*78	Computerize land management and registration system	MoLand	The greatest number of criminal cases is associated with land related issues. Digitization of land records will save citizens from tremendous hassle, corruption and harassment.	All circles of Dhaka through PPP bytaking lessons from Demra/ Manikganj	All DC offices and district A/C land offices	country wide
*79	Establish electronic payment gateway for inter-bank electronic transactions for citizens and businesses	BB	This would obviate the need for having designated banks for making electronic payments to the government. Citizens can make paymentsfrom any banks.	√		
*80	Make all public tenders available online.	All public sector organisations	Increase transparency in government purchases.	√		
*81	Promote online publishing of and adherence to Citizens' Charters	All ministries, divisions, departmenst		√		
82	Publish public procurement notices in at least one tender portal operated by the Bangladeshi ITES providers.	All public sector organisations	This will make the procurement process more transparent, easy, dynamic and costeffective.	√		
Strategic Theme 3.3: Establish interconnectivity across government offices for effective data sharing						
*83	Use ICT tools for file and information sharing among all the ministries/ divisions and departments/offices under these. Motivation and training to relevant govt. officials will be conducted	MoSICT, MoPT, BTRC, BCC	Effective information sharing will ensure more informed policy decisions. File movement can be tracked transparently.	Use of email and LAN for electronic file sharing and dissemination (not physical files)	tracking of physical files.	transformation of govt. towards electronicfile processing

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
*84	Create a national network for the government to connect the public organisations.	MoSICT, MoPT, BTRC, BCC	Enable electronic sharing of information across govt. offices.	Ministries, Divisions, Departments, DC offices, Upazila offices	District offices other than DC offices, Upazila offices	
85	Establish necessary policy framework and introduce IP telephony and video conferencing services in critical government offices.	MoSICT, MoPT, BTRC, BCC	Reduce, and in some cases obviate, travel time and cost for meetings.	Ministries, Divisions, Departments, DC offices	District offices with DC offices, Upazila offices	
*86	Establish National Data Resource Centre to control and manage the public network and act as a system of national databases to store and supply national data	BCC, MoSICT, Cabinet Division	Improve delivery of e- Services to citizens; ensure security of public data; improvement of data sharing and reduction of duplication across government organisations	Establishment of National Data Resource Centre	Develop capacity for national data network management	
87	Provide training to officials of all public sector organisations through web-based mechanisms and video conferencing	PATC, BCSAA, APD, BCC, regional govt. offices	Reduce, and in some cases obviate, travel time and cost for trainings.	PATC, BCSAA, BCC, BCS	Regional admin academies	
	Strategic Theme 3.4: Build capacity of government officials and foster leadership for electronic service delivery					
*88	Mandate basic computer and Internet literacy for all Class I and II appoint-ments in all public sector organisations for practical examina-tions (before viva voce).	PSC, MoEst	Enable much wider and more informed ICT usage within all public sector organisations	Starting from BCS exam to be held in 2009		

*89	Add a 50-mark examination (to the current 300-mark examination) for applied computer and Internet literacy for senior scale promotion examinations for cadre services.	MoEst	Enable much wider and more informed ICT usage within govt.	Starting in January, 2010		
*90	Ensure no promotion to national pay grade 1 and 2 without demonstration of basic computer and Internet literacy.	MoEst	Enable much wider and more informed ICT usage within govt.	Starting in January, 2010		
*91	Insert new criteria for assessment of basic computer and Internet literacy in the ACR.	MoEst	Enable much wider and more informed ICT usage within govt.	Starting from January, 2010 (or before, if it can be included in the current ACR revision process).		
92	Cease new stenotypist recruitment in the government. Convert all existing stenotypists to data entry operators through proper training.	MoEst, all GoB organisations	Enable much wider and more informed ICT usage within govt.	Starting in January, 2010.		
*93	Redesign ICT and e-Governance curriculum of government training academies with a distinct focus on change management and process re-engineering.	MoSICT, MoPT, BCC, Cabinet Division, MoEst	Update curriculum to be consistent with 21st century skills for govt. officials. The training should be updated every two years. Training will include the following: 1)e-Governance	√		

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
			leadership focusing on change management and process re-engineering 2) Basic computer and internet literacy 3) ICT Policy and Act			
*94	Orient all senior public servants towards effective use of ICTs in service delivery and administration. This needs to be driven through a mandate from Cabinet Division and orchestrated by the Ministry of Establishment.	MoSICT, MoPT, BTRC, Cabinet Division, PATC, BCSAA, BCC, NIMC	Enable more informed ICT usage for administrative automation and service delivery.	√		
*95	Develop institutional buy-in, incentive mechanisms and leadership for leveraging ICTs for service delivery with appropriate modifications to the Terms of Reference of e- Governance Focal Points and budget authority on the ICT part of the agency budget.	PMO, Cabinet Division, MoEst, MoSICT, BCC	Develop necessary high-level leadership for e-Governance and ICT-based service delivery.	Appoint Secretary in the Ministry/ Division and head of org at dept./corp. level as the e-Gov Focal Point. The Secretaries will report to the ICT Task Force for ICT Policy Implementation. The non-Secretary FPs will report to respective Secretaries.	Evolve the leadership structure with changes in the organisational structure of the govt in terms of ICT focus.	

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
*96	Develop ICT Cell for all public sector organisations to be run by ICT professionals. Create ICT posts for this Cell. All ICT posts in the public sector should be declared technical posts.	All government organisatios, MoEst, MoSICT	Ensure sustainability of e-Governance projects; employment generation in public sector	All ministries, divisions and directorates	District and upazila level governm ent organisations	
*97	Develop career ladder (including in situ promotion) and special compensation/ incentive packages to be offered to the ICT professionals of all public sector organisations comparable to those of private sector.	MoFin, MoEst, MoSICT	Encourage ICT professionals in the government sector; strengthen ICT capacity within the government		Develop capacity in MoSICT to facilitate transfer, posting. and career managem ent of ICT profession als in the govt.	
*98	Develop shared services for supporting and maintaining technologies within the government (system analysis, process re-engineering, support, maintenance, upgrade, project management) with additional technical allowance for ICT personnel.	PMO, Cabinet Division, MoEst, MoSICT, BCC	Significantly improve technical capabilities of the government to initiative, implement and sustain service delivery and administrative automation projects using ICTs. Enable transfer & promotion of ICT personnel within the government with selective compensation according to market rates.	▪Develop ICT resource pool within the ministry structure to provide support and maintenance ▪Establish govt.-owned company to provide skills such as project management, process re-engineering, system analysis, etc. ▪Modify government procurement rules to accommodate the above.	Central shared services for a cluster of ministries or all ministries	

Strategic Theme 3.5: Mandate availability of all public information through electronic means and ensure sustainability of ICT-based citizens' services delivery						
*99	Mandate all public information to be made accessible through appropriate electronic means including SMS and other channels.	All govt., semi- govt. and local govt. institutions	Enable citizens to access critical information on-demand in a cost effective and efficient manner.	All ministries and divisions, departments, all divisional HQs,	All directorates & agencies, all district and upazila administration	All UPs
*100	Allocate development budget at the level of each organisation on e-Governance initiatives and revenue budget for operations and maintenance of ICT-based citizens' services delivery systems	All ministries, divisions, departments		Upto 5% of ADP, 2% of revenue budget		
*101	Promote public-private partnerships for the private sector to invest in government service delivery using ICTs	All ministries, divisions, departments	Ensure financial sustainability and reduce burden of high initial investment on the part of the government	Feasibility study based on local and domestic best practices in ICT and non-ICT sectors. Promote PPP in as many new e-Citizens' Service initiatives as possible.	Establish PPP as the preferred model of launching e-Citizen Services	
Strategic Theme 3.6: Introduce ICT-based monitoring of planning, implementation and effectiveness of development projects						
102	Monitor collection and disbursement of foreign aid electronically	ERD	Enhance the transparency of aid disbursement, keep track of incoming and outgoing grants while increasing the administrative efficiency			

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
103	Assess effectiveness of development projects by exchanging dialogue with citizens using ICT.	IMED	Citizens' voices will be heard in the assessment of effectiveness and improvement of projects.	√		
*104	Deploy computer-based project planning and resource allocation system	Planning Commission	Ensure appropriate and adequate allocation of funds and resources for effective project planning.	√		

3.4 Objective : Education and research

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
	Strategic Theme 4.1: Assess skills of ICT professionals and meet gaps with targeted training programmes to overcome the short-term skills shortage in the ICT industry and adopt continuing education & professional skills assessment & enhancement programmes					
*105	Initiate ICT Professional Skill Assessment and Enhancement Programme (IPSAEP)	BCC, BASIS, BCS, Academia	1. More Industry ready people. 2. Increased opportunity for skilled IT workforce to get overseas jobs.	Initiate IPSAEP as a government programme in collaboration with industry and academia	Establish private entity for operations with ownership from the govt., industry, & academia	
	Strategic Theme 4.2: Encourage closer collaboration between academia and industry to align curriculum with market needs					
*106	Develop labour market information system to assess domestic and global labour demands for education planning	MoEdu, MoLabour, MoEWOE, BANBEIS, BBS	Create market-oriented skill sets			
*107	Encourage Industry affiliation & attachment programme for ICT students / graduates. Industry will offer at least 5% of their HR for internship.	ICT Industry, Academia	1. Fresh Graduates / Interns get good Industry exposure, which makes them more employable.			
108	Adopt need-based research projects with Industry, Academia, and Government partnership.	ICT Industry, Academia ICT Industry, Academia	2. Industry can pick and choose with less HR investment.			
109	Mandate Continuous Professional Development (CPD) through industry certifications for software design, development, quality assurance and project management		1. Foster innovation for appropriate and sustainable technologies for our country. Industry & Academia share their knowledge, practices and experience.			

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
110	Mandate Continuous Professional Development (CPD) through industry certifications for hardware and networking troubleshooting and maintenance, system integration, and network design	ICT Industry, Academia				
111	Create technology transfer programmes with success indicators through the involvement of NRBs	ICT Industry, Academia, NRBs				
*112	Identify market niches with global competitive advantage for Bangladesh for ICT and ITES (web and mobile content development, animation, Game	ICT Industry				
113	Development, DTP, financial transaction processing, etc.). Develop marketable skills for domestic and international markets by incorporating ITES-focused short courses in TVET programmes	MoEdu, MoEWOE, ICT Industry				
Strategic Theme 4.3: Establish an ICT Centre of Excellence with necessary long-term funding to teach and conduct research in advanced ICTs						
*114	Invest in Bio-Informatics R&D to record the genetic mapping profiles of our agricultural products		Improve the quality of education through research on latest technologies, tools, processes and QA systems			

115	Provide incentives to create of subject-focused ICT centre of excellence in each university		Improve the quality of education through research on latest technologies, tools, processes and QA systems			
*116	Adopt industry-ready applied research projects with mandatory industry & academia collaboration using government grant facilities.					
	Strategic Theme 4.4: Extend the reach of ICT literacy throughout the country by incorporating ICT courses in secondary education and TVET programmes					
*117	Redesign the ICT literacy curriculum for secondary and higher secondary syllabus at regular intervals based on the needs of an inclusive and cost-effective knowledge society.					
118	Ensure ICT literacy in a cost- effective way for primary and secondary students and teachers, since ICT skills have been recognized as part the 21st century basic skills.	MoPME, MoEdu, DPs		Ensure LAN and internet connected computer labs with appropriate technical support in district secondary schools, and all model primary schools. Publish yearly impact assessment reports.	Expand such labs to all secondary schools and 25% of primary schools with electricity.	

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
119	Ensure ICT skills as part of TVET programmes for marketable skills development	MoEdu, MoPME, MoEWOE, DPs		Identify marketable niches for most productive ICT areas for TVET and introduce updated curriculum through TVET programmes.	Update TVET ICT programm es every three years	
120	Ensure subsidized pricing for internet connectivity to primary and secondary educational institutions and TVET programmes	MoPME, MoEdu, MoPT, BTRC, DPs				
	Strategic Theme 4.5: Enhance the quality and reach of education at all levels with a special focus on Mathematics, Science and English					
121	Install computers, LAN, reliable Internet connectivity with reasonable speed and multimedia teacher training content for all Secondary Teachers' Training Colleges; with a special focus on Mathematics, Science and English	MoEdu, Planning Commission, DPs	tools for imparting effective Teachers' Training at the secondary level with special focus in Mathematics, English, and Science subjects.	Ensure LAN and internet connectivity for Secondary education TTCs. Pilot multimedia teacher training content in all TTCs with selected schools.	Mainstream multimedia-based teacher training through TTCs and self-paced training curriculum with a strong focus on peer learning and action research	Furnish video-conferenc ing for teacher training with action research as predomin ant mode of teacher training

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
122	Install computers, LAN, reliable Internet connectivity with reasonable speed and develop multimedia teacher training content (emphasising Mathematics, Science & English) for all Primary Teachers' Training Institutes, like PTIs, URCs and NAPE	MoPME, Planning Commission, DPs	Leverage ICT tools for imparting effective Teachers' Training using e- learning materials in all subjects at the primary level.	Ensure LAN and internet connectivity for PTIs, URCs and NAPE. Pilot multimedia teacher training content in 10% URCs with selected schools.	Mainstream multimedia-based teacher training through all URCs and self-paced training curriculum with a strong focus on peer learning and action research.	Furnish video-conferencing for teacher training with action research as predominant mode of teacher training
123	Organise regular national (including at grassroots level), regional, and international competitions on ICT related topics and support participation of national teams in international events.	MoSICT, BCC, Industry, Academia	Create enthusiasm about ICT among various segments of the population, and lead to enhancement of ICT skills.	✓		
124	Provide incentives/special loans/performanc e-based grants to teachers to acquire ICT tools			✓		
125	Create central repository for e-Learning content for teacher training and for all students. Provide Incentives for e-Learning content development.	MoSICT, MoEdu, MoPME, PMO, Planning Commission			✓	

126	Provide incentives/special loans/performance-based grants to teachers to acquire ICT tools	MoEdu, DPs	More science enrollments will ensure a larger pipeline of ICT professionals	✓		
127	Install computers, Internet connectivity and appropriate multimedia educational content for every primary, secondary & higher secondary school accessible to each student; include solar energy panels, if necessary.	MoEdu, different NGOs, DPs	Increased ICT literacy among all students.		✓	
128	Develop multimedia educational content for the secondary and higher secondary levels, and distribute to the students.	MoEdu, different NGOs	Leverage ICT tools to mitigate the shortage of good quality teachers, particularly in rural schools and colleges.		✓	
129	Create a Model School as an Information Access Centre with ICT facilities in each union, so that all other adjacent school students can use that facility.	MoEdu, MoSICT, different NGOs	Increased ICT literacy among all students.	10% of Union Parishads	50% of UPs	All UPs
130	Mandate Higher Mathematics for secondary science students	MoEdu	Empower students to enroll into ICT subjects at the tertiary level.	✓		

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
131	Install computers, LAN, reliable Internet connectivity with reasonable speed and multimedia educational content for TVET institutions	MoEdu, MoEWOE	Leverage ICT tools for improving technical & occupational skills with minimum investment.		✓	
132	Install computers, LAN, reliable high-speed Internet connectivity for tertiary educational institutions	UGC, Universities	1. Students will become ICT enabled & effective professionals. 2. Use ICT for accessing global knowledge resources.		✓	
133	Ensure that the teachers of higher secondary level and secondary level ICT courses are at least IT graduates and IT diploma holders respectively.			✓		
Strategic Theme 4.6: Ensure ICT Literacy for all in public service						
134	Ensure ICT literacy evaluation as part of public service entrance exams	Public Service Commission (PSC), MoEst	Govt. employees will be more efficient and able to deliver public services through ICT.	✓		
135	Ensure ICT literacy evaluation as part of the Annual Confidential Report (ACR)	Public Service Commission (PSC), MoEst	Govt. employees will be more efficient and able to deliver public services through ICT.	✓		

Strategic Theme 4.7: Boost use of ICT tools in all levels of education including ECDP, mass literacy and lifelong learning						
136	Create Bangla language platform for mobile applications	BTRC, Telecom companies (both operators & phone manufacturers)	Enhance adult learning through Bangla content.	✓		
137	Participate with international endeavours for social inclusion using ICT.	MoSICT, MoPME, MoEdu, DPs		Explore low-cost computer options		
138	Ensure access to Public Library Services through ICT	MoCA	Central Public Library and divisional branches	All district branches		
139	Utilize mass media tools such as radio and television to broadcast educational programmes	MoPME. MoEdu. MoI, private sector, DPs		Allocate significant time slots for educational purposes in the under-utilized BTV terrestrial channel	Ensure 12- hour educationa l TV broadcast	Ensure 24- hour educational TV broadcast
140	Introduce ECDP for all poor rural children in regular and community schools for at least six months using multimedia tools	MoPME			✓	
141	Introduce ECDP for the children in the remote areas, including the ethnic minorities, using multimedia tools	MoPME			✓	

142	Develop marketable skills (i.e. English, Graphics courses, etc) for domestic and international market by incorporating e-Learning in existing youth development programmes.	MoYS, MoEdu			Pilot this in 10 Youth Development Centres of the govt.	Expand this programme to all youth development centres of the govt.
Strategic Theme 4.8: Ensure access to education and research for people with disabilities and special needs using ICT tools						
143	Develop Bangla speech processing tools – text to speech (TTS), automatic speech recognition (ASR) – for print disabled community			Create the required linguistic resources	Create Bangla TTS	Create Bangla ASR
144	Develop Bangla script processing tools – optical character recognition (OCR), Braille reader – for the print disabled			Create a single- font fixed-size printed script OCR	Multi-font size independent printed script OCR	OCR for typewritten documents
145	Integrate natural language processing tools in applications					Integrate TTS, ASR, OCR in various applications
Strategic Theme 4.9: Ensure that all universities provide global standard ICT education and introduce Postgraduate Programmes in ICT education to encourage research and innovation						
146	Periodic ranking of IT programmes of private and public universities by a competent body (including academia and industry) approved by UGC	UGC, BCC, IPSAEP Authority, ICT Industry	1. Encourage healthy competition for higher quality ICT education. 2. More alignment towards Industry needs.			

147	Preferentially allocate private university merit-based scholarships to boost ICT- related studies	UGC, private universities	Increased enrollments of bright students in ICT related subjects to reverse the current declining trend.			
148	Encourage industry to collaborate with universities to carry out their mid to long term research activities	ICT Industry, Academia	1. Foster innovation for appropriate and commercially feasible technologies for the ICT Industry. 2. Industry & Academia share their knowledge, practices and experience.		✓	
149	Mandate industry to have in- house R&D department. This R&D unit may collaborate with universities.	ICT Industry, Academia	1. Industry moves upward in the Value Chain. 2. Industry becomes more attractive for the talented people who want to pursue creative and challenging work.			✓
150	Organise regular national, regional, and international conferences.	Academia	Bangladesh ICT brand gets exposure.			
151	Publish regular national journals on the various ICTs.	BCS, Academia, BCC	Bangladesh ICT brand gets exposure.		✓	

152	Build electronic library in tertiary teaching institutions to make knowledge produced there easily available. Link to other similar institutions.	Tertiary educational institutions – govt, and private	Archive and share knowledge produced in universities.	Bring all universities including Open University under a National Research and Education Network (NREN)	Bring all colleges under National University under this network	
153	Link all the electronic libraries to the global hierarchical research networks.	Academia, Govt, TEIN-3	Leverage global research and enrich local knowledge.	✓		
154	Create Bangladesh Computer, Communications & Electronics Society to coordinate research and development activities.	BCS, BCC	A single apex body will be able to coordinate different ICT activities more cohesively.			✓
155	Introduce ICT based defense solutions from local Industry & academia for the sake of national security	Academia, govt.	Preserve strategic independence for national defense issues.	✓		
156	Establish mechanism to revise computer science curriculum at the tertiary level every two years.					
157	Promote data collection through alternative channels like telecentres, for social and scientific research					✓

3.5 Objective : Employment generation

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
158	Establish an Authority/Body on ICT Industry development	PMO, MoSICT, Industry Associations	Speed up implementation of decisions taken on the basis of ICT policy.	✓		
159	Establish ICT Industrial Development Fund (IIDF).	PMO, MoFin, proposed ICT Industrial Development Authority	Facilitate funding of projects for software/ITES industry development by reducing the time of regular budgetary approval.	US$ 100 Million (Tk. 700 crore)		
160	Establish a separate ICT Company Accreditation Body to evaluate company eligibility for govt. support	BCC, BTRC, proposed ICT Industrial Development Authority, Industry Associations	Accreditation will make the evaluation and approval process faster and more transparent.	✓		
*161	Establish Special Working Capital Funding at reduced bank interest rate for both local and export works	BB, MoFin and different commercial financial institutions	Solve the problem of access of finance for IT companies	✓		
162	Reimburse training cost (50%) of ICT Professionals	MoSICT, MoFin	Incentive for companies to invest in training of HR, which will enable them to employ more ICT professionals.	✓		

163	Discount price for rent in govt. owned IT Parks, STP, Incubator, HiTech Park, Internet and other utilities	MoFin, MoPT, MoSICT, BTRC, BTCL, MoPEMR, PDB	Initial support for high prospect IT companies will enable them to overcome the early challenges of becoming competitive	✓		
164	Ensure price preference (at least 25% for all public procurement) for local ICT products	IMED, CPTU	Ensure enough jobs for the local ICT industry	✓		
165	Create a Venture Capital fund for young ICT graduates to establish startup ICT companies	BB, BCC, financial institutions	Enable young and talented IT & business professionals with bright ideas to set up new ventures		✓	
166	Create special ICT Entrepreneurship Development Fund.	BB, financial institutions	In absence of right kind of capital/equity market, this fund (should be matched by sponsors' own equity) can play the role of source for 'long term investment fund'	✓		
167	Provide special benefit proportionate to the number of ICT professionals employed	Proposed ICT Industrial Development Authority	Encourage IT companies to grow & increase recruitment.		✓	

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
Strategic Theme 5.2: Build institutional capacity for producing greater number of IT professionals in ine with domestic and global demands for knowledge workers						
168	Establish special scholarship/ education loan for science education at the secondary/higher secondary/Bachelor 's level	MoEdu, BB, financial institutions	Reverse the trend of non-science education (less than 15% of higher secondary graduates are in Science group)	✓		
169	Double the number of seats at the CS/CSE/CE departments at all the public universities	MoEdu, UGC	Increase the pipeline of HR pool for the software industry by making IT education affordable to larger number of poor students	✓		
170	Provide special incentive for IT teachers in cities to go to regional colleges (on short-term deputation)	MoEdu, UGC, National University	Ensure quality IT subject teachers outside Dhaka	✓		
171	Provide special privilege for local ICT professionals / ICT Teachers to stay in their home districts	MoEdu, UGC, MoEWOE, National University	Ensure quality IT subject teachers outside Dhaka.		✓	
172	Introduce ICT undergraduate programme at the district level colleges under National University (at least one college at every district)	MoEdu, UGC, National University	Disseminate IT education across the country and make it more affordable to poor students		✓	

173	Assess global ICT HR requirements, create existing ICT HR database. Forecast future ICT HR demands and identify national focus.	MoSICT, BASIS, BCS	Assess the demand and supply situation of IT professionals to make appropriate decisions		✓	
174	Increase enrollment of female students in the ICT courses	MoWCA, MoEdu, MoEWOE	Ensure gender balance in ICT sector. Females are better suited for some ITS/ITES jobs.	Target Divisional & District levels	Target Upazila levels	Target Union / Village Levels
175	Mandate ICT Industry to gradually increase their female workforce to at least 30% of total HR	Industry Associations	Ensure gender balance in ICT sector. Females are better suited for some ITS/ITES jobs.		✓	
Strategic Theme 5.3: Standardize skills for local ICT industry						
176	Ensure the quality of education (content, delivery, teachers) by UGC	UGC	Improve the quality and effectiveness of IT education at tertiary level	✓		
177	Create one-year on-the- job training programme for all ICT Graduates (under strict criteria) with 80% salary (max. Tk. 10,000 per month) reimbursed to software companies	MoSICT, MoFin	Incentive for software companies to recruit fresh graduates and train them to become skilled professionals.	✓		
Strategic Theme 5.4: Facilitate global employment of skilled ICT workforce						
178	Collect information on and create awareness about global ICT Employment	BASIS, BCS, BCC	Helping IT professionals to explore opportunities for global placement	✓		

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
179	Provide training on foreign languages (other than English) and specialized technologies for overseas employment	BCC	Make the IT professionals more 'employable' in certain high growth markets (e.g. Japan, Korea, Germany, etc)	✓		
180	Conduct research on global Human Resource needs vis-à-vis local capability to identify national focus	BASIS, BCS, BCC	Identify the right type of skill gaps in the global market to make the right strategic decisions		✓	
181	Create special promotional programme (by EPB, BMET, Probashi Ministry, and Foreign Labour wings, and Bangladesh Missions abroad) for high end overseas employment in IT	MoEWOE, MoFA	Promotion of Bangladeshi IT professionals in the selected markets	✓	✓	
182	Provide incentives for recruitment agents/exchanges working with ICT professionals	MoEWOE/BMET	Incentives for agents to explore new IT employment markets		✓	
183	Create strategic roadmap for Human Resources Development for the ICT industry (both home & abroad)	BCC	This planning tool will ensure right supply of IT workforce to meet the demand, thus creating employment	✓		

Strategic Theme 5.5: Provide financial assistance to ICT professionals for skills development						
184	Provide long term loan (with minimum 4 yr. grace period and max. 4% interest rate) for ICT education	BB, financial institutions	Make IT education affordable to the talented but poor students, who will be able to repay the loan after graduation	√		
185	Provide 100% govt. scholarship in ICT Study for students getting CGPA 5 in both the secondary and higher secondary levels.	MoEdu, MoSICT	Make IT education affordable to the talented but poor students.		√	
186	Provide special scholarship for ICT education (10 meritorious students from every Upazila) at the undergraduate level based on the higher secondary results.	MoEdu, MoSICT	Make IT education affordable to the talented but poor students, thus increasing the HR pool for the software industry		√	

3.6 Objective : Strengthening exports

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
Strategic Theme 6.1: Develop strong marketing, promotion and branding for Bangladeshi ICT products and services in global markets						
*187	Provide proper funding and priority for Competency Assessment & Strategic Roadmap of the ICT Industry for export.	MoCommerce, PMO	Attract FDI and local investment.	Prepare Competency Assessment and Roadmap	Revisit Roadmap every 2 years	
*188	Establish ICT Marketing Desk with ICT knowledgeable people at the Bangladesh Embassies in major markets.	MoCommerce, MoFA	Increase export of Software & ITES.	In USA and Sweden	In at least 5 more countries based on roadmap (e.g. UK, Japan, etc.)	In at least 20 countries
*189	Create a Bangladesh ICT brand as a top ICT outsourcing destination (more than just logo, website, brochures and support desk to promote Bangladesh ICT)	MoCommerce, MoFA	Strategic marketing and branding will make Bangladesh ICT known to foreign buyers.	Develop a marketing plan to promote Bangladesh ICT in the international market	Promote Bangladesh ICT in international forums including news and electronic media.	
190	Participate in major ICT fairs, conferences and business linkage programmes by ensuring highest level of policy & industry level	MoCommerce, EPB, IBPC	Attract foreign buyers, investors, and media. Generate export leads.	Participate in fairs in 5 major countries	Participate in fairs, conferences and road shows in more than 10 major markets	Participate in fairs, conferences and road shows in more than 20 major markets

191	Invite international ICT companies, opinion leaders and journalists to Bangladesh by organizing international fairs and conferences to promote Bangladesh ICT domain and technology focus for sales & marketing. Their travel and other expenses will have to be covered to make them interested in Bangladesh.	MoCommerce, MoSICT, IBPC	Promote and enhance image of Bangladesh ICT among foreign buyers.	Invite from 5 countries	Invite from 15 countries	
*192	Create ICT clusters based on region, services, domain and technology focus for sales & marketing	MoCommerce, MoSICT, IBPC	Increase performance and reduce costs in production, marketing, etc. ICT clusters can learn from each other and thus improve expertise and quality.	Create a marketing cluster for European and North American markets	Create a marketing cluster for new markets; also create technology and domain clusters.	
*193	Improve EEF policy based on Industry proposal	MoFin, BB, MoSICT	Improve service delivery and speed up the process.	Revise policy with input from industry, academia and govt. agencies	Increase EEF fund allocation to meet industry demand.	
*194	Allocate collateral-free loan fund against working capital in software & ITES sector.	MoFin, BB, MoSICT	Make finance available to ICT companies to execute their projects on time.	Allocate Tk 100 crore.	Allocate more funding according to industry demand.	

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
*195	Formulate financial policy to support and develop Venture Capital fund for the ICT sector	MoFin, BB, MoSICT	Support companies with new and innovative ideas			
Strategic Theme 6.3: Develop and maintain reliable ICT infrastructure						
*196	Provide regionally cost-competitive and reliable Internet bandwidth for everyone	MoPT, BTRC	ICT companies can get uninterrupted service.	✓		
197	Allow lease facility of the existing connectivity infrastructure (fiber, copper and other cabling set up of BTCL & other operators) to the Internet distribution.	MoPT, BTRC	increase access to the Internet, reduce deployment time, increase revenue income, and avoid monopoly			
198	Provide discounted rates for bandwidth for software industry, ICT incubator or park, libraries, education & research organisations, Internet kiosks, telecentres, etc. to promote a knowledge-based society. The process of sanctioning discount should be as simple as possible	MoPT, BTRC	Make Bangladeshi ICT companies cost effective compared to their competitors	75% discount for ICT industry		

*199	Establish more Software Technology Parks, Hi- Tech Parks and ICT Incubators all over the country.	MoSICT	Increase investment in ICT sector from local and foreign investors, make local companies cost-competitive, increase employment & export.	Set up Software Technology Park in Mohakhali		
200	Expedite the process of setting up an alternative / second submarine cable connectivity for redundancy. Ensure connectivity at the village level.	MoPT, BTRC	Ensure redundancy of Internet	Set up second submarine cable	Ensure connectivity at village level	
*201	Introduce one stop service for right of way permission, payment of fees, etc. for installation of cable and ducts by concerned authorities. Ensure nominal charges for right of way.	BTRC, MoPT	Ensure redundancy of Internet	Provide fast, efficient and reliable Internet service all over the country		
202	Ensure proper implementation and updating of IPR Laws (Patent & Design, Trademark, Copyright). Strengthen IPR offices.	MoSICT, MoHA	Build confidence of global companies to outsource jobs to Bangladesh. Protect intellectual property of local and foreign companies and professionals.			
*203	Provide income tax exemption to Software & ITES sector till 2018	MoFin	Boost investment in ICT sector	✓		

204	Waive customs duty and VAT on network equipment (for data connectivity) to reduce the cost of connectivity to common people	MoFin, MoComme rce	Reduce cost and increase connectivity	Sign WTO IT Agreement to reduce import duty and lower domestic VAT		
*205	Provide appropriate incentives to attract FDI in ICT sector	MoFin, MoCommerce, MoSICT	Foster FDI	Set up second submarine cable	Set up Mohakhali STP; minimize bandwidth cost	
206	Withdraw VAT from ICT services including Internet services and ICT consulting services.	MoFin, NBR	Reduce cost and increase connectivity for common people	✓		
207	Waive taxes on locally developed software to encourage exports.	NBR				
208	Provide incentives for locally produced computer hardware.	NBR				
	Strategic Theme 6.5: Foster innovation through research & development to improve quality, process, technology, domain, value chain and niche markets					
*209	Develop Centres of Excellence with participation of industry and academia for creation of intellectual property.	MoSICT, BCC	Improve the quality of human capital, products and services	In 5 leading universities	In 15 universities and 10 colleges	In all universities and major colleges
210	Establish International Institute for Business Analysis (IIBA)	BCC	Develop the number and quality of business analysts and system analysts to provide high value to end business customers.	Set up IIBA in Dhaka	Set up chapters in divisions	

*211	Establish Project Management Institute (PMI)	BCC	Improve the expertise and numbers of project managers through PMI	Set up PMI in Dhaka	Set up PMI chapters in divisions	
212	Provide grants for ICT research	MoSICT	Encourage research on new technologies and tools	Allocate Tk 150 crore for ICT research for innovative projects and ideas		
213	Establish High Speed Education Network all over the country for e-learning and distance education. Also start a terrestrial TV channel for education.	MoEdu, MoCommunication, MoSICT	Improve the education system by providing access to up-to-date knowledge and resources	Set up network for all universities	Set up network for colleges and some schools	Bring all educational institutions under this network
*214	Establish an institute for developing senior management in collaboration with leading business schools from home and abroad	BCC	Enhance the skills of senior management of the ICT sector and encourage them to embrace global best practices in management			

3.7 Objective : Health care

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
Strategic Theme 7.1: Improve management of healthcare delivery system						
*215	Develop a national health network of all medical institutions in the public sector for availability of critical management information	MoHFW & private sector	Greater transparency and effectiveness in decision making	Pilot in one district	Establish a national network	
216	Develop database of usage, lifespan etc. for important hospital machinery and equipment like X-ray, ultra-sonogram etc. in use in the Governmental Hospitals for proper & timely procurement thereof	MoHFW & private sector	Ensure economic return from the machines, Avoid duplication of machinery etc.	Pilot in one district	Establish a national network	
217	Develop infrastructure database for ensuring timely maintenance of governmental facilities	MoHFW & private sector		Pilot in one district	Establish a national network	
Strategic Theme 7.1: Improve management of healthcare delivery system						
218	Update and use database for management of doctors, alternative medical care professionals, nurses, paramedics and other health workers for posting, training and promotion	MoEdu		✓		

*219	Utilize Geographical Information Systems (GIS) to facilitate health sector planning, as well as helping to predict and identify the spread of emerging disease conditions	MoHFW & private sector		✓		
*220	Promote and facilitate the use of ICTs in monitoring health service delivery systems.	MoHFW		Develop appropriate software for HMIS. Train all district level staff.	Train all upazila level staff	Train all union level staffs in HMIS
221	Use ICT (mobile) facilities for monitoring, contact & discussions with among field personnel	MoHFW, private sector, NGOs				
Strategic Theme 7.2: Improve community awareness and access to health care facilities for all including difficult to access areas, with a special emphasis on child and maternal health						
222	Utilize ICT and telemedicine as well as develop websites for all hospitals to spread awareness about health issues including child and maternity care, birth control and reproductive health etc.	MoHFW, MoInformation, NGOs and private sector		✓		
223	Deliver cost effective, prompt and responsive services through remote consultation up to the Upazila levels (Helpline)	MoHFW & private sector, NGOs		Establishment of connectivity between 50% of all upazila hospitals and	Establish ment of connectivity between	Establish connectivity between Union Health

				tertiary care hospitals	100% of all upazila hospitals and tertiary care hospitals	Centre and tertiary/district hospitals
224	Deliver cost effective, prompt and responsive services through telemedicine	MoHFW & private sector, NGOs		Establish remote tele-diagnostic centre, connected to tertiary care facility at every district town	Establish remote diagnostic centres at every Upazila	Establish remote diagnostic centres at Union/ growth centres
*225	Adopt ICTs to improve and extend health care and health information system to remote and underserved areas and vulnerable population	MoHFW & private sector, NGOs		✓		
226	Run mobile health units, especially for emergency cases, equipped with advanced medical equipments, staffed by specialists, and a high tech communication network, to which data and images from all the units can be sent electronically.	MoHFW, private sector, NGOs		Pilot in a district HQ.	Available from all district HQs	Available from all upazila HQs
*227	Create ICT based networking of research and training institutions for development of standards of operation and standard operating procedures	MoHFW, private sector, NGOs		✓		

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
*228	Create ICT based (including video conferencing) monitoring of critical services provided in the health system through such institutions mandated for the purpose.	MoHFW, private sector, NGOs		✓		
229	Create ICT based monitoring of drug quality in the country.	MoHFW, private sector, NGOs		✓		
Strategic Theme 7.3: Ensure Quality Assurance of health care services						
230	Create ICT based monitoring of diagnostic (pathology and other testing) facilities in the country	MoHFW, private sector, NGOs				
Strategic Theme 7.4: Enhance capacity of National Health Service Delivery System						
231	Provide health professionals with access to global health knowledge and research resources through ICT	MoHFW, private sector, NGOs		Develop ICT based audio-visual content for skill development and make the district hospital as the resource centre for the whole district	Train all health service providers	
*232	Use ICT based contact for critical medical advice/ peer review/ suggestions in hospitals	MoHFW, private sector, NGOs		Pilot one national call centre	Expand to regional call centres at the divisional HQs	Expand to district call centres

*233	Develop ICT based networking of medical based organisations for sharing of information	MoHFW, private sector, NGOs				
234	Promote innovative use of ICT for cost-effective diagnosis and treatment.	MoHFW				

3.8 Objective : Universal access

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
*235	Increase teledensity	Telecom operators, ISPs, BTRC, MoPT			70%	90%
236	Increase broadband connectivity : 30% by 2015, 40% by 2018	Telecom operators, ISPs, BTRC, MoPT			30%	40%
*237	Develop a policy and fund for Universal Access Obligation	BTRC, MoPT		✓		
Strategic Theme 4.9: Ensure that all universities provide global standard ICT education and introduce Postgraduate Programmes in ICT education to encourage research and innovation						
238	Launch country satellite	BTRC, MoPT, private sector				✓
239	Establish new submarine connectivity (for redundancy and capacity enhancement)	BTRC, MoPT			✓	

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
240	Reduce right of way charges charged by DCC and other authorities for installing broadband fixed networks			✓		
241	Make internet access charges from all DDN points throughout the country equal			✓		
	Strategic Theme 8.3: Extend Internet and IP telephony services to all parts of the country within 5 years through providing incentives as stipulated in the national telecom policy					
242	Introduce number portability for better telecommunication customer service	BTRC			✓	
243	Introduce toll-free numbering	BTRC			✓	
244	Provide IP telephony license to ISP			✓		
245	Make IP to IP calls charge free as customers will have paid for Internet access already to use IP telephony			✓		
	Strategic Theme 8.4: Make IP-based telecommunications ubiquitous and affordable by all through aggressive adoption of NGN and license-free regime					
*246	Introduce 3G services for better and faster data, multimedia and voice communication	BTRC, Telecom operators		✓		

Strategic Theme 5.2: Build institutional capacity for producing greater number of IT professionals in ine with domestic and global demands for knowledge workers						
*247	Introduce a simplified telecomm licensing regime	ICT Task Force, MoPT	Remove barriers of introducing new services to help facilitate broader services categories in a quick & transparent manner		Introduce international standard guidelines for spectrum allocation and allow trading of spectrum	
	Create Broadband Wireless Access network (through WiMax and/or other modern technologies) throughout the country	Telecom operators, ISPs, BTRC, MoPT			✓	

3.9 Objective : Environment, climate & disaster management

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
Strategic Theme 9.1: Promote environmental preservation by adopting environment-friendly green technologies						
*249	Mandate energy-saving and low-power-consumption ICT devices for govt. procurement based on pre-determined, internationally accepted consumption benchmarks.	All ministries/ divisions		Develop awareness for procurement and use. All govt. machines will use built-in energy-saving devices.	100% of all govt. ICT procurement will be energy-saving devices	

250	Set and enforce regulatory standards to control dumping of ICT devices to prevent electronic waste. Establish safe disposal and recycling mechanisms and organisations.	MOSICT, BCS, BCC				
Strategic Theme 9.1: Promote environmental preservation by adopting environment-friendly green technologies						
251	Reduce use of paper in offices by increasing electronic communication, file processing, information sharing and archiving.	All government offices		Replace paper based communication system with an ICT based one in the PMO	All Ministries and Divisions	All Govt. Offices
Strategic Theme 9.2: Promote environmental protection through the use of ICT tools						
*252	Utilize remote sensing technologies and communication networks for more effective monitoring, resource management and mitigation of environmental risks, e.g. GIS to combat illegal logging, illegal fishing, to help forest protection, land degradation, water quality, etc.			Monitor illegal fishing using remote sensing facilities in the major ports with the help of coast guards	Stop illegal deforestation and trade of valuable wildlife with the help of forest officials	All areas where GIS may be applicable for monitoring activities related to environment al protection
253	Increase access to/awareness of sustainable development strategies in areas such as agriculture, sanitation and water management, mining, etc.				✓	

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
Strategic Theme 9.1: Promote environmental preservation by adopting environment-friendly green technologies						
*254	Ensure greater transparency and monitoring of environmental abuses/enforcement of environmental regulations.					
255	Develop modeling tools for assessment of risks and developing a National Action Plan for Adaptation (NAPA) for climate-change	PMO, MoEF, MoWR, MoA, MoFL, NGOs, academia, CEGIS				
256		NGOs, MoEF				
257	Develop technical and intellectual skills of forest officials on necessity of wildlife preservation and utilization of various tools available to them through CBTs and/or Distance Learning.					
*258	Raise awareness and train city corporation officials on effective & humane methods to stabilize (not eliminate) street animal population as part of city planning and urban development.			Monitor illegal fishing using remote sensing facilities in the major ports with the help of coast guards	Stop illegal deforestation and trade of valuable wildlife with the help of forest officials	All areas where GIS may be applicable for monitoring activities related to environmental protection

Strategic Theme 9.3: Protect citizens from natural disasters through ICT-based disaster warning & management technologies						
*259	Utilize remote sensing technologies for disaster management and mitigation.	MoFDM, Dept. of Meteorology, SPARRSO, MoDefense			✓	
*260	Web-based environmental clearance certification system	MoEF		Green	others	
*261	Promote cell phone/SMS-based disaster warning systems targeted to the population likely to be affectedt	DMB, DMIC, BTRC, ATOB, BMetD, BDRCS, NGOs		100%		
*262	Utilize GIS based systems to monitor flood & cyclone shelters (including equitable distribution in vulnerable areas)	MoFDM, MoWR			✓	
Strategic Theme 9.4: Ensure safe disposal of toxic wastes resulting from use of ICTs						
263	Build plants for cannibalizing old PCs and ICT accessories to extract precious metals.				✓	
Strategic Theme 9.4: Ensure safe disposal of toxic wastes resulting from use of ICTs						
*264	Utilize GIS based systems to ensure equitable distribution of relief goods with special focus on the hard-to-reach areas.	MoFDM, MoA, MoDefense				

3.10 Objective : Supports to ICTs

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
*265	Ensure availability of electricity supply all over the country according to current demand and ensure fulfilling future demand	MoPEMR			✓	
266	Govt. funded replacement programme of conventional light with energy saving light in 10 years	MoPEMR	Reduce consumption of electricity, thereby reducing load shedding.		✓	
*267	Provide incentives for use of alternative energy sources such as solar, wind, bio-fuel, etc.	MoPEMR	Enable more people to use technology. Serve as backup power source for computers and network equipment.			
268	Ensure uninterrupted power supply in Incubator/Hi-tech Park/Software Technology Park/IT Park	MoPEMR	Enable ICT industry production to run smoothly.			
269	Reduce tax on power generator, solar panel, IPS, UPS/Online UPS, battery used in IPS/UPS	NBR	Minimize the cost of backup power systems.			

270	Encourage private investment in power generation and provide same facilities and benefits as the govt.	NBR	Ensure more power generation.			
271	Encourage R&D for efficient power consumption.	BoI, MoPEMR	Find ways to produce small unit substitute power for ICT use			
272	Minimize system loss	BoI, MoPEMR	Minimize power distribution systems loss			
273	Introduce prepaid meter	MoPEMR				
Strategic Theme 10.2: Create supportive legal framework for IPR protection, online document sharing, transactions and payments						
274	Implement payment gateway	MoSICT, BB	Open the window for online transactions, and reduce traffic on roads as people can get many required services online.			

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
275	Introduce Cyber police	MoSICT, MoHA & MoLaw	Ensure cyber security.			
276	Implement ICT Act 2006 (electronic signature, certification authorities, etc)	MoSICT & MoLaw	Open up online transactions and e-commerce.			
277	Introduce special tribunal for handling Cyber Crime and IPR violation.	MoSICT & MoLaw	Ensure cyber security and IPR law enforcement			
278	Establish additional Internet Exchanges	MoSICT	Minimize wastage of expensive international bandwidth			
279	Update Patent and Design Act	MoIndustries	Allow software patents and designs to be registered			
280	Introduce an Act so that procurement and recruitment notices for the public sector are published in the relevant service web portals. Allow submission of bids and job applications online.	MoEst, PSC, CPTU, MoSICT, MoPlanning MoInformation	Ensure that the procurement and recruitment process is more transparent, easy, dynamic and effective. Expedite the "E- Governance" policy of the government	✓		

*281	Introduce and enforce Electronic Fund Transfer Act, Cyber Crime Act, and Competition Ordinance	MoFin, BB, MoCommerce, MoLaw	Facilitate secured electronic transactions to enable citizens to pay through electronic means			
*282	Review and amend ICT Act 2006 or its rules to address unaddressed or under-addressed issues	MoSICT, MoLaw	Address stamp duty for e- documents in accordance with Stamp Act 1899, Evidence Act 1872 & Power of Attorney Act 1882; and for the registration of e-documents under the Registration Act 1908			
Strategic Theme 10.3: Establish a Government Interoperability Framework to be adhered to by all government ICT projects						
283	Develop GIF for all ICT projects	MoSICT, BCC	Reduce duplication of data and systems; develop ability to share data and software across government agencies	Specifications and working solutions with e-GIF standards	Introduce National Enterprise Architecture (NEA)	Establish NEA for all e-Governance projects
284	Develop training for ICT professionals on how to use the GIF	MoSICT, BCC, BASIS, BCS	Ensure GIF is followed in e-Governance implementations	✓		
285	Create a support structure for GIF issues	MoSICT, BCC	Ensure sustainability of GIF usage	✓		

Strategic Theme 10.4: Promote the use of cost-effective, open source and open architecture solutions						
286	Build awareness about IPR and open source in all government institutions, recognized associations, schools/colleges/ universi ties	MoSICT, MoEnergy, Trade Bodies, NGOs	Ensure easy implementation of IPR laws, and spread awareness about low cost open source solutions where feasible			
287	Build awareness on the usability of open source and proprietary software from a business perspective, especially with regard to Total Cost of Ownership (TCO). Whenever the business case from a TCO perspective favors open source, it should be given preference.	MoFin, MoPlannin g, CPTU	Open source options have lower or no licensing costs; freedom to customize for localization and other specific govt needs.	30% of all government institutions to be given guidelines on how to evaluate TCO and be provided with training.	70%	100%
288	Introduce open source in all educational institutes to enhance learning and knowledge creation.	MoEdu, MoPlanning	Eliminate unwanted software piracy and prepare better knowledge workers at all levels.	40% of the all educational institutes will run on open source operating systems, office tools, & educational software	80%	100%
289	Introduce open source operating system, tools & office applications in public sector organisations.	MoFin, MoPlanning, CPTU	Open source options have lower or no licensing costs; freedom to customize for localization and other specific govt needs.	10% of all the govt IT infrastructur e will run on open source operating systems & tools	30%	60%

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
290	Establish open source R&D centre in collaboration with Industry and Academia.	MoSICT	Contribute to open source world; understand strengths and weaknesses of open source			
291	Implement govt. ICT projects, preferably by outsourcing.					
Strategic Theme 10.5: Build ICT infrastructure facilities in educational institutions						
292	Establish one computer lab for each school and college with at least 20 computers.	MoSICT	Enable all students to have general knowledge of computers & software and their benefits			
293	Provide 1 mbps free Internet connectivity in each school and college programme	BTRC	Give students access to global knowledge to compete in a globalized world			
294	Increase the capacity of science departments in all schools & colleges with enough lab facilities and teachers	MoSICT	Increase science enrolment			
295	Establish a long term Corporate Social Responsibility (CSR) programme to donate new and old PCs.	MoF, MoCommerce FBCCI				

Strategic Theme 10.5: Build ICT infrastructure facilities in educational institutions						
296	Decentralize govt activities using high speed data connectivity and automation (e-governance).	MoFin, MoPlanning	Increase demand for software and technology use, and balance growth and social equity			
297	Develop optical fiber network up to Upazila level.	MoSICT & BTRC	Enable general people to get connected.			
298	Provide facilities to ISPs, Data Connectivity providers, Housing and infrastructure builders to increase the market in other cities of the country.	MoSICT & BTRC	Enable general people to get connected.			
Strategic Theme 10.7: Improve education quality in IT, Mathematics and English						
299	Create programme for special teacher training in Mathematics and English	MoEdu	Improved quality of Mathematics and English will produce better students for science education			
300	Create programme for one library in each school & college with enough books on IT (>100 titles in each on IT)	MoEdu	Give all students access to knowledge of ICT			
301	Standardize the salary scale of Science Subject teachers over others in govt. and semi-govt. schools & colleges.	MoEdu	Make good teachers available for science education			

No.	Action Item	Primary Actors	Expected Deliverables & Benefits	Short Term	Mid Term	Long Term
Strategic Theme 10.7: Improve education quality in IT, Mathematics and English						
302	Add at least 2 more submarine cables for better international connectivity using the private sector, ensuring competitive environment	BTRC	Secure, quality and competitive Internet supply for growth of ICT use and export			
303	Reduce the retail price of Internet (ISPs and mobile Internet using GPRS/EDGE/3G technology)	BTRC	Give citizens the benefit of Internet at an affordable price			
304	Make Internet affordable for common people	BTRC	Give citizens the benefit of Internet at an affordable price			
305	Implement broadband policy	BTRC	Encourage growth of ICT around the country rather than in a single city			
306	Open up WiMAX for licensing	BTRC	Provide faster Internet coverage for greater number of people, including IP telephony service, etc.			

Practice questions and answers with explanations

Q1. Social equity – community access

Fatema lives in a remote union in Sylhet. She needs to apply for a social safety net programme but the nearest government office is 40 km away. She has no computer at home, but a nearby shop has one connected to the internet.

Under the National ICT Policy 2009, which action item MOST directly addresses Fatema's situation?

A) Launching a Development TV Channel using BTV's terrestrial channel

B) Establishing Community e-Centres in Union Parishads to provide access to e-citizen services

C) Enabling online VAT registration through NBR

D) Developing Bangla speech processing tools for the print-disabled

Answer: B

Explanation: Action items *1 and *2 under Strategic Theme 1.1 specifically mandate establishing Community e-Centres (telecentres) in Union Parishads to allow citizens to access critical services from their locality – reducing cost, time, and hassle. Action item *8 further mandates that 100 public services (including social safety net programmes) be accessible online.

Options A, C, and D address other objectives entirely unrelated to Fatema's immediate need.

Q2. Integrity – E-government services

A Dhaka-based businessman needs to renew his trade licence. In the past, this required multiple visits to City Corporation offices, interactions with middlemen, and payment of unofficial fees. The government wants to eliminate this corruption.

Which strategic theme and action item of the National ICT Policy 2009 BEST resolves this problem?

A) Action Item *55 – developing a national web portal as a one-stop shop for e-citizen services ’

B) Action Item *66 – allowing online issuance and renewal of trade licences through City Corporations

C) Action Item *80 – establishing an electronic payment gateway for inter-bank transactions

D) Action Item *83 – using ICT tools for file sharing across ministries

Answer: B

Explanation: Action item *66 under Strategic Theme 3.2 explicitly addresses the online issuance and renewal of trade licences, directly eliminating the opportunity for bribery and nepotism. The policy states this "will ensure transparency in the trade license issuance system since there will be no room for bribery or nepotism, thus reducing illegal trades."

Option A is the broader portal; option

C addresses payment infrastructure; option

D focuses on internal government file sharing – none target trade licence renewal specifically.

Q3. Education and research – ICT literacy in schools

A secondary school in Rajshahi has 800 students but no computer lab. The headteacher applies to the government for support, citing the national ICT policy.

Which short-term action item of the National ICT Policy 2009 DIRECTLY supports this school's request?

A) Action Item 149 – mandating industry to have in-house R&D departments

B) Action Item *118 – ensuring LAN and internet-connected computer labs in district secondary schools

C) Action Item *129 – creating a Model School as an Information Access Centre in each union

D) Action Item 132 – installing computers and internet connectivity in tertiary educational institutions

Answer: B

Explanation: Action item *118 under Strategic Theme 4.4 explicitly targets secondary schools at the district level in the short term – mandating LAN and internet-connected computer labs with appropriate technical support. The policy recognises ICT skills as part of 21st-century basic skills.

Option C targets union-level model schools;

Option D is for tertiary (university-level) institutions;

option A relates to private-sector industry – none of these match a district secondary school in the short term.

Q4. Productivity – agriculture and supply chain

A cooperative of mango farmers in Chapai Nawabganj struggles to get fair prices because middlemen control market information. They want direct access to demand-supply data and buyers.

Which combination of action items under the National ICT Policy 2009 BEST addresses their problem?

A) Action items 30 and 37 – SME resource centres and real-time market price information at market yards B) Action items 22 and 43 – mass media campaigns and ERP pilot projects

C) Action items 28 and 48 – e-commerce platforms and implementing ICT Act 2006

D) Action items 35 and 46 – farmer training and automation at division level

Answer: A

Explanation: Action item 30 calls for establishing SME resource centres with local chamber/telecentre alliances spanning the agricultural supply chain, while action item 37 mandates disseminating up-to-date demand-supply and market rate information on agricultural produce at market yards – explicitly targeting the elimination of rent-seeking middlemen. Action item 33 also supports this with knowledge-based trading platforms.

Options B and C address enterprise ERP and legal frameworks;

option D addresses training – not the price transparency and market access issue the farmers face.

Q5. Employment generation – gender inclusion

A garment factory owner in Gazipur notices that her female workers are increasingly interested in ICT-based work. She wants to recruit more women for her new software data-entry unit but finds qualified female ICT workers scarce.

Which two action items of the National ICT Policy 2009 directly address this talent shortage?

A) Action items *174 and *175 – increasing female enrolment in ICT courses and mandating industry to achieve 30% female workforce

B) Action items 162 and 177 – reimbursing training costs and on-the-job training programmes for graduates

C) Action items 168 and 186 – ICT scholarships and Upazila-level scholarships for IT education

D) Action items 170 and 171 – incentives for IT teachers in regional colleges

Answer: A

Explanation: Action item *174 specifically targets increasing female student enrolment in ICT courses from divisional level in the short term to union/village level in the long term. Action item *175 mandates ICT industry associations to gradually increase their female workforce to at least 30% of total HR, directly addressing the employer's demand.

Options B and C address financial support for education and general graduate training;

option D focuses on teacher deployment – not the systemic gender inclusion the question requires.

Q6. Healthcare – telemedicine

A pregnant woman in a remote char area of Sirajganj needs specialist consultation but the nearest qualified obstetrician is in Dhaka. A local paramedic has a mobile phone and basic equipment.

Which action items of the National ICT Policy 2009 form the MOST complete solution for this woman?

A) Action items *222 and *223 – using telemedicine to spread maternal health awareness and establishing remote consultation up to Upazila level

B) Action items 215 and 218 – building a national health network and a database for health workers

C) Action items 224 and 226 – establishing tele-diagnostic centres and running mobile health units

D) Action items *225 and 231 – extending healthcare to remote areas and providing ICT-based global health knowledge

Answer: C

Explanation: Action item 224 explicitly calls for establishing remote tele-diagnostic centres connected to tertiary care facilities at every district town (short term), extending to Upazila and union/growth centres (mid and long term). Action item 226 supports mobile health units equipped with advanced medical equipment and a high-tech communication network for emergency cases piloted at district HQs. Together, these create the most practical and technically complete pathway for the woman's situation.

Option A addresses awareness and helplines;

Option D addresses knowledge access for health professionals – neither provides the direct clinical consultation mechanism needed here.

Q7. Universal access – broadband connectivity

The owner of a small software firm in Sylhet complains that internet costs are three times higher than in Dhaka, making his firm uncompetitive against Dhaka-based rivals for the same government contracts.

Which strategic theme and action items of the National ICT Policy 2009 MOST directly address this inequity?

A) Strategic Theme 8.2 – extending internet backbone to all district headquarters at the same access cost as in the capital (Action items 238–241)

B) Strategic Theme 6.3 – providing discounted bandwidth rates for software industry (Action item 198)

C) Strategic Theme 10.6 – decentralising ICT growth outside the capital (Action items 296–298)

D) All of the above, as they collectively address regional digital cost disparity

Answer: D

Explanation: All three strategic themes are relevant and complementary. Strategic Theme 8.2 mandates equal internet access costs at all district headquarters as in the capital – directly targeting the pricing disparity. Action item 198 under Strategic Theme 6.3 provides a 75% bandwidth discount

specifically for software industry firms. Strategic Theme 10.6 targets decentralising ICT infrastructure outside Dhaka, addressing the structural inequality. The policy envisions these as mutually reinforcing actions, and isolating any one of them as the sole answer would be incomplete.

No option A, B, or C alone captures the full policy response.

Q8. Environment and Disaster Management – Flood Risk

The government receives early warning that a severe cyclone will hit coastal districts in 48 hours. The challenge is reaching the most vulnerable rural and coastal communities quickly.

Which action items under the National ICT Policy 2009 form the MOST effective early-warning response strategy?

A) Action items *259 and *261 – remote sensing for disaster management and SMS-based disaster warning systems targeted to affected populations

B) Action items 255 and 256 – modeling tools for climate risk and reporting environmental pollution through ICT networks

C) Action items *262 and 264 – GIS-based monitoring of flood shelters and equitable relief distribution

D) Action items 249 and 251 – energy-saving ICT devices and reducing paper use in offices

Answer: A

Explanation: Action item *259 mandates the use of remote sensing technologies for disaster management and mitigation, providing the scientific detection layer. Action item *261 specifically promotes cell phone/SMS-based disaster warning systems targeted to populations likely to be affected – with a short-term target of 100% coverage. This combination addresses both detection and last-mile communication to vulnerable communities.

Option C addresses post-disaster relief distribution, not early warning.

Option D is about green ICT in offices – entirely irrelevant to disaster response.

4. Understanding ethical & social issues related to systems

Section summary

Information systems amplify ethical dilemmas by making privacy invasion, property infringement, and diffused accountability cheap and hard to detect. The "rock-in-the-pond" model shows how technology disrupts individuals, institutions, and politics, producing five moral dimensions: information rights, property rights, accountability, system quality, and quality of life – all intensified by trends like Moore's Law, cheap storage, analytics, networking, and mobile tracking. Managers navigate these using a five-step analysis process and six ethical principles, grounded in responsibility, accountability, and liability. The core lesson: technology is filtered through human choices, and managers – not machines – carry the ethical weight..

The past decade has produced some of the most ethically challenging periods in business history. Information systems, while not designed for fraud, were instrumental in major corporate scandals – perpetrators used financial reporting IS to conceal decisions. Modern managers must now decide for themselves what constitutes proper legal and ethical conduct.

4.1 A model for thinking about ethical, social & political issues

Ethical, social and political issues are closely linked. Imagine society as a calm pond – individuals know how to act because social institutions have developed rules, supported by laws that prescribe behavior and promise sanctions for violations. Now introduce powerful new information technology as a 'rock' thrown into the pond. The result: ripples that disturb the equilibrium.

- Individual level: Confronted with new situations not covered by old rules
- Social level: Institutions cannot respond overnight – it may take years to develop etiquette, expectations and social responsibility
- Political level: Legislation requires demonstration of real harm before acting; legal gray areas emerge in the interim

This model illustrates how IT ripples outward from individual to social to political levels, and helps identify the five moral dimensions of the information society.

4.1.1 Five moral dimensions of the information age

1. Information Rights & Obligations: What information rights do individuals and organizations possess with respect to themselves? What can they protect? What obligations do information gatherers have?
2. Property Rights & Obligations: How will traditional intellectual property rights be protected in a digital society where tracing ownership is difficult and ignoring property rights is easy?
3. Accountability & Control: Who can and will be held accountable and liable for the harm done to individual and collective information and property rights?
4. System Quality: What standards of data and system quality should we demand to protect individual rights and the safety of society?
5. Quality of Life: What values should be preserved in an information- and knowledge-based society? Which institutions should we protect from violation? Which cultural values are supported by new IT?

These five moral dimensions recur throughout all ethical debates about IS and should be used as a framework for analysing any ethical dilemma involving information technology.

4.1.2 Key technology trends that raise ethical issues

Ethical issues long preceded IT. However, information technology has heightened ethical concerns, taxed existing social arrangements, and made some laws obsolete. Five key technological trends are responsible:

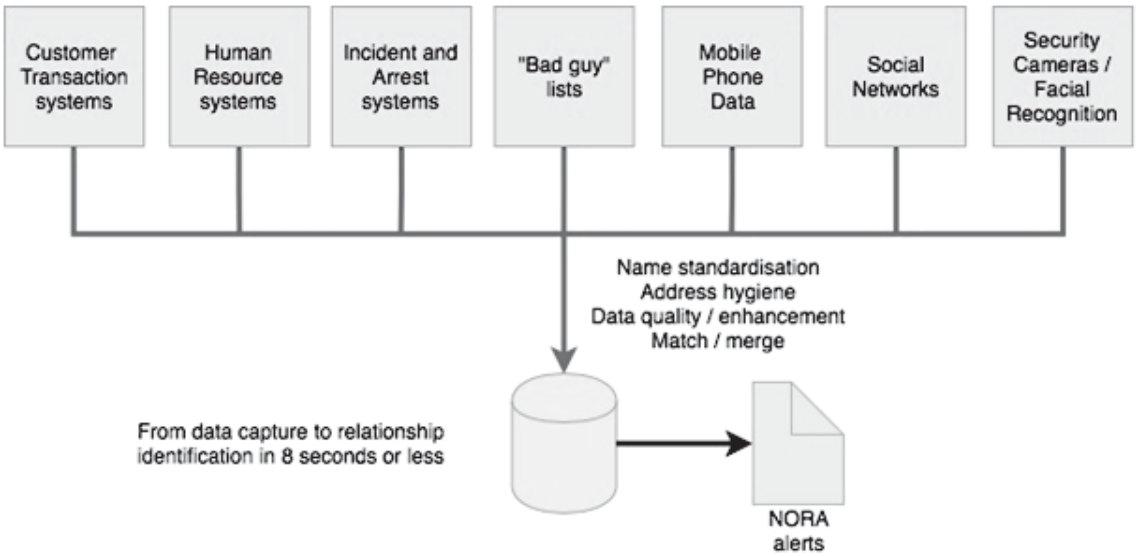
1. Computing Power Doubles Every 18 Months (Moore's Law): More organizations depend on computer systems for critical operations. Our dependence on systems and vulnerability to system errors and poor data quality has increased. Social rules and laws have not adjusted to this dependence.
2. Data Storage Costs Rapidly Declining: Organizations can easily maintain detailed databases on individuals – employees, customers, potential customers. Advances in data storage have made routine violation of individual privacy cheap and effective. Very large data storage systems (terabytes) are now inexpensive enough for large firms.
3. Data Analysis Advances: Companies and government agencies can find out highly detailed personal information about individuals. Contemporary data management tools allow companies to assemble and combine myriad pieces of information stored on computers far more easily than in the past. This enables profiling.
4. Networking Advances: Copying data from one location to another and accessing personal data from remote locations are much easier. The Internet has opened the possibility of mining large pools of data remotely using small desktop machines, permitting invasion of privacy on a previously unimaginable scale and precision.
5. Mobile Device Growth Impact: Individual cell phones may be tracked without user consent or knowledge. Location data gathered from cell phones has extraordinary commercial value for targeted advertising.

4.1.3 Data profiling & nora

Profiling: The use of computers to combine data from multiple sources and create electronic dossiers of detailed information on individuals.

Examples: DoubleClick (Google) tracks browsing across thousands of websites; ChoicePoint assembles dossiers from police, criminal, motor vehicle, credit and employment records on almost every adult.

NORA (Nonobvious Relationship Awareness): Technology that takes information about people from many disparate sources (employment applications, telephone records, customer listings, 'wanted' lists) and correlates relationships to find obscure hidden connections. Used for homeland security but has significant privacy implications.



Real Example: NORA can instantly discover a man at an airline ticket counter who shares a phone number with a known terrorist before that person boards an airplane. The same technology that protects security can also constitute a profound invasion of privacy.

4.2 Ethics in an information society

Ethics is a concern of humans who have freedom of choice. Ethics is about individual choice: When faced with alternative courses of action, what is the correct moral choice? Ethics requires individuals to take responsibility for the consequences of their decisions.

4.2.1 Basic concepts: responsibility, accountability & liability

Responsibility: A key element of ethical action. You accept the potential costs, duties and obligations for the decisions you make. Ethical choices are decisions made by individuals who are responsible for the consequences of their actions.

Accountability: A feature of systems and social institutions. Mechanisms are in place to determine who took responsible action and who is responsible. Systems in which it is impossible to find out who took what action are inherently incapable of ethical analysis or ethical action.

Liability: Extends responsibility to the area of laws. A feature of political systems where a body of laws permits individuals to recover the damages done to them by other actors, systems or organizations.

Due Process: A related feature of law-governed societies. Laws are known and understood, and there is an ability to appeal to higher authorities to ensure laws are applied correctly.

4.2.2 Three foundational principles for ethical IS analysis:

- Information technologies are filtered through social institutions, organizations and individuals – systems do not have impacts by themselves
- Responsibility for the consequences of technology falls clearly on the institutions, organizations and individual managers who choose to use the technology
- In an ethical political society, individuals can recover damages done to them through a set of laws characterized by due process

4.2.3 Five-step ethical analysis process

When confronted with a situation that presents ethical issues, use this structured process:

1. Identify and describe the facts clearly – Find out who did what to whom, where, when, and how. Getting the facts straight often helps define the solution. Getting opposing parties to agree on facts is the first step.
2. Define the conflict or dilemma and identify the higher-order values involved – Ethical issues always reference higher values (freedom, privacy, protection of property, free enterprise). Identify the dilemma: two diametrically opposed courses of action that both support worthwhile values.
3. Identify the stakeholders – Players who have an interest in the outcome, who have invested in the situation, and who have vocal opinions. Understanding stakeholder needs is essential when designing solutions.
4. Identify the options you can reasonably take – Some options satisfy more interests than others. A good ethical solution may not always be a simple balancing of consequences to stakeholders.
5. Identify the potential consequences of your options – Some options may be ethically correct but disastrous from other viewpoints. Ask: 'What if I choose this option consistently over time?'

4.2.4 Six candidate ethical principles

Once ethical analysis is complete, use these principles – rooted in many cultures and surviving throughout recorded history – to guide decisions:

1. Golden Rule: Do unto others as you would have them do unto you. Putting yourself in the place of others helps you think about fairness in decision making.
2. Kant's Categorical Imperative: If an action is not right for everyone to take, it is not right for anyone. Ask: 'If everyone did this, could the organization or society survive?'
3. Descartes' Rule of Change (Slippery Slope): If an action cannot be taken repeatedly, it is not right to take at all. An action acceptable now may, if repeated, bring unacceptable changes in the long run – 'once started down a slippery path, you may not be able to stop.'
4. Utilitarian Principle: Take the action that achieves the higher or greater value. Assumes you can prioritize values in a rank order and understand the consequences of various courses of action.
5. Risk Aversion Principle: Take the action that produces the least harm or least potential cost. Avoid high-failure-cost actions paying attention to their probability – avoid those with extremely high failure costs at moderate to high probability.
6. Ethical 'No Free Lunch' Rule: Assume that virtually all tangible and intangible objects are owned by someone else unless there is a specific declaration otherwise. If something created by someone else is useful to you, it has value and you should assume the creator wants compensation.

The appearance of unethical behavior may do as much harm to you and your company as actual unethical behavior.

4.2.5 Professional codes of conduct

When groups of people claim to be professionals, they take on special rights and obligations because of their special claims to knowledge, wisdom and respect. Professional codes of conduct are promulgated by associations such as:

- AMA (American Medical Association)
- ABA (American Bar Association)
- AITP (Association of Information Technology Professionals)
- ACM (Association for Computing Machinery)

Codes of ethics are PROMISES by professions to regulate themselves in the general interest of society. For example, the ACM Code of Ethics includes: avoiding harm to others, honoring property rights (including intellectual property), and respecting privacy.

4.2.6 Real-world ethical dilemmas in information systems

IS creates new ethical dilemmas where one set of interests is pitted against another. Common conflicts include:

- Technology replacing workers (voice recognition software replacing telephone operators) – productivity vs. employee welfare
- Employer monitoring of employee Internet usage – business productivity vs. employee privacy
- Social media platforms (Facebook) monitoring subscribers and selling information to advertisers – business model vs. user privacy
- AI and automation replacing white-collar, middle-class jobs – efficiency vs. employment stability

A close analysis of the facts can sometimes produce compromised solutions that give each side 'half a loaf.' The challenge is to balance competing values using the ethical analysis and principles described above.

4.3 The moral dimensions of information systems

Section 4.3 explores each of the five moral dimensions in detail, identifying ethical, social and political levels of analysis with real-world examples. This is the core of the chapter and the most heavily examined section.

▶ MORAL DIMENSION 1: Information Rights – Privacy & Freedom

Defining Privacy

Privacy: The claim of individuals to be left alone, free from surveillance or interference from other individuals or organizations, including the state. Claims to privacy also apply at the workplace – millions of employees are subject to electronic and high-tech surveillance.

Information technology and systems threaten individual claims to privacy by making the invasion of privacy cheap, profitable and effective.

- Protected in the US Constitution primarily by the First Amendment (freedom of speech and association) and the Fourth Amendment (protections against unreasonable search and seizure)
- Protected in Canadian and German constitutions
- Protected in other countries through various statutes

Fair Information Practices (FIP)

Most American and European privacy law is based on the regime called Fair Information Practices (FIP), first set forth in 1973 by a federal government advisory committee and updated in 2010. FIP governs the collection and use of information about individuals based on mutuality of interest.

FTC's Five FIP Principles

1. Notice/Awareness (Core Principle): Websites must disclose their information practices before collecting data. Includes identification of collector, uses of data, recipients, nature of collection, voluntary/required status, consequences of refusal, and data protection steps.
2. Choice/Consent (Core Principle): There must be a choice regime allowing consumers to choose how their information will be used for secondary purposes other than supporting the transaction, including internal use and transfer to third parties.
3. Access/Participation: Consumers should be able to review and contest the accuracy and completeness of data collected about them in a timely, inexpensive process.
4. Security: Data collectors must take responsible steps to assure that consumer information is accurate and secure from unauthorized use.
5. Enforcement: There must be a mechanism to enforce FIP principles. This can involve self-regulation, legislation giving consumers legal remedies for violations, or federal statutes and regulations.

Key US Privacy Legislation

- Privacy Act of 1974 – most important general law; regulates federal government's collection, use and disclosure of information
- COPPA (1998) – Children's Online Privacy Protection Act; requires parental permission before collecting data on children under 13
- HIPAA (1996) – Health Insurance Portability and Accountability Act; protects medical records; limits disclosure to minimum necessary
- Gramm-Leach-Bliley Act (1999) – financial institutions must disclose privacy policies; customers can opt out of information-sharing
- CAN-SPAM Act (2003) – bans deceptive email practices; requires accurate subject lines, true sender identification, easy unsubscription

The European Directive on Data Protection

Privacy protection in Europe is much more stringent than in the United States. Unlike the US, European countries do NOT allow businesses to use personally identifiable information without consumers' PRIOR consent.

- EU Directive on Data Protection (1998): Companies must inform people when collecting data, disclose how it will be stored and used; customers must provide informed consent before any company can legally use data
- Informed consent: Consent given with KNOWLEDGE of all the facts needed to make a rational decision
- 'Right to be forgotten': EU 2012 proposed rules allow users to request deletion of information
- Fines up to 2% of annual gross revenue for offending firms
- Third-party cookies require explicit consent under EU 2009/2011 rules

Safe Harbor: A private, self-regulating policy and enforcement mechanism that meets the objectives of government regulators and legislation but does NOT involve government regulation or enforcement. Allows US firms to use personal data from EU countries if they develop privacy protection policies meeting EU standards.

Internet Challenges to Privacy

Tracking Technologies

Cookies: Small text files deposited on a computer hard drive when a user visits websites. Identify visitor's browser and track visits. Web sites can combine cookie data with registration information to identify visitors and develop detailed profiles. Cannot directly obtain names/addresses without combining with other data.

Super Cookies / Flash Cookies: Cannot be easily deleted. Installed whenever a person clicks on a Flash video. Used by Flash to play videos; placed on the user's computer without their consent. Called 'Local Shared Object' files.

Web Beacons (Web Bugs / Tracking Files): Tiny software programs that keep a record of users' online clickstream. Invisibly embedded in email messages and web pages. Report data back to whoever owns the tracking file. Placed on popular websites by third-party firms who pay websites for access to their audience.

Spyware: Secretly installs itself on an Internet user's computer by piggybacking on larger applications. Once installed, sends banner ads and other unsolicited material to the user and reports the user's movements on the Internet to other computers.

Scale of Web Tracking

Google's dominance is particularly striking. Google Static alone is active on over 9,000 of the internet's most popular 10,000 sites, and just 62 of those top 10,000 sites don't establish any connection to a Google server. Eight of the top ten trackers globally are operated by Google. According to WhoTracks.Me, Google Tag Manager appears on 38.48% of top sites and Google Static on 37.74%, making them the two most prevalent trackers on the web.

A Kaspersky analysis covering July 2023 to June 2024 found its Do Not Track tool was triggered almost 39 billion times in that 12-month span. The top four trackers detected were all Google-operated: Google Display & Video 360, Google Analytics, Google AdSense, and YouTube Analytics. Microsoft trackers also appeared in every regional top-25 list, though at a smaller share.

The bandwidth cost is now measurable. According to AdGuard's 2025 Ad Trackers Report, ad trackers accounted for 10.22% of all global internet traffic in 2025 — up from 7.84% in 2024 and crossing into double digits for the first time. Blocking a single primary ad-related request prevents an average of 4.17 additional background requests, showing how rapidly tracker traffic multiplies behind a single page load.

Tracking methods have also grown more invasive. Beyond traditional cookies, trackers now rely on techniques such as tracking pixels, URL trackers, and browser fingerprinting – and regulators note that fingerprinting is considered more invasive than cookies because it cannot be cleared or opted out of by the user.

Opt-Out vs. Opt-In Models

Opt-Out Model: Permits collection of personal information until the consumer specifically requests that the data NOT be collected. Currently the dominant model in the United States.

Opt-In Model: A business is PROHIBITED from collecting any personal information unless the consumer specifically takes action to APPROVE information collection and use. The default is no collection. Privacy advocates prefer this model.

Consumer Reality: Studies show consumers want: access to their information, controls on what can be collected, ability to opt out of tracking, clarity on policies – they are NOT saying 'Take my privacy, I don't care, send me the service for free.'

Technical Solutions

Technical tools to protect privacy include: email encryption, anonymous surfing tools, cookie blocking, and spyware detection/elimination. However, for the most part, technical solutions have FAILED to protect users from being tracked as they move from site to site. Browser Do Not Track options exist but remain largely unenforceable as no legislation requires sites to stop tracking.

▶ MORAL DIMENSION 2: Property Rights – Intellectual Property

Intellectual Property & Digital Challenges

Intellectual Property: Intangible property created by individuals or corporations. Information technology has made it difficult to protect because computerized information can be so easily copied or distributed on networks.

Digital media differ from books and other media in critical ways that challenge intellectual property protection:

- Ease of replication – perfect digital copies can be made instantly
- Ease of transmission – information can be distributed globally at near-zero cost
- Ease of alteration – digital works can be modified easily
- Difficulty in classification – software can be a program, book, or music
- Compactness – makes theft easy and difficult to detect
- Difficulty in establishing uniqueness

Three Legal Traditions Protecting Intellectual Property

i) Trade Secrets

Any intellectual work product (formula, device, pattern, or compilation of data) used for a business purpose can be classified as a trade secret, provided it is not based on information in the public domain.

- Trade secret laws grant a monopoly on the IDEAS behind a work product (not just the expression)
- Creators must bind employees and customers with nondisclosure agreements
- Limitation: difficult to prevent ideas from falling into the public domain when software is widely distributed

ii) Copyright

Copyright is a statutory grant protecting creators from having their work copied by others for any purpose:

- Duration: life of author plus 70 years; corporate-owned works: 95 years after initial creation
- Coverage: books, periodicals, lectures, dramas, musical compositions, maps, drawings, artwork, motion pictures, software programs
- Computer Software Copyright Act (1980): clearly provides protection for software program code and copies sold in commerce
- Protection: against copying of entire programs or their parts — damages readily obtained for infringement
- Limitation: underlying IDEAS are NOT protected, only their manifestation — a competitor can replicate the concept without infringing copyright
- DMCA (Digital Millennium Copyright Act, 1998): makes it illegal to circumvent technology-based protections of copyrighted materials; ISPs required to take down infringing sites once notified

iii) Patents

A patent grants the owner an exclusive monopoly on the IDEAS behind an invention for 20 years. Key concepts: originality, novelty and invention.

- Intent: ensure inventors receive the full financial benefits of their labor; make widespread use possible via licensing
- Software patents: accepted after 1981 Supreme Court decision holding computer programs could be part of a patentable process
- Strength: grants monopoly on underlying concepts and ideas (unlike copyright)
- Difficulty: must pass stringent criteria of nonobviousness, originality and novelty, plus years of waiting
- Landmark case: Apple v. Samsung (2012) — jury awarded Apple $1 billion in damages for patent violations; established criteria for how close a competitor can come to an industry-leading product

Global Software Piracy: Global software piracy has declined from its 2011 peak of 42% (worth $63 billion) to an estimated 35% as of 2023, partly due to the rise of cloud and subscription models. The BSA's most recent Global Software Survey valued unlicensed PC software at $46.3 billion, with China, Russia, and India ranked as the top three hotspots. Regional rates remain stark — as low as 17% in North America but exceeding 60% in parts of Asia-Pacific, Latin America, and Africa. Beyond lost revenue, malware from unlicensed software now costs businesses an estimated $359 billion a year globally.

▶ MORAL DIMENSION 3: Accountability, Liability & Control

Computer-Related Liability Problems

New information technologies challenge existing liability laws. Key questions: If a person is injured by a machine controlled by software, who should be held accountable and liable? Should Internet service providers be treated as broadcasters (subject to content liability) or as common carriers (held harmless for what users transmit)?

The BlackBerry Outage Case (2011)

For a week in October 2011, millions of BlackBerry users worldwide experienced disruption to their email service. The three-day blackout involved users in Asia, Europe, the Middle East and the Americas. Root cause: failure of a core switch, with redundant failover systems also failing unexpectedly. Key liability questions raised:

- Who is liable for economic harm caused to individuals or businesses during a three-day service outage?
- If consumers pay for cell phone service, come to rely on it, and are denied service for a significant period, is the cell phone provider liable for damages?
- Information systems executives are ultimately responsible for any harm done by systems they have selected and installed

The Liability Landscape

- Software as a product like books: courts have been reluctant to hold software authors liable (similar to publishers and booksellers; concerns about First Amendment interference)
- Software as a service (ATMs, financial systems): if service fails and causes economic harm, liability law may extend to software publishers and operators
- Software is DIFFERENT from books: users develop expectations of infallibility; less easily inspected; claims to perform tasks rather than describe them; people depend on software-based services
- Telephone systems: not held liable for messages transmitted because they are regulated common carriers with obligations to provide access to all at reasonable rates
- Web sites: in the United States, generally NOT held liable for content posted by users with few exceptions

Given the centrality of software to everyday life, liability law will very likely extend its reach to include software even when the software merely provides an information service.

▶ MORAL DIMENSION 4: System Quality – Data Quality & System Errors

Acceptable Levels of System Quality

The debate over liability and accountability raises the moral dimension of system quality. What is an acceptable, technologically feasible level of system quality? When should system managers say, 'Stop testing, we've done all we can to perfect this software. Ship it!'

- Individuals and organizations may be held responsible for avoidable and foreseeable consequences, which they have a duty to perceive and correct
- Some system errors are foreseeable and correctable ONLY at very great expense – so great that pursuing this level of perfection is not feasible economically
- Software companies knowingly ship buggy products because the time and cost of fixing all minor errors would prevent products from ever being released

Three Principal Sources of Poor System Performance

1. **Software Bugs & Errors:** Zero defects in software code of any complexity cannot be achieved. The seriousness of remaining bugs cannot be estimated. A technological barrier to perfect software exists; users must be aware of the potential for catastrophic failure. The software industry has NOT yet arrived at testing standards for software of acceptable but imperfect performance.
2. **Hardware or Facility Failures:** Caused by natural or other causes. Hardware failures, power outages, natural disasters can cause system failures. Redundancy and failover systems provide protection but may themselves fail (as in the BlackBerry case).
3. **Poor Input Data Quality:** The MOST COMMON source of business system failure, by far – yet the least reported. Few companies routinely measure the quality of their data. Individual organizations report data error rates ranging from 0.5% to 30%.

While software bugs and facility catastrophes are likely to be widely reported in the press, the MOST COMMON source of business system failure is DATA QUALITY – poor quality data fed into systems, producing incorrect outputs and flawed decision-making.

▶ MORAL DIMENSION 5: Quality of Life – Equity, Access & Boundaries

Overview: Negative Social Consequences of IS

The negative social costs of IS are mounting alongside the power of the technology. Many of these consequences are not violations of individual rights or property crimes, but they can be extremely harmful to individuals, societies and political institutions. Computers and IT potentially can destroy valuable elements of culture and society even while bringing benefits.

i) Balancing Power – Center vs. Periphery

An early fear of the computer age was that huge centralized mainframe computers would centralize power, resulting in a 'Big Brother' society (as suggested in George Orwell's novel 1984). Reality is more complex:

- Shift toward decentralized computing has reduced fears of government power centralization
- BUT much 'empowerment' is trivial – lower-level employees may make minor decisions while key policy decisions remain as centralized as in the past
- Corporate Internet behemoths (Google, Apple, Yahoo, Amazon, Microsoft) now dominate collection and analysis of personal private information
- Power has become more centralized in the hands of a few PRIVATE oligopolies, not government

ii) Rapidity of Change – Reduced Response Time to Competition

Information systems have helped create much more efficient national and international markets. Today's more efficient global marketplace has reduced the normal social buffers that permitted businesses many years to adjust to competition.

- Time-based competition: a business may not have enough time to respond to global competitors and may be wiped out in a year, along with its employees' jobs
- Risk of developing a 'just-in-time society' with 'just-in-time jobs' and 'just-in-time' workplaces, families and vacations

iii) Maintaining boundaries – family, work & leisure

The 'do anything anywhere' computing environment is actually coming true. Traditional boundaries that separate work from family and leisure have been weakened.

- Ubiquitous computing, telecommuting, nomad computing and mobile computing extend the work umbrella far beyond the eight-hour day into commuting time, vacation time and leisure time
- Even leisure time spent on computers threatens close social relationships – extensive Internet use takes people away from family and friends
- Among middle school and teenage children, excessive computer/Internet use can lead to harmful anti-social behavior such as cyberbullying
- Family and friends historically have provided powerful support mechanisms and act as balance points in society

iv) Dependence & vulnerability

Today, businesses, governments, schools and private associations are incredibly dependent on information systems and, therefore, highly vulnerable if these systems fail.

- Secondary schools increasingly rely on educational software – if systems shut down, there is no backup educational structure
- Unlike telephone, electrical, radio and television utilities, there are no regulatory or standard-setting forces equivalent for IS
- The absence of standards and criticality of some system applications will call forth demands for national standards and regulatory oversight

v) Computer crime & abuse

Computer Crime: The commission of illegal acts through the use of a computer or against a computer system. Computers can be BOTH the object of the crime AND the instrument of a crime. Simply accessing a computer system without authorization, even by accident, is a federal crime.

Computer Abuse: The commission of acts involving a computer that may not be illegal but are considered unethical.

Scale of Computer Crime (IC3 Report 2024)

The FBI's Internet Crime Complaint Center (IC3) received 859,532 complaints in 2024 – nearly three times the volume it processed in 2011 – with reported losses hitting a record $16.6 billion, a 33% increase from 2023 and more than 33 times the $500 million reported in 2011. Of those, 256,256 complaints involved actual financial losses, putting the average loss per victim at approximately $19,372 – compared to roughly $4,100 a decade ago. The top three cybercrime categories by complaint volume were phishing/spoofing, extortion, and personal data breaches, while investment fraud – particularly cryptocurrency scams – accounted for the greatest financial losses at over $6.5 billion. People over the age of 60 were the hardest-hit demographic, suffering nearly $5 billion in losses. Since IC3's founding, it has now received over 9 million total complaints, with the frequency of reports growing from roughly 2,000 per month in its early years to more than 2,000 per day today.

vi) Employment: Trickle-down technology & reengineering job loss

Reengineering work is hailed as a major benefit of new IT, but it is much less frequently noted that redesigning business processes has caused millions of mid-level managers and clerical workers to lose their jobs.

- Voice recognition, robotics, numerically controlled machines, computerized inventory control, pattern recognition and online commerce can now do many jobs previously reserved for humans
- One economist raised the possibility of 'a society run by a small high-tech elite of corporate professionals... in a nation of the permanently unemployed' (Rifkin, 1993)
- Jobs at risk: tech support, call center work, X-ray examiners, legal document review, middle management
- Most at risk: unskilled blue-collar workers and older, less well-educated middle managers – unclear if these groups can be retrained for high-quality (high-paying) jobs

vii) Equity & access – the digital divide

Digital Divide: The gap between those who have access to computers and the Internet and those who do not, distributed along ethnic and social class lines.

Does everyone have an equal opportunity to participate in the digital age? Key findings:

- Poor and minority groups in the US are less likely to have computers or online Internet access, even as computer ownership and Internet access have soared
- Higher-income families in each ethnic group are still more likely to have home computers and Internet access than lower-income families in the same group
- Schools in high-poverty areas are less likely to have computers, high-quality educational technology programs, or Internet access
- Left uncorrected, the digital divide could lead to a society of information 'haves' (computer literate and skilled) versus a large group of information 'have-nots' (computer illiterate and unskilled)
- Today's digital divide is not only about ACCESS to technology but also about HOW that technology is being used

viii) Health risks: RSI, CVS & technostress

Repetitive Stress Injury (RSI): The most common occupational disease today. Occurs when muscle groups are forced through repetitive actions. The single largest source of RSI is computer keyboards.

Carpal Tunnel Syndrome (CTS): The most common computer-related RSI. Pressure on the median nerve through the wrist's bony structure (carpal tunnel) produces pain. In a single shift, a word processor may perform 23,000 keystrokes. Symptoms: numbness, shooting pain, inability to grasp objects, tingling.

Computer Vision Syndrome (CVS): Any eyestrain condition related to display screen use (desktop computers, laptops, e-readers, smartphones, handheld video games). Affects about 90% of people who spend 3+ hours per day at a computer. Symptoms: headaches, blurred vision, dry and irritated eyes.

Technostress: Stress induced by computer use. Symptoms include aggravation, hostility toward humans, impatience and fatigue. Humans working continuously with computers expect other humans and human institutions to behave like computers – providing instant responses, attentiveness and an absence of emotion.

Health risk prevention

- Design workstations for neutral wrist position – wrist rests, proper monitor stands, footrests
- Ergonomically correct keyboards; frequent rest breaks; rotation of employees to different jobs
- Managing screen time and taking regular breaks to prevent CVS
- Organizations should recognize technostress and its correlation with high job turnover, early retirement and substance abuse in the computer industry

Professional skills focus – applying judgement

The most consequential judgement the IS auditor makes during a project is whether to intervene now or report later. Early intervention – advising on control design during requirements and design – produces better outcomes for the enterprise but narrows the auditor's ability to perform a subsequent independent audit. Deferring engagement preserves independence but often means findings are raised when remediation is most expensive.

A disciplined auditor navigates this by engaging as a consulted, documented adviser on control design, while keeping operational decision authority and sign-off with management. Any advisory work is formally scoped and recorded, and the individual who advised is not the individual who later opines on the operating effectiveness of those same controls.

When evaluating project risk, the auditor distinguishes between inherent risk in the project and the effectiveness of the mitigating controls. A project in an unfamiliar technology with an inexperienced team and an aggressive deadline carries inherent risk that no stage-gate document can eliminate; the auditor's report must say so plainly, in language that a non-technical steering committee can act upon.

Practice questions and answers with explanations

1. A company installs software to track employee activity without prior policy.
What is the key ethical issue?
   A. Lack of system quality
   B. Violation of employee privacy
   C. Poor data storage
   D. Network failure

Answer: B

Explanation: Monitoring without transparency raises ethical concerns.

2. Mobile apps continuously track user location without awareness.
Which ethical concern is most relevant?
   A. Intellectual property
   B. Privacy invasion
   C. System performance
   D. Software piracy

Answer: B

Explanation: Location tracking without consent violates privacy.

3. An employee copies licensed software and distributes it illegally.
Which ethical dimension is violated?
   A. Accountability
   B. Property rights
   C. System quality
   D. Quality of life

Answer: B

Explanation: Software is protected intellectual property.

4. A bank's ATM system crashes, causing financial losses.
Who may be held responsible?
   A. Only customers
   B. Only software developers
   C. Organization and system managers
   D. Government

Answer: C

Explanation: Accountability lies with those managing systems.

5. Low-income communities lack access to computers and the Internet.
This represents which issue?
   A. System failure
   B. Equity and access problem
   C. Data breach
   D. Intellectual theft

Answer: B

Explanation: Unequal access creates a digital divide.

Chapter 2
Management information systems and developments in technology

1. Introduction to decision support in business
2. Management information systems (MIS)
3. Executive information systems (EIS)
4. Artificial intelligence technologies in business
5. Branches of artificial intelligence
6. Applications of AI in accounting and finance
7. Understanding blockchain technology
8. Understanding fintech technologies
9. Big data

Practice questions and answers with explanations



1. Introduction to decision support in business

Section summary

Modern businesses rely on data-driven decision-making across three managerial levels – strategic, tactical, and operational – supported by high-quality information judged on time, content, and form. Decisions vary in structure (structured, semi structured, unstructured), which dictates the right system: MIS for routine reports, DSS for interactive modelling (what-if, sensitivity, goal-seeking, optimization), and BI/BA for deeper insight into why things happen and what will happen next. Tools like OLAP, GIS, data visualization, EIS, dashboards, scorecards, portals, and KMS extend this support across the enterprise. The core lesson: technology works only when matched to the decision's level and structure – systems support judgement, they do not replace it.

Modern businesses are increasingly migrating toward responsive e-business models that demand data-driven decision-making. Information systems must support the diverse information and decision-making needs of managers and business professionals at all levels. The Internet, intranets, and other Web-enabled technologies have significantly strengthened the role that information systems play in supporting decision-making activities.

The Three Levels of Management Decision Making

The classic managerial pyramid framework applies even in today's flattened organizational structures. Three distinct levels must be supported by information technology:

Strategic Management	Executives and directors develop overall goals, strategies, policies, and objectives. They monitor strategic performance and the organisation's direction in the political, economic, and competitive environment.
Tactical Management	Business unit managers and self-directed teams develop short- and medium-range plans, schedules, and budgets. They allocate resources and monitor performance of organisational subunits.
Operational Management	Operating managers and self-directed teams develop short-range plans (e.g., weekly production schedules). They direct the use of resources according to procedures and within established budgets.

1.1 Information quality

High-quality information is essential for effective decision making. Information that is outdated, inaccurate, or hard to understand has little value. Information quality is assessed across three key dimensions: Time, Content, and Form.

The three dimensions of information quality

Time Dimension	Content Dimension	Form Dimension
• Timeliness • Currency • Frequency • Time Period	• Accuracy • Relevance • Completeness • Conciseness • Scope • Performance	• Clarity • Detail • Order • Presentation • Media

1.2 Attribute definitions

Timeliness	Information should be provided when it is needed.
Currency	Information should be up-to-date when it is provided.
Frequency	Information should be provided as often as needed.
Accuracy	Information should be free from errors.
Relevance	Information should be related to the recipient's needs for a specific situation.
Completeness	All information that is needed should be provided.
Conciseness	Only information that is needed should be provided.
Scope	Information can have a broad or narrow scope, or an internal or external focus.
Clarity	Information should be provided in a form that is easy to understand.
Presentation	Information can be presented in narrative, numeric, graphic, or other forms.

Decision Structure

Decision structure refers to how well-defined the procedures are for making a decision. It varies by management level and determines what type of information system is most appropriate.

1.3 Types of decision structure

Structured Decisions	The procedures to follow when a decision is needed can be specified in advance. Example: inventory reorder decisions. Typically found at the operational management level.
Semistructured Decisions	Some decision procedures can be prespecified, but not enough to lead to a definite recommended decision. Example: starting a new e-commerce service line. Most common type in business.
Unstructured Decisions	No procedures or rules exist to guide decision makers. Many sources must be accessed; decisions rest on experience and judgment. Example: 'What business should we be in 10 years from now?' Found at strategic management level.

Decision structure by management level – examples

Decision Structure	Operational	Tactical	Strategic
Unstructured	Cash management	Business process reengineering / Workgroup performance	New e-business initiatives / Company reorganisation
Semistructured	Credit management / Production scheduling / Daily work assignment	Employee performance appraisal / Capital budgeting / Program budgeting	Product planning / Mergers and acquisitions / Site location
Structured	Inventory control	Program control	–

2. Management information systems (MIS)

Management Information Systems (MIS) produce information products that support the day-to-day decision-making needs of managers. They provide predefined, prespecified information that satisfies structured and semistructured decision needs at operational and tactical levels.

2.1 MIS VS. decision support systems – key differences

Dimension	Management Information Systems	Decision Support Systems
Decision Support	Information about organisational performance	Information + techniques to analyse specific problems
Information Form	Periodic, exception, demand, and push reports	Interactive inquiries and responses
Format	Prespecified, fixed format	Ad hoc, flexible, and adaptable format
Processing	Extraction and manipulation of business data	Analytical modelling of business data

Four MIS Reporting Alternatives

- Periodic Scheduled Reports: Regular reports in a prespecified format delivered on a set schedule (e.g., daily sales reports, monthly financial statements).
- Exception Reports: Reports generated only when exceptional conditions occur, reducing information overload by filtering out normal activity.
- Demand Reports and Responses: Information available whenever a manager requests it, using query tools or report generators for immediate, customised output.
- Push Reporting: Information is actively broadcast to a manager's workstation via Webcasting software over corporate intranets.

2.2 Decision support systems (DSS)

Decision Support Systems (DSS) are computer-based information systems that provide interactive support to managers and business professionals during the decision-making process. Unlike MIS, DSS supports semistructured decisions through analytical modelling and interactive exploration.

Four components of a DSS

- Analytical models (model base)
- Specialised databases
- A decision maker's own insights and judgments
- Interactive, computer-based modelling process

The DSS model base

A DSS model base is a software component consisting of models used in computational and analytical routines that mathematically express relationships among variables. Examples include linear programming models, multiple regression forecasting models, and capital budgeting present value models.

2.3 Four types of analytical modelling in DSS

What-If Analysis	A user makes changes to variables (or relationships among variables) and observes the resulting changes in other variables. Example: 'What if we cut advertising by 10%? What would happen to sales?'
Sensitivity Analysis	A special case of what-if analysis where only one variable is changed repeatedly to observe its relationship with other variables. Example: 'Let's cut advertising by $100 repeatedly to see its relationship to sales.'
Goal-Seeking Analysis	Reverses the direction – sets a target value for a variable, then repeatedly changes other variables until the target is reached (also called 'how-can' analysis). Example: 'Try increases in advertising until sales reach $1 million.'
Optimization Analysis	A more complex extension of goal-seeking that finds the optimum value for target variables given certain constraints, using tools like linear programming or Excel Solver. Example: 'What's the best amount of advertising given our budget and choice of media?'

Business intelligence (BI) and business analytics (BA)

Business Intelligence (BI) was coined by Howard Dresner (Gartner Group, 1989) as an umbrella term for 'concepts and methods to improve business decision making by using fact-based support systems.' It is now considered a mission-critical element in crafting and executing a firm's strategy.

BI VS. business analytics – key distinction

Business Intelligence (BI)	Focuses on using a consistent set of metrics to measure past performance and guide business planning. Associated with querying, reporting, OLAP, and alerts. Answers: What happened? How many? How often? Where?
Business Analytics (BA)	Makes extensive use of data, statistical/quantitative analysis, explanatory and predictive modelling, and fact-based management. Answers: Why is this happening? What will happen next? What is the best possible outcome?

 Key BI Technologies: Decision Support Systems · Management Information Systems · Knowledge Management Systems · Online Analytical Processing (OLAP) · Data Mining

2.4 Online analytical processing (OLAP)

Online Analytical Processing (OLAP) enables managers and analysts to interactively examine and manipulate large amounts of detailed and consolidated data from many perspectives. OLAP sessions take place in real time, providing rapid responses so the analytical or decision-making process is not interrupted.

Three core OLAP operations

- Consolidation (Roll-Up): Aggregating data from lower to higher levels (e.g., sales offices district → regional). Can involve simple roll-ups or complex groupings of interrelated data.
- Drill-Down: The reverse of consolidation – automatically displaying detailed data that comprise consolidated figures (e.g., breaking down a regional sales total into individual products or sales reps).
- Slicing and Dicing: Viewing the database from different viewpoints or angles. One slice might show all sales of a product type by region; another might show all sales by channel within each product type. Often performed along a time axis to analyse trends.

Common OLAP business applications

- Marketing and sales analysis
- Clickstream data analysis
- Database marketing
- Budgeting
- Financial reporting and consolidation
- Profitability analysis
- Quality analysis
- Customer churn analysis and retention modelling

2.5 Geographic information systems (GIS) and data visualization

Geographic Information Systems (GIS) and Data Visualization Systems (DVS) are special categories of DSS that integrate computer graphics with other DSS features to support spatially-aware and visually-oriented decision making.

Geographic information systems (GIS)

A GIS is a DSS that uses geographic databases to construct and display maps and other graphics displays that support decisions affecting the geographic distribution of people and other resources. Often used with GPS technology to choose retail locations, optimise distribution routes, or analyse target audience demographics.

Data visualization systems (DVS)

DVS represent complex data using interactive, three-dimensional graphical forms such as charts, graphs, and maps. DVS tools help users interactively sort, subdivide, combine, and organise data in graphical form, helping to discover patterns, links, and anomalies – a process called interactive knowledge discovery.

One of the earliest uses of data visualization was Dr. John Snow's 1854 cholera epidemic map of London. By plotting deaths with dots and water pumps with Xs, he identified the Broad Street pump as the source – and stopped the epidemic by having its handle removed. This demonstrates the power of spatial data visualization in decision support

3. Executive information systems (EIS)

Executive Information Systems (EIS) combine features of MIS and DSS, originally designed to meet the strategic information needs of top management. They are now widely used by managers at all levels and are often called Enterprise Information Systems or Executive Support Systems (ESS).

Key features of an EIS

- Graphical user interface tailored to executive preferences
- Exception reporting and trend analysis
- Drill-down capability to access lower levels of detail quickly
- Web-browsing, e-mail, and groupware integration
- Personalised and customised information displays
- Integration of internal and external data sources

3.1 EIS VS. dashboards VS. scorecards

Dashboard	A decision-support interface that monitors the health of the business by displaying key metrics visually in real time. Typically not tied to a formal grand methodology. Example: Valero Energy's Refining Dashboard (updated every 5 minutes).
Scorecard	Tracks performance against predefined metrics and is usually attached to a formal methodology such as the Balanced Scorecard or TQM. Linked to organisational goals and individual employee performance targets.
EIS	A broader system that combines MIS, DSS, and other tools. Provides top executives with strategic information about critical success factors (CSFs), but now widely used across all management levels.

3.2 Enterprise information portals (EIP) and knowledge management

Enterprise information portals (EIP)

An Enterprise Information Portal is a Web-based interface and integration of MIS, DSS, EIS, and other technologies that gives all intranet users and selected extranet users access to a variety of internal and external business applications and services. EIPs are typically personalised to individual users, giving each a customised digital dashboard.

Benefits of enterprise information portals

- More specific and selective information delivery to business users
- Easy access to key corporate intranet resources
- Delivery of industry and business news
- Better access to company data for customers, suppliers, and partners
- Reduces excessive surfing by making needed information easier to find
- Improves overall workforce productivity

Knowledge management systems (KMS)

Knowledge Management Systems use information technology to gather, organise, and share business knowledge within an organisation. In many organisations, hypermedia databases at corporate intranet Web sites serve as knowledge bases for storing and disseminating best practices, policies, and business solutions at the project, team, business unit, and enterprise levels.

Real-World Example: Northrop Grumman faced a critical knowledge-loss crisis when 11,800 of 13,000 engineers left in 1997. The company responded by videotaping interviews with top experts, implementing document management systems, creating mentoring programmes, and using knowledge-capture software – demonstrating the strategic importance of KMS in preserving institutional knowledge

Professional skills focus – applying judgement

1. Match the System to the Decision. Structured decisions need MIS; semi structured need DSS; strategic ones need BI or EIS.
2. Judge Information Quality. Test reports against time, content, and form before trusting them – bad data produces confident but wrong decisions.
3. Ask the Right Analytical Question. Use what-if for exploration, sensitivity for drivers, goal-seeking for targets, optimisation for trade-offs.
4. Move from BI to BA. Go beyond "what happened" to "why" and "what next" before committing resources.
5. Use Visualisation to Discover. Treat dashboards, GIS, and charts as tools for finding patterns, not just displaying them.
6. Balance Dashboards with Scorecards. Dashboards show real-time health; scorecards link performance to strategy.
7. Protect Institutional Knowledge. Capture expertise through documentation, mentoring, and KMS before it walks out the door.
8. Keep the Human in the Loop. Systems inform decisions; judgement and accountability stay with the manager.

4. Artificial intelligence technologies in business

Introduction to artificial intelligence

Section summary

AI enables computers to learn from data and perform cognitive tasks like reasoning, language, and decision-making. Its main branches – ML, Deep Learning, NLP, Computer Vision, RPA, and Expert Systems – power accounting applications such as automated bookkeeping, fraud detection, forecasting, audit automation, tax advisory, and chatbots, driving gains in efficiency, accuracy, and decision quality. But AI also brings risks: data privacy, bias, lack of explainability, job displacement, and over-dependence. The accountant's role is shifting from recorder to analyst and AI governance advisor – making judgement, ethics, and data literacy more vital than ever.

4.1 What is Artificial Intelligence?

The term 'Artificial Intelligence' was first coined by John McCarthy at the Dartmouth Conference in 1956. Today, AI refers broadly to the capability of computer systems to perform cognitive tasks – such as learning, reasoning, problem-solving, perception, and language understanding – that have traditionally required human intelligence.

Artificial Intelligence (AI): The simulation of human intelligence processes by computer systems, encompassing capabilities such as learning from experience, recognizing patterns, understanding language, solving problems, and making decisions.

It is important to distinguish AI from traditional software. Conventional software follows explicit, pre-programmed rules: if condition A occurs, execute action B. AI systems, by contrast, are capable of learning from data and improving their performance over time without being explicitly reprogrammed.

4.2 Evolution of Artificial Intelligence

AI has developed through several distinct phases over the past seven decades:

Period	Key Development
1950s – Foundations	Alan Turing proposes the 'Turing Test' (1950). John McCarthy coins 'Artificial Intelligence' at the Dartmouth Conference (1956). Early programs demonstrated logical reasoning.
1960s–1970s – Early programmes	Development of early AI programs such as ELIZA (an early chatbot). Optimism about AI's potential, followed by reduced funding ('AI Winter') due to slow progress.
1980s – Expert Systems	Rule-based expert systems gained commercial traction. XCON (Digital Equipment Corp) saved millions in configuration costs. Financial institutions began adopting early AI tools.
1990s – Machine Learning emerges	Shift from rule-based to data-driven approaches. IBM's Deep Blue defeats chess world champion Garry Kasparov (1997). Statistical ML methods become mainstream.
2000s – Big Data era	The explosion of digital data enables more powerful ML. Internet companies (Google, Amazon) lead AI research. Natural Language Processing advances significantly.
2010s – Deep Learning revolution	Deep neural networks achieve breakthrough results in image recognition and language translation. Platforms such as TensorFlow and PyTorch democratise AI development.
2020s – Generative AI & professional integration	Large Language Models (ChatGPT, GPT-4, Claude) demonstrate human-like text generation. AI integrates into mainstream accounting software (QuickBooks, Xero, Sage). Professional bodies issue AI governance guidance.

4.3 Importance of AI in Modern Business and Finance

AI is considered one of the most transformative technologies of the 21st century. Its relevance to accounting and finance professionals is significant and growing rapidly.

Volume and velocity of financial data

Modern organisations generate enormous quantities of financial transactions every second. Manual processing is no longer feasible for real-time analysis. AI enables instantaneous processing, classification, and review of transaction data at a scale that is impossible for human teams alone.

Competitive pressure

Global financial services organisations – including the Big Four accounting firms, major banks, and fintech companies – are investing heavily in AI capabilities. Firms that fail to adopt AI risk losing competitive advantage in terms of cost, speed, and analytical insight.

Regulatory expectations

Regulators worldwide are increasingly expecting organisations to deploy technology-based controls for fraud prevention, anti-money laundering, and financial reporting accuracy. AI is becoming a tool of regulatory compliance as much as competitive advantage.

5. Branches of artificial intelligence

5.1 Machine learning (ML)

Machine Learning is the most widely deployed branch of AI in accounting and finance. Rather than following explicit rules, ML systems identify patterns in data and use those patterns to make predictions or decisions.

Machine Learning: A method of data analysis that automates analytical model building. It enables computer systems to learn from data, identify patterns and make decisions with minimal human intervention.

Types of machine learning

- Supervised learning: The algorithm is trained on a labelled dataset – each input is paired with a correct output. Example: training a model on thousands of historical invoices labelled 'legitimate' or 'fraudulent' so it can classify new invoices.
- Unsupervised learning: The algorithm finds hidden patterns or groupings in unlabelled data. Example: identifying unusual clusters of transactions that may indicate money laundering without prior labelled examples.
- Reinforcement learning: The algorithm learns through trial and error by receiving rewards for correct actions. Example: a trading system that learns to optimise investment decisions by maximising portfolio returns over time.

Context example: ML in credit scoring

A leading retail bank in Bangladesh implemented a supervised ML model to improve its credit scoring process. Previously, loan officers evaluated applications based on a fixed set of financial ratios. The new ML system was trained on five years of historical loan data – including applicant financial profiles and repayment outcomes – enabling it to identify subtle patterns predictive of default.

The result: approval accuracy improved by 18%, non-performing loans reduced by 12%, and processing time fell from three days to four hours. The model is retrained quarterly using new outcome data, continuously improving its predictive power.

Accounting implications: The bank's finance team must now audit and validate the ML model as part of annual financial controls – a new skill requirement for accounting professionals.

5.2 Deep learning

Deep Learning is a specialised subset of Machine Learning that uses artificial neural networks with many layers (hence 'deep') to model complex patterns in large datasets.

Deep Learning: A subset of Machine Learning that uses multi-layered artificial neural networks to learn representations of data with increasing levels of abstraction, enabling the detection of complex patterns.

Deep learning has achieved remarkable results in image recognition, speech recognition, and natural language processing. Its accounting applications include analysing large numbers of documents (such as contracts or receipts) simultaneously. Training deep learning models requires substantial computing power and very large datasets.

5.3 Natural language processing (NLP)

Natural Language Processing (NLP) enables computers to understand, interpret, and generate human language – both written and spoken. It bridges the gap between unstructured textual data and structured analytical systems.
Natural Language Processing (NLP): A branch of AI that deals with the interaction between computers and human language, enabling machines to read, understand, and derive meaning from text and speech.

NLP applications in accounting and finance include:

- Reading and summarising legal contracts and loan agreements (e.g., JPMorgan's COIN platform reviewed 12,000 commercial loan agreements in seconds – a task that previously took 360,000 hours of lawyer time annually).
- Analysing the sentiment of earnings calls, news articles, and social media to support investment decisions.
- Extracting financial data from unstructured reports, invoices, and emails.
- Powering customer service chatbots and virtual financial assistants.
- Automated generation of management commentary and financial narrative.

5.4 Computer vision

Computer Vision enables machines to interpret and understand visual information from images and videos. In accounting and finance, it is increasingly used to automate the processing of physical documents.

Computer Vision: A field of AI that enables computers to derive meaningful information from digital images, videos, and other visual inputs, replicating and extending human visual perception.

Practical applications include:

- Optical Character Recognition (OCR): Extracting text from scanned invoices, receipts, and purchase orders and automatically populating accounting systems.
- Cheque processing: Automated reading and validation of cheque information in banking operations.
- Identity verification: KYC (Know Your Customer) compliance through facial recognition and document scanning.
- Expense management: Mobile apps (such as Expensify) use computer vision to capture and categorise expense receipts instantly.

5.5 Robotics and robotic process automation (RPA)

Robotic Process Automation (RPA): The use of software robots ('bots') to automate repetitive, rule-based business processes by mimicking human interactions with digital systems – such as logging in, extracting data, filling forms, and moving files.

RPA differs from AI in that it does not learn; it executes pre-defined rules with high speed and accuracy. However, when combined with AI (Intelligent Process Automation, or IPA), bots can handle more complex, judgment-intensive tasks.

RPA is widely deployed in accounting for:

- Accounts payable: automatically matching purchase orders, goods receipts, and invoices (three-way matching).
- Bank reconciliation: comparing bank statements with internal ledger entries and flagging discrepancies.
- Month-end close: automating routine journal entries and reconciliation procedures.
- Tax return compilation: extracting financial data and populating tax reporting templates.

Consider the month-end close process. Which specific tasks involve repetitive data input or matching activities? How would RPA change the role of an accounts assistant in performing these tasks?

5.6 Expert systems

Expert Systems were among the earliest commercial AI applications. They encode the knowledge and reasoning of human experts into a rule-based system that can provide advice or make decisions in a specific domain.

Expert System: A computer programme that uses a knowledge base of human expertise and a set of logical rules (inference engine) to solve problems or provide recommendations in a specific domain.

Expert systems in accounting and finance include:

- Tax advisory systems: tools that apply complex tax legislation rules to client circumstances and recommend optimal tax treatments.
- Audit planning systems: tools that assess risk areas in an audit based on pre-defined criteria.
- Credit approval systems: rule-based decision tools used by lenders before ML models became prevalent.

While traditional expert systems are being supplemented or replaced by machine learning, they remain in use where regulations require explainable, auditable decision-making processes.

Professional skills focus: Structuring problems and solutions

When evaluating AI applications in the exam or in practice, a useful framework is to match the AI branch to the type of data involved: structured numerical data suits ML; unstructured text suits NLP; images and scans suit Computer Vision; repetitive rules-based tasks suit RPA; and complex regulatory reasoning may suit Expert Systems

6. Applications of AI in accounting and finance

6.1 Automated bookkeeping and data entry

Bookkeeping has historically been one of the most time-consuming and error-prone aspects of accounting. AI dramatically reduces the time and effort required while improving accuracy.

AI-powered bookkeeping systems use a combination of OCR, ML, and NLP to:

- Capture and extract data from paper and digital invoices, receipts, and purchase orders.
- Automatically classify transactions to the correct ledger accounts using learned patterns.
- Reconcile bank transactions with the accounting system, flagging exceptions for human review.
- Process high volumes of transactions in real time, reducing the need for batch processing.

Context example: AI in Small Business Accounting – Xero and QuickBooks

Xero and QuickBooks, two of the world's leading cloud accounting platforms, have embedded AI throughout their core products. Using ML trained on millions of historical transactions, these platforms automatically categorise bank transactions by learning from the client's past coding decisions.

For example, when a restaurant business processes a payment to a food supplier, the system automatically codes the transaction to 'Cost of Sales – Food' based on prior patterns. Over time, the system's accuracy improves, typically reaching 90%+ automation rates for regular transaction types.

The practical implication for accounting technicians and trainees is significant: the role shifts from data entry to review and exception management – requiring greater analytical judgment and less manual input.

6.2 Fraud detection and risk management

Financial fraud costs the global economy trillions of dollars annually. AI has become an essential tool in detecting and preventing fraud at a scale and speed impossible for human analysts.

AI-based fraud detection systems work by:

- Establishing a baseline of 'normal' behaviour for each customer or account using historical transaction data.
- Continuously monitoring all transactions in real time and scoring each one for anomaly against the baseline.
- Flagging or blocking transactions that exceed a predefined anomaly threshold for human review or automatic prevention.
- Learning from confirmed fraud cases to improve detection accuracy over time.

Anomaly detection: An AI technique that identifies data points, transactions, or patterns that deviate significantly from established normal behavior, which may indicate fraud, error, or unusual activity.

Context example: Real-Time Payment Fraud – Visa Decision Intelligence

Visa's Decision Intelligence platform processes over 200 billion transactions annually using deep learning to assess fraud risk in real time. Each transaction is scored within milliseconds against thousands of data variables, enabling Visa to block fraudulent transactions before they complete.

The system uses unsupervised learning to detect new fraud patterns that have not been seen before, adapting automatically as criminal tactics evolve. Visa reports that AI-powered fraud detection prevents over USD 25 billion in fraudulent transactions each year.

For accountants: as external auditors, understanding that clients' payment systems use AI for fraud prevention is relevant to risk assessment. As internal auditors, reviewing the effectiveness of these AI controls is an emerging audit responsibility.

6.3 Financial forecasting and predictive analytics

Traditional financial forecasting relies on historical averages, simple statistical models, and management judgement. AI-driven forecasting can process far larger datasets, incorporate non-financial variables, and continuously update predictions.

- Cash flow forecasting: ML models analyse historical cash flow patterns, accounts receivable ageing, payroll cycles, and seasonal factors to predict future cash positions with greater accuracy.
- Revenue forecasting: models incorporate sales pipeline data, market conditions, customer behaviour patterns, and macroeconomic indicators.
- Scenario analysis: AI can rapidly generate thousands of scenarios (e.g., Monte Carlo simulations) to model the range of possible financial outcomes under different assumptions.
- Credit risk modelling: banks and finance companies use ML models to predict the probability of loan default.

Professional skills focus: Applying judgement

AI forecasting models provide probability estimates and confidence intervals – not certainties. Professional accountants must critically evaluate these outputs, understand the assumptions embedded in models, and exercise independent judgement. The Conceptual Framework principle of faithful representation requires that forecasts disclosed to users accurately reflect the entity's best estimate, not simply the output of a model

6.4 Audit automation and compliance

AI is reshaping external and internal audit by enabling continuous, comprehensive transaction testing rather than traditional sampling approaches.

How AI enhances audit

- Full population testing: AI can test 100% of transactions for specific criteria (e.g., amounts just below approval thresholds, split transactions, weekend postings) rather than relying on samples.
- Journal entry analysis: AI identifies unusual journal entries – such as those posted by finance directors outside normal business hours, or entries reversing significant provisions – that may indicate earnings manipulation.
- Contract review: NLP tools read and extract key terms from thousands of contracts, identifying those requiring specific accounting treatment (e.g., embedded leases under IFRS 16).
- Continuous monitoring: Rather than year-end or quarterly audits, AI enables real-time monitoring of financial controls.
- Working paper automation: AI assists in preparing and cross-referencing audit working papers.

Context example: Deloitte Omnia – AI-Powered Audit Platform

Deloitte has developed Omnia, an AI-powered audit platform that analyses 100% of client transaction data using advanced analytics and machine learning. The platform identifies statistical anomalies, unusual patterns, and potential misstatements that might be missed by conventional sampling.

For a large retail client processing over 50 million transactions annually, Omnia identified a cluster of transactions just below the GBP 1,000 authorisation limit that were subsequently found to represent systematic procurement fraud. The pattern was invisible in the 0.5% sample traditionally tested.

Implication for audit students: understanding AI-based audit tools is increasingly expected of trainees. The IAASB (International Auditing and Assurance Standards Board) is developing guidance on the use of automated tools and techniques in audit.

6.5 Tax planning and advisory

Tax is one of the most complex and rules-dense domains in accounting — making it well-suited to AI augmentation. AI applications in tax span compliance, planning, and advisory services.

- Tax compliance automation: AI tools extract financial data from accounting systems, apply current tax rules, and generate draft tax returns, significantly reducing preparation time.
- Legislative monitoring: NLP tools continuously scan new tax legislation, HMRC/NBR guidance, and court rulings, alerting tax professionals to relevant changes.
- Transfer pricing: ML models analyse transactions between related parties and benchmark against comparable independent transactions to support transfer pricing documentation.
- VAT/GST reconciliation: AI reconciles sales transaction data against VAT returns, identifying discrepancies or potential errors.
- Tax planning scenarios: AI tools rapidly model the tax impact of different corporate structures, financing arrangements, or transaction structures.

In Bangladesh, the National Board of Revenue (NBR) is developing AI-assisted compliance systems. Tax professionals who can understand, validate, and advise on AI-generated tax outputs will be highly valued.

6.6 Customer service and AI chatbots

Financial services organisations — banks, insurers, investment firms — have deployed AI chatbots to handle routine customer enquiries at scale and at any time of day.

Chatbot: A computer programme designed to simulate conversation with human users, typically via text or voice, using NLP to understand queries and generate appropriate responses.

- Balance enquiries, transaction history, and account management.
- Guiding customers through loan applications and investment product selection.
- Providing personalised financial planning recommendations based on spending patterns.
- Escalating complex or sensitive queries to human advisors.

Advanced chatbots, powered by Large Language Models (LLMs), can handle increasingly sophisticated financial conversations. For accounting firms, AI assistants can support clients with routine tax queries, document submission, and deadline reminders.

6.7 Benefits of AI for accountants

6.7.1 Efficiency and productivity

The most immediately visible benefit of AI is the dramatic acceleration of routine accounting processes. Tasks that previously required hours or days can now be completed in minutes or seconds.

Key efficiency benefits include:

- Invoice processing time reduced from days to minutes through AI-powered OCR and automated coding.
- Bank reconciliations completed automatically, with only genuine exceptions requiring human review.
- Month-end close cycles shortened – industry surveys suggest AI reduces close times by 25–50% in organisations that have fully implemented automated reconciliation and reporting.
- Audit procedures completed on the full transaction population rather than samples, without additional time cost.

Practical example: A mid-sized accounting firm processing 10,000 invoices per month spent an average of 4 minutes per invoice on manual data entry and coding. Implementing AI-powered invoice processing reduced this to under 30 seconds per invoice for 85% of invoices, with the remaining 15% flagged for human review. The efficiency gain freed senior accountants to focus on advisory and analytical work.

6.7.2 Accuracy and error reduction

Human error in accounting – transposition errors, miscoding, missed transactions – is a persistent and costly problem. AI systems, once correctly trained, apply rules with perfect consistency.

- AI eliminates transcription errors in data entry: a number entered from an invoice is captured exactly as it appears, without the risk of human mis-keying.
- Consistent application of accounting classifications reduces coding errors across large transaction populations.
- Continuous monitoring means errors are flagged in real time rather than discovered during period-end review.
- AI audit tools can identify misstatements that would be invisible in a conventional sample-based approach.

AI systems are only as accurate as the data they are trained on and the rules they are designed to apply. What could cause an AI system to produce inaccurate accounting outputs? Consider data quality, model bias, and changes in accounting standards.

6.7.3 Cost savings

AI generates significant direct and indirect cost savings for accounting organisations and their clients.

Cost saving area	Explanation
Reduced headcount for routine processing	Automation of data entry, reconciliation, and compliance tasks reduces the number of staff required for transactional processing.
Faster compliance	AI-prepared tax returns and financial statements reduce billable hours and the cost of compliance for clients.
Lower error correction costs	Fewer errors mean less time spent on investigation, correction, and restatement.
Fraud loss prevention	AI fraud detection reduces losses from fraudulent transactions and the costs of subsequent investigation and recovery.
Scalability without proportional cost increase	AI systems can handle growing transaction volumes without corresponding increases in staffing or infrastructure costs.

6.7.4 Better decision-making

Perhaps the most strategically important benefit of AI is its ability to transform the quality and timeliness of financial decision-making.

- Real-time financial data: AI provides finance teams with up-to-the-minute financial performance data, enabling faster and more informed decisions.
- Predictive insight: ML models identify trends and forecast future performance, giving management a forward-looking basis for decisions rather than relying solely on historical reporting.
- Scenario modelling: AI rapidly quantifies the financial impact of strategic decisions – such as entering a new market, acquiring a business, or changing a pricing model.
- Risk identification: AI surfaces emerging risks – in credit, fraud, compliance, or market exposure – before they become material financial events.

6.8 Challenges and risks

6.8.1 Data privacy and security

AI systems require access to large volumes of data – including sensitive personal and financial information. This creates substantial data privacy and cybersecurity risks.

- Personal data: AI systems used for credit scoring, fraud detection, or customer service may process large quantities of personal financial data. Compliance with data protection legislation – including the EU General Data Protection Regulation (GDPR), the Bangladesh Data Protection Act, and sector-specific regulations – is essential.
- Data breaches: the concentration of sensitive data within AI systems creates attractive targets for cybercriminals. A breach of an AI-powered accounting or banking system could expose millions of customer records.
- Data sovereignty: for multinational organisations, determining which jurisdiction's data laws apply to AI-processed data is a complex and evolving area.
- Third-party risk: many AI tools are provided by external vendors. Organisations must assess and monitor the data security practices of these vendors.

Data governance: The policies, procedures, and accountabilities that ensure data is accurate, available, secure, and used ethically within an organisation – a critical framework for responsible AI deployment.

6.8.2 Ethical concerns

AI raises profound ethical questions that are directly relevant to professional accountants as stewards of financial integrity.

Algorithmic bias

AI models learn from historical data. If historical data reflects past discrimination or systemic biases – for example, lending decisions that disadvantaged certain demographic groups – the AI model will learn and perpetuate those biases. A credit scoring model trained on biased historical data could systematically disadvantage minority applicants, raising both ethical and regulatory concerns.

Explainability and transparency

Many AI models – particularly deep learning models – function as 'black boxes': they produce outputs without a clear, human-interpretable explanation of how those outputs were reached. In accounting, where decisions must be justifiable and auditable, this lack of explainability is a significant challenge.

Explainable AI (XAI): An approach to AI development that prioritises the ability to explain and interpret the decisions made by AI models in human-understandable terms – increasingly required for regulated financial applications.

Manipulation of financial information

AI-generated financial reports, forecasts, and analyses could potentially be manipulated to present misleading information. The professional accountant's duty to ensure the integrity of financial information requires vigilance about how AI outputs are used and presented.

Professional skills focus: Applying judgement

The ICAB Code of Ethics requires professional accountants to uphold the fundamental principles of integrity, objectivity, professional competence, confidentiality, and professional behaviour. When AI systems are involved in producing or influencing financial outputs, accountants must apply professional scepticism to the AI's outputs – they cannot simply assume that because a computer produced a number, it is correct. The duty of professional judgement does not transfer to the machine.

6.8.3 Job displacement VS. job transformation

One of the most frequently discussed risks of AI is its impact on employment. The accounting profession is not immune to this concern.

Tasks at risk of automation

Routine, high-volume, rules-based tasks are most susceptible to AI automation. These include data entry, transaction coding, bank reconciliation, standard report generation, and basic tax compliance.

The transformation perspective

Most professional and academic research suggests that AI will transform rather than eliminate the accounting profession. As routine tasks are automated, accountants will shift their focus toward:

- Strategic financial advisory – helping organizations understand and act on AI-generated insights.
- AI governance and risk management – overseeing AI systems, validating their outputs, and managing associated risks.
- Complex judgement-intensive work – areas requiring interpretation of complex accounting standards, professional ethics, and business context.
- Relationship management – advising clients on financial strategy and building trust that no machine can replicate.

Key insight: A 2024 World Economic Forum report estimated that while AI will displace approximately 85 million jobs globally by 2025, it will create 97 million new roles. In accounting, the net effect is projected to be positive, but requires significant upskilling.

6.8.4 Over-dependence on technology

As accounting processes become increasingly automated, there is a risk that professionals lose the foundational skills and critical thinking required to operate without AI tools – and to recognise when AI tools are producing erroneous outputs.

- Model risk: AI models can fail, particularly when applied to scenarios materially different from their training data (for example, during a financial crisis or economic shock).
- Systemic risk: widespread adoption of similar AI models across the financial system could amplify market movements if many systems simultaneously generate the same decision signals.
- Skills erosion: if accountants no longer understand the underlying calculations because AI performs them, they may be unable to identify when outputs are unreasonable.

If an AI system incorrectly codes a large number of transactions in your client's accounts and the error is not detected until after the financial statements are published, who bears responsibility? Consider the roles of the client's finance team, the external auditor, and the AI vendor.

6.9 Future of AI in accounting

6.9.1 The evolving role of accountants

The traditional image of an accountant as a preparer and verifier of historical financial records is giving way to a broader, more strategic professional profile. AI is a principal driver of this transformation.

From recorder to analyst

As AI automates the preparation of financial records, the accountant's primary contribution shifts toward interpretation and analysis: What do the numbers mean? What are the trends? What decisions should the organisation make on this basis?

From compliance preparer to risk advisor

As AI handles much of routine compliance work, accountants increasingly focus on understanding, communicating, and managing the risks embedded in financial activities – including the new risks introduced by AI itself.

The AI governance role

Organisations deploying AI in finance require professionals who can:

- Validate and approve AI models before deployment (model risk management).
- Monitor AI systems in operation, reviewing outputs for reasonableness and investigating anomalies.
- Establish governance frameworks for the ethical and compliant use of AI.
- Communicate AI-related risks and opportunities to boards and audit committees.
- Ensure AI systems comply with accounting standards and regulatory requirements.

This is a new professional frontier for accountants – one where technical accounting expertise meets technology governance.

6.9.2 Skills required for future accountants

Professional bodies including ICAB, ACCA, ICAEW, and CIMA have all identified technology literacy as a critical competency for the next generation of accountants. The future accountant is often described as a 'T-shaped professional' – with deep technical accounting knowledge combined with broad digital skills.

T-shaped professional: A professional who combines deep expertise in one field (the vertical bar of the 'T') with broad competency across adjacent skills and disciplines (the horizontal bar), enabling effective collaboration across specializations.

Technical skills for AI-era accountants

Skill area	Why it matters for accountants
Data literacy	Ability to read, interpret, and critically evaluate datasets and AI-generated outputs. Understanding what a model is telling you – and what it is not – is fundamental.
Understanding of AI concepts	Familiarity with ML, NLP, and other AI branches enables accountants to evaluate AI tools, participate in implementation projects, and advise on AI governance.
Data analytics tools	Proficiency in tools such as Excel (advanced), Power BI, Tableau, and Python (basic) enables accountants to conduct their own data analysis and validate AI outputs.
Cybersecurity awareness	Understanding of data protection principles, cybersecurity risks, and governance frameworks relevant to the deployment of AI in financial systems.
Ethical AI governance	Knowledge of ethical AI frameworks, bias identification, and model risk management – enabling accountants to fulfil their governance responsibilities.
Critical thinking and professional scepticism	As AI produces more of the analytical output, the accountant's most distinctive contribution becomes the quality of their professional judgement applied to that output.

Human skills remain essential

Alongside technical competencies, the following human skills will be increasingly, not less, valuable in an AI-driven accounting environment:

- Communication: translating complex AI outputs into clear, actionable insights for non-technical stakeholders.
- Ethics and integrity: maintaining professional standards in an environment where AI could be misused to manipulate financial information.
- Relationship management: building client trust in a world where much routine work is automated.
- Adaptability: continuously updating skills as AI technology and its applications evolve.

Professional skills focus – applying judgement

1. Match AI to the Problem: ML for numbers, NLP for text, CV for images, RPA for rules, Expert Systems for regulation.
2. Treat Outputs as Estimates: AI gives probabilities, not certainties – apply scepticism.
3. Validate the Data: Biased inputs produce biased outputs.
4. Demand Explainability: Reject "black box" answers in regulated work.
5. Guard Against Skills Erosion: Keep the fundamentals to spot unreasonable results.
6. Uphold Ethics: Judgement stays with the accountant, not the machine.
7. Embrace Governance: Validate, monitor, and advise on AI risks.
8. Build T-Shaped Skills: Pair accounting depth with data and tech literacy.

7. Understanding blockchain technology

Introduction to blockchain technology

Section summary

Blockchain is a distributed, decentralised digital ledger that records transactions in cryptographically linked blocks – making them immutable, transparent, and tamper-evident without a central authority. It comes in three types: public (Bitcoin, Ethereum), private (Hyperledger), and consortium (R3 Corda). In accounting, it enables real-time recording, continuous auditing, fraud prevention, transparent reporting, smart contract automation, and asset tracking – even supporting triple-entry accounting. But it brings challenges around regulation, scalability, cost, expertise, and private key security. The accountant's role shifts from data entry to governance and digital assurance, making blockchain literacy and professional scepticism essential.

7.1 Defining blockchain

The term 'blockchain' describes both a data structure (a chain of data blocks) and the distributed network that maintains it. At its most fundamental, a blockchain is a shared database in which records – once written – cannot be altered or deleted without the agreement of all network participants and without detection by any observer.

A distributed, decentralised digital ledger that records transactions across a network of computers in cryptographically linked blocks, creating a tamper-evident, transparent, and immutable record that does not require a central authority to maintain its integrity.

For accounting purposes, blockchain can be understood as a perpetual, shared, tamper-proof accounting record – a ledger accessible to all authorised participants simultaneously, in which no single party can unilaterally alter or delete an entry once made. This is profoundly significant for audit, financial reporting, and fraud prevention.

Key distinction: Traditional accounting systems rely on centralised trust – we trust the numbers in a company's accounts because we trust the accountants who prepared them (subject to audit). Blockchain creates distributed trust – we can verify the records ourselves, mathematically, without needing to trust any individual preparer.

7.2 Evolution of blockchain technology

Phase	Key Development
Generation 1: Cryptocurrency (2008–2014)	Satoshi Nakamoto publishes the Bitcoin White Paper (2008), introducing blockchain as the underpinning technology for a peer-to-peer electronic cash system. Bitcoin launches (2009). Blockchain demonstrates that digital value can be transferred without trusted intermediaries. Focus: payments and cryptocurrency.
Generation 2: Programmable Blockchain (2015–2016)	Ethereum launches (2015), introducing smart contracts – self-executing code that extends blockchain beyond payments to programmable financial agreements. Concept of 'blockchain 2.0' emerges. Financial institutions begin exploring blockchain for trade finance and securities settlement.
Generation 3: Enterprise Blockchain (2017–2019)	Enterprise blockchain platforms emerge: Hyperledger Fabric (IBM/Linux Foundation), R3 Corda (banking consortium), Quorum (JPMorgan). These platforms are designed for business use – permissioned, scalable, privacy-preserving. Big Four accounting firms begin blockchain pilots. Maersk and IBM launch TradeLens for supply chain.

Generation 4: DeFi and Institutional Adoption (2020–2022)	Decentralised Finance (DeFi) protocols create blockchain-based alternatives to banks, exchanges, and lending markets. Total DeFi value exceeds USD 200 billion at peak. Central banks worldwide announce CBDC research. Institutional investors (Goldman Sachs, BlackRock) enter cryptocurrency markets. NFTs create new digital asset categories.
Generation 5: Integration and Maturity (2023–present)	Blockchain integrates with AI and IoT for complex financial applications. IASB begins developing cryptocurrency accounting guidance. Governments launch regulatory frameworks (EU MiCA regulation, 2023). Blockchain audit tools enter mainstream accounting practice. Prokopenko et al. (2024) identify this phase as the transition from experimental to operational deployment in financial accounting.

7.3 Importance of blockchain in modern finance and accounting

Blockchain's relevance to accounting arises directly from its three core properties – immutability, transparency, and decentralisation – each of which addresses a fundamental challenge in financial accounting:

Immutability and fraud prevention

Once a transaction is recorded on a blockchain, it cannot be altered without invalidating all subsequent records and being immediately detectable by network participants. Prokopenko et al. (2024) identify this as blockchain's most significant contribution to financial accounting: the elimination of the possibility of retroactive manipulation of financial records – a primary mechanism of accounting fraud.

Transparency and audit efficiency

All authorised participants in a blockchain network can see the same transaction records in real time. For accounting, this means that auditors, regulators, management, and investors could potentially access the same verified financial records simultaneously – transforming audit from a periodic sampling exercise to a continuous verification process.

Decentralisation and trust

Blockchain distributes record-keeping across many independent nodes, eliminating the single point of failure and single point of manipulation that exist in centralised accounting systems. This decentralisation creates trust through mathematics rather than reliance on the integrity of any individual actor – a fundamental shift in the trust architecture of financial reporting.

7.4 How blockchain works

7.4.1 The distributed ledger

In a traditional accounting system, a single organisation maintains the master ledger. Employees enter transactions, the accountant reviews them, and the auditor verifies them – but at each stage, a human being with access rights can potentially alter the data. The entire system relies on the trustworthiness of those with access.

A distributed ledger changes this fundamentally. Instead of one organisation holding the master copy, thousands of computers (nodes) around the world each hold an identical copy of the ledger. When a new transaction is added, it is added to every copy simultaneously. If anyone tries to change a record on their copy, their version will no longer match the other thousands of copies – and the discrepancy will be immediately apparent.

Distributed ledger: A database that is consensually shared, replicated, and synchronised across multiple sites, institutions, or geographies, with no central administrator – allowing all participants to have an identical, simultaneously updated record of transactions.

7.4.2 Blocks, transactions, and hashing

Transactions

A blockchain transaction is any record of data being added to the chain – in a payment blockchain, this is a transfer of value; in an accounting blockchain, this might be an invoice, a journal entry, or an asset transfer. Transactions are broadcast to the network by participants and collected into blocks for processing.

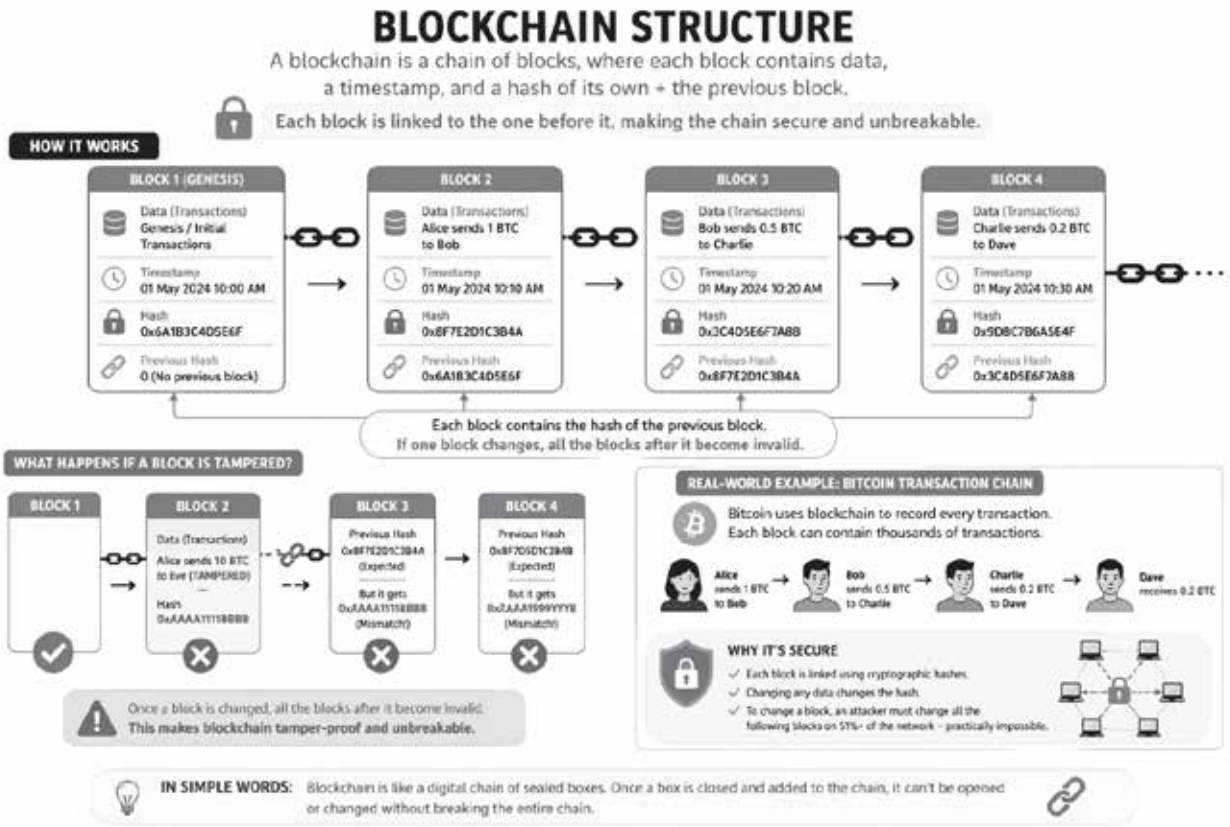
Blocks

A block is a container for a group of validated transactions. Each block contains: (1) a header with metadata; (2) a set of validated transactions; and (3) most importantly, a cryptographic hash of both its own contents and the hash of the previous block.

Block: A container in a blockchain that holds a batch of validated transactions together with metadata, including a cryptographic hash of the previous block in the chain.

Cryptographic hash: A fixed-length alphanumeric string produced by a mathematical algorithm (hash function) that uniquely represents a specific input. Any change to the input – even a single character – produces a completely different hash output.

The blockchain structure – illustrated



Why hashing prevents fraud

The critical anti-fraud property of blockchain arises from the chain of hashes. Because each block's hash is calculated from both its own transaction data and the previous block's hash, altering any historical transaction would change that block's hash – which would then make the next block's 'previous hash' reference incorrect, breaking the chain. The altered chain would be rejected by all other network participants whose unaltered chains remain valid.

Accounting parallel: Imagine a traditional paper ledger where each page's header includes a seal that is calculated from every transaction on that page and the seal from the previous page. Changing any entry on any page would break its seal – and because subsequent pages also reference that seal, the fraud would be visible throughout the ledger. Blockchain implements this mathematically, making it computationally infeasible to produce a fraudulently altered chain that passes verification.

7.4.3 The role of cryptography

Blockchain employs two forms of cryptography that accounting students should understand: cryptographic hashing (introduced above) and public-key cryptography.

Public-key cryptography: An encryption method that uses a pair of mathematically linked keys: a public key (shared openly, like an address) and a private key (kept secret by the owner). A message or transaction signed with a private key can be verified by anyone with the corresponding public key, proving authenticity without revealing the private key.

Digital signature: A cryptographic mechanism by which a transaction originator signs the transaction with their private key, allowing network participants to verify that the transaction was authorised by the legitimate account holder – without the verifier needing to know the private key

In accounting blockchain applications, digital signatures serve the function of authorisation controls. Just as a manual payment requires a physical signature, a blockchain transaction requires a digital signature from the authorised private key holder. This creates an automatic, cryptographically verifiable authorisation trail for every financial transaction.

7.4.4 Consensus mechanisms

In a distributed network with no central authority, all participants must agree on which transactions are valid and in what order they occurred. This agreement is achieved through consensus mechanisms – rules that all network participants follow to reach agreement on the state of the ledger.

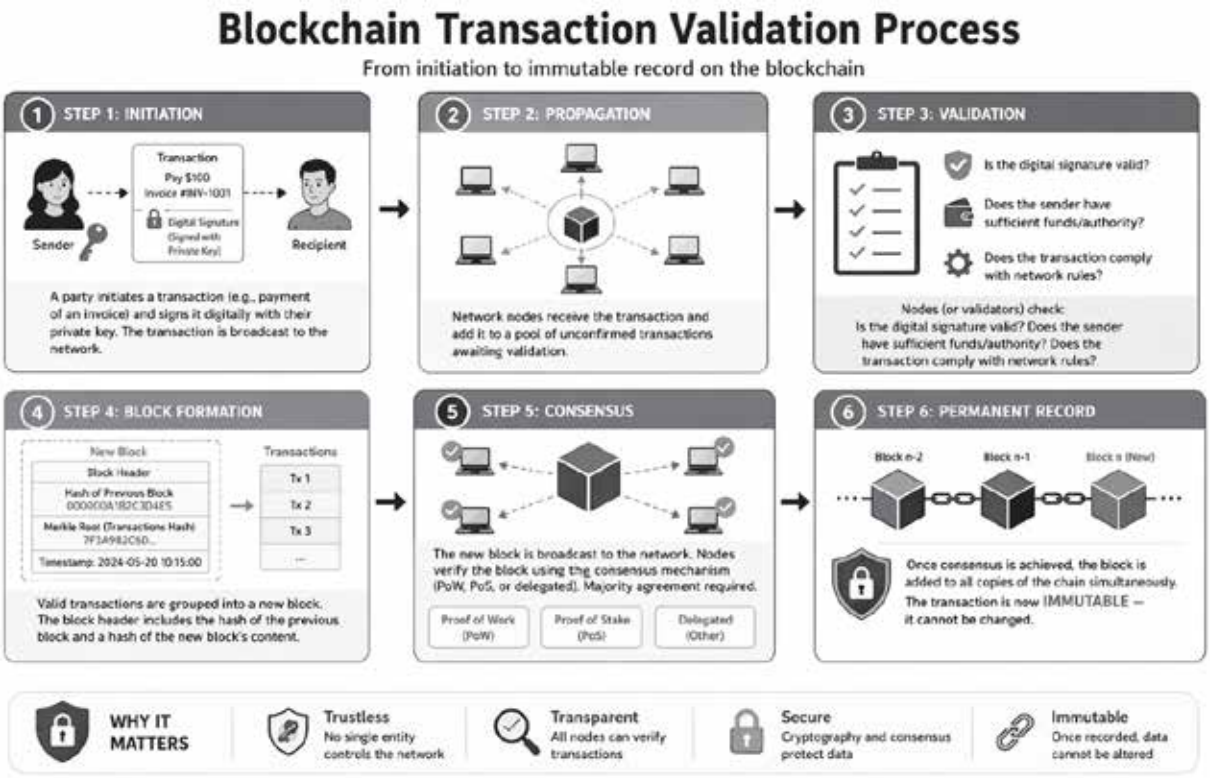
Consensus mechanism: The protocol by which all participants in a distributed blockchain network reach agreement on the validity of new transactions and the order in which they are added to the shared ledger, without requiring a central authority.

The two principal consensus mechanisms are:

Mechanism	How it works	Accounting relevance
Proof of Work (PoW)	Nodes ('miners') compete to solve a computationally intensive mathematical puzzle. The winner adds the next block and earns a reward. Bitcoin uses PoW.	High energy consumption and slow transaction speed (7 transactions/second for Bitcoin) make PoW unsuitable for high-volume accounting applications. Important to understand for cryptocurrency accounting.
Proof of Stake (PoS)	Validators are selected to add new blocks based on the cryptocurrency they have 'staked' as collateral. Ethereum migrated to PoS in 2022.	More energy-efficient and faster than PoW. PoS blockchains (e.g., Ethereum) are increasingly used for financial applications. The staked collateral creates economic incentives for honest behaviour.
Delegated / Practical BFT	Used in enterprise blockchains – trusted validators are pre-approved by network participants. No energy-intensive competition.	Used in private and consortium blockchains (Hyperledger Fabric, R3 Corda) deployed for accounting and finance – fast, efficient, and suitable for regulated financial applications.

7.4.5 How a blockchain transaction is validated

The lifecycle of a blockchain transaction proceeds through the following steps, which accounting students should be able to describe:



7.4.6 Key features: Decentralization, immutability, and transparency

Key feature	What it means for accounting
Decentralisation	No single entity controls the ledger. This eliminates the risk of a single point of manipulation – no individual, not even the CFO or the auditor, can unilaterally alter a financial record. Prokopenko et al. (2024) identify decentralisation as the property that most fundamentally transforms the trust architecture of financial reporting.
Immutability	Once recorded, transactions cannot be altered or deleted. This creates a permanent, tamper-evident historical record of all financial transactions – precisely the audit trail that accountants and regulators require but that centralised systems can never fully guarantee.
Transparency	All authorised participants see the same real-time record. In a private or consortium accounting blockchain, this means auditors, regulators, and management all see the same verified data – eliminating the information asymmetry that allows management to present selective or misleading financial information.
Traceability	Every transaction is timestamped and linked to all preceding transactions, providing a complete, verifiable provenance record for every financial entry from its original creation to the present.
Smart contract automation	Programmable rules embedded in the blockchain can automate financial processes – releasing payments upon delivery, triggering tax remittances upon sales, or rebalancing portfolios on defined criteria – without human intermediaries.

7.5 Types of blockchain

7.5.1 Public blockchain

Public blockchain: A blockchain network that is open to all participants – anyone can read the ledger, submit transactions, and participate in the consensus process. No permission is required to join.

Public blockchains are fully decentralised and maximally transparent. Bitcoin and Ethereum are the most prominent examples. All transactions are visible to all participants (pseudonymously – wallet addresses rather than real names are shown).

Accounting relevance of public blockchains

- Cryptocurrency transactions: Bitcoin, Ether, and other public blockchain assets increasingly appear on corporate balance sheets, requiring accounting treatment under IAS 38 (see Chapter 17).
- NFT accounting: Non-fungible tokens (NFTs) issued and traded on public blockchains (primarily Ethereum) create novel accounting challenges for creators, holders, and marketplace operators.
- DeFi protocol accounting: Decentralised finance protocols operate on public blockchains, generating complex financial statement questions around revenue recognition, asset classification, and risk disclosure.
- Transparency for regulators: public blockchain transaction records are permanently accessible to regulators and tax authorities, creating implications for tax compliance.

Limitations for enterprise accounting

Public blockchains are generally unsuitable for enterprise accounting applications because: (1) all transactions are publicly visible, making commercially sensitive financial data accessible to competitors and the public; (2) transaction throughput is low (Bitcoin: 7 transactions/second; Ethereum: 15–30 transactions/second), insufficient for high-volume financial operations; and (3) transaction costs ('gas fees') are variable and sometimes very high.

7.5.2 Private blockchain

Private blockchain: A blockchain in which participation is restricted to pre-approved participants, controlled by a single organisation or authority. Only authorised parties can read the ledger, submit transactions, or participate in consensus.

Private blockchains retain the technical properties of immutability and traceability but sacrifice full decentralisation – the controlling organisation has administrative rights over the network. They offer high transaction speed, strong privacy controls, and lower energy consumption.

Examples in accounting and finance

- Hyperledger Fabric: an enterprise-grade private blockchain framework developed by IBM and the Linux Foundation. Used by Walmart (food supply chain tracking), Everledger (diamond provenance), and numerous banks for internal payment systems.
- Bank-internal settlement systems: major banks have deployed private blockchains for internal settlement of securities and payments, reducing reconciliation costs between departments.
- Corporate treasury management: multinational corporations use private blockchains to record and settle intercompany transactions in real time across jurisdictions.

7.5.3 Consortium (Hybrid) blockchain

Consortium blockchain: A blockchain governed by a group of organisations rather than a single entity or the general public. Participation is permissioned – only approved members can join – but control is distributed among the founding consortium members rather than any single organisation.

Consortium blockchains represent the most practically relevant type for many accounting and finance applications: they provide the benefits of decentralisation (no single party can unilaterally manipulate records) while maintaining the privacy and performance required for business use.

Leading consortium blockchain platforms

- R3 Corda: developed by a consortium of over 40 major financial institutions including Barclays, HSBC, and Goldman Sachs. Designed for financial contracts and regulatory compliance – each transaction is only visible to the parties directly involved.
- Quorum (ConsenSys): JPMorgan's enterprise blockchain platform, used for interbank settlements and trade finance.
- Marco Polo Network: a trade finance consortium blockchain connecting banks and corporations for real-time working capital financing and payment obligations.
- We.Trade: a European consortium blockchain for trade finance among 12 major European banks.

Feature	Public	Private	Consortium
Access	Open to all	Single organisation controls	Group of pre-approved members
Decentralisation	Fully decentralised	Centralised (one controller)	Partially decentralised
Transparency	Fully transparent (pseudonymous)	Controlled – admin can restrict	Visible only to members
Transaction speed	Slow (7–30 TPS)	Very fast (1,000+ TPS)	Fast (100–1,000+ TPS)
Energy consumption	High (PoW) / Medium (PoS)	Low	Low to medium
Best accounting use	Crypto accounting, DeFi	Internal records, treasury	Inter-company, trade finance, audit
Examples	Bitcoin, Ethereum	Hyperledger Fabric	R3 Corda, Quorum, Marco Polo

7.6 Applications of blockchain in accounting and finance

7.6.1 Real-time accounting and continuous auditing

From periodic to continuous financial recording

Traditional accounting operates on a periodic basis: transactions are recorded throughout the period, then reviewed, reconciled, and adjusted at month-end and year-end. This periodicity creates information gaps – management and investors receive stale financial information, and discrepancies may not be discovered until months after they occur.

Blockchain enables a fundamentally different model. When financial transactions are recorded on a shared blockchain in real time, the financial record is continuously current – no period-end closing process is needed because the ledger is always up to date and already verified.

Continuous auditing enabled

Traditional external audit is a point-in-time sampling exercise. Auditors select samples from the population of transactions and test them for accuracy and compliance. This means most transactions are never independently verified, and the opinion relates to a historical period that may be over a year old by the time it is issued.

Blockchain audit changes this model fundamentally. When audit-relevant transactions are recorded on an immutable, transparent blockchain, auditors can:

- Access 100% of recorded transactions at any time, without waiting for the client to provide data.
- Verify the integrity of any transaction by checking the cryptographic hash chain – any tampered record is immediately detectable.
- Issue continuous or real-time assurance rather than a once-yearly audit opinion.
- Automate routine testing procedures, freeing audit resources for higher-value analytical work.

KPMG clara – blockchain-enhanced audit platform

KPMG has deployed its Clara audit platform, which incorporates blockchain technology to create a shared, verifiable audit record accessible to both KPMG and their clients. When client transactions are blockchain-recorded, KPMG auditors can access real-time transaction data, verify the cryptographic integrity of records, and automate standard audit tests across 100% of the transaction population.

In pilot engagements with large retail and financial services clients, KPMG reports a 30–45% reduction in audit fieldwork time, with the time saved redirected to higher-risk areas and analytical procedures requiring professional judgment.

Prokopenko et al. (2024) cite continuous auditing as the most transformative application of blockchain for the audit profession, noting that the shift from annual sampling to real-time verification fundamentally changes both the value and the process of independent assurance.

7.6.2 Fraud prevention and data integrity

Financial fraud – from management manipulation of earnings to accounts payable fraud and revenue recognition manipulation – typically involves altering or creating financial records. Blockchain addresses this at a structural level.

Fraud mechanisms prevented by blockchain

- Retroactive alteration: the cryptographic hash chain makes it computationally infeasible to alter any historical financial record without immediate detection. Accounting fraud schemes that rely on changing historical journal entries or altering prior-period accounts are structurally prevented.
- Duplicate transactions: each transaction on a blockchain has a unique cryptographic identifier. Duplicate payment fraud – submitting the same invoice twice – is automatically detected and rejected.
- Unauthorised entries: only cryptographically signed, digitally authorised transactions can be added to the blockchain. Fraudulent journal entries created by an unauthorised employee are prevented at the point of entry.
- Collusion between counterparties: in a multi-party blockchain, neither buyer nor seller can alter their version of a transaction record – both parties see the same immutable record. This eliminates the type of fraud where a buyer and supplier agree to falsify transaction records between them.

Prokopenko et al. (2024) finding: The authors specifically identify immutability as blockchain's primary fraud prevention mechanism for financial accounting, noting that the inability to alter historical records without detection removes the principal tool available to perpetrators of earnings manipulation fraud. The paper cites studies showing that public companies recording transactions on blockchain-based systems demonstrate materially lower rates of suspicious accounting adjustments than comparable companies using traditional ledger systems.

Everledger – Blockchain for Diamond Fraud Prevention

Everledger uses a private blockchain to record the provenance, characteristics, and ownership history of individual diamonds. Each diamond is assigned a unique digital identifier based on its physical characteristics (cut, clarity, carat, colour), and every transfer of ownership is recorded on the blockchain.

From an accounting and audit perspective, Everledger solves a specific fraud problem: the substitution or misrepresentation of diamonds in insurance claims, trade finance, and collateral arrangements. With blockchain provenance records, insurers, banks, and auditors can verify the identity and value of any diamond against an immutable historical record.

The platform now covers over 2 million diamonds. Fraud claims in participating insurers' portfolios have reduced materially, and audit procedures for diamond-backed financial instruments are significantly more reliable.

7.6.3 Transparent financial reporting

Reducing information asymmetry

A core problem in financial reporting is information asymmetry: management knows far more about the company's financial position than investors, creditors, or regulators. Financial statements are designed to reduce this asymmetry, but preparers retain significant discretion over what to disclose, how to classify items, and what assumptions to make in estimates.

Blockchain reduces information asymmetry at a structural level. When significant financial transactions – revenues, payments, borrowings, asset acquisitions – are recorded on a shared blockchain accessible to all authorised stakeholders, the gap between what management knows and what investors can verify narrows dramatically.

Triple-entry accounting

Triple-entry accounting: An extension of double-entry bookkeeping in which every transaction creates three records: a debit entry in the payer's accounts, a credit entry in the payee's accounts, and a shared, cryptographically signed entry on a shared blockchain visible to both parties and potentially to auditors and regulators.

Triple-entry accounting, first theorised by Ian Grigg in 2005, becomes practically feasible through blockchain. In a triple-entry system, every financial transaction between two parties generates a third, shared, tamper-proof record that neither party alone can alter. Mismatching accounts between counterparties – a primary audit risk in intercompany and third-party transaction testing – becomes structurally impossible.

7.6.4 Smart contracts for automated financial transactions

Smart contracts are self-executing programmes stored on a blockchain that automatically enforce financial agreements when pre-defined conditions are met. They are the mechanism through which blockchain moves from passive record-keeping to active financial process automation.

Smart contract (blockchain context): Immutable computer code deployed on a blockchain that automatically executes, controls, or documents legally relevant events and actions according to the terms of a contract or agreement – without the need for human intermediaries.

Accounting applications of smart contracts include:

- Automated invoice settlement: a smart contract monitoring a goods delivery blockchain can automatically release payment to a supplier when the blockchain confirms delivery – eliminating the manual accounts payable process.
- Revenue recognition: a smart contract can automatically recognise revenue when specific IFRS 15 performance obligations recorded on the blockchain are satisfied – reducing the judgment element in revenue recognition for certain contract types.
- Dividend distribution: smart contracts automatically distribute dividends to shareholders when board approval is blockchain-recorded – eliminating the risk of dividend payment errors or delays.
- Loan covenants: financial covenant compliance (e.g., maintaining a minimum interest cover ratio) can be monitored automatically – with smart contracts triggering notifications or remedial actions when covenants are breached.

Maersk and IBM – tradelens smart contract trade finance

Maersk (the world's largest shipping company) and IBM collaborated to create TradeLens, a blockchain platform for global trade documentation. TradeLens recorded shipping events (vessel departure, customs clearance, port of entry arrival) on a consortium blockchain shared with over 150 participating banks, customs authorities, and port operators.

Smart contracts on TradeLens automatically triggered Letters of Credit payment releases when the blockchain confirmed that the goods had cleared customs at the destination – a process that previously took 7–10 days of manual document review and reduced to hours.

Accounting implications: the automation of payment triggers through smart contracts removes the accounts payable approval step for routine documented transactions. Finance teams at participating companies reported 40–60% reductions in trade finance processing costs. Although TradeLens was discontinued in 2022, it remains a definitive proof-of-concept for blockchain-enabled trade finance – subsequent industry platforms have adopted its model.

7.6.5 Asset tracking and verification

Blockchain provides a tamper-proof record of asset provenance, ownership, and condition throughout an asset's lifecycle. For accounting and audit purposes, this has significant implications for fixed asset management, inventory valuation, and the audit of assets.

- Fixed asset registers: assets recorded on a blockchain carry a verifiable history of acquisition cost, depreciation charges, revaluation events, and disposals – providing auditors with complete, independently verified asset records.
- Inventory management: blockchain-based supply chain records track inventory from raw material through production to final goods – supporting the audit of inventory existence, completeness, and valuation.
- Intellectual property: blockchain records of patent filings, licence agreements, and royalty payments provide verifiable documentation for intangible asset accounting under IAS 38.
- Real estate: property blockchain platforms (e.g., deployed in several US states and in Sweden) record ownership transfers, mortgage registrations, and valuations on a public or consortium blockchain, simplifying the audit of real estate assets.

7.6.6 Blockchain in auditing and compliance

Blockchain transforms auditing in three dimensions: evidence quality, evidence availability, and the audit process itself.

Evidence quality

Blockchain records are tamper-evident, timestamped, and cryptographically signed by all parties to a transaction. This makes them among the highest-quality audit evidence available – higher quality than paper documents, which can be forged, and potentially higher quality than traditional electronic records, which can be altered without guaranteed detection.

Evidence availability

In traditional audit, obtaining evidence requires requesting documents from the client – who controls what is provided. In a blockchain audit, the auditor accesses the shared ledger directly, seeing exactly what all participants see, without relying on management to provide or select documents.

Automated compliance

Smart contracts can encode regulatory compliance rules directly into financial processes – for example, automatically ensuring that all payments above a threshold are dual-authorised, or that VAT is calculated and remitted automatically on every taxable transaction. This changes compliance from a periodic checking exercise to a continuous automated process.

Applying judgement

Blockchain audit evidence is only as reliable as the blockchain platform producing it. Before relying on blockchain records as audit evidence, auditors must assess: (1) the governance and access controls of the blockchain platform; (2) whether the smart contracts correctly implement the intended business rules; (3) whether all relevant transactions are recorded on the blockchain (completeness risk); and (4) the security of private key management. Blockchain does not eliminate the need for professional scepticism – it changes what scepticism must focus on.

7.7 Benefits of blockchain for accountants

7.7.1 Improved transparency and trust

Blockchain creates transparent, shared financial records accessible to all authorised parties simultaneously. This transparency has three distinct dimensions of value for accountants:

- Management and investor alignment: when significant transactions are blockchain-recorded, investors can verify key financial events independently rather than relying solely on management's periodic disclosures. This reduces the cost of information asymmetry and the risk premium that investors demand for uncertainty.
- Regulator access: regulators granted access to a firm's accounting blockchain can verify compliance with financial reporting requirements in real time – potentially enabling lighter-touch inspection regimes for compliant firms.
- Inter-company transparency: in group accounting, blockchain records of intercompany transactions eliminate the mismatches that frequently require time-consuming reconciliation during group consolidations. All group entities see the same transaction record simultaneously.

7.7.2 Reduced fraud and data manipulation

The immutability property of blockchain is the most significant structural anti-fraud mechanism available in modern accounting. Unlike traditional internal controls – which deter fraud but cannot prevent a sufficiently motivated or powerful actor from altering records – blockchain makes retroactive alteration computationally infeasible and immediately detectable.

Fraud type	How blockchain addresses it
Journal entry manipulation (earnings fraud)	Blockchain journal entries are immutable. Any attempt to alter a prior-period entry changes the hash chain and is immediately detectable by all participants.
Duplicate invoice fraud	Each invoice on a blockchain has a unique cryptographic identifier. Duplicates are automatically rejected by the network.
Asset misappropriation	Blockchain asset records provide complete, verifiable ownership and custody histories – making it much harder to misappropriate or misrepresent assets.

Related party transaction concealment	In a shared blockchain, related party transactions are visible to all authorised participants – making concealment from auditors structurally more difficult.
Revenue manipulation	Smart contracts that automatically recognise revenue when performance obligations are satisfied remove management discretion in revenue timing.
Collusion between parties	No single party can alter a shared blockchain entry – collusion-based falsification of intercompany transactions is structurally prevented.

7.7.3 Enhanced audit efficiency

Blockchain has the potential to fundamentally reduce the cost and time of external audit, while simultaneously improving its quality.

- Population testing: auditors can test 100% of blockchain-recorded transactions rather than relying on sampling – significantly improving the statistical confidence of audit conclusions.
- Real-time evidence access: auditors access blockchain records directly without waiting for client document requests – reducing audit timeline and eliminating the risk of selective document provision.
- Automated reconciliation verification: mismatches between counterparties' accounts are structurally prevented by blockchain – eliminating a substantial portion of traditional reconciliation testing.
- Reduced reliance on management representations: blockchain evidence is verified by the network rather than attested by management, reducing the audit risk associated with management misrepresentation.

7.7.4 Real-time financial data access

Cloud-based blockchain accounting platforms provide authorised participants – management, accountants, auditors, and regulators – with real-time access to the same verified financial data, from any location.

- Management reporting: financial KPIs are available continuously rather than through period-end closing processes – enabling faster, better-informed management decisions.
- Cash management: real-time visibility of blockchain-recorded payments and receipts enables more precise liquidity management.
- Regulatory reporting: automatic compilation of regulatory returns from blockchain-recorded transaction data, with real-time accuracy and no manual aggregation.

7.7.5 Cost reduction in reconciliation and verification

Reconciliation – matching records between counterparties, between systems, and between periods – is one of the most resource-intensive activities in accounting. Industry estimates suggest that financial firms spend 5–10% of their operating costs on reconciliation and verification activities.

- Intercompany reconciliation: blockchain eliminates mismatches between group companies' records, removing the need for intercompany reconciliation procedures – estimated to save large multinational groups millions of dollars annually.
- Bank reconciliation: direct integration between accounting systems and bank blockchain records enables automatic, continuous bank reconciliation.
- Trade finance: smart contract-automated trade finance processes reduce letter of credit processing costs by an estimated 70–90% according to multiple industry studies.
- Audit cost reduction: industry pilots suggest blockchain-enabled audit processes could reduce external audit fees by 20–40% for organisations with mature blockchain accounting implementations.

7.8 Challenges and risks of blockchain

7.8.1 Regulatory uncertainty

Blockchain operates ahead of the regulatory frameworks designed to govern it. This creates legal and compliance uncertainty that many organisations find prohibitive.

- Legal status of smart contracts: in many jurisdictions, including Bangladesh, the legal enforceability of smart contract-executed agreements is not yet definitively established. If a smart contract executes a financial transaction incorrectly, it is unclear which party bears liability and through what legal mechanism disputes are resolved.
- Cryptocurrency accounting standards: as discussed in Chapter 17, IFRS does not yet have a comprehensive standard for digital asset accounting. The current treatment under IAS 38 is widely acknowledged as inadequate for many digital asset types. The IASB's ongoing standard-setting project is unlikely to produce a final standard before 2027.
- Data protection and blockchain immutability conflict: GDPR (and equivalent data protection laws) grants individuals the right to erasure of their personal data. Blockchain's immutability makes it structurally impossible to delete individual data records – creating a direct conflict between data protection rights and blockchain's core property. This is an active area of legal and technical development.
- Cross-border regulatory fragmentation: blockchain networks operate globally, but financial regulation is national. A consortium blockchain spanning multiple jurisdictions must comply with multiple, potentially conflicting regulatory frameworks – a significant compliance management challenge.

Bangladesh context: Bangladesh Bank has issued limited guidance on blockchain use by financial institutions. Cryptocurrency transactions are subject to significant regulatory restrictions. Organisations deploying blockchain for accounting applications in Bangladesh must engage proactively with Bangladesh Bank and relevant regulators to ensure compliance with the evolving regulatory framework.

7.8.2 Scalability issues

Transaction throughput – the number of transactions a blockchain can process per second – remains a significant technical limitation for high-volume financial applications.

System	Transactions per second
Bitcoin (public blockchain)	7 TPS
Ethereum (public blockchain)	15–30 TPS
Visa payment network (traditional)	24,000 TPS (peak capacity: 65,000 TPS)
Hyperledger Fabric (private blockchain)	1,000–3,500 TPS
R3 Corda (consortium blockchain)	170 TPS (standard) – higher in optimised deployments
Solana (public, high-performance)	65,000 TPS (theoretical)

For accounting applications requiring high transaction volumes – such as a retail bank processing millions of daily payment transactions – even enterprise blockchain platforms may fall short of required throughput. Layer 2 solutions (off-chain transaction processing with periodic blockchain settlement) address some but not all scalability limitations.

7.8.3 High implementation costs

Blockchain implementation in an accounting context is not a software purchase – it is an infrastructure transformation requiring significant investment in technology, process redesign, and organisational change.

- Technology infrastructure: deploying and operating blockchain nodes, integrating with existing accounting and ERP systems, and managing network participation involves substantial technology investment.
- Process redesign: accounting processes must be redesigned around blockchain's properties – defining what goes on-chain, what remains off-chain, how exceptions are handled, and how the blockchain record interfaces with traditional accounting systems.
- Staff training: accountants, IT staff, and auditors require specialised training in blockchain technologies, smart contract design, and the audit of blockchain-based systems.
- Ongoing maintenance: blockchain networks require ongoing technical management, including software updates, security monitoring, and node management – costs that are less visible but significant.

Industry estimates suggest that enterprise blockchain implementations for financial applications typically cost USD 1–10 million for initial deployment, with ongoing operational costs of 20–30% of the initial investment annually.

7.8.4 Lack of Technical Expertise

Blockchain accounting is an interdisciplinary field requiring expertise in distributed systems, cryptography, smart contract programming, accounting standards, and audit – a combination of skills that very few professionals currently possess.

- Skills shortage: there is a global shortage of professionals who combine accounting expertise with blockchain technical knowledge. This shortage drives up implementation costs and creates execution risk in blockchain projects.
- Auditor competence: ISA 315 requires auditors to understand the entity's information systems. Blockchain accounting systems require auditors to understand distributed ledger architecture, cryptographic controls, and smart contract logic – skills not included in standard audit training.
- Smart contract risk: bugs or vulnerabilities in smart contract code can result in incorrect financial transaction execution or, in the case of DeFi protocols, the loss of substantial funds. The DAO hack of 2016 resulted in the loss of USD 60 million due to a smart contract vulnerability – demonstrating that technical errors in blockchain code can have catastrophic financial consequences.

7.8.5 Security risks: Private key management

Blockchain's security model depends fundamentally on private keys – the cryptographic keys that authorise transactions on behalf of their holder. Private key management represents the primary operational security risk in blockchain deployments.

Private key loss/theft: The loss, theft, or compromise of a blockchain private key results in permanent, irrevocable loss of access to (and control over) all assets and authorisations associated with that key. Unlike a forgotten password, a lost private key cannot be reset or recovered.

Definition

- Permanent loss of assets: if the private key controlling a company's cryptocurrency holdings is lost or destroyed, those assets are permanently and irrecoverably inaccessible – a risk with no equivalent in traditional accounting.
- Theft enabling fraudulent transactions: if a private key is stolen by a malicious actor, they can sign blockchain transactions on behalf of the legitimate key holder – executing payments, transferring assets, or executing smart contracts without authorisation.
- Key custody and segregation of duties: best practice requires enterprise private key storage in hardware security modules (HSMs) with multi-signature requirements (multiple authorised parties required to sign any transaction) – equivalent to dual-signature controls for cheques.
- 51% attack risk: in public blockchain networks, a party controlling more than 50% of the network's computing power (PoW) or staked assets (PoS) could potentially manipulate transaction records. While economically infeasible for major public blockchains, this risk exists in smaller networks.

7.9 Future of blockchain in accounting

7.9.1 Integration with AI and FinTech

Blockchain and artificial intelligence are powerful in combination. Blockchain provides a trusted, immutable data foundation; AI provides the analytical intelligence to extract insight from that data. Together, they enable accounting systems that are simultaneously more transparent, more fraud-resistant, and more analytically capable than any existing technology.

- AI-powered smart contracts: AI models integrated with smart contract platforms can make more complex, context-sensitive financial decisions – moving beyond simple if-then rules to judgment-like assessments of contract compliance, performance, and risk.
- Autonomous audit agents: AI systems monitoring blockchain accounting records can identify anomalies, flag suspicious patterns, and generate continuous assurance reports – forming the backbone of automated internal audit functions.
- Predictive financial reporting: AI analysis of blockchain transaction data can generate forward-looking financial projections and risk assessments in real time, transforming the finance function from historical reporter to predictive strategist.
- CBDC integration: as Central Bank Digital Currencies are deployed, blockchain-based financial systems will interact directly with national monetary systems, creating new accounting and compliance challenges and opportunities.

Prokopenko et al. (2024) identify the convergence of blockchain, AI, and the Internet of Things (IoT) as the defining trajectory of financial accounting technology in the current decade. IoT devices recording physical events (goods delivery, asset condition, production output) on blockchain create verified real-world data inputs for AI-driven financial analysis – closing the gap between physical reality and financial record.

7.9.2 The role of accountants in blockchain-based systems

Blockchain does not eliminate the need for professional accountants – it transforms what accountants do. The following table maps traditional accounting activities to their blockchain-enabled evolution:

Traditional accounting activity	Blockchain-enabled evolution
Manual data entry and transaction recording	Automated blockchain recording – accountants focus on governance, exception handling, and system design.
Period-end reconciliation	Continuous, automatic reconciliation – accountants monitor dashboards and investigate flagged exceptions.
Periodic audit evidence gathering	Real-time blockchain audit access – auditors focus on smart contract logic review and risk assessment rather than document collection.
Compliance checking and regulatory reporting	Smart contract-automated compliance – accountants focus on designing and validating the rules encoded in smart contracts.
Financial statement preparation	Automated compilation from blockchain records – accountants focus on disclosures, estimates, and professional judgment items not captured by automated systems.
Fraud investigation	Exception analysis of blockchain anomalies – accountants apply professional scepticism to AI-flagged patterns rather than manually searching for fraud.

7.9.3 Skills required for future accounting professionals

The integration of blockchain into accounting creates specific skill requirements for the next generation of accounting professionals:

Skill area	Why it matters
Blockchain literacy	Understanding how blockchain works – distributed ledgers, hashing, consensus, smart contracts – at a conceptual level sufficient for governance, advisory, and audit oversight roles.
Smart contract understanding	Ability to review smart contract logic for compliance with intended accounting rules – critical for auditors and controllers in blockchain-enabled environments.
Cryptography basics	Sufficient understanding of public-key cryptography and hash functions to assess the security and integrity of blockchain-based accounting systems.
Digital asset accounting	Proficiency in applying current IFRS Standards to digital assets, plus awareness of emerging standard-setting developments – an active area of professional examination.
Blockchain governance and controls	Ability to design and evaluate internal controls for blockchain-based accounting systems – including private key management, smart contract authorisation, and node governance.
Data analytics	Ability to analyse and interpret large-scale blockchain transaction data using appropriate tools – essential for blockchain-enabled audit and management reporting.
Professional scepticism in digital environments	Maintained rigour in questioning automated outputs – the ability to challenge smart contract outputs, AI-generated analyses, and blockchain records when professional judgment suggests they may not reflect economic reality.

Prokopenko et al. (2024) conclude their analysis with the observation that 'the accountant of the future must be simultaneously a financial expert, a data analyst, and a technology governance professional – not because technology will replace accounting judgment, but because the environments in which that judgment must be exercised will be fundamentally digital.'

8. Understanding fintech technologies

8.1 Introduction to financial technology (FinTech)

Section summary

FinTech is technology-driven innovation in financial services, combining mobile, cloud, AI, big data, and cryptography to transform how finance is delivered. It has evolved through five phases into today's era of embedded and intelligent finance. Its seven branches – digital payments, blockchain/crypto, AI, robo-advisory, InsurTech, RegTech, and P2P lending – reshape accounting through cloud systems, real-time reporting, blockchain audit, fraud detection, and AI forecasting. Platforms like bKash show its power to drive financial inclusion. But FinTech also brings risks: cybersecurity, regulation, data privacy, tech dependency, and digital asset volatility. The accountant's role shifts from processor to technology-aware advisor – making digital fluency and judgement essential.

Defining FinTech

The term 'FinTech' is a portmanteau of 'Financial Technology'. While technology has always played a role in finance – from the mechanical adding machine to the first ATM in 1967 – the modern FinTech era is defined by the convergence of mobile connectivity, cloud computing, big data analytics, artificial intelligence, and cryptographic protocols, enabling fundamentally new ways of providing and consuming financial services.

FinTech: Technology-enabled innovation in financial services that can result in new business models, applications, processes, or products with an associated material effect on financial markets, institutions, and the provision of financial services (Financial Stability Board, 2019).

It is important to note that FinTech encompasses both: (i) new technology-driven entrants disrupting established financial institutions, and (ii) the adoption of new technologies by traditional banks, insurers, and accounting firms to improve their own services and operations. Both dimensions are directly relevant to accounting professionals.

Reference insight: Kou and Lu (2025) in their systematic review of FinTech literature identify seven principal domains of FinTech activity: digital payments, blockchain and cryptocurrencies, artificial intelligence, robo-advisory, InsurTech, RegTech, and peer-to-peer lending and crowdfunding. Each domain has distinct implications for accounting and financial management, which are explored in Section 2 of this chapter.

Evolution of financial technology

FinTech has not emerged overnight. Its development can be traced through five distinct phases:

Phase	Key Developments
Phase 1: Infrastructure (1960s–1980s)	Back-office computerisation of banking operations. Introduction of ATMs (Barclays Bank, UK, 1967). Electronic funds transfer (EFT) and SWIFT international payments network (1973). Credit card proliferation. Technology used to improve internal efficiency, not to disrupt business models.
Phase 2: Internet Finance (1990s–2000s)	World Wide Web enables online banking. PayPal founded (1998) – the first major FinTech disruptor. E-commerce drives demand for digital payments. Algorithmic trading emerges on equity markets. Financial data becomes digitised and accessible in real time.
Phase 3: Mobile and Platform Finance (2007–2014)	iPhone launch (2007) creates the smartphone economy. Mobile banking apps reach mass adoption. M-Pesa (Kenya, 2007) demonstrates mobile money for the unbanked. Bitcoin White Paper published by Satoshi Nakamoto (2008). App stores democratise financial tools. Peer-to-peer lending platforms emerge.
Phase 4: Disruptive FinTech (2015–2020)	FinTech investment reaches USD 135 billion globally by 2019. Blockchain pilots in banking, trade finance, and audit. Robo-advisors challenge traditional wealth management. RegTech addresses post-2008 regulatory burden. bKash transforms mobile payments in Bangladesh (15 million users by 2020). Open Banking APIs allow third-party access to bank data.
Phase 5: Embedded and Intelligent Finance (2021–present)	Embedded finance integrates financial services into non-financial platforms (e.g., buy-now-pay-later at retail checkout). Central Bank Digital Currencies (CBDCs) piloted in over 100 countries. Generative AI enters financial services. Decentralised Finance (DeFi) challenges traditional financial intermediaries. Financial inclusion reaches new frontiers through FinTech. Kou & Lu (2025) identify AI and blockchain convergence as the defining FinTech trend of the current phase.

Importance of FinTech in modern accounting and finance

FinTech is significant to accounting and finance professionals for three overarching reasons:

Transformation of core accounting processes

Cloud-based accounting platforms, AI-powered bookkeeping, blockchain-based audit trails, and automated regulatory reporting are directly replacing or augmenting traditional manual accounting procedures. Accountants who cannot navigate these systems will find their skills increasingly obsolete.

New accounting and reporting challenges

FinTech creates new accounting challenges: how are cryptocurrencies valued and disclosed? How are smart contract revenues recognised? What are the audit implications of blockchain records? How should FinTech companies' financial statements be prepared? These questions are emerging topics in accounting standard-setting and professional examinations.

Financial inclusion and development

In Bangladesh and other developing economies, FinTech is a primary driver of financial inclusion – extending banking, credit, insurance, and investment services to populations previously excluded from the formal financial system. This has profound implications for accounting in development finance, microfinance, and NGO accounting.

8.2 Branches of financial technology

Digital payments

Digital payments are the most mature and widely adopted dimension of FinTech. They encompass all electronic methods of transferring value between parties – replacing physical cash and cheques with digital equivalents.

Digital payment: Any transaction in which monetary value is transferred electronically between parties, including bank transfers, card payments, mobile payments, e-wallets, and payment gateways.

Mobile financial service (MFS): A financial service – such as payments, transfers, or savings – delivered via a mobile phone, enabling access for populations without conventional bank accounts.

Payment gateway: A technology platform that authorises and processes digital payment transactions between buyers and sellers, serving as the connection between a merchant's systems and the payment network.

Key digital payment technologies include:

- Mobile wallets: applications that store payment credentials and enable contactless or in-app payments (Apple Pay, Google Pay, bKash, Nagad, Rocket in Bangladesh).
- Real-time gross settlement (RTGS): central bank-operated systems enabling immediate, irrevocable large-value electronic transfers.
- QR code payments: widely adopted in Bangladesh through the BEFTN (Bangladesh Electronic Funds Transfer Network) and merchant payment systems.
- Buy Now, Pay Later (BNPL): short-term interest-free credit embedded at the point of sale, growing rapidly in retail and e-commerce.
- Central Bank Digital Currencies (CBDCs): sovereign digital currencies issued by central banks (e.g., Bangladesh Bank's ongoing CBDC feasibility study; the digital yuan in China).

bKash: Digital Payments and Financial Inclusion in Bangladesh

bKash, a BRAC Bank subsidiary, was founded in 2011 as Bangladesh's first mobile financial service. By 2024, it had grown to over 67 million registered accounts, processing billions of transactions annually including person-to-person transfers, salary disbursement, utility bill payments, and merchant payments.

From an accounting perspective, bKash illustrates several FinTech challenges: the reconciliation of millions of micro-transactions daily; the need for real-time financial reporting to Bangladesh Bank; and the accounting treatment of agent commissions, float income, and transaction fees under IFRS Standards.

For auditors, bKash requires specialised audit procedures: data analytics to test 100% of transactions, evaluation of mobile money float controls, and assessment of the completeness and accuracy of revenue recognition across diverse transaction types.

Kou & Lu (2025) highlight mobile payment platforms in emerging markets as one of the most significant drivers of financial inclusion in the FinTech literature, noting their role in reaching the previously unbanked population.

Blockchain and cryptocurrencies

Blockchain is a foundational technology with implications across accounting, audit, and financial reporting. A blockchain is a distributed, decentralised ledger that records transactions in chronological blocks, linked cryptographically to form a tamper-evident chain.

Accounting implications of blockchain include:

- Triple-entry accounting: blockchain enables a shared transaction record between buyer, seller, and their accountants – potentially transforming the traditional double-entry bookkeeping model.
- Real-time audit: immutable blockchain records create a permanent, verifiable audit trail without reliance on paper documents.
- Cryptocurrency accounting: IFRS does not currently have a specific standard for cryptocurrencies. IAS 38 (Intangible Assets) typically applies – cryptocurrencies held as investments are measured at cost less impairment (or at fair value under IAS 2 if held as inventory by traders). Significant judgment is required.
- Smart contract revenue recognition: automatic execution of payment upon delivery creates novel questions for the timing of revenue recognition under IFRS 15.

Artificial intelligence in finance

Artificial Intelligence in financial contexts is covered comprehensively in Chapter 16 of this workbook. In the FinTech context, AI serves as a horizontal enabler – enhancing the capabilities of every other FinTech domain, from fraud detection in payments to risk modelling in lending and claim processing in InsurTech.

Key AI applications in financial services include machine learning-driven credit scoring, natural language processing for contract analysis, deep learning for fraud pattern recognition, and predictive analytics for cash flow forecasting. Students should cross-reference Chapter 16 for detailed treatment of these applications.

Robo-advisory and wealth management

Robo-advisors are automated digital investment platforms that provide algorithm-driven financial planning and portfolio management services with minimal human intervention. They represent a significant disruption to the traditional wealth management and financial advisory industry.

Robo-advisor: An automated digital platform that uses algorithms and AI to provide investment advice, portfolio construction, and ongoing portfolio rebalancing, typically at a fraction of the cost of a human financial advisor.

The robo-advisory process typically works as follows:

- The client completes an online risk tolerance and financial goals questionnaire.
- An algorithm maps the client's profile to an optimal asset allocation strategy.
- The platform automatically invests the client's funds in a diversified portfolio (typically using low-cost exchange-traded funds, or ETFs).
- The portfolio is automatically rebalanced as market movements shift the allocation away from the target.
- Tax-loss harvesting features optimise the tax position of the portfolio by strategically realising losses.

Accounting implications: robo-advisory platforms generate high volumes of investment transactions requiring reconciliation, valuation, and tax reporting. Accountants advising high-net-worth clients need to understand robo-advisory fee structures, performance reporting, and the tax implications of automated trading.

Betterment and the robo-advisory revolution

Betterment, founded in 2010 in the United States, was among the first robo-advisors to achieve significant scale, managing over USD 45 billion in assets by 2024 with annual management fees of just 0.25% – compared with 1–2% for traditional human advisors.

For accounting students: a Betterment client's annual tax reporting involves hundreds of individual buy and sell transactions, dividend reinvestments, and potentially complex tax-loss harvesting positions across multiple asset classes. Accountants advising such clients must understand the platform's data export capabilities and the applicable tax treatment of each transaction type.

In Bangladesh, platforms such as the Dhaka Stock Exchange's digital trading platform and emerging robo-advisory services represent an early stage of this revolution in the local context.

InsurTech (insurance technology)

InsurTech: The application of technology – including AI, IoT (Internet of Things), big data analytics, and blockchain – to disrupt and improve the insurance industry, from product design and underwriting to claims processing and customer service.

InsurTech applications relevant to accounting include:

- Usage-based insurance (UBI): motor insurance premiums calculated in real time based on actual driving behaviour collected via telematics devices – requiring new approaches to premium accrual and revenue recognition.
- Parametric insurance: policies that pay out automatically when a pre-defined trigger event occurs (e.g., an earthquake above a certain magnitude) without requiring a claims assessment – simplifying accounting for insurance payables.
- Automated claims processing: AI systems that assess and approve routine claims without human review – reducing claims processing costs and enabling faster settlement.
- Peer-to-peer insurance: groups of policyholders pool premiums to cover shared risks, with any unclaimed pool returned to members – creating novel accounting treatment questions for premium pools and unclaimed reserves.

For accountants working with insurance companies, understanding InsurTech is essential for applying IFRS 17, Insurance Contracts, which requires sophisticated measurement of insurance liabilities using current estimates and discount rates.

RegTech (regulatory technology)

RegTech is one of the fastest-growing FinTech domains, driven by the exponential growth of financial regulation following the 2008 global financial crisis. It encompasses technologies that help financial institutions comply with regulation efficiently, accurately, and at scale.

RegTech: The use of technology – particularly AI, cloud computing, big data analytics, and blockchain – to help financial services firms comply with regulatory requirements more efficiently, cost-effectively, and accurately.

Principal RegTech applications:

- KYC and AML automation: AI-powered Know Your Customer and Anti-Money Laundering tools that automatically screen customers, transactions, and counterparties against sanctions lists, adverse media, and risk models – replacing time-consuming manual processes.
- Regulatory reporting automation: tools that extract financial data, apply reporting rules, and generate regulatory returns (e.g., Bangladesh Bank reports, VAT returns, income tax filings) automatically.
- Transaction monitoring: real-time surveillance systems that flag suspicious transactions for regulatory investigation.
- Audit trail management: systems that maintain immutable records of all regulated activities, supporting internal audit and regulatory inspections.
- Policy and risk management: platforms that map regulatory requirements to internal policies and monitor compliance status across the organisation.

Peer-to-peer (P2P) lending and crowdfunding

P2P lending: A form of direct lending that connects individual or institutional borrowers with lenders via an online platform, bypassing traditional banks and enabling potentially lower borrowing costs and higher lending returns.

Crowdfunding: Raising capital from a large number of individuals, typically via an online platform, in exchange for rewards (reward crowdfunding), equity (equity crowdfunding), or interest-bearing loans (debt crowdfunding).

P2P lending and crowdfunding platforms create specific accounting challenges:

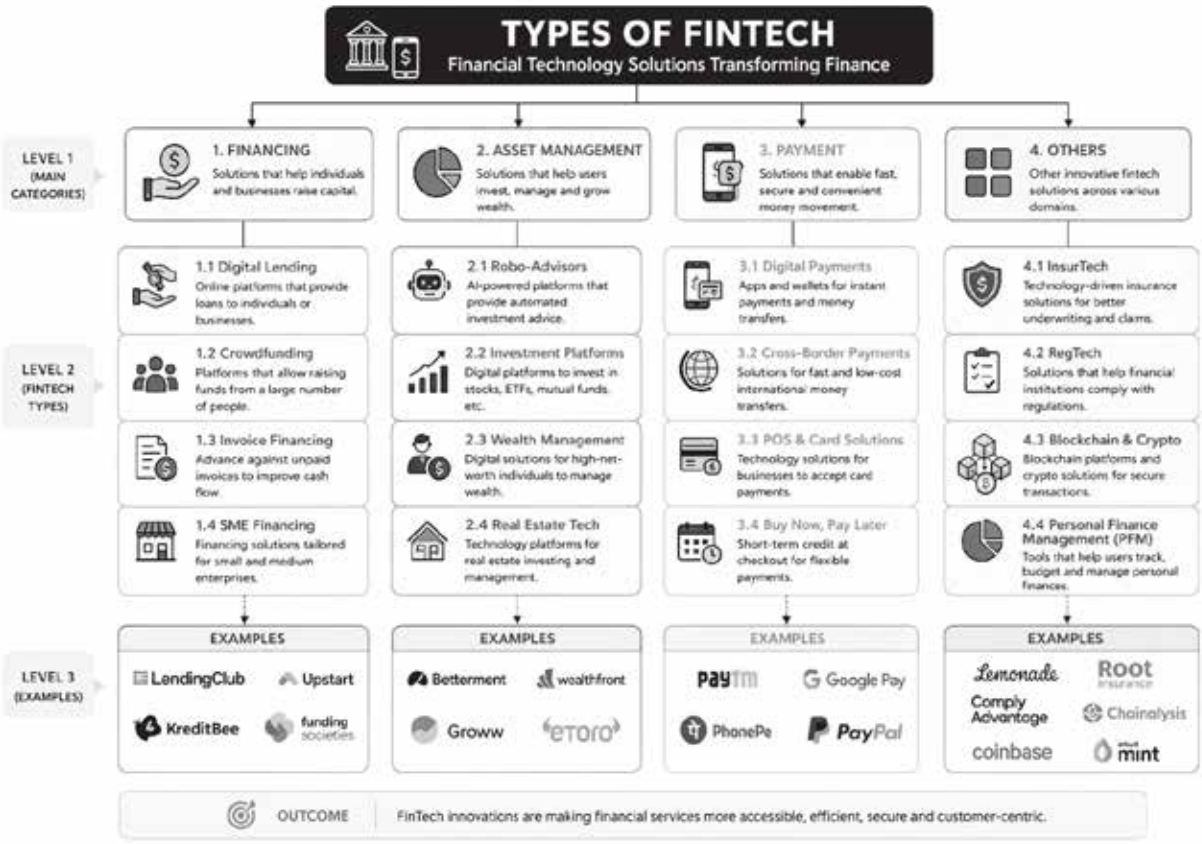
- Loan impairment: lenders must assess the expected credit losses on their P2P loan portfolios in accordance with IFRS 9, Financial Instruments. The credit risk assessment methodologies of P2P platforms vary widely.
- Revenue recognition: platform fee income must be recognised in accordance with IFRS 15, which requires careful analysis of performance obligations and the timing of fee recognition.
- Accounting for equity crowdfunding: investors receiving equity in exchange for crowdfunding contributions receive shares that must be valued at fair value, often in entities without active market prices.
- Regulatory treatment: in Bangladesh, P2P lending platforms are subject to Bangladesh Bank oversight under the FinTech regulatory framework, affecting financial statement disclosures.

Funding circle – P2P business lending

Funding Circle, founded in the UK in 2010, is one of the world's largest P2P business lending platforms, having facilitated over GBP 15 billion in loans to small businesses in the UK, US, and Germany.

For accountants advising clients who have borrowed through Funding Circle: loan accounting under IFRS 9 requires recognition of the liability at amortised cost using the effective interest method. The effective interest rate must be calculated based on all contractual cash flows, including any platform origination fees, which may differ from the headline interest rate shown on the platform.

For accountants advising clients who have invested in Funding Circle loans: each loan constitutes a financial asset under IFRS 9. An expected credit loss provision must be calculated using a forward-looking model, considering historical default rates, macroeconomic forecasts, and the borrower's financial health



8.3 Applications of FinTech in accounting and finance

Automated accounting systems and cloud accounting

Cloud accounting represents perhaps the most transformative FinTech application for the day-to-day work of practising accountants. Cloud accounting systems are accounting software hosted on remote servers and accessed via the internet rather than installed locally on individual computers.

Cloud accounting: An accounting software model in which financial data is stored on remote servers and accessed via the internet, enabling real-time multi-user access, automatic software updates, and integration with other business systems and financial institutions.

Key capabilities of cloud accounting platforms:

- Automated bank feeds: direct connection between the accounting system and the entity's bank account, importing transactions automatically and matching them to existing accounting records – eliminating manual data entry.
- AI-powered transaction coding: automatic classification of imported transactions based on machine learning from historical patterns (see Chapter 16 for detailed treatment).
- Multi-currency: automatic conversion of foreign currency transactions using live exchange rates, with revaluation at period-end.
- Integration ecosystem: APIs connecting the accounting platform to payroll, e-commerce, inventory management, CRM, and payment gateway systems – creating a fully integrated financial data environment.
- Anywhere access: finance teams, accountants, and clients can access real-time financial data from any device, from any location.

Cloud accounting transformation – a bangladeshi manufacturing company

A mid-sized garments manufacturer in Dhaka had been using legacy desktop accounting software requiring manual data entry by five accounts staff. After migrating to a cloud accounting platform integrated with their bank (BRAC Bank), e-commerce portal (Daraz), and payroll system, the following outcomes were achieved:

Data entry work reduced by 70%, freeing two accounting staff to focus on financial analysis and management reporting. Bank reconciliation (previously a two-day monthly exercise) became automated and continuous. The external auditor accessed the accounting platform directly during audit fieldwork, eliminating the need to request and transmit data files. Management received real-time financial dashboards on their mobile phones.

Accounting consideration: the migration of financial data to a cloud platform raises questions of data security, data ownership, and the auditability of system-generated journal entries – all areas requiring professional accountant involvement.

Real-time financial reporting

Traditional financial reporting operates on a periodic basis – monthly management accounts, quarterly reporting, and annual financial statements. FinTech enables a paradigm shift toward continuous financial reporting, where financial data is available in real time.

- Management dashboards: cloud accounting and ERP systems provide live financial KPIs – revenue, costs, cash position, accounts receivable ageing – viewable at any time on any device.
- Integrated Business Reporting (IBR): connected data systems that combine financial and non-financial data (e.g., sustainability metrics, operational KPIs) in a single reporting environment.
- XBRL (Extensible Business Reporting Language): a digital reporting standard that enables financial statements to be machine-readable – facilitating automated analysis by regulators, investors, and analysts. Bangladesh's BSEC has mandated XBRL filing for listed companies.
- Continuous close: as transactions are recorded automatically throughout the period, the traditional month-end and year-end close processes are compressed significantly.

Blockchain-based auditing and transparency

Blockchain's core properties — immutability, transparency, and distributed verification — have profound implications for the audit profession. Transactions recorded on a blockchain cannot be altered retroactively without invalidating all subsequent blocks, creating an inherently tamper-evident audit trail.

Fraud detection and risk management

FinTech-powered fraud detection combines machine learning, real-time transaction monitoring, and behavioural analytics to identify and prevent financial fraud at a scale and speed impossible for human analysts. This application overlaps with the AI-in-finance discussion in Chapter 16, but is examined here specifically in the FinTech payments and banking context.

- Card fraud detection: ML models score every card transaction in milliseconds against the cardholder's normal spending patterns, blocking anomalies in real time. Visa's Decision Intelligence system prevents an estimated USD 25 billion in fraud annually.
- Account takeover prevention: behavioural biometrics (typing patterns, mouse movements, device fingerprints) identify when a genuine customer's account is being accessed by a fraudster — even if the correct password is entered.
- AML transaction monitoring: ML models identify complex money laundering patterns — structuring, layering, circular transactions — across millions of accounts simultaneously.
- Insider fraud detection: AI tools monitor employee behaviour patterns in financial systems, flagging unusual access, unusual transaction approval patterns, or unusual changes to supplier payment details.

For accountants and internal auditors, understanding the FinTech fraud detection tools deployed by their organisations is increasingly a component of IT audit and internal control evaluation.

Digital payments and reconciliation

The proliferation of digital payment channels — bank transfers, card payments, mobile wallets, QR codes, online payment gateways — creates significant accounting challenges around reconciliation. Each payment channel generates separate transaction records that must be reconciled with the accounting system.

FinTech solutions address this through:

- Payment aggregator APIs: single integrations that consolidate transaction data from multiple payment channels into one data feed for the accounting system.
- Automated reconciliation tools: AI-powered reconciliation software that matches payment data to invoices, sales records, and ledger entries — handling the complex many-to-many matching that manual reconciliation struggles with.
- Virtual bank accounts: unique payment references automatically assigned to each customer or invoice, enabling automatic identification and allocation of incoming payments.
- Real-time settlement: instant payment systems (e.g., Bangladesh Bank's BEFTN Instant Payment) settle transactions immediately, eliminating the timing differences that create reconciling items.

AI-driven financial analysis and forecasting

FinTech platforms combine AI with real-time financial data to deliver financial analysis and forecasting capabilities that were previously only available to large organisations with dedicated quantitative teams.

- Cash flow forecasting: platforms such as Fluidly, Float, and Dryrun analyse historical cash flow patterns, integrate accounts receivable and payable data, and generate rolling 13-week cash flow forecasts automatically – a critical tool for SME financial management.
- Scenario modelling: AI financial planning tools generate multiple financial scenarios simultaneously, quantifying the financial impact of strategic decisions such as new product launches, market entries, or financing arrangements.
- Credit risk assessment: alternative credit scoring models use non-traditional data sources – mobile payment history, social media activity, supply chain transaction records – to assess creditworthiness for borrowers without traditional credit histories.
- Market intelligence: NLP tools scan news, analyst reports, regulatory announcements, and social media to generate real-time sentiment scores and financial risk signals.

Kou & Lu (2025) research insight: The literature review identifies AI-driven credit risk assessment as one of the most significant FinTech advances for financial inclusion, particularly in emerging markets where large portions of the population lack traditional credit histories. Machine learning models trained on alternative data sources have demonstrated lower default rates than traditional credit bureau models for previously unscored borrowers, according to multiple studies reviewed by Kou and Lu.

8.4 Challenges and risks of FinTech

Cybersecurity risks

FinTech's fundamental characteristic – the digitisation of financial value and financial data – makes it an inherently attractive target for cybercriminals. The cyber risk landscape for FinTech-enabled accounting and finance is both broad and rapidly evolving.

Categories of cybersecurity risk

- Data breaches: unauthorised access to financial data held in cloud accounting systems or FinTech platforms, exposing customer financial information and business secrets.
- Ransomware: malicious software that encrypts organisational data and demands payment for decryption – a particularly devastating attack for organisations whose financial operations depend on cloud systems.
- Payment fraud: social engineering attacks (e.g., business email compromise, authorised push payment fraud) that manipulate employees into initiating fraudulent payments from digital banking platforms.
- API vulnerabilities: open banking APIs and FinTech integrations create new attack surfaces through which malicious actors can access financial systems via third-party platforms.
- Cryptojacking: malware that hijacks computing resources to mine cryptocurrency – degrading system performance and creating liability if organisational resources are c ompromised.

Scale of the challenge: The global cost of cybercrime is estimated to reach USD 10.5 trillion annually by 2025 (Cybersecurity Ventures). Financial services firms experience 300 times more cyberattacks than other industries. For accountants, cybersecurity is not just an IT concern – it is a financial risk, a governance risk, and an accounting risk (costs of breaches, impact on going concern, disclosure requirements).

Regulatory compliance issues

FinTech operates at the intersection of financial regulation, data protection law, consumer protection, and in some cases securities law. The regulatory landscape is complex, fragmented, and evolving rapidly – creating significant compliance challenges.

- Jurisdictional complexity: FinTech platforms operating across multiple countries face different, often conflicting regulatory requirements in each jurisdiction. A payment platform operating in Bangladesh, India, and the UK simultaneously faces the requirements of Bangladesh Bank, the Reserve Bank of India, and the UK's Financial Conduct Authority.
- Regulatory ambiguity: novel FinTech products – particularly DeFi, stablecoins, and certain P2P lending models – operate in regulatory grey areas where the applicable rules are uncertain or actively contested.
- Pace of regulatory change: FinTech regulations are changing rapidly globally. Keeping pace with regulatory developments requires dedicated compliance resources.
- Licensing requirements: many FinTech activities require specific licences (e.g., payment service provider licences, e-money issuer licences, investment advisory licences) that impose ongoing compliance obligations and capital requirements.

In Bangladesh, Bangladesh Bank has established a FinTech regulatory framework including the Payment Service Provider (PSP) and Payment System Operator (PSO) licensing regime. Accountants advising FinTech startups must understand these licensing requirements and their financial implications.

Data privacy concerns

FinTech systems process vast quantities of sensitive personal and financial data. Data privacy requirements impose significant obligations on organisations that collect, process, store, and share this data.

- Legal basis for processing: organisations must identify a legal basis (e.g., consent, contractual necessity, legitimate interest) for each category of personal financial data they process.
- Data retention: financial data must be retained for regulatory purposes (typically 5–7 years) but also must be deleted when no longer required – creating tension between compliance and privacy obligations.
- Cross-border data transfers: international FinTech operations must comply with data localisation requirements that restrict the transfer of personal financial data across national borders.
- Data subject rights: individuals have rights to access, correct, and in some cases delete their financial data – requiring FinTech platforms to build processes for handling these requests.
- Third-party data sharing: open banking APIs share customer financial data with third-party applications – raising questions about consent, data security, and liability in the event of a breach.

Technology dependency and system risk

As financial operations become increasingly dependent on FinTech platforms and cloud services, the risk of technology failure carries escalating financial consequences.

- System outages: cloud accounting platform outages prevent staff from accessing financial records or processing transactions, potentially causing significant financial and reputational damage. Major cloud providers (AWS, Azure, Google Cloud) have all experienced significant outages in recent years.

- Vendor concentration risk: the widespread adoption of a small number of dominant FinTech platforms creates systemic risk – a failure of a single major cloud accounting provider could affect thousands of accounting firms and businesses simultaneously.
- Vendor lock-in: migration from one FinTech platform to another can be expensive and complex, reducing the ability to switch if a vendor's service deteriorates.
- Skills erosion: over-reliance on FinTech automation may degrade the underlying accounting skills needed to identify errors in automated outputs or to operate when systems are unavailable.

Volatility in digital assets

Cryptocurrencies and other digital assets present specific accounting, valuation, and risk management challenges arising from their extreme price volatility.

Accounting challenges

- Fair value measurement: cryptocurrency prices fluctuate dramatically (Bitcoin has experienced intraday price movements of over 20%), making fair value measurement at any particular date a significant accounting judgment.
- Absence of specific IFRS Standard: IFRS does not currently have a specific standard for cryptocurrency accounting. The IASB issued IFRS 10 (IAS 38 for most holders) guidance, but practice remains diverse. The IASB published an agenda decision in June 2019 confirming IAS 38 as the applicable standard for most cryptocurrency holders, but has not issued a comprehensive standard.
- Going concern implications: organizations with significant cryptocurrency holdings may face going concern questions if the value of those holdings falls materially – requiring careful disclosure.
- Tax treatment: the tax treatment of cryptocurrency gains and losses varies significantly between jurisdictions and is evolving rapidly.

Entity risk management

For organisations that accept cryptocurrency as payment or hold digital assets on their balance sheets, robust risk management policies are required, covering: acceptable digital assets, maximum holding limits, hedging strategies, and segregation of duties for digital asset custody.

Professional skills focus – applying judgement

1. Know the Landscape. Understand all seven FinTech branches to advise effectively.
2. Apply IFRS to Novel Products. Crypto, smart contracts, and P2P loans need careful judgement under IAS 38, IFRS 9, 15, and 17.
3. Reconcile in Real Time. Multi-channel payments demand automated reconciliation.
4. Treat Cyber as Financial Risk. Not just an IT issue.
5. Navigate Regulation. Track licensing and cross-border rules.
6. Protect Data Privacy. Balance retention, deletion, and consent.
7. Manage Tech Dependency. Plan for outages and vendor lock-in.
8. Judge Digital Asset Volatility. Apply robust valuation and disclosure.

9. Big data

9.1 Introduction to big data

Definition of big data

Big Data is not simply 'a lot of data'. The term describes data environments that are so large, fast-moving, or structurally diverse that they challenge the capacity of traditional database technologies to collect, store, manage, and analyse – requiring new tools, architectures, and analytical approaches.

Big Data: Extremely large, fast-moving, or structurally diverse datasets that cannot be effectively captured, stored, managed, or analysed by conventional database and software tools – and that, when analysed appropriately, yield valuable insights for decision-making.

The concept was popularised by analyst Doug Laney in 2001, who defined it through three initial Vs – Volume, Velocity, and Variety. Subsequent researchers and practitioners have expanded this to five (adding Veracity and Value) and sometimes six or seven Vs, though the 5Vs framework remains the most widely accepted academic and professional standard. The ICBDC (2024) paper specifically uses the 5Vs framework in analysing Big Data's integration with Accounting Information Systems.

Evolution of data in accounting and business

Era	Data landscape in accounting
Manual era (pre-1950s)	All accounting records maintained in physical ledgers. Data volumes limited by human writing capacity. Analysis confined to aggregated totals. No automated processing. Errors corrected by hand with pen strokes.
Early computerization (1950s–1970s)	Mainframe computers enable batch processing of accounting transactions. Structured data in fixed-format files. Limited storage capacity forces data summarisation. Audit still primarily manual.
Database era (1980s–1990s)	Relational databases (Oracle, SQL Server) enable structured financial data storage and retrieval. ERP systems (SAP, Oracle) integrate accounting data across business functions. Spreadsheets (Lotus 1-2-3, Excel) democratise financial analysis.
Internet and ERP era (2000s)	Internet generates new data sources: web transactions, email, electronic documents. ERP systems accumulate years of transactional history. Data warehouses enable management reporting across multiple data sources. Volume begins to challenge traditional systems.
Big Data era (2010s–present)	Explosion of data from mobile, IoT, social media, and digital payments. Traditional databases cannot process data at required speed or scale. Cloud computing provides virtually unlimited storage and compute capacity. AI and ML enable analysis of previously unstructured data. ICBDC (2024) identifies this era as requiring a complete reconceptualisation of Accounting Information Systems design.

Importance of big data in modern finance and accounting

From historical recording to predictive intelligence

Traditional accounting systems are fundamentally backward-looking – they record what has already happened and summarise it for users. Big Data analytics enables accounting information systems to become forward-looking: predicting future financial performance, identifying emerging risks before they materialise, and recommending optimal courses of action.

Transforming the information base of accounting

Traditional accounting systems process structured financial data – numbers in defined formats: amounts, dates, account codes. Big Data expands the information base of accounting to include: unstructured text (emails, contracts, management commentary), social media sentiment, geographic and satellite data, IoT sensor readings, voice recordings, and video – all of which can provide material information about an entity's financial performance and position.

The AIS dimension

ICBDC (2024) finding: The paper identifies Big Data as requiring a fundamental redesign of Accounting Information Systems architecture. Traditional AIS designs – based on structured transaction data, periodic processing cycles, and single-source reporting – are inadequate for the volume, velocity, and variety of data that organisations now generate. Next-generation AIS must be designed around real-time, multi-source, multi-format data ingestion and continuous analytics.

9.2 How big data works

The 5Vs of big data

The 5Vs framework provides the conceptual foundation for understanding what makes data 'big' and what challenges and opportunities it presents for accounting and finance. The ICBDC (2024) paper uses the 5Vs as the organising framework for its analysis of Big Data integration with AIS.

The V	Description and Example	Accounting and Finance Relevance
Volume	Scale of data generated A global bank processes over 1 billion transactions daily. Bangladesh's bKash processes millions of micro-transactions every hour.	Accounting relevance: Financial databases, transaction logs, historical account records spanning decades.
Velocity	Speed of data generation and processing Stock exchanges process millions of trades per second. Credit card fraud must be detected within 50 milliseconds of transaction initiation.	Accounting relevance: Real-time fraud detection, instant payment verification, live financial dashboards.
Variety	Diversity of data types and formats Financial data now includes: structured (transaction records, balance sheets), semi-structured (emails, XML financial reports), and unstructured (social media sentiment, news articles).	Accounting relevance: AIS must now process invoices, contracts, audio notes, satellite imagery for commodity forecasting.

Veracity	Trustworthiness and accuracy of data 30% of customer data in typical CRM systems is estimated to be inaccurate. In accounting, data veracity failures cause misstatements, compliance failures, and fraudulent reporting.	Accounting relevance: Data validation controls in AIS ensure the accuracy and reliability of financial information reported.
Value	Business value extracted from data Amazon generates an estimated USD 100 billion in additional annual revenue from Big Data-driven product recommendations – data with no inherent monetary value converted into commercial value.	Accounting relevance: Predictive analytics generating actionable financial forecasts; fraud detection models saving billions in loss prevention.

Data sources for accounting and finance

The data inputs available to modern accounting and financial analysis far exceed the traditional transaction ledger. Understanding the diversity of data sources is essential for designing effective Big Data accounting systems.

Data source category	Examples	Data type	Accounting application
Transactional / ERP data	Purchase orders, invoices, payments, payroll, GL journal entries	Structured	Core financial records, reconciliation, audit trails
Banking and payment data	Bank statements, card transaction feeds, mobile payment data	Structured	Cash management, fraud detection, reconciliation
Social media data	Twitter/X sentiment, LinkedIn hiring activity, Facebook advertising spend	Unstructured	Revenue forecasting, brand valuation, ESG indicators
IoT and sensor data	Smart meter energy data, GPS vehicle tracking, inventory RFID tags	Semi-structured	ESG reporting, asset utilisation, inventory management
Financial market data	Stock prices, exchange rates, commodity prices, credit spreads	Structured / time-series	Fair value measurement, hedging, investment portfolios
Regulatory and public data	Tax filings, company registrations, court records, land registry	Structured	Compliance monitoring, counterparty due diligence
Contracts and legal documents	Loan agreements, lease contracts, supplier agreements	Unstructured (NLP)	Lease accounting (IFRS 16), revenue recognition (IFRS 15)
News and media	Financial news, analyst reports, management interviews	Unstructured	Risk assessment, going concern evaluation, fraud indicators

Data collection and storage

Data warehouses

Data warehouse: A centralised repository that stores structured, processed data from multiple sources, optimised for analytical queries and reporting. Data is cleaned, transformed, and loaded (ETL process) before storage. Designed for historical analysis and business intelligence.

Data warehouses are the traditional approach to centralising financial data for analysis. They excel at structured financial data – general ledger transactions, trial balances, consolidated group data – and support the management reporting and analytical tools that finance teams use. Major accounting software systems (SAP BW, Oracle Warehouse) are built around the data warehouse model.

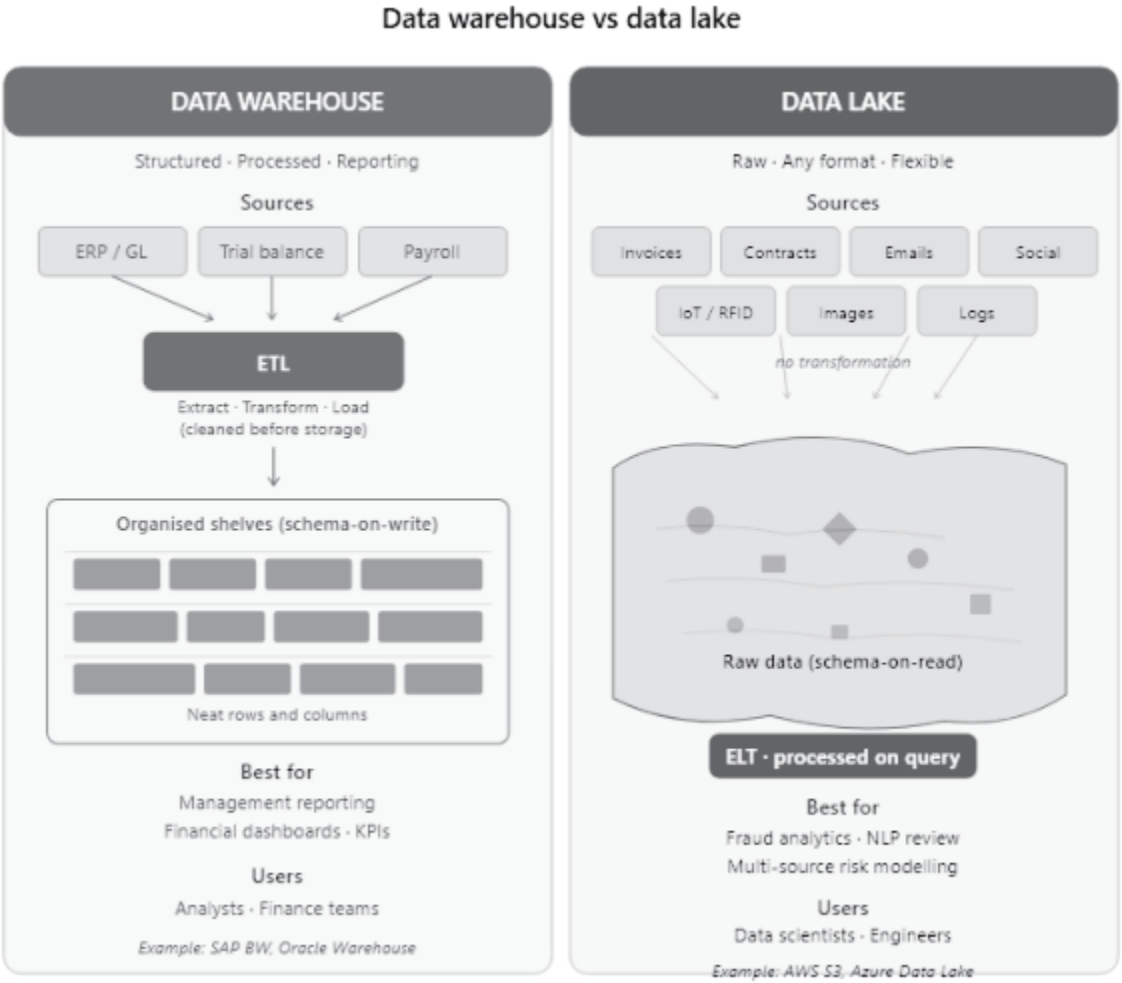
Data lakes

Definition

Data lake: A large-scale storage repository that holds raw data in its native format – structured, semi-structured, and unstructured – until it is needed for analysis. Unlike a data warehouse, data is not processed or structured before storage, enabling greater flexibility but requiring more sophisticated governance.

Data lakes can store financial data alongside non-financial data – contracts, emails, social media feeds, sensor data – enabling the multi-source analysis that Big Data accounting requires. Cloud providers (AWS S3, Azure Data Lake, Google Cloud Storage) have made data lake infrastructure economically accessible to organisations of all sizes.

Dimension	Data Warehouse vs Data Lake
Data type	Data warehouse: structured only. Data lake: structured, semi-structured, and unstructured.
Processing	Data warehouse: processed and transformed before storage (ETL). Data lake: raw data stored, processed on query (ELT).
Users	Data warehouse: business analysts, finance teams. Data lake: data scientists, data engineers, advanced analysts.
Accounting use case	Data warehouse: management reporting, financial dashboards, KPI tracking. Data lake: fraud pattern analysis, NLP contract review, multi-source risk modelling.
Bangladesh examples	Warehouse: DBL Group's SAP BW consolidation platform. Lake: bKash's transaction analytics environment processing billions of unstructured transaction records.



Data processing: batch VS. real-time

Batch processing: Processing large volumes of data at scheduled intervals – for example, nightly payroll calculation, monthly management account generation, or end-of-day reconciliation. All data collected during the period is processed in one operation.

Batch processing:
Data generated --> Accumulated during period --> Processed in bulk at scheduled time --> Output
Example: Month-end close; payroll run; quarterly tax computation
Suitable for: high-volume, non-time-sensitive accounting processes

Real-time (stream) processing: Processing data continuously as it is generated, enabling immediate analysis and response. Required for fraud detection, live financial dashboards, and instant payment verification.

Real-time (stream) processing:
Data generated --> Immediately processed as it arrives --> Instant output / action
Example: Payment fraud detection; live cash balance; real-time audit monitoring
Suitable for: time-sensitive financial controls and monitoring

Data analytics: From descriptive to prescriptive

The four levels of analytics represent a spectrum from describing what has happened to recommending what should be done. Each level adds analytical sophistication and business value. The ICBDC (2024) paper identifies predictive analytics as the level with the highest current impact on accounting information systems.

Analytics Type	Key Question	How It Works	Accounting Application
Prescriptive Analytics	What should we do?	Recommends optimal courses of action. Uses optimisation algorithms, simulation, and AI. Most advanced and most valuable.	Automated cash allocation recommendations; AI-driven tax planning; optimal audit sample selection; treasury optimisation.
Predictive Analytics	What will happen?	Forecasts future outcomes using statistical models and ML. Uses historical patterns to predict future events with probability estimates.	Cash flow forecasting; credit default prediction; revenue projection; audit risk scoring; budget variance prediction.
Diagnostic Analytics	Why did it happen?	Identifies causes of past events. Drills down into data to find root causes of anomalies, variances, or trends.	Budget variance analysis; fraud root cause investigation; identification of drivers behind unusual financial ratios.
Descriptive Analytics	What happened?	Summarises historical data to understand what occurred. Foundation level of analytics – most commonly used today.	Financial statements; management accounts; KPI dashboards; transaction reports; ageing schedules.

Note the progression: most organisations today operate primarily at the descriptive and diagnostic levels – understanding and explaining historical performance. Big Data technologies enable the shift to predictive and prescriptive analytics – a fundamental transformation in the value that accountants can add to their organisations.

Big data tools and technologies

Tool / Technology	Role in Big Data accounting
Apache Hadoop	Open-source framework for distributed storage and processing of very large datasets. Stores data across multiple servers (HDFS) and processes it in parallel (MapReduce). Enables processing of datasets too large for single servers. Used for batch processing of large financial datasets.
Apache Spark	In-memory data processing engine – up to 100x faster than Hadoop for certain tasks. Supports real-time stream processing as well as batch. Increasingly preferred for financial analytics requiring fast iterative computation (ML model training, real-time fraud scoring).
SQL / NoSQL Databases	SQL databases (structured, relational) handle traditional financial transaction data. NoSQL databases (MongoDB, Cassandra) handle unstructured and semi-structured financial data at scale – social media, IoT, document stores.
Cloud Platforms (AWS, Azure, GCP)	Provide scalable, pay-per-use infrastructure for Big Data storage and processing. Eliminate the need for large upfront infrastructure investment. Enable accounting firms to access Big Data capabilities without building their own data centres.
Data Visualisation (Tableau, Power BI)	Transform processed financial data into visual dashboards, charts, and interactive reports. Enable non-technical finance professionals to explore Big Data insights. Power BI integrates directly with Excel and Microsoft Dynamics – widely used in accounting.
Python and R	Programming languages used by data analysts for statistical modelling, ML, and custom analytics. Python libraries (Pandas, NumPy, Scikit-learn) are increasingly used in audit analytics and financial modelling. Basic Python proficiency is an emerging competency for senior accountants.

9.3 Components of the big data ecosystem

Data ingestion

Data ingestion is the process of collecting data from diverse sources and bringing it into the Big Data ecosystem for storage and processing. It is the entry point of the pipeline and one of the most critical stages for data quality.

- Batch ingestion: data is collected and loaded at scheduled intervals. Example: nightly loading of ERP transaction data into a data warehouse for management reporting.
- Real-time (streaming) ingestion: data is ingested continuously as it is generated. Example: payment transaction data streamed in real time to a fraud detection system. Apache Kafka is the most widely deployed streaming ingestion platform.
- API-based ingestion: data is pulled from external systems via APIs. Example: bank statement data ingested via Open Banking APIs directly into cloud accounting platforms.
- File-based ingestion: data extracted from legacy systems as flat files (CSV, XML, JSON) and loaded into the ecosystem. Most common method for integrating older financial systems with Big Data platforms.

Data quality issues arise primarily at the ingestion stage: incomplete records, format inconsistencies, duplicate data, and incorrect encoding. A comprehensive data governance framework must address these risks at ingestion to prevent low-quality data propagating through the pipeline.

Data storage

The storage layer holds both raw and processed data in formats appropriate for the analytical uses to which it will be put. Modern Big Data accounting environments typically use a combination of storage technologies:

- Structured data stores (SQL databases, data warehouses): for financial transaction records, trial balances, and management reporting datasets where structured queries are required.
- Semi-structured stores (document databases like MongoDB): for JSON-formatted financial documents, contract data, and API responses where schema flexibility is required.
- Unstructured stores (data lakes): for raw documents, images, audio, and other unstructured financial data awaiting processing and analysis.
- Archive storage (cold storage): for historical financial data required for compliance and audit trail purposes but rarely accessed – stored at very low cost in cloud archive tiers.

Data processing

The processing layer transforms raw ingested data into a form suitable for analytics. Key processing activities in an accounting Big Data environment include:

- Data cleaning: identifying and correcting errors, inconsistencies, and missing values in raw financial data.
- Data transformation: converting data from its source format into the standardised format required by the analytics layer. Example: converting foreign currency transactions to functional currency using live exchange rates.
- Data enrichment: augmenting financial data with additional information from external sources. Example: enriching payment transaction data with merchant category codes and geographic information to support fraud analytics.
- Aggregation: summarising detailed transaction data into higher-level analytical datasets. Example: aggregating daily transaction data to monthly totals for management reporting.
- Feature engineering: creating new analytical variables from raw data for use in ML models. Example: creating a 'payment velocity' variable from individual transaction timestamps to support fraud detection.

Data analytics and visualisation

The analytics and visualisation layer is where raw data is converted into actionable financial insight – the ultimate purpose of the entire Big Data ecosystem. The four analytics types (introduced in Section 2.5) operate at this stage, supported by visualisation tools that communicate insights to decision-makers.

Visualisation in accounting contexts

Effective data visualisation is a critical professional skill for modern accountants. The ability to design, interpret, and communicate financial dashboards, charts, and interactive reports is increasingly expected of finance professionals at all levels.

- Financial dashboards: real-time displays of key financial KPIs – revenue, costs, cash position, budget variance – updated continuously from the data processing layer.
- Trend analysis charts: time-series visualisations of financial performance metrics enabling identification of patterns, seasonal effects, and emerging risks.
- Anomaly heat maps: visual representations of transaction data highlighting outliers and unusual patterns for audit and fraud investigation.

- Geographic financial analysis: maps visualising financial data by region, country, or location – increasingly used in multi-national group financial management and audit.

9.4 Applications of big data in accounting and finance

Predictive analytics for financial forecasting

Financial forecasting has traditionally relied on historical financial ratios, management judgement, and simple statistical extrapolation. Big Data predictive analytics transforms forecasting by incorporating vastly more data, more sophisticated models, and continuous updates.

What changes with big data forecasting

- Data breadth: Big Data forecasting models incorporate not only historical financial performance but also: macroeconomic indicators, industry sales data, social media sentiment, commodity prices, weather data, and competitor financial disclosures – providing a far richer information base than traditional models.
- Model sophistication: ML models (gradient boosting, neural networks, random forests) identify complex, non-linear patterns in financial data that traditional regression models cannot capture.
- Continuous updating: Big Data forecasting models can be updated daily or even in real time as new information arrives, rather than producing monthly or quarterly forecasts on fixed schedules.
- Uncertainty quantification: probabilistic forecasting models produce confidence intervals and scenario distributions rather than single-point estimates, providing more decision-useful information.

ICBDC (2024) finding: The paper identifies predictive analytics as the highest-value Big Data application for accounting information systems, noting that organisations deploying predictive financial analytics consistently outperform peers in forecast accuracy and decision quality. The paper specifically highlights cash flow forecasting and revenue prediction as the accounting applications where Big Data delivers the most quantifiable business value.

JPMorgan chase – big data cash flow forecasting

JPMorgan Chase's Treasury Services division deployed a Big Data predictive analytics platform to provide corporate clients with 13-week cash flow forecasts updated daily. The platform integrates: client ERP transaction data; payment network data showing pending receivables and payables; macroeconomic data feeds; and historical seasonal pattern analysis.

For a corporate client processing USD 500 million in monthly payments, the platform reduces forecast error by an average of 35% compared with the client's previous manual forecasting process – enabling more efficient working capital management and a reduction in idle cash balances.

Accounting implication: accountants advising clients on Big Data cash flow forecasting must understand the data inputs, model assumptions, and uncertainty ranges of these platforms – not just the output number – to provide meaningful professional advice on the reliability of forecast information.

Fraud detection and anomaly detection

Fraud detection is one of the most mature and commercially significant applications of Big Data in accounting. The combination of high-velocity transaction data processing and ML anomaly detection has transformed the ability of organisations to identify and prevent financial fraud in real time.

How Big Data fraud detection works

- Baseline modelling: ML models analyse historical transaction data to establish a statistical baseline of 'normal' behaviour for each account, customer, or entity – considering time patterns, amounts, counterparties, geographies, and transaction types.

- Real-time scoring: each incoming transaction is scored against the baseline model in milliseconds, generating an anomaly probability score.
- Multi-dimensional analysis: Big Data models simultaneously consider hundreds of variables – whereas a human analyst examining a transaction might consider five or ten. This enables detection of complex fraud schemes invisible to human review.
- Network analysis: graph analytics tools map the relationships between accounts and entities, identifying suspicious network patterns – such as circular payment schemes or unusual concentration of payments to previously unrelated entities.

ICBDC (2024) finding: The conference paper identifies fraud detection as the most operationally mature Big Data application in accounting, with multiple peer-reviewed studies demonstrating that ML-based anomaly detection consistently outperforms rule-based systems and human review – detecting between 40% and 60% more fraudulent transactions while reducing false positive rates by 20–30%. The paper specifically notes that the integration of Big Data fraud detection with AIS transaction recording creates a continuous, automated internal control environment.

American express – big data fraud prevention

American Express processes over USD 1 trillion in transactions annually across 100+ million cards globally. Their Big Data fraud detection system analyses over 115 variables per transaction in real time, scoring each transaction within 2 milliseconds using a gradient boosting ML model trained on billions of historical transactions.

The system detects complex fraud patterns that would be invisible to human review: a card used in Bangladesh in the morning and the UK in the afternoon (impossible travel); a sudden shift from BDT 500 micro-transactions to a single BDT 500,000 purchase; or a merchant who receives an unusual concentration of payments from newly-issued cards.

AmEx reports that Big Data fraud detection has reduced fraud losses by over 60% compared with the previous rule-based system, saving hundreds of millions of dollars annually. For accounting students: the effectiveness of these AI/Big Data controls is directly relevant to the audit risk assessment for payment-processing clients.

Real-time financial reporting

Traditional financial reporting produces periodic summaries of historical performance – monthly management accounts, quarterly filings, annual financial statements. Big Data enables a paradigm shift to continuous financial reporting, where financial data is available in real time.

- Live financial dashboards: Big Data platforms consolidate transaction data from multiple systems and currencies into real-time management dashboards, enabling immediate visibility of revenue, costs, cash position, and KPIs without waiting for period-end closes.
- Continuous close: as transactions are recorded and processed in real time by Big Data systems, the traditional month-end close process is compressed – many organisations have reduced close times from 10+ days to 3–5 days using Big Data approaches, with some achieving near-continuous close.
- Management commentary generation: NLP tools analyse real-time financial data to generate draft management commentary explaining performance, variance from budget, and key drivers – for review and approval by human accountants.
- Regulatory reporting automation: Big Data systems can automatically compile and file regulatory returns (VAT, withholding tax, exchange control reports) from real-time transaction data, replacing manual compilation processes.

Audit analytics and continuous auditing

Big Data is transforming external and internal audit from a periodic sampling exercise to a continuous, comprehensive analytical process. The ICBDC (2024) paper identifies this as one of the most significant transformations currently underway in accounting practice.

Audit data analytics

- 100% population testing: Big Data tools enable auditors to test the entire population of transactions — not a sample — for specified criteria. This dramatically improves the statistical confidence of audit conclusions and eliminates the sampling risk inherent in traditional approaches.
- Journal entry analysis: ML models analyse the entire population of journal entries for anomalies: entries posted outside business hours, entries near material thresholds, entries reversing large provisions, or entries by unusual combinations of preparers and approvers.
- Accounts receivable analytics: Big Data tools analyse the full aged receivables population, customer payment pattern histories, and external credit data to produce statistically rigorous estimates of the impairment allowance required under IFRS 9.
- Revenue completeness testing: analytics tools compare the entity's transaction records with third-party data sources — payment network data, shipping records, delivery confirmations — to identify revenue that should have been recorded but was not.

Deloitte argus — big data audit analytics

Deloitte's Argus audit analytics platform applies Big Data techniques to audit engagements across 150 countries. For a large retail client with 200 million annual transactions, Argus analyses the complete transaction population in hours — identifying statistical anomalies, testing all journal entries against PCAOB/IAASB journal entry testing criteria, and flagging items for focused human investigation.

A specific audit application: Argus identified a pattern of revenue transactions being recorded on the last day of each quarter at values just below the senior management approval threshold — a pattern consistent with revenue inflation to meet quarterly targets. This pattern, present in 0.003% of transactions, was invisible in a traditional statistical sample but immediately apparent in population analytics.

The ICBDC (2024) paper cites platforms like Argus as evidence that Big Data audit analytics is moving from innovative pilot to mainstream practice, with major audit firms now deploying analytics tools as standard procedure on all significant audit engagements.

Risk management and compliance monitoring

Financial risk management has been transformed by Big Data — enabling more comprehensive, real-time, and forward-looking risk assessment across credit, market, operational, and compliance risk dimensions.

- Credit risk: Big Data credit models incorporate alternative data sources — mobile payment history, social media activity, utility payment records, supply chain transaction data — enabling risk assessment for borrowers without traditional credit histories. Particularly significant for financial inclusion in Bangladesh and other emerging markets.
- Market risk: Big Data sentiment analysis of news feeds, analyst reports, and social media provides real-time market risk signals — enabling earlier identification of emerging market stress conditions than traditional VaR models based solely on historical price data.
- Operational risk: Big Data monitoring of operational systems, transaction patterns, and employee behaviour enables earlier identification of emerging operational risk events — reducing the frequency and severity of operational losses.

- Compliance monitoring: Big Data AML and sanctions monitoring systems analyse full transaction populations in real time against regulatory requirements – replacing the sampling-based compliance testing that created significant regulatory risk in traditional approaches.

Customer behaviour analysis and revenue optimisation

While primarily a marketing and operations application, customer behaviour analytics has direct accounting and finance implications – particularly for revenue recognition, pricing strategy, and segment reporting.

- Revenue segmentation: Big Data analysis of transaction patterns enables precise segmentation of revenue by customer type, product, geography, and channel – supporting more granular and decision-useful segment reporting than traditional ERP-based approaches.
- Churn prediction: ML models predict which customers are likely to stop purchasing, enabling proactive retention actions that protect the revenue base and improve the reliability of revenue forecasts.
- Pricing optimization: prescriptive analytics models recommend optimal pricing for financial products (loan interest rates, insurance premiums, banking fees) that maximize revenue while managing risk – directly affecting the quantum and timing of revenue recognized.

Professional skills focus – applying judgement

1. Know the 5Vs. They frame every Big Data decision.
2. Move Up the Analytics Ladder. Aim for predictive and prescriptive.
3. Match Storage to Purpose. Warehouses for reporting, lakes for analysis.
4. Guard Data Veracity. Bad inputs corrupt every output.
5. Embrace Continuous Audit. Test full populations, not samples.
6. Visualise Clearly. Dashboards must inform, not decorate.
7. Question Model Inputs. Understand assumptions, not just outputs.
8. Build Digital Skills. Power BI, Tableau, Python are now core.

Practice questions and answers with explanations

Artificial intelligence in accounting and finance

Question 1

Case scenario

A leading retail bank in Bangladesh implemented a supervised machine learning model to improve its credit scoring process. Previously, loan officers evaluated applications using a fixed set of financial ratios. The new model was trained on five years of historical loan data – including applicant financial profiles and repayment outcomes. As a result, approval accuracy improved by 18%, non-performing loans reduced by 12%, and processing time fell from three days to four hours.

Required

Which type of machine learning is described in the scenario above, and what is its defining characteristic?

Options

A) Unsupervised learning, in which the model identifies hidden patterns in unlabelled data.

B) Reinforcement learning, in which the model learns by trial and error through a system of rewards.

C) Supervised learning, in which the model is trained on a labelled dataset pairing each input with a known correct output.

D) Deep learning, in which the model uses multi-layered artificial neural networks to detect complex patterns.

Correct Answer: C

Explanation

Supervised learning is employed when a model is trained on labelled historical data in which each input observation (a loan application) is paired with a known correct output (loan repaid or defaulted). The bank used five years of labelled outcome data, which is the defining characteristic of supervised learning. Unsupervised learning operates without labels; reinforcement learning learns through reward signals; deep learning is a subset of machine learning defined by neural network architecture, not by the labelling of data.

Question 2

Case scenario

JPMorgan deployed its COIN (Contract Intelligence) platform to review commercial loan agreements. The platform completed a review of 12,000 commercial loan agreements in seconds – a task that had previously required an estimated 360,000 hours of lawyer time annually. COIN extracts financial data and obligations from unstructured legal text and flags clauses requiring human attention.

Required

Which branch of artificial intelligence primarily enables COIN to read, interpret, and extract meaning from unstructured legal text?

Options

A) Computer Vision, which enables machines to interpret visual information from scanned images and documents.

B) Robotic Process Automation (RPA), which automates repetitive rule-based processes by mimicking human interactions with digital systems.

C) Natural Language Processing (NLP), which enables machines to read, understand, and derive meaning from human language.
D) Expert Systems, which encode specialist knowledge and logical rules into a domain-specific inference engine.

Correct Answer: C

Explanation

Natural Language Processing (NLP) is the branch of artificial intelligence that enables computers to read, understand, and derive meaning from human language – both written and spoken. COIN processes unstructured legal text, which is precisely the domain of NLP. Computer Vision processes images, not text. RPA executes pre-defined rules without comprehending language. Expert systems apply coded logical rules and cannot interpret novel unstructured text in the flexible manner NLP models can.

Question 3

Case scenario

A mid-sized accounting firm wishes to automate its month-end close process. The requirement is for a system that can automatically match purchase orders with goods receipts and supplier invoices (three-way matching), reconcile bank statements against internal ledger entries, and flag discrepancies for review – without any requirement for the system to learn from data or improve its performance over time.

Required

Which technology is most appropriate for the firm's stated requirements, and why?

Options

A) Machine Learning, which trains predictive models on historical reconciliation data to identify discrepancies.
B) Deep Learning, which uses neural networks to model complex patterns within large financial datasets.
C) Natural Language Processing, which interprets unstructured textual content in financial documents.
D) Robotic Process Automation (RPA), which executes pre-defined, rule-based matching and reconciliation tasks at high speed and accuracy without requiring the system to learn.

Correct Answer: D

Explanation

Robotic Process Automation (RPA) is designed precisely for this requirement: it executes pre-programmed, repetitive, rule-based tasks – such as three-way matching and bank reconciliation – with high speed and without error. The firm explicitly does not require learning or improvement over time, which eliminates Machine Learning and Deep Learning. NLP is applicable to language interpretation, not numerical matching or reconciliation. RPA is the appropriate tool for structured, deterministic, rule-based automation within accounting workflows.

Big data in accounting and finance

Question 4

Case scenario

A large e-commerce corporation generates millions of transaction records every minute from mobile payment gateways, website activity, and IoT-connected delivery devices. The finance team wishes to detect fraudulent transactions in real time as they occur. The organisation's existing relational database infrastructure cannot process incoming data at the required speed or at the scale required for real-time fraud detection.

Required

Which two of the 5Vs of Big Data are the principal drivers of the challenge described in this scenario?

Options

A) Volume and Veracity – the database cannot assess the trustworthiness of the data at scale.

B) Variety and Value – the diversity of data formats prevents extraction of meaningful insight.

C) Volume and Velocity – the scale of data generation and the speed of required processing exceed the capacity of traditional database systems.

D) Veracity and Value – data quality is unreliable and the analytical potential of the data remains unrealised.

Correct Answer: C

Explanation

Volume refers to the scale of data generation (millions of transactions per minute), while Velocity refers to the speed at which data is produced and must be processed for real-time fraud detection. The scenario explicitly identifies both the volume of data and the speed of required processing as the constraints preventing the existing system from functioning adequately. Veracity (data trustworthiness) and Value (insight generation) are not identified as constraints in this scenario, and Variety is not cited as a challenge.

Question 5

Case scenario

A retail chain's Finance Director requires answers to four distinct business questions: (i) What were our sales last quarter, analysed by region? (ii) Why did the Northern region underperform against target? (iii) What are sales likely to be in the next quarter? (iv) What pricing strategy would maximise profit next quarter? The organisation's data science team has been tasked with building an analytics capability to address all four questions.

Required

Which sequence correctly maps each of the four questions to the corresponding type of analytics?

Options

A) Descriptive → Prescriptive → Diagnostic → Predictive

B) Diagnostic → Descriptive → Predictive → Prescriptive

C) Descriptive → Diagnostic → Predictive → Prescriptive

D) Predictive → Diagnostic → Descriptive → Prescriptive

Correct Answer: C

Explanation

The four types of analytics map as follows: Question (i) – 'What happened?' – is Descriptive analytics; Question (ii) – 'Why did it happen?' – is Diagnostic analytics; Question (iii) – 'What will happen?' – is Predictive analytics; and Question (iv) – 'What should we do?' – is Prescriptive analytics. These four types represent a hierarchy of analytical sophistication, each building upon the preceding level. This framework is fundamental to Big Data literacy for accounting and finance professionals.

Question 6

Case scenario

A bank's internal audit team proposes to analyse 100% of all transactions rather than relying on traditional sample-based audit procedures. The team plans to store raw, unprocessed data from multiple source systems – including the core banking system, payment gateway, and customer relationship management platform – and then apply analytics tools to identify anomalies and patterns indicative of fraud or material error. The data arrives in structured, semi-structured, and unstructured formats.

Required

Why is a data lake more appropriate than a traditional data warehouse for this audit use case?

Options

A) A data lake stores only pre-formatted structured data, which accelerates analytical query processing.

B) A data lake requires all data to be cleansed and transformed before ingestion, thereby ensuring data quality at the point of storage.

C) A data lake stores raw data in its native format from diverse sources without requiring a pre-defined schema, enabling flexible and large-scale analytics – unlike a data warehouse, which requires data to conform to a fixed structure prior to ingestion.

D) A data lake is a cloud-based replacement for relational database management systems and offers superior security controls.

Correct Answer: C

Explanation

A data lake stores raw, unprocessed data in its native format – whether structured, semi-structured, or unstructured – without requiring a pre-defined schema at the point of ingestion. This makes it suited to the audit team's requirement to store diverse data from multiple banking systems for subsequent flexible analysis. A data warehouse, by contrast, requires data to be cleansed, transformed, and structured before storage (through an Extract, Transform, Load process), which is inflexible for exploratory audit analytics. The absence of a mandatory schema in a data lake is its defining advantage in this context.

Blockchain technology in accounting And finance

Question 7

Case scenario

Maersk and IBM launched the TradeLens platform to digitise and manage documentary processes in global container shipping. The platform requires multiple parties – including shipping companies, port authorities, customs agencies, and trade finance banks – to access and verify shipping documents simultaneously. It is essential that no single party can alter an approved document unilaterally, and that all authorised participants share a single, consistent view of the record without depending on a central trusted administrator.

Required

Which type of blockchain is most appropriate for the TradeLens platform, and what is its key distinguishing feature?

Options

A) Public blockchain, which is open to participation by any individual or organisation globally without access restrictions.

B) Private blockchain, which is controlled by a single organisation and offers maximum data confidentiality.

C) Consortium blockchain, which is operated jointly by a defined group of authorised organisations, providing transparency among members while restricting access to external parties.

D) Cryptocurrency blockchain, which is designed primarily for the transfer of digital assets between individual participants.

Correct Answer: C

Explanation

A consortium blockchain (also referred to as a federated blockchain) is governed and operated by a defined group of organisations – in this instance, Maersk, IBM, and the various shipping, port, and regulatory participants. It provides a shared, transparent view of records to all consortium members while restricting access to authorised participants only. A public blockchain would permit unrestricted participation, which is inappropriate for commercially sensitive supply chain documentation. A private blockchain is controlled by a single entity, which defeats the multi-party trust architecture required in this scenario.

Question 8

Case scenario

An external auditor is conducting the statutory audit of a client that records all sales transactions on a private blockchain. The auditor notes that once a transaction has been validated through the network's consensus mechanism and added to the chain, it cannot be altered or deleted without the agreement of the majority of network participants and without such alteration being detectable by all participants. The auditor is assessing whether blockchain transaction records constitute reliable and sufficient audit evidence.

Required

Which property of blockchain technology most directly supports the reliability of blockchain records as audit evidence?

Options

A) Decentralisation – the absence of a central controlling authority reduces single points of failure and systemic risk.

B) Immutability – validated records, once added to the chain, cannot be altered or deleted without consensus and without such alteration being detectable by all network participants.

C) Smart contracts – the automated execution of contractual terms without the need for human intermediation.

D) Tokenisation – the conversion of rights in assets into digital tokens recorded on the blockchain.

Correct Answer: B

Explanation

Immutability is the blockchain property that most directly underpins the reliability of blockchain records as audit evidence. Once a transaction has been validated through the consensus mechanism and recorded on the chain, altering it would require modifying all subsequent blocks and achieving the consensus of the majority of network nodes – rendering any tampering computationally infeasible and detectable. This property directly addresses the auditor's concern regarding the integrity and authenticity of the financial record. Decentralisation supports resilience rather than record reliability per se.

Question 9

Case scenario

A property developer and a purchaser enter into an agreement under which legal title to a commercial property is to be transferred automatically upon confirmed receipt of the agreed purchase price. The transfer mechanism is encoded as computer code stored on a blockchain, which executes automatically when the pre-agreed condition – payment confirmed by the escrow mechanism – is satisfied. No solicitor, notary, or other intermediary is required to effect the transfer manually.

Required

Which blockchain mechanism is being utilised in this transaction, and what is the primary accounting implication it creates?

Options

A) Cryptographic hashing, which provides security by converting transaction data into a fixed-length digest that conceals the underlying information.

B) Distributed ledger technology, which allows all authorised parties to view an identical copy of the transaction record simultaneously.

C) A smart contract, which is a self-executing programme stored on the blockchain that automatically transfers the asset when pre-set conditions are met — with accounting implications for the timing of revenue recognition and the point at which control of the asset passes.

D) Proof of Work consensus, which requires substantial computational effort to validate the transaction before it is added to the chain.

Correct Answer: C

Explanation

This scenario describes a smart contract — code stored on the blockchain that self-executes upon satisfaction of pre-defined conditions (payment confirmed title transferred). The accounting implications are significant: smart contracts automate the triggering of asset transfer, raising questions under IFRS 15 and related standards as to the precise moment at which control of the asset passes and revenue or the disposal of the asset should be recognised. Auditors must additionally assess whether the smart contract code accurately reflects the agreed contractual terms.

Decision support in business

Question 10

Case scenario

A regional production manager currently receives a daily pre-formatted report comparing actual output to target, automated exception alerts when any machine's efficiency falls below 85%, and access to an on-demand query tool for ad hoc data retrieval. The Chief Information Officer is planning an upgrade to a system that will allow the manager to modify input assumptions interactively — for example, changing the number of production shifts — and immediately observe the projected effect on output and cost.

Required

The current system constitutes a Management Information System (MIS). The planned upgrade describes which category of system, and which type of analytical modelling best characterises the capability being introduced?

Options

A) An Executive Information System (EIS), utilising Online Analytical Processing (OLAP) drill-down functionality to disaggregate summary data.

B) A Decision Support System (DSS), utilising what-if analysis to allow the user to modify input variables and observe the consequent changes in output variables.

C) An upgraded Management Information System (MIS), incorporating push reporting and expanded exception alert functionality.

D) A Knowledge Management System (KMS), utilising goal-seeking analysis to determine the input values required to achieve a specified output target.

Correct Answer: B

Explanation

A Decision Support System (DSS) provides interactive, model-based support for semi-structured decision-making, enabling users to modify variables and explore the analytical consequences — in contrast to an MIS, which delivers fixed, pre-formatted reports. The specific modelling capability described is what-if analysis: the user changes one or more input assumptions and the system calculates the resulting change in output variables. This is distinct from sensitivity analysis (iterative single-variable change), goal-seeking analysis (working backwards from a target output), and optimisation analysis (determining the optimal value subject to defined constraints).

Question 11

Case scenario

A Group Chief Financial Officer uses an executive dashboard that consolidates financial key performance indicators from 47 subsidiaries across multiple geographies. The CFO is able to select a regional aggregate and navigate to the underlying country-level figures, and from there to the performance of individual business units within each country. The system also permits filtering by product line, customer segment, and reporting period. All responses are delivered in real time, without interrupting the CFO's analytical workflow.

Required

Which Business Intelligence technology is the CFO utilising, and which specific operation describes the navigation from regional aggregate to country level to individual business unit?

Options

A) Data Mining, whereby the system autonomously discovers previously unknown patterns and relationships in large financial datasets.

B) Online Analytical Processing (OLAP), with the Drill-Down operation — moving from consolidated aggregate totals progressively to the underlying detailed data.

C) Management Information Systems (MIS) with Periodic Scheduled Reporting, which delivers standardised summary reports at pre-set intervals.

D) Decision Support Systems (DSS) with Goal-Seeking Analysis, which determines the input values r required to achieve a nominated KPI target.

Correct Answer: B

Explanation

Online Analytical Processing (OLAP) enables real-time, interactive, multidimensional analysis of large datasets. The operation of navigating from a regional aggregate to country-level figures and then to individual business units is termed Drill-Down — the converse of Consolidation (or Roll-Up). The ability to filter by product line, customer segment, and time period represents OLAP's slicing and dicing functionality. OLAP is specifically engineered to deliver real-time responses during continuous analytical workflows, as described in this scenario.

Question 12

Case scenario

A Board-level strategic planning committee is evaluating three potential major capital investments. The decision involves material uncertainty regarding competitor responses, macroeconomic conditions, and the pace of technological change. No standardised procedures or quantitative rules exist to guide the selection. The committee relies principally on the collective experience and judgement of its members, supplemented by scenario analysis and external market intelligence.

Required

How should this decision be classified, and which information system framework most appropriately supports it?

Options

A) A structured decision at the operational management level, most appropriately supported by a Management Information System providing standardised performance reports.

B) A semi-structured decision at the tactical management level, most appropriately supported by a Decision Support System incorporating what-if modelling tools.

C) An unstructured decision at the strategic management level, most appropriately supported by an Executive Information System or Decision Support System providing external intelligence, flexible scenario modelling, and analytical tools.

D) A structured decision at the strategic management level, most appropriately supported by Robotic Process Automation to standardise and accelerate the evaluation process.

Correct Answer: C

Explanation

This is an unstructured decision: no established procedures or rules exist to guide it, it depends substantially on human judgement and experience, and it must draw on multiple uncertain and external information sources. Unstructured decisions are characteristic of the strategic management level. The most appropriate support is an Executive Information System (EIS) or Decision Support System (DSS) capable of providing external environmental intelligence, flexible scenario and sensitivity modelling, and analytical tools adapted to the specific decision context. MIS is designed for structured, operationally routine decisions; RPA automates deterministic rule-based processes and is wholly inappropriate for strategic judgement.

Financial technology (fintech) in accounting and finance

Question 13

Case scenario

bKash, Bangladesh's leading mobile financial services platform, reached 15 million registered users by 2020 by enabling peer-to-peer money transfers, bill settlement, salary disbursement, and merchant payments via basic mobile handsets – without requiring customers to hold a conventional bank account. The platform operates through a network of registered agents and leverages mobile network operator infrastructure to extend financial services to previously unbanked populations in rural and urban Bangladesh.

Required

Which FinTech domain does bKash primarily represent, and what are the most direct implications for the accounting profession?

Options

A) RegTech – regulatory technology applied to automate compliance monitoring and reporting obligations for mobile financial service providers.

B) InsurTech – digital technology enabling the distribution of insurance products through mobile channels to underserved populations.

C) Digital payments FinTech – with accounting implications including real-time digital transaction recording, the creation of electronically verifiable audit trails, the recognition and measurement of e-money float balances and liabilities, and financial inclusion disclosures in integrated reporting.

D) Peer-to-peer lending FinTech – enabling the direct intermediation of credit between individuals without the involvement of licensed deposit-taking institutions.

Correct Answer: C

Explanation

bKash exemplifies the digital payments domain of FinTech, utilising mobile technology to facilitate financial transactions outside conventional banking infrastructure. The accounting implications are material and immediate: all transactions generate real-time digital records constituting electronically verifiable audit evidence; accountants must appropriately recognise and measure e-money float balances, agent commission liabilities, and deferred revenue; and financial inclusion indicators are increasingly required as non-financial disclosures in integrated and sustainability reporting frameworks. Kou and Lu (2025) identify digital payments as one of the seven principal FinTech domains with direct implications for accounting practice.

Question 14

Case scenario

A major insurance corporation has deployed an artificial intelligence platform that automatically prices motor insurance policies by reference to telematics data derived from in-vehicle sensors, processes claims by analysing photographic evidence of vehicle damage through computer vision algorithms, and identifies potentially fraudulent claims through anomaly detection models applied to claims history. The platform has reduced average claims processing time from 14 days to four hours.

Required

This application integrates which two FinTech domains, and what is the primary audit risk that arises from the deployment of this system?

Options

A) RegTech and peer-to-peer lending – with the primary audit risk being non-compliance with automated lending regulations.

B) InsurTech and Artificial Intelligence FinTech – with the primary audit risk being model risk: the possibility that AI algorithms produce systematically biased, opaque, or inaccurate pricing and fraud-detection determinations that are difficult to subject to independent audit.

C) Blockchain technology and digital payments FinTech – with the primary audit risk being the exposure of claims reserves to cryptocurrency price volatility.

D) Robo-advisory and InsurTech – with the primary audit risk being the automated provision of investment advice that may not meet individual suitability requirements.

Correct Answer: B

Explanation

This scenario integrates InsurTech (technology-driven insurance underwriting, pricing, and claims management) with Artificial Intelligence FinTech (computer vision applied to damage assessment and anomaly detection applied to fraud identification). The primary audit risk is model risk – the risk that the AI models produce systematically biased outputs (for example, unfair differential pricing by demographic group), make determinations that cannot be adequately explained or independently verified (the 'black box' problem), or perform inaccurately in scenarios not represented in their training datasets. Auditors are required to assess model governance frameworks, independent validation procedures, and the completeness and integrity of the automated decision audit trail.

Question 15

Case scenario

In the years following the 2008 global financial crisis, a major bank experienced a 60% increase in compliance costs over five years arising from substantially expanded regulatory obligations – including Anti-Money Laundering (AML) transaction monitoring, Know Your Customer (KYC) verification, Basel III capital adequacy reporting, MiFID II transaction reporting, and General Data Protection Regulation (GDPR) compliance. The Chief Technology Officer has proposed investment in a technology platform to automate regulatory monitoring, reporting, and compliance checking in real time.

Required

Which FinTech domain directly addresses this requirement, and what are its primary benefits for the accounting and compliance function?

Options

A) Robo-advisory – automated generation of investment recommendations designed to satisfy regulatory suitability obligations.

B) Blockchain technology – provision of an immutable and independently verifiable audit trail for all regulatory submissions and disclosures.

C) RegTech (Regulatory Technology) – automation of compliance monitoring, regulatory reporting, and AML/KYC obligations through technology, directly reducing compliance costs, minimising human error in regulatory processes, and enabling continuous real-time compliance monitoring rather than periodic retrospective review.

D) Peer-to-peer lending platforms – enabling regulated lending activity to be conducted more efficiently by connecting lenders and borrowers directly, thereby reducing intermediation and associated compliance overhead.

Correct Answer: C

Explanation

RegTech (Regulatory Technology) is the FinTech domain specifically engineered to assist regulated organisations in meeting their compliance obligations efficiently through the application of technology. It automates AML transaction monitoring, KYC verification, capital adequacy calculations, regulatory reporting submissions, and data protection compliance – directly addressing the bank's escalating compliance cost base. The primary benefits for the accounting and compliance function are: material reduction in manual compliance effort and associated cost; real-time continuous monitoring enabling proactive rather than reactive compliance management; reduction in the risk of regulatory reporting errors; and timelier, more accurate submission of mandatory regulatory returns. Kou and Lu (2025) identify RegTech as one of the seven principal FinTech domains with direct implications for accounting and compliance professionals.

Chapter 3
IT Governance, Organization and Strategy

1. Laws, regulations and industry standards
2. Organizational structure, IT governance and IT strategy
3. IT policies, standards, procedures and guidelines
4. Enterprise architecture and considerations
5. Enterprise risk management
6. Data privacy program and principles
7. Data governance and classification
8. IT resource management
9. IT vendor management
10. IT performance monitoring and reporting
11. Quality assurance and quality management of IT

Practice questions and answers with explanations



IT Governance

Section summary

IT Governance covers how organizations direct, control, and align their information technology with business strategy. IT Governance is the responsibility of the board and executive management, ensuring IT delivers value, manages risk, and supports strategic objectives – guided by frameworks like COBIT, ITIL, ISO/IEC 38500, and ISO/IEC 27001. IT Management, by contrast, is the day-to-day execution of plans, policies, and controls. Key areas include IT strategy alignment, organisational structure, policies and procedures, enterprise architecture, risk management, performance measurement (KPIs/KRIs/balanced scorecard), resource and portfolio management, and compliance with laws and standards. Auditors assess whether governance structures exist, roles are clearly defined, segregation of duties is enforced, and IT investments deliver measurable business value. The core principle: governance sets direction and accountability; management executes within that frame – and IS auditors independently verify that both are working.

IT governance is not an isolated discipline. It is an integral part of comprehensive enterprise governance that includes audit, compliance, legal, and risk management. The IT governance process starts with setting objectives for the enterprise's IT function, assessing risks to those objectives, establishing controls to mitigate risk, monitoring performance against objectives, and adjusting as needed. All governance functions share responsibility for providing strategic direction, ensuring organisational objectives are achieved, ascertaining whether risk is managed appropriately, and verifying the responsible deployment of resources.

1. Laws, regulations and industry standards

1.1 Impact of laws, regulations and industry standards on IS audit

Enterprises may be subject to audits related to specific applicable laws, regulations, and industry standards. The purpose of such audits is to ascertain compliance with statutory requirements. The IS auditor must be aware of the following categories of legislation and how they affect IS audit scope and procedures:

United States Laws

- Gramm-Leach-Bliley Act (GLBA): Requires financial institutions to protect the privacy of consumer financial information.
- Health Insurance Portability and Accountability Act (HIPAA): Protects the privacy and security of health information. Requires covered entities to implement administrative, physical, and technical safeguards.
- Sarbanes-Oxley Act (SOX) 2002: Requires senior management to certify the accuracy of financial reports and mandates internal control assessments. Section 404 requires management assessment and external audit of internal control over financial reporting.
- Federal Information Security Management Act (FISMA): Requires US federal agencies to develop, document, and implement programmes to protect government information systems.

International Laws and Frameworks

- EU General Data Protection Regulation (GDPR): Applies globally to enterprises that handle personal data of EU individuals. Requires specific guidelines for data transmission, storage, and destruction. Non-compliance penalties are severe.
- Canada's PIPEDA: Personal Information Protection and Electronic Documents Act, governing how private-sector organisations collect, use, and disclose personal information.
- Australia's Privacy Act 1988: Governs how Australian Government agencies and private organisations handle personal information.
- Saudi Arabia's PDPL: Personal Data Protection Law, establishing requirements for processing personal data within the Kingdom.

Enterprises operating in multiple jurisdictions must be aware of all applicable legal and regulatory requirements, including laws that apply to enterprises NOT headquartered in the relevant jurisdiction. For example, GDPR applies to any enterprise doing business with individuals in the European Union, regardless of where the enterprise is located.

1.2 Governance, risk and compliance (GRC)

GRC is an integrated approach that recognises that assurance processes cannot exist in isolation. Each component addresses overlapping activities within an enterprise:

- Governance: Managing the enterprise's policies, processes, and decisions. Setting the strategic direction and ensuring accountability.
- Risk (Management): Identifying, assessing, and treating potential threats to the achievement of enterprise objectives.
- Compliance: Adhering to laws, regulations, standards, and internal policies. Includes both voluntary standards (ISO) and mandatory requirements (SOX, GDPR).

GRC may be applied in financial (Financial GRC ensures SOX compliance), IT (IT GRC ensures proper IT processes and policy compliance), and legal domains. The overall goal is to promote a combined, holistic view of risk that could prevent the enterprise from achieving its objectives.

When auditing regulatory compliance, the IS auditor should verify: (1) standards and procedures are established; (2) responsibility is assigned to senior personnel; (3) reliable staff background checks are conducted; (4) procedures are communicated effectively; (5) compliance is monitored and audited; (6) enforcement is consistent; and (7) appropriate responses to offences are in place.

2. Organizational structure, IT governance and IT strategy

2.1 Enterprise governance of information and technology (EGIT)

EGIT implies a system in which all stakeholders – including the board, senior management, internal customers, and functional departments such as finance – provide input into IT decision-making. EGIT is fundamentally concerned with two issues: (1) that IT delivers value to the business, and (2) that IT risk is managed appropriately.

COBIT Distinction: Governance VS. management

- Governance: Ensures that stakeholder needs, conditions, and options are evaluated to determine balanced, agreed-on enterprise objectives. Direction is set through prioritisation and decision-making. Performance and compliance are monitored against agreed direction and objectives. Governance is a board-level responsibility.
- Management: Plans, builds, runs, and monitors activities in alignment with the direction set by the governance body to achieve the enterprise objectives. Management is an executive and operational responsibility.

The EGIT framework addresses three overarching processes: IT resource management (maintaining an inventory of all IT resources and addressing risk); performance measurement (ensuring IT resources deliver expected value); and compliance management (addressing legal, regulatory, and contractual obligations). EGIT has become significant due to several converging forces: board demands for better IT investment returns, increasing IT expenditure, regulatory requirements (SOX, GDPR, Basel Accords), the growing complexity of cloud and outsourcing arrangements, and the need for cost optimisation through standardised approaches.

2.2 Three lines model

Enterprise governance spans the entire enterprise. The IIA's Three Lines Model defines how different roles manage risk:

- First Line: Operational management (business units) that provision products/services and manage risk in day-to-day operations. They identify control weaknesses and are expected to implement improvements.
- Second Line: Risk management function that evaluates risk independently using appropriate tools and methods. It partners with the first line to ensure risk is identified, documented, and mitigated through control design and implementation.
- Third Line: The internal audit function. Independent from both the first and second lines. Internal auditors set their own audit programmes, decide independently on scope, and report to the audit committee. IS audit's role is to provide assurance that the enterprise is taking necessary action to mitigate risk.

2.3 Information security governance

Information security governance is a subset of corporate governance that provides strategic direction for security activities. According to NIST: information security governance is the process of establishing and maintaining a framework to provide assurance that information security strategies are aligned with business objectives, are consistent with applicable laws and regulations through adherence to policies and internal controls, and provide assignment of responsibility.

An effective information security governance framework includes: a comprehensive security strategy linked to business objectives; governing security policies addressing each aspect of strategy, controls, and regulation; a complete set of standards for each policy; an effective security organisational structure free of conflicts of interest; and institutionalised monitoring processes.

Key governance roles include:

- Board of Directors: Accountable and liable for information security governance. Must establish risk tolerance, oversee risk management policies, and ensure regulatory compliance. Board members must know the enterprise's information assets and their criticality.
- CEO: Accountable to the board for information security governance and responsible for its discharge through executive management.
- CISO: Develops the security strategy, oversees the security programme, ensures risk and business impact assessments are conducted, develops risk mitigation strategies, and enforces policy compliance.

Information Security Standards Committee (ISSC): A cross-functional deliberating committee including C-level executives, IT managers, application owners, business process owners, HR, audit, and legal. Deliberates on the suitability of controls and ensures the security programme is aligned with business objectives.

2.4 IT strategy and steering committees

Enterprises traditionally have executive-level committees handling IT governance. ISACA makes a clear distinction between two levels of IT committee:

Dimension	IT Strategy Committee	IT Steering Committee
Responsibility	Provides insight and advice to the board on IT relevance, alignment with business direction, achievement of strategic IT objectives, availability of IT resources, optimisation of IT costs, risk/return aspects of IT investments, and progress on major projects	Decides IT spending levels and cost allocation; aligns and approves enterprise IT architecture; approves project plans, budgets, priorities and milestones; acquires and assigns resources; monitors projects to deliver expected value; monitors resource conflicts between divisions
Authority	Advises board and management on IT strategy; is delegated by the board to provide input to strategy and prepare its approval; focuses on current and future strategic IT issues	Assists executive in IT strategy delivery; oversees day-to-day management of IT service delivery and IT projects; focuses on implementation
Membership	Board members and specialists who are not board members	Sponsoring executive; business executives (key users); Chief Information Officer (CIO); key advisors as required (IT, audit, legal, finance)

2.5 Separation of duties within IT

SoD is a critical preventive control that avoids the possibility that a single person can be responsible for diverse and critical functions, thereby preventing undetected errors or misappropriations. Duties to be segregated include: custody of assets, authorisation, and recording of transactions.

If adequate SoD does not exist, the following risks arise: misappropriation of assets, misstated financial statements, inaccurate financial documentation, undetected improper use of funds or data modification, and undetected unauthorised changes to data and programmes.

Key incompatible function combinations

- Security Administration + Change Management: Security administration access rights could allow changes to go undetected.
- Computer Operations + System Development: An operator could run a programme they themselves amended.
- System Development + Change Control: Programme modifications could bypass change control approvals.
- DBA + Data Access Granting: The DBA should not also control who has access to data – this is the data owner's responsibility.

When SoD cannot be fully achieved, compensating controls include: audit trails; reconciliation; exception reporting; transaction logs; supervisory reviews; and independent reviews. The IS auditor must evaluate whether compensating controls are adequate and effective before relying on them.

2.6 IS strategic planning

IS strategic planning relates to the enterprise's long-term direction in leveraging IT to improve business processes. The IT strategic plan must be fully aligned and consistent with the overall enterprise goals and objectives. The IT steering committee, IT department management, and the strategy committee play key roles in developing and implementing plans.

The IS auditor evaluates: whether IT strategic plans are aligned with business strategy; how operational, tactical, and business development plans are considered in IT strategy formulation; the contents and completeness of strategic plans; requirements for updating and communicating plans; and monitoring and evaluation requirements. A lack of IT involvement in the creation of the overall business strategy indicates a risk that the IT strategy will not be aligned.

Business Intelligence (BI) supports strategic planning by providing management with the data and insights needed for informed decision-making. BI enables organisations to: identify trends and patterns; understand customer behaviour; assess performance; and make better decisions. A complete data architecture for BI includes an Enterprise Data Flow Architecture (EDFA) with layers including data source, data access, data staging and quality, data warehouse, data mart, data preparation, metadata repository, warehouse management, application messaging, and presentation/desktop access layers.

3. IT policies, standards, procedures and guidelines

3.1 Policies

Policies are high-level statements of management intent, expectations, and direction. They can remain relatively static for extended periods in a mature enterprise. Policies must be clearly aligned with and support the enterprise's strategic objectives. Individual divisions should define lower-level policies consistent with and supportive of high-level policies.

When reviewing the Information Security Policy (ISP), the IS auditor assesses: the basis or framework on which the policy has been defined; appropriateness and completeness of the policies; the contents of policies; exceptions to the policies (clearly noting where policies do not apply and why); the policy approval process; the policy implementation process; effectiveness of implementation; awareness and training; and the periodic review and update process.

ISP essential elements

- A definition of information security within the enterprise
- The scope and objectives of the policy document
- A statement of management's intent and expectations regarding information security
- Acknowledgement of the frameworks used for setting control objectives and controls
- Brief explanation of compliance requirements: legislative, regulatory, and contractual
- Information security education, training, and awareness requirements
- Business continuity management and disaster recovery plans
- Consequences of policy violations
- A definition of responsibilities for information security management
- References to supplemental documentation

The ISP must be approved by senior management. It should be documented, communicated to all employees and relevant third parties, and employees should be required to sign off on their understanding and willingness to comply when hired and regularly thereafter (e.g., annually).

3.2 Standards

A standard is a mandatory requirement, code of practice, or specification approved by a recognised external standards organisation. Within the enterprise, standards are the criteria used to determine whether procedures, processes, or systems meet policy requirements. Where policies are the enterprise's constitution, standards are the laws used to measure policy compliance.

Standards govern the creation of procedures and guidelines by setting boundaries within which procedures operate, the security baselines, and acceptable risk appetite as directed by management. Strong standards are essential in fast-moving environments – they help ensure the effectiveness and reliability of products and services.

3.3 Procedures and guidelines

Procedures are documented, defined steps for achieving specific policy objectives. They must be derived from the parent policy and reflect the spirit of the policy while operating within the boundaries of the standards. Procedures document business and aligned IT processes and embedded controls. They are more dynamic than policies and require frequent review to remain current.

Guidelines provide additional detail to help individuals execute procedures. They may include: clarification of policies and standards; dependencies; suggestions and examples; narrative clarifying procedures; background information; and tools that can be used. Unlike policies and standards, guidelines are advisory rather than mandatory.

Policy-Standard-Procedure-Guideline example: Policy: 'Information resources must be controlled to effectively prevent unauthorised access.' Standard: 'Only minimum system resources and authorisations should be granted (principle of least privilege).' Procedure: 'Accounting department individuals are provided access to the AP system based on their specific job title and role.' Guideline: 'Each accounting team member is assigned a specific job title and role. Job changes trigger a mandatory access review within five days.'

4. Enterprise architecture and considerations

4.1 Zachman framework

The Zachman Framework, first published by John Zachman in the late 1980s, provides a foundational starting point for EA projects. Zachman reasoned that constructing IT systems had considerable similarities to constructing a building – one moves from the abstract to the physical using models and representations. The framework is structured as a matrix with five rows (perspectives): Scope, Enterprise Model, Systems Model, Technology Model, and Detailed Representation. The columns address six aspects: Data (What), Functional/Application (How), Network/Technology (Where), People/Organisation (Who), Process/Workflow (When), and Strategy (Why).

	What data	**How** function	**Where** network	**Who** people	**When** time	**Why** motivation
Executive scope	Inventory	Processes	Locations	Org units	Events	Goals
Business concepts	Entities	Workflow	Geography	Org chart	Cycles	Strategy
Architect logic	Data model	Sys flow	Network	Access	Schedule	Rules
Engineer physical	Schema	Design	Platform	Screens	Triggers	Logic
Technician detail	Tables	Code	Nodes	Security	Timing	Specs
Enterprise running	Instances	Running	Sites	Users	Runtime	In force

The goal is to complete all cells of the matrix. At the outset of an EA project, enterprises are expected to have difficulty providing details for every cell, particularly at the highest level. EA can be approached from either a technology perspective (clarifying complex technology choices) or a business process perspective (understanding core value-adding and supporting processes).

4.2 Other EA frameworks

- TOGAF (The Open Group Architecture Framework): Provides a high-level approach for designing, planning, implementing, and governing an enterprise IT architecture. It is a widely adopted standard for enterprise architecture practice.
- SABSA (Sherwood Applied Business Security Architecture): Focuses specifically on information security architecture. It provides a framework for developing risk-driven enterprise security architectures aligned with business objectives.

SABSA Framwork

Feature	Advantage	Benefits							
		Chairman & Board	CEO	CFO	COO	CRO	CIO	CISO	CTO & Architects
Business Driven	Value – assured	Protects shareholder value	Protects corporate reputation	Ensures efficient return on investment	Focuses on performance management	Enables flexible fit with industry regulations	Enables a digital information-age business	Facilitates alignment of security strategy with business goals	Leverages the full power of information technology
Risk focused	Prioritized & proportional responses	Optimizes shareholder risk & aligns with risk appetite	Meet corporate governance requirements	Improves predictability & consistency	Enables process improvement	Supports enterprise risk management	Identifies information exploitation opportunities	Facilitates prioritization of security & risk – control solutions	Manages information system risk
Comprehensive	Scalable scope	Addresses all shareholder concerns	Meets enterprise wide requirements	Supports scalable, granular budgeting	Provides end-to-end process coverage	Enables a fully integrated risk control strategy	Sustains through-life information architecture	Ensures all business concerns regarding security & control are addressed	Applies at any level of project size or complexity
Modular	Agility for ease of implementation & management	Ensures flexibility to meet dynamic market & economic conditions	Enables fast time to market with business solutions	Facilitates effective management of both development & operational costs	Integrates with legacy environments	Enables incrementally increasing maturity	Enables technology neutral information management strategies	Enables a project-focused approach to security & control development	Provides a holistic architectural approach
Open Source *	Free use, open source, global standard	Guarantees 'escrow' & perpetuity of return on investment	Provides assurance through industry standard	Eliminates expensive on-going license fees	Simplifies recruitment & training	Provides global acceptability for auditors & regulatory supervisors	Provides a future-proof strategic framework for information management	Provides a sustainable framework for integration of other security standards	Avoids vendor dependence & lock-in
Auditable	Demonstrates compliance to relevant authorities	Demonstrates compliance to regulators & external auditors	Ensures a smooth & successful external & regulatory audit process	Minimizes cost of management time dealing with audit processes	Minimizes adverse effect of audits on performance targets	Ensures that compliance risk is effectively managed	Facilitates smooth & successful internal audits of information systems & processes	Supports security & risk review processes	Improves relationship & interactions with auditors & security reviewers
Transparent	Two-way traceability	Supports market transparency & disclosure	Provides a clear view of where expenditure is made & what value is returned	Enables full audit ability for effectiveness of expenditure	Measures efficiency & effectiveness of processes & resource deployment	Demonstrates 'current state' and 'desired state' of compliance levels	Encourages fully integrated people – process – technology solutions	Provides traceability of implementation of business-aligned security requirements	Verifies justification & completeness of technical solutions.

When auditing infrastructure and operations, the IS auditor should: follow the overall EA selected by the enterprise as the main source of information; ensure systems are aligned with the EA; verify that the EA supports the enterprise's objectives; and assess whether IT investments are consistent with the documented architecture.

5. Enterprise risk management

5.1 Risk appetite and risk tolerance

- Risk Appetite: The amount of risk that an enterprise is willing to take to achieve its strategic objectives. This is a deliberate, strategic decision made by senior leadership with the board of directors. It is set at the enterprise level.
- Risk Tolerance: The acceptable deviation from the enterprise risk appetite – the amount of risk the enterprise can withstand without jeopardising its ability to achieve strategic objectives. Risk tolerance can be set at different levels: departmental or project.

Risk appetite is a strategic concept; risk tolerance is a tactical concept. Both inform the enterprise's decision-making process. When an enterprise considers a new initiative, it assesses the associated risk against its appetite and tolerance to determine whether to proceed.

5.2 Risk response strategies

- Avoid: Eliminate the risk exposure by not pursuing activities, processes, or business relationships that would incur the risk. Appropriate when the risk exceeds the enterprise's appetite and cannot be adequately mitigated.
- Mitigate (Reduce): Lessen the probability of a risk event or the magnitude of its impact by defining, implementing, and monitoring appropriate controls. The most common risk response in IT environments.
- Share / Transfer: Spread the impact across multiple enterprises through partnership, or place the impact on a third party through insurance coverage or contractual agreement. Note that accountability for information security cannot be fully transferred – the enterprise retains ultimate responsibility.
- Accept: Acknowledge the existence of the risk and move forward despite the possible impact. Appropriate when the cost of mitigation exceeds the expected loss, or when the risk falls within the enterprise's risk tolerance. Requires formal monitoring.

An enterprise can also REJECT risk by ignoring it. This is dangerous and should be considered a red flag by the IS auditor, as it represents an uninformed and undocumented risk decision.

5.3 Risk management lifecycle

To ensure consistent and appropriate risk management, the enterprise must establish a repeatable risk management process:

- Step 1 – IT Risk Identification: Identify and collect relevant data to enable effective risk identification, analysis, and reporting. Identify information resources or assets that need protection because they are vulnerable to threats. Classify assets by value and criticality. Common asset categories include: information and data, hardware, software, documents, personnel, and clients/customers.

  Common classes of threats include: errors and omissions, malicious damage/attack, fraud, theft, and equipment/software failure. Vulnerabilities (characteristics of information resources that can be exploited by threats) include: lack of user knowledge, lack of security functionality, inadequate user education, untested technology, and transmission of unprotected communications.

- Step 2 – IT Risk Assessment: Assess the threats and vulnerabilities associated with information resources and determine the likelihood of their occurrence and the resulting impact. Risk = Probability of occurrence × Magnitude of impact. Factors such as velocity (speed of impact propagation) may also be incorporated. The result is a relative prioritisation of risk for the enterprise.

- Step 3 – Risk Response and Mitigation: Evaluate existing controls or design new controls to reduce vulnerabilities to an acceptable level. Controls are evaluated through cost-benefit analysis. Residual risk is the remaining risk after controls have been applied. If residual risk exceeds the risk appetite, additional controls are required. If residual risk is below the appetite, the enterprise may be over-controlling and incurring unnecessary cost.

  The Control Strength Matrix classifies controls on two dimensions: type (Preventive, Detective, Corrective) and nature (Manual, IT Dependent, Automated). The strongest controls are preventive, automated, and formal, because they stop occurrences without human interaction and have been tested for effectiveness.

- Step 4 – Risk and Control Monitoring and Reporting: Monitor performance levels of managed risk and identify significant changes in the environment that would trigger reassessment. Risk assessment should be an ongoing process, not a one-time event.

5.4 Risk analysis methods

- Qualitative Analysis: Uses descriptive rankings (high, medium, low) based on checklists, interviews, and subjective risk ratings. Simplest and most frequently used, but lacks the rigor of quantitative methods and can be time-consuming when text-based information must be gathered and analysed.
- Semiquantitative Analysis: Associates descriptive rankings with a numeric scale (e.g., high = 5, medium = 3, low = 1). Frequently used when quantitative methods are not feasible or when reducing subjectivity in qualitative methods is desired.
- Quantitative Analysis: Uses numeric (monetary) values to describe likelihood and impacts, drawing on historical records, past experiences, industry practices, statistical theories, and testing. Provides measurable results but requires reliable data. A quantitative risk analysis is generally performed during a Business Impact Analysis (BIA).

6. Data privacy program and principles

6.1 Privacy documentation

- Privacy Notice: An outward-facing statement written for data subjects and data protection authorities. Describes how the enterprise collects, uses, retains, safeguards, and discloses personal information. Establishes the enterprise's legal accountability. Must be written in easily understood language.
- Consent Form: Documents the agreement by a data subject with the terms of a privacy notice. Provides the legal basis for data processing. Data subjects generally have the right to withdraw consent at any time.
- Personal Information Inventory: A documented repository of all personal data assets collected, derived, processed, stored, or otherwise handled by the enterprise. An internally focused document supporting privacy and data protection measures.
- Privacy Impact Assessment (PIA): A process used to determine if personal information is appropriately safeguarded, used, shared, made available to associated individuals, and destroyed. A PIA report details findings and associated risk mitigation plans.
- Data Incident Register: Stores records of all personal data incidents, including facts about the incident, effects of the breach, remedial measures, and preventive measures.
- Individual Rights Register: Records all requests from individuals about their records and how/when they were received and resolved.

6.2 IS auditor role in privacy

IS auditors play a vital role in evaluating the data privacy programme. This involves evaluating the effectiveness of data privacy policies, including whether:

- Data privacy requirements are included in third-party contracts
- Data retention and destruction policies are implemented and followed
- Cross-border regulations for data privacy are addressed in data processes
- Employees have received training about data privacy regulations
- A data inventory is created, maintained, and regularly updated
- Data subject requests (access, rectification, deletion) are handled appropriately and within required timeframes

7. Data governance and classification

7.1 Data classification

Data classification assigns sensitivity and criticality levels to information resources. This enables: a consistent perspective of security requirements across the enterprise; cost-benefit analysis for security investment; and compliance with regulatory requirements. The information owner is responsible for deciding on appropriate classification.

- Public: Openly and freely accessible to anyone. Examples: marketing materials, press releases, publicly available reports.
- Internal: Limited to employees expressly granted access. Not intended for external distribution. Examples: business plans, organisation charts, internal reports.
- Confidential: Must be kept private to prevent negative ramifications if exposed. May fall under data privacy laws (HIPAA, PCI DSS). Examples: unpublished financial information, customer lists, payment card data, contracts.
- Restricted: Highly sensitive data that can lead to criminal charges or legal fines if exposed. Examples: proprietary research, data protected by state/federal regulations, trade secrets.

Data classification as a control measure must define: the importance of the information asset; the information asset owner; the process for granting access; the person responsible for approving access rights and levels; and the extent and depth of required security controls.

7.2 Data ownership roles

- Data Owners: Generally managers and directors responsible for using information to run and control the business. Security responsibilities include: authorising access; ensuring access rules are updated when personnel changes occur; and regularly reviewing access rules for data under their ownership. Data owners are responsible for security throughout the data life cycle – from origination to disposal.
- Data Custodians: Responsible for storing and safeguarding the data. Include IS personnel such as systems analysts and computer operators. The DBA is typically a data custodian.
- Data Users: Internal and external user communities whose access levels should be authorised by data owners and restricted and monitored by security administrators.

Data classification is also critical for identifying who should access production data versus test data. Application or system development programmers should not have access to production data or programmes. Using production data in development or test environments is a material control failure.

IT Management

IT management consists of overseeing all activities related to IT operations and resources. IT management plans, builds, implements, operates, and monitors activities in alignment with the direction set by the governance body to achieve enterprise objectives. While IT governance sets direction, IT management executes against that direction.

8. IT resource management

8.1 IT portfolio management

IT portfolio management determines if the enterprise is pursuing the best IT-related projects to achieve its goals. Implementation tasks include: ensuring management commitment and agreed targets; planning the portfolio management model; specifying portfolio inclusion criteria; describing roles, tasks, and decisions; and organising required tools.

IT portfolio management is distinct from the Balanced Scorecard (BSC): portfolio management has an explicitly directive, strategic goal in determining investment levels; the BSC focuses on operationalising the strategic plan across four perspectives (business contribution, user orientation, operational excellence, and future orientation). Both include a feedback loop, but the BSC loop relates to strategic planning while the portfolio loop considers entire programme investments.

8.2 Human resource management controls

Key HR controls of IS audit interest

- Background Checks: Criminal, educational, financial, and professional checks performed before hiring. Ensures that critical access and authority roles are not delegated to individuals who have conducted illegal activity.
- Mandatory Vacations: Ensures that, at minimum once per year, someone other than the regular employee will perform a job function. Reduces the opportunity to commit improper or illegal acts. Fraudulent activity may be discovered during the employee's absence if there is no collusion.
- Job Rotation: Provides additional control by ensuring the same individual does not always perform the same tasks. Guards against fraud risk and over-dependence on key staff by spreading experience.
- Termination Procedures: Immediate revocation of all logical and physical access upon termination. This includes: return of all devices, access keys, ID cards, and badges; deletion/revocation of all login IDs and passwords (including application-specific credentials); notification to appropriate staff; removal from payroll; and a termination interview.

8.3 Information security management

Information security management ensures enterprise information and information processing resources are properly protected. Key responsibilities include:

- Risk Assessment and Management: Conduct regular risk assessments, evaluate vulnerabilities, and implement risk management strategies.
- Security Policy Development: Develop and enforce ISPs, standards, guidelines, and procedures.
- Incident Response and Management: Establish procedures to handle security incidents, investigate breaches, mitigate impact, and prevent future incidents.
- Vulnerability Management: Regularly scan systems and networks for vulnerabilities, apply patches and updates, and conduct penetration testing.
- BCP and DRP: Conduct BIAs and desktop scenarios to determine RTO (Recovery Time Objective – the maximum acceptable downtime) and RPO (Recovery Point Objective – the maximum acceptable data loss expressed in time units).
- Identity and Access Management: Manage user accounts, access rights, and privileges. Implement strong authentication, enforce least privilege, and monitor user activity for suspicious behaviour.

9 IT vendor management

9.1 Sourcing practices

Delivery of IT functions can be characterised as: Insourced (fully performed by enterprise staff), Outsourced (fully performed by vendor staff), or Hybrid (mix of enterprise and vendor staff). Geographically, IT functions can be delivered onsite, offsite (nearshore), or offshore.

The decision to outsource is strategic, not merely a procurement decision. The enterprise is effectively reconfiguring its value chain – identifying core activities to retain and non-core activities for outsourcing. Key questions to consider: Is this a core function? Can it be replicated externally? Can it be done for the same or lower price at the same or higher quality without increasing risk? Are there contractual or regulatory restrictions on offshore execution?

9.2 Essential outsourcing contract provisions

The IS auditor must review outsourcing contracts for the following essential elements:

- Service Level Agreements (SLAs): Stipulate and commit the vendor to a required level of service, including: guaranteed system performance (uptime/downtime), customer support levels, software/hardware requirements, penalty provisions, and enforcement options. SLAs are a contractual means of control.
- Right-to-Audit Clause: Provides the enterprise (and its IS auditor) the right to audit vendor operations, including access to facilities, records, copies, personnel, and computerised files.
- Software Escrow: Ensures that source code is accessible to the enterprise if the vendor fails. Critical for long-term system continuity.
- Data Ownership and Confidentiality: Clearly establishes ownership of enterprise-owned data, requiring CIA (Confidentiality, Integrity, and Availability) to be maintained by the vendor. NDAs protect both parties.
- BCP and DR Provisions: Ensures the vendor has adequate business continuity and disaster recovery plans, including appropriate testing.
- Regulatory Compliance: Requires the vendor to comply with all relevant legal and regulatory requirements, including those enacted after contract initiation.
- Subcontractor Control: Requires the vendor to identify all subcontract relationships and obtain the enterprise's approval before changing subcontractors.

9.3 Third-party audit reports (soc reports)

One method for obtaining assurance of third-party controls is through periodic third-party audit reports under SSAE 18 (USA) or ISAE 3402 (International):

- SOC 1 Report: Covers controls at the service organisation that are likely to be relevant to user entities' internal control over financial reporting (ICFR). Relevant for financial audit purposes.
- SOC 2 Report: Covers controls relevant to security, availability, processing integrity, confidentiality, or privacy. Includes the service organisation's compliance with its privacy practices. Provides detailed understanding of control design and testing results. Most relevant for IS auditors.
- SOC 3 Report: Similar to SOC 2 but does not include a detailed understanding of the design of controls and tests performed. Suitable for general distribution.

The IS auditor should understand: management assertions and how well they address services provided; how to validate that third-party assessments were performed by independent, objective, and competent parties; internal processes for handling qualified opinions; the use of bridge letters when the annual report is not yet available; and how to present report results to management.

9.4 Cloud governance

Cloud computing presents unique governance challenges. Key concerns include: business unit personnel can now bypass IT and receive cloud services directly (shadow IT); policies must address the sourcing, managing, and discontinuing of cloud services; and the enterprise must maintain sufficient overall control and visibility into all security aspects of information managed by the cloud provider.

Considerations for cloud risk management include: developing a cloud risk management strategy; implementing strong cybersecurity controls; managing cloud resilience, vendor lock-in, and concentration risk; and ensuring staff have adequate skills to manage cloud risk. The enterprise must retain visibility into security activities such as change management, vulnerability identification, and incident reporting through a clearly defined reporting process.

10 IT performance monitoring and reporting

10.1 Performance indicators

- Key Performance Indicators (KPIs): Measure how well a process is performing in enabling a goal to be reached. They are lead indicators of whether a goal will likely be achieved. Example: employee satisfaction with IT services; system availability percentage; percentage of projects delivered on time and within budget.

- Key Risk Indicators (KRIs): Provide early warning of risk exposure that may harm business performance. Include a threshold above which alerts are sent to responsible individuals. Example: percentage increase in phishing attempts; number of unpatched critical vulnerabilities; staff turnover rate in critical IT roles.

- Key Control Indicators (KCIs): Measure how well a control performs in reducing causes, consequences, or likelihood of risk. Example: percentage of IT assets compliant with security policies; percentage of change requests with successful post-implementation verification.

For a metric to be effective, it should be: consistently measured; based on acceptable best practices; useful for internal and external comparison; meaningful to IT's customers and sponsors; expressed as a number, percentage, or unit of measure; and contextually specific.

10.2 IT Balanced scorecard

The IT BSC is a management evaluation technique for assessing IT functions and processes. It goes beyond traditional financial evaluation to include four balanced perspectives:

- Business Contribution: How does management view the IT function? Captures the business value of IT investments.
- User Orientation: How do users view the IT function? Reflects the end user's perspective or evaluation of IT.
- Operational Excellence: How effective and efficient are IT processes? Describes the IT processes used to develop and deliver IT resources.
- Future Orientation: How well is IT positioned to meet future needs? Represents the human and technology resources that IT needs to deliver future capabilities.

Using an IT BSC is one of the most effective means to aid the IT strategy committee and management in achieving IT governance through proper IT and business alignment. It establishes a vehicle for management reporting to the board, fosters consensus among key stakeholders, demonstrates effectiveness and added value, and communicates IT performance, risk, and capabilities.

10.3 Improvement methodologies

- PDCA Cycle: An iterative four-step management method: (1) Plan – establish objectives and processes; (2) Do – implement the plan and collect data; (3) Check – study results and compare against expected outcomes; (4) Act – request corrective actions on significant differences and determine root causes.
- Six Sigma / Lean Six Sigma: A quantitative, data-driven process analysis and improvement approach. Six Sigma aims to implement a measurement-oriented strategy focused on process improvement and defect reduction. Lean Six Sigma additionally seeks to eliminate unnecessary steps that do not add value.
- COBIT: Developed by ISACA to support EGIT. Ensures IT is aligned with the business, IT resources are used responsibly, and IT risk is managed appropriately. Provides tools to assess and measure IT process performance.
- ITIL: Developed by the UK OGC. A detailed framework providing hands-on information for achieving successful operational IT service management and business value delivery.

  ISO/IEC 38500:2015: Provides guiding principles for governing bodies on the effective, efficient, and acceptable use of IT within an enterprise.

11 Quality assurance and quality management of IT

11.1 QA VS. QC

The terms QA and QC are often used interchangeably but have different meanings:

- Quality Assurance (QA): A planned and systematic pattern of all actions necessary to provide adequate confidence that an item or product conforms to established technical requirements. QA ensures that personnel follow prescribed quality processes – it is process-focused. Example: QA sets up ISO 9001-compliant procedures to facilitate widespread use of quality management practices. QA personnel verify that system changes are authorised, tested, and implemented in a controlled manner before production introduction.
- Quality Control (QC): The observation techniques and activities used to fulfil requirements for quality. QC is responsible for conducting tests or reviews to verify and ensure that software is free from defects and meets user expectations – it is product-focused. Example: QC helps ensure that programmes and documentation adhere to standards and naming conventions. QC is conducted at various stages of application development but must always be done before programmes are moved to production.

The QA function is in charge of developing, promulgating, and maintaining standards for the IT function. It also provides training in QA standards and procedures. The QC group assists by periodically checking the accuracy and authenticity of input, processing, and output of various applications.

To enable the QA function to play an effective role, the QA group must be independent within the enterprise. Under no circumstances should an individual review their own work. The review should not be performed by an individual whose role would create a SoD conflict (e.g., a DBA performing a quality review of application system changes that would impact the database).

11.2 Quality management

Quality management is how IT department processes are controlled, measured, and improved. Areas of control for quality management include: software development, maintenance, and implementation; acquisition of hardware and software; day-to-day operations; IT control performance; service management; security; HR management; and general administration.

The IT department's development and maintenance of defined, documented processes are evidence of effective governance of information resources. Various quality standards have emerged to assist IT organisations in achieving a predictable, measurable, repeatable, and certifiable operating environment.

11.3 Operational excellence

Operational excellence teams are responsible for improving the efficiency and effectiveness of enterprise operations. They identify and eliminate waste, streamline processes, improve communication and collaboration, and use data and analytics to identify improvement areas. Responsibilities include: developing and implementing best practices; providing training and support; conducting research and development; managing knowledge and information; and serving as a resource for other employees and stakeholders.

Professional skills focus – applying judgement

1. Distinguish Governance from Management. Boards direct and oversee; management executes. Auditors must know which layer they are evaluating.
2. Test Strategic Alignment. Verify IT strategy flows from business strategy – not the reverse.
3. Apply the Right Framework. Use COBIT for governance, ITIL for service management, ISO 27001 for security.
4. Check Roles and Accountability. Ensure clear ownership, segregation of duties, and escape from key-person risk.
5. Evaluate Risk Management. Confirm risks are identified, assessed, treated, and monitored – not just listed.
6. Assess Performance Metrics. KPIs and KRIs must link to strategy, not vanity numbers.
7. Review Policies for Relevance. Policies must be current, approved, communicated, and enforced – paper compliance is not compliance.
8. Maintain Independence. IS auditors advise but do not design or operate the controls they test.

Practice questions and answers with explanations

Q1. Organizations requiring employees to take a mandatory vacation each year PRIMARILY want to ensure:

A. adequate cross-training exists between functions.

B. an effective internal control environment is in place by increasing morale.

C. potential irregularities in processing are identified by a temporary replacement.

D. the risk of processing errors is reduced.

Correct Answer: C

Explanation: Employees who perform critical and sensitive functions should be required to take some time off so that a temporary replacement performs their duties. This is a detective control that helps uncover irregularities, fraud, or concealed errors. Cross-training, morale, and error reduction are secondary benefits, not the primary reason.

Q2. In a review of HR policies and procedures, an IS auditor is MOST concerned with the absence of a:

A. requirement for periodic job rotations.

B. process for formalized exit interviews.

C. termination checklist.

D. requirement for new employees to sign a nondisclosure agreement (NDA).

Correct Answer: C

Explanation: A termination checklist is critical to ensure the logical and physical security of the enterprise. Beyond recovering company property, it protects against unauthorized access, intellectual property theft, and sabotage by a disgruntled former employee. NDAs, exit interviews, and job rotations are good practices but pose lower risks than a missing termination process.

Q3. An IS auditor is evaluating management's risk assessment of information systems. The IS auditor should FIRST review:

A. controls in place.

B. effectiveness of the controls.

C. mechanism for monitoring the risk.

D. threats/vulnerabilities affecting the assets.

Correct Answer: D

Explanation: Risk assessment begins with understanding the assets, their value, and the threats and vulnerabilities affecting them. Controls are meaningless until you know what risk they are intended to address. The risk related to assets must be evaluated in isolation from the installed controls.

Q4 .The PRIMARY benefit of an enterprise architecture (EA) initiative is to:

A. enable the organization to invest in the most appropriate technology.

B. ensure security controls are implemented on critical platforms.

C. allow development teams to be more responsive to business requirements.

D. provide business units with greater autonomy to select IT solutions.

Correct Answer: A

Explanation: The primary focus of EA is to ensure that technology investments are consistent with the platform, data, and development standards of the IT organization. This alignment helps the organization implement the most effective technology. Security, developer agility, and business-unit autonomy are not EA's primary goals.

Q5. Which of the following situations is addressed by a software escrow agreement?

A. The system administrator requires access to software to recover from a disaster.

B. A user requests to have software reloaded onto a replacement hard drive.

C. The vendor of custom-written software goes out of business.

D. An IS auditor requires access to software code written by the organization.

Correct Answer: C

Explanation: A software escrow agreement is a legal contract between a vendor and customer where source code is held by a trusted third party. It protects the customer if the vendor goes out of business, enters a contractual dispute, or fails to maintain the software. Escrow does not apply to internal software or disaster recovery backups.

Q6. Sharing risk is a key factor in which of the following methods of managing risk?

A. Transferring risk

B. Tolerating risk

C. Terminating risk

D. Treating risk

Correct Answer: A

Explanation: Transferring risk (for example, by purchasing an insurance policy or outsourcing) is how organizations share risk with another party. Tolerating means accepting the risk, terminating means eliminating the process, and treating is a broader term covering multiple strategies.

Q7. Which of the following is a function of an IT steering committee?

A. Monitoring vendor-controlled change control and testing

B. Ensuring a separation of duties within the information processing environment

C. Approving and monitoring the status of IT plans and budgets

D. Liaising between the IT department and end users

Correct Answer: C

Explanation: The IT steering committee serves as a general review board for major IT projects. It approves and monitors IT plans and budgets to ensure IT investments align with business strategy. It should not involve itself in routine operations, vendor change control, or day-to-day liaison activities.

Q8 Establishing the level of acceptable risk is the responsibility of:

A. quality assurance management.

B. senior business management.

C. the chief information officer.

D. the chief security officer.

Correct Answer: B

Explanation: Senior business management has ultimate responsibility for the effective and efficient operation of the organization, so determining acceptable risk levels is their responsibility. The CIO or CSO may implement and enforce, but the business owner sets the tolerance. QA is focused on process reliability, not risk appetite.

Q9. IT governance is PRIMARILY the responsibility of the:

A. chief executive officer.

B. board of directors.

C. IT steering committee.

D. audit committee.

Correct Answer: B

Explanation: IT governance is primarily the responsibility of executives and shareholders, represented by the board of directors. The CEO implements governance based on board direction, the steering committee enforces it on behalf of the board, and the audit committee oversees audit-related governance activities.

Q10. When an employee is terminated from service, the MOST important action is to:

A. hand over all of the employee's files to another designated employee.

B. complete a backup of the employee's work.

C. notify other employees of the termination.

D. disable the employee's logical access.

Correct Answer: D

Explanation: A terminated employee may misuse access rights, making disabling logical access the most important and immediate action. Backups, file handovers, and notifications matter but are not as time-critical as cutting off the former employee's ability to access systems.

Q11 An IS auditor reviewing IT function roles finds individuals serving multiple roles. Which combination should be of GREATEST concern?

A. Network administrators are responsible for quality assurance.

B. System administrators are application programmers.

C. End users are security administrators for critical applications.

D. Systems analysts are database administrators.

Correct Answer: B

Explanation: A person who holds both system administration and application programming rights can do almost anything on a system, including creating back doors, modifying production code, and covering tracks. This represents the most severe segregation-of-duties violation. The other combinations are less risky and sometimes acceptable in small organizations.

Q12. Which of the following is responsible for the approval of an information security policy?

A. IT department
B. Security committee
C. Security administrator
D. Board of directors

Correct Answer: D

Explanation: Approval of an information security policy normally rests with top management or the board of directors. The IT department executes the policy, the security committee operates within the framework set by the board, and the security administrator implements and monitors the established rules.

Q13 Which of the following does a lack of adequate security controls represent?

A. Threat
B. Asset
C. Impact
D. Vulnerability

Correct Answer: D

Explanation: A vulnerability is a weakness that can be exploited by a threat. Missing or inadequate security controls expose information assets to attack and unauthorized access, which is the definition of a vulnerability. A threat acts against an asset, and impact is the result of a threat exploiting a vulnerability.

Q14 From an IT governance perspective, what is the PRIMARY responsibility of the board of directors? To ensure that the IT strategy:

A. is cost-effective.
B. is future thinking and innovative.
C. is aligned with the business strategy.
D. has the appropriate priority level assigned.

Correct Answer: C

Explanation: The board of directors is responsible for ensuring that IT strategy aligns with business strategy. Cost-effectiveness, innovation, and prioritization are important but secondary – they only deliver value when the IT strategy is first aligned with business objectives.

Q15 A poor choice of passwords and unencrypted data transmissions over unprotected communications lines are examples of:

A. vulnerabilities.
B. threats.
C. probabilities.
D. impacts.

Correct Answer: A

Explanation: Vulnerabilities are weaknesses of information resources that may be exploited by a threat. Weak passwords and unencrypted transmissions are weaknesses the security specialist can address, so they qualify as vulnerabilities. Threats are external circumstances (usually outside the specialist's control), probabilities are likelihoods, and impacts are the resulting outcomes.

Chapter 4
Information Systems Security

1. Information asset security policies, frameworks, standards, and guidelines
2. Physical and environmental controls
3. Identity and access management (IAM)
4. Network and endpoint security
5. EDR components
6. Data encryption
7. Public key infrastructure (PKI)
8 Cloud and virtualized environments virtualization overview
9. Mobile, wireless and internet of things devices
10. Security awareness, training and education
11. Information system attack methods & techniques
12. Security testing tools and techniques
13. Security monitoring logs tools & techniques
14. Security incident response management
15. Evidence collection and forensics

Practice questions and answers with explanations



Section summary

Protection of information assets is about preserving the confidentiality, integrity, and availability of data and systems in proportion to their value and the threats they face. It spans identity and access management, data classification, cryptographic controls, network and endpoint security, physical safeguards, and incident response – all underpinned by governance, policy, training, and third-party oversight. Cloud adoption, mobile work, and expanding vendor ecosystems have dissolved the traditional enterprise perimeter, so protection must now be judged against a shared-responsibility landscape rather than a fixed boundary. The auditor's role is to form a defensible opinion on whether the protection posture is adequate, proportionate, and sustainable – not simply to confirm that individual controls exist.

1. Information asset security policies, frameworks, standards, and guidelines

1.1 Information asset security policies, procedures, and guidelines

An information security policy is a set of rules, directives, and practices designed to ensure the protection of information assets. It is crafted by senior management and the board, and clearly stipulates the role of information security in the organization.

Key elements of an information security policy

- Scope: Specifies where information is located, who can access it, and where/how/when it can be stored across systems, facilities, and infrastructure.
- Policy Statement: Explains the organization's approach to information security, the operating environment, applicable laws/regulations, and types of information handled.
- Objectives: Should be SMART (Specific, Measurable, Achievable, Realistic, Time-bound). Core objectives include:
  - Confidentiality – protecting information from unauthorized access
  - Integrity – safeguarding information from unauthorized alteration
  - Availability – ensuring authorized users can access information when needed
- Monitoring: Documentation of protective measures and oversight of information system operations.
- Governance: Commitment to structured decision-making, clearly defined roles, and continuous enhancement of security practices.
- Compliance: Ensuring organizational systems align with applicable legal and regulatory requirements.
- Privacy: Guidance on protecting customer information and other critical data.

Characteristics of an effective information security policy

- Executive Support: Must have management buy-in for budget and resources.
- Business-Driven: Should be aligned with and support business objectives.
- Simple: Easy to understand and usable as a reference for all staff.
- Integrated: Addresses security of all business functions and processes.
- Accessible: Ideally posted on the organization's intranet for all to access.
- Strategic: Long-term in focus; part of organizational strategic objectives.
- Professional: Presented professionally, reinforcing the importance of adherence.
- Penalties: Should include penalties for noncompliance to cultivate a security culture.
- Flexible: Adaptable to organizational growth and new security challenges.
- Regularly Updated: Updated in line with industry developments; revisions documented.

Types of information security policies

- Organizational Information Security Policy: Primary master blueprint covering security aspects of the entire organization.
- System-Specific Policy (SysSP): Derived from the master policy; addresses security of a single system, application, or network (e.g., payroll system). Often enforced through access controls.
- Issue-Specific Policy (ISSP): Builds on the master policy to address guidelines for specific threats or activities.

Common issue-specific policy types:

Policy Type	Description
Acceptable Use Policy	Outlines the constraints an employee must accept to use an organizational system and/or network.
Change Control Policy	Guidelines for the formal process for making changes to IT, software development, and information security processes.
Access Control Policy	Outlines access controls to an organization's data and IS, and the steps users need to follow to gain access.
Incident Response Policy	Provides an organized approach to how the organization manages, remediates, and recovers from information security incidents.
IAM Policy	Deals with the authorization of systems and applications to employees, contractors, and third parties.
Remote Access Policy	Outlines acceptable methods of remotely and securely connecting to internal organizational networks.
BYOD Policy	Outlines requirements that allow employees to use personal devices to access organizational infrastructure and reduce associated risk.

Information security procedures and guidelines

- Procedures: Step-by-step tasks for specific objectives. Lowest level in the documentation chain; must be detailed enough for all employees.
- Guidelines: Recommendations when specific standards do not apply. Less prescriptive than procedures; open to interpretation and do not need to be strictly followed.

1.2 Information security frameworks and standards

An information security framework is a set of processes defining policies and procedures for implementing and managing an information security program. Frameworks assist in managing risk, reducing vulnerabilities, and achieving compliance. Organizations should customize frameworks to solve specific problems.

Common and frequently used information security frameworks and standards:

Framework / Standard	Description
ISO/IEC 27001	International standard specifying procedures for development and maintenance of an information security management system (ISMS). Addresses organizational, people, physical, and technological controls holistically.
COBIT	IT governance framework specifying best approaches for governing enterprise IT to minimize IT risk while ensuring efficiency in resource use.
NIST Cybersecurity Framework (CSF)	Consists of standards, guidelines, and best practices that assist organizations in improving their management of cybersecurity risk. Flexible and integrable with existing processes.
SABSA	Model and methodology for risk-driven, opportunity-focused information security enterprise architectures and service management. Life cycle: strategy, design, implementation, managing and measuring.
TOGAF	Enterprise architecture framework used to define business objectives and align them with architecture objectives. Ensures adoption of consistent standards and methodologies.
PCI DSS	Standard developed by major credit card companies for enhancing payment account data security. Applies to organizations that store, process, or transmit cardholder data.
CIS Critical Security Controls	Provides technical security and operational controls applicable to any environment. Covers inventory, data protection, log management, malware, and penetration testing.
ITIL	Framework promoting standardization of IT service management. Standardizes selecting, planning, delivering, and maintaining IT lifecycle processes.
Cloud Control Matrix (CCM)	Developed by CSA; composed of 197 control objectives in 17 domains covering all key aspects of cloud technology. De facto standard for cloud security.
STAR Program	Developed by CSA as an assurance framework for cloud service providers. Combines transparency, rigorous auditing, and harmonization of cloud security standards.

Benefits of using a framework

- Improved Security Management: Encourages active implementation of security measures and controls.
- Effective Risk Management: Adherence reduces breach risk and instills a culture of risk management.
- Effective Incident Response: Ensures an effective incident response capability in case of breach.
- Increased Market Reach: Certification opens new business opportunities and makes the organization eligible for contracts requiring specific frameworks.
- Increased Security Reliability: Framework-based approach ensures adequate controls, processes, and procedures are in place.

1.3 Information security baselines

An information security baseline is the minimum level of security that a system, network, or device must adhere to. It maps to industry standards and mechanisms used to secure information systems. A baseline plan should be followed by a full security evaluation.

Baseline security topics and their objectives include: environment/inventory management, malware protection (antivirus with auto-updating DAT files), password policies, automatic patching, minimizing unnecessary system services, vulnerability management via organizationwide scans, and offsite backup storage.

2. Physical and environmental controls

2.1 Environmental exposures and controls

IT infrastructure is exposed to environmental threats primarily from naturally occurring events. IS auditors must evaluate applicable controls across all environmental dimensions.

Power failure categories

- Blackout (Total Failure): Complete loss of electrical power spanning a single building to an entire geographical area. Caused by weather or utility capacity issues.
- Brownout (Severely Reduced Voltage): Failure to supply power within acceptable range (108–125V AC in the US). Can permanently damage electronic equipment.
- Sags, Spikes, and Surges: Temporary rapid decreases or increases in voltage. Can cause data loss, data corruption, network errors, or physical hardware damage.
- Electromagnetic Interference (EMI): Caused by electrical storms or noisy equipment. May cause systems to hang or crash.

Power interruption controls

- Short-term (milliseconds): Prevented by surge protectors.
- Intermediate-term (seconds to 30 minutes): Controlled by Uninterruptible Power Supply (UPS) devices.
- Long-term (hours to days): Requires alternative power generators (diesel, gasoline, or propane-powered).

Fire protection controls

- Alarm Control Panels: Should be separated from burglar systems, accessible to fire departments, located in weatherproof boxes, and comply with local/national regulations.
- Smoke and Water Detectors: Smoke detectors installed above and below ceiling tiles; water detectors under raised floors and near drains. Both should produce audible alarms and link to monitored stations.
- Fire Suppression Systems: Auto-activate on heat detection. Should be inspected annually and segmented to localize fires. Types include: wet-pipe sprinklers, dry-pipe systems, FM-200 (preferred), and Novec 1230.
- Computer Room Location: Best location is a middle floor (3rd–6th) to reduce flooding risk. Avoid basements, top floors, and areas adjacent to high-risk zones (paper storage, chemical plants).

Emergency and protective controls

- Electrical Surge Protectors: Reduce risk of equipment damage from power spikes. Typically built into UPS systems.
- Emergency Power-Off Switches: Two switches: one inside the computer room, one outside. Should be clearly labeled, accessible, but shielded from accidental activation.
- Redundant Power Lines: Power lines from two substations reduce risk of single-line failure.
- Fire-Resistant Infrastructure: Walls surrounding the Information Processing Facility (IPF) must have at least a two-hour fire resistance rating. Wiring should be placed in fire-resistant conduit.
- Inhibited Activities: Food, drink, and tobacco must be prohibited from the IPF to prevent contamination and fire risk.

2.2 Physical access exposures and controls

Physical exposures can result in financial loss, legal repercussions, loss of credibility, or loss of competitive edge. They originate from natural and human-made hazards.

Physical Access Exposures Include

- Unauthorized entry
- Vandalism or theft of equipment/documents
- Copying or viewing sensitive information
- Alteration of sensitive equipment or information
- Blackmail and embezzlement
- Wiretapping and eavesdropping

Physical access controls

- Bolting Door Locks: Traditional metal key; stamped 'do not duplicate'; issued under strict management control.
- Combination Door Locks (Cipher Locks): Numeric keypad; combination changed regularly or when employee with access leaves.
- Electronic Door Locks: Magnetic/chip-based card, token, or biometric. Cards assigned to identifiable individuals; can be remotely deactivated; can trigger silent/audible alarms.
- Biometric Door Locks: See Section 5.3.16.
- Manual Logging: Visitors sign log with name, company, reason, person to see, and entry/departure time.
- Electronic Logging: All access logged; unsuccessful attempts highlighted.
- Identification Badges: Worn by all personnel; visitor badges a different color. Photo IDs can also serve as electronic card keys.
- Video Cameras: Strategically located; monitored by security guards; recordings retained for future playback.
- Mantrap / Airlock Entrance: Two doors; second door operates only after first closes and locks with one person in holding area. Reduces piggybacking risk.
- Lighting: Adequate lighting deters unauthorized access and improves effectiveness of video surveillance.
- Security Guards: Useful in conjunction with video cameras and locked doors; external guards should be bonded.

2.3 Industrial control systems (ICS) security

ICSs refer to systems that manage and operate infrastructure-supporting functions such as water, power, and transportation. Types include SCADA systems, Programmable Logic Controllers (PLCs), and Remote Terminal Units (RTUs).

Key ICS security risks

- Poor Security Posture: Focuses only on physical security; gives less thought to network and application security.
- Improper Input Validation: Content provided to ICS applications may allow unintended functionality or privilege escalation.
- Improper Authentication: Most ICS remote elements do not authenticate commands, leading to execution of illegitimate commands.
- Network Design Weaknesses: Typically lack defense-in-depth strategies, defined zones, and port security.
- Technological Depreciation: Legacy systems with limited processing capacity cannot run modern secure applications or cryptographic modules.
- Weak ICS Protocols: Designed before modern threat knowledge; often lack adequate encryption or content protection.

ICS security best practices

- Conduct Asset Inventory: Full visibility of ICS assets and network connectivity; classify by criticality.
- Monitor Network Baselines: Establish baselines and detect anomalies against them.
- Segment ICS Networks: Use firewalls understanding ICS protocols; segmentation prevents general IS attacks from reaching ICS.
- Implement POLP: Principle of Least Privilege restricts damage even if access is obtained.
- Deploy IDS/IPS: Detect and immediately block exploitation of known vulnerabilities.
- Implement Redundancy: For critical components; ensures production continuity if one line fails.
- Supply Chain Security: Assess third-party vendors for vulnerabilities and malicious code.

3. Identity and access management (IAM)

Identification and Authentication (I&A) is the first line of defense for most systems because it prevents unauthorized access. The identification system and authentication system are separate. Key difference: identity does not normally change, but authentication tokens must be regularly replaced.

3.1 IAM framework

An IAM framework consists of policies, procedures, processes, and technologies that enable the management of identity and access information. Its purpose is to provide the right access to the right people at the right time, with minimum interference. IAM consists of four major service components:

- Authentication Services: SSO, Federated Identity Management (FIM), MFA, biometric authentication, adaptive authentication, session management.
- Authorization Services: Rule-based access control, RBAC, attribute-based access control, privileged access management, remote authorization.
- User Management: Provisioning, deprovisioning, self-service, credential management, delegated administration.
- Central User Repository: Directory services, identity providers (IdPs), data synchronization, identity stores, directory federation, virtual directory.

Benefits of IAM

- Improves Regulatory Compliance: Enables formal access control policies, user activity tracking, and audit evidence.
- Enhances Data Security: Narrows points of failure; reduces credential theft by adding authentication layers (defense in depth).
- Promotes Digital Transformation: Centralizes IAM while maintaining security without affecting user experience.
- Improves Productivity: SSO allows employees to access multiple tools with one set of credentials.
- Streamlines Access Control: Simplifies provisioning and administration in complex cloud environments.

3.2 IAM life cycle management

Identity life cycle management creates and maintains a digital identity for every human or non-human entity on a network.

IAM Life Cycle Stagev	Description
Enrollment	Creating and/or registering user accounts. Methods: automatic enrollment (system-initiated), self-enrollment, or manual enrollment.
Role Determination	Determining the roles of enrolled users, which in turn determines privileges and access requirements. Note: a role itself does not inherently contain permissions.
Provisioning	Specifying access levels to grant a user based on RBAC policies. Some users may update accounts; others may be restricted to viewer status.
Review / Updating	Continuously updating roles, privileges, and access requirements as they change (e.g., promotions). IS auditors should watch for privilege creep.
Deprovisioning	Revoking access when users leave or change roles. Actions include: deleting the account, disabling it immediately, or retaining and disabling it later.

3.3 Authentication, authorization, and accountability (AAA)

A subject (entity that can access/manipulate objects) must be identified, then authenticated, then authorized to access objects. The whole chain operates within accountability through tracking user access and resource consumption.

Authentication Methods

- Password Authentication: Most common (something you know). IS auditor should encourage strong password practices over convenience.
- Multifactor Authentication (MFA): Two or more factors: knowledge (something you know), possession (something you have), biometric (something you are).
- Adaptive/Risk-Based Authentication: Changes requirements in real time based on risk level – e.g., extra factors required from untrusted devices.
- Token-Based Authentication: Possessive technology (something you have); user logs in once to receive encrypted tokens used for subsequent access.
- Certificate-Based Authentication: Uses digital certificates to authenticate subjects.
- LDAP Authentication: Standards-based protocol storing user/group metadata. Authenticates via bind operation. Microsoft Active Directory is the most common implementation.
- Smart Card Authentication: Embedded microprocessor card offering MFA, cashless vending, and photo ID capabilities.

Single sign-on (SSO)

SSO consolidates all platform authentication and authorization functions into a single centralized administrative function. Users enter credentials once to access all configured applications.

- SSO Advantages: Encourages stronger single passwords; simplifies administration; reduces password reset overhead; reduces login time.
- SSO Limitations: Support for all OS environments is difficult; high development costs; centralized nature creates a single point of failure – mitigated by strong authentication (complex passwords, biometrics).

Authorization

Authorization is the process of granting access to services or resources based on the authentication result. It enforces least privilege, need-to-know, and separation of duties.

- Coarse-Grained Authorization: High-level determination of whether a subject may access an object; does not specify what the subject can do.
- Fine-Grained Authorization: Refines coarse-grained to restrict access based on specific conditions (e.g., role + tenure requirement). Enforces POLP, need-to-know, and SoD.
- Access Control Lists (ACLs): Register of users, groups, machines, and processes with permission to use a system resource, and the types of access permitted.
- File-Level Access Restrictions: Read/inquiry/copy only | Write/create/update/delete | Execute only | Combination.

Accountability

Accountability tracks user activity and resource consumption. All actions from identification through authentication and authorization should be logged. Supports nonrepudiation, deterrence, fault isolation, and legal action.

3.4 Zero-trust architecture (ZTA)

ZTA is a cybersecurity framework that requires every access request to be authenticated, authorized, and validated for security configuration and posture before being granted access. Motto: "Never Trust, Always Verify."

Core principles of ZTA

- All Data and Computing Services are Resources: A network may be composed of multiple classes of devices, including those sending data to SaaS systems.
- Communication is Always Secured: Location alone does not imply trust; internal assets must meet the same requirements as external ones.
- Session-Based Access: Access granted per-session based on trust evaluation; based on POLP.
- Dynamic Policy-Based Access Control (PBAC): Access defined by security policies with POLP restricting both visibility and accessibility.
- Monitoring and Measurement: No asset is inherently trusted; enterprise continuously evaluates security posture.
- Dynamic Authentication and Authorization: Constant cycle: obtain access → scan/assess threats → adapt → reevaluate trust.
- Intensive Information Gathering: Collects data on assets, network traffic, and access requests to improve policy enforcement.

ZTA best practices

- Monitor network traffic and connected devices for verification and authentication
- Regularly update devices; patch vulnerabilities quickly
- Implement POLP for all users to minimize compromise damage
- Segment the network to contain and identify breaches early
- Implement hardware-based security keys for MFA (more secure than soft tokens)
- Subscribe to latest threat intelligence feeds
- Enforce strict password requirements organization-wide

3.5 Privileged access management (PAM)

PAM consists of the information security strategies and technologies for controlling privileged or elevated access levels for users, accounts, processes, and systems. It is a component of IAM.

Types of privileged accounts

- Administrative Accounts: Non-personal accounts providing administrative access to local hosts or domain-wide systems.
- Emergency Accounts: "Break glass" accounts giving unprivileged users admin access in emergencies.
- Service Accounts: Privileged accounts used by applications/services to interact with the OS.
- Application Accounts: Used by applications to access databases, run batch jobs, or interact with other applications.
- SSH Keys: Access control protocols providing direct root access to critical systems.

PAM Benefits

- Reduces Attack Surface: Limits exposure across networks, servers, and identities.
- Enforces POLP: Prevents privilege creep.
- Resolves Security Risk: Eliminates shared admin passwords and long-standing static passwords.
- Reduces Data Breach Risk: Both internal and external threats are mitigated.

PAM best practices

- Implement POLP First: No PAM solution can succeed without POLP as the foundation.
- Track All Privileged Accounts: All accounts must be incorporated into the PAM solution.
- Consider Temporary Privilege Escalation: Grant access only when needed, then revoke it.
- Implement RBAC: PAM requires differentiated role-based access levels to function correctly.
- Automate PAM Processes: Reduces human error and increases operational efficiency.
- Monitor and Audit: Actively log all privileged account activity.
- Limit Lateral Movement: Remove all endpoint users from local admin groups on workstations.
- Invest in Red Team Exercises: Validate resilience against real-world attacks.

3.6 Types of access controls

Access Control Type	Description
Mandatory Access Control (MAC)	Logical access control filters that cannot be controlled or modified by normal users. Only administrators may change resource categories. Prohibitive – anything not expressly permitted is forbidden. Used in highly sensitive environments.
Discretionary Access Control (DAC)	Protection activated or modified at the discretion of the data owner. Cannot override MACs; acts as an additional filter. The data owner selects who is permitted to access the resource.
Rule-Based Access Control (RuBAC)	Access rules are predefined via ACLs and constantly evaluated. Rules are enforced equally for all users (e.g., firewall rules). Simple but complex at granular level.
Role-Based Access Control (RBAC)	Bases access restriction on user roles. Custom roles are created and access is revoked when no longer needed. Industry-standard best practice in widespread use.
Attribute-Based Access Control (ABAC)	Governs access based on user attributes, resource/object attributes, and environmental attributes (department, location, date). Automates authorization decisions.
Policy-Based Access Control (PBAC)	Combines users' business roles with policies to determine access privileges. Uses policy guidance to determine which access role each person must have in organizational systems.

3.7 Biometrics

Biometric access controls authenticate a user's identity based on unique, measurable physical or behavioral attributes. Performance is measured by four key metrics:

- FER (Failure to Enroll Rate): Proportion of people who fail to be enrolled successfully.
- FRR (False Rejection Rate / Type 1 Error): An authorized subject is rejected. Causes frustration but is not a direct security issue.
- FAR (False Acceptance Rate / Type 2 Error): An unauthorized subject is falsely accepted. The most serious security concern.
- CER (Crossover Error Rate): The point where FRR = FAR. Also called Equal Error Rate (EER). Lower CER = better overall accuracy.

Biometric types (best to lowest accuracy/CER)

Biometric Type	Details
Palm	Analyzes ridges and valleys of the palm. High accuracy and social acceptance.
Hand Geometry	Measures physical characteristics (length, width, thickness) of the hand in 3D. ~90 measurements. Low storage (10–20 bytes). Lacks uniqueness.
Iris	Captures unique iris patterns. Over 400 characteristics, ~260 used. No contact required. High cost and high storage requirement.
Retina	Scans retinal blood vessel patterns. Very accurate but invasive. High user resistance.
Fingerprint	Scans ridge patterns. Low cost, small device size. Requires physical contact. Possible quality issues from residue.
Face Recognition	Analyzes facial features via video camera. Fast and non-invasive. Lacks uniqueness; people who look alike may fool the device.
Signature Dynamics	Analyzes signing speed, pen pressure, stroke length, and timing. Fast and low cost. Inconsistency in signing is a disadvantage.
Voice Recognition	Converts acoustic signals to a digital template. Deployable in telephone apps. Subject to background noise and voice changes.

Biometric audit considerations

- Privacy Concerns: Cultural and religious considerations; intrusive systems may be resisted.
- Personal Health: Chronic conditions or contagious disease concerns may affect reliability.
- Cost: Some biometric systems are expensive; IS auditor should assess ROI.
- Accuracy: FAR is the most critical factor – determines probability of unauthorized access.

Compliance: All biometric systems must comply with applicable laws and privacy regulations.

3.8 Federated identity management (FIM)

FIM (also known as identity federation) is an arrangement between multiple enterprises to use common identification data to provide access to organization systems. The main objective is making access easier for users. It links a user's identity across multiple security domains.

FIM VS. SSO comparison

Protocol	Description
SAML	Open XML standard for exchanging authentication and authorization data between an IdP and applications/services. Facilitates access to multiple domains with a single credential set. Also used by SSO.
OAuth	Allows third-party services to exchange user information without sharing user credentials. Uses authorization tokens to prove user identity rather than sharing passwords.
OpenID Connect (OIDC)	Adds identity layer on top of OAuth 2.0. Login flow is essentially the same as SAML but uses JSON instead of XML. Adds authentication layer on top of authorization.
SCIM	Standard for automatically synchronizing identity information between two systems. Keeps user information updated as events change (new users, deletions). Key component of IAM provisioning.

FIM VS. SSO comparison

Aspect	FIM	SSO
Extent of Access	Access across multiple enterprise domains in a federated configuration. FIM supports and extends SSO to multiple domains.	Access to multiple applications within the same organization or domain.
Centralization	Decentralized – more scalable and easier to manage than SSO.	Centralized – users authenticate with a single provider.
Use Case	Consumer-facing websites and applications across multiple organizations.	Business environments where employees need access to email, shared files, internal applications.
Security Level	Less secure – compromised credentials could access multiple organizations.	More secure – virtually no possibility of cross-entity credential compromise.

3.9 Password security

Passwords are the most common authentication method. They are also the most targeted. IS auditors should ensure strong password policies are in place and enforced.

Password best practices

- Length and Complexity: Minimum length depends on threat model. Should include upper/lowercase, numbers, and punctuation. Avoid dictionary words, user ID derivatives, and personal details.
- History: Maintain encrypted history of at least 13 previous passwords; prohibit reuse.
- Change Frequency: 30 days for privileged access; 90 days for regular access. Mandatory change at first login.
- Lockout Policy: Maximum 5 consecutive failed attempts leads to account suspension until reset by administrator.
- Session Timeout: Screensaver/timeout after 15 minutes of inactivity; re-authentication required.
- Storage: Always encrypted (hashed with strong algorithm); never displayed in any form.

Common password attacks

Attack Type	Description
Password Sniffing	Passive attack that intercepts unencrypted network transmissions to capture passwords. Also includes guessing default passwords.
Phishing	Social engineering technique that tricks users into revealing passwords, ostensibly to solve a critical problem. Attackers may also guess default passwords.
Brute-Force Attack	Uses combinations of personal information (birthdate, anniversary, name, etc.) derived from social media to systematically guess passwords.
Dictionary Attack	Uses common words and phrases from dictionaries to guess passwords. Countered effectively by lockout policies after repeated failed attempts.
Keylogger Attack	Records keystrokes to capture passwords as they are typed. Highly accurate; detection is difficult once installed. Prevention is the best defense.
Rainbow Attack	Uses precomputed hash tables (rainbow tables) to reverse-lookup hashed passwords. Tables for common algorithms are available on the dark web. Salting mitigates this attack.
Credential Stuffing	Exploits password reuse by attempting stolen username/password combinations (from dark web). Users should be educated to use unique passwords.
Password Spraying	Targets many users at once with a small set of common passwords to avoid lockout triggers. Often targets SSO and cloud-based platforms.

4. Network and endpoint security

Enterprises prevent and detect most network attacks through perimeter security controls. Firewalls and IDSs provide protection at borders between trusted and untrusted networks. Effective security requires understanding both the infrastructure and the protocols in use.

4.1 Types of networks

- PAN (Personal Area Network): Microcomputer network for communications among devices used by one individual. Range ~10 meters. Wireless versions (WPANs) use Bluetooth (piconet) or IrDA.
- LAN (Local Area Network): Covers limited area (home, office, campus). Higher data transfer rates, smaller geographic range. Common technologies: Ethernet and Wi-Fi.
- SAN (Storage Area Network): Dedicated network connecting storage devices to servers. Provides block-level storage. Vulnerable to authentication weaknesses and lateral movement attacks.
- WAN (Wide Area Network): Covers broad area (city, region, nation, international). Internet is the largest example. Connects LANs and other networks.

4.2 Virtual private networks (VPN)

A VPN extends the corporate network securely through encrypted packets sent via virtual connections over the public Internet. Platform independent; enables secure remote connectivity without expensive dedicated leased lines.

VPN types

- Remote-Access VPN: Connects telecommuters and mobile users to the enterprise WAN securely.
- Intranet VPN: Connects branch offices within an enterprise WAN.
- Extranet VPN: Gives business partners limited access to corporate networks (e.g., manufacturer and suppliers).

VPN protocols

VPN Protocol	Description
IPSec	Implemented in two modes: Tunnel mode encrypts the entire packet (header + data); Transport mode encrypts only data. Commonly used for site-to-site VPNs.
IKEv2	Useful for re-establishing temporarily lost connections. Most secure and robust; ideal for mobile devices switching between Wi-Fi and mobile data.
PPTP	Encrypts multi-protocol traffic and wraps it in an IP header. Used for remote access and site-to-site VPNs. Has known security vulnerabilities requiring compensating controls.
SSTP	Uses HTTPS (TCP 443) to pass traffic through firewalls and proxies. Wraps PPP traffic over SSL/TLS for strong authentication and encryption.
L2TP/IPSec	Combines PPTP and L2F. Relies on IPSec (transport mode) for encryption. Supports perfect forward secrecy. Both client and server must support L2TP and IPSec.
OpenVPN	Open-source. Uses custom protocol with SSL/TLS for key exchange. Can traverse NATs and firewalls. Supports secret key, certificate, or username/password authentication.

VPN best practices

- Establish and regularly review a VPN policy with minimum security requirements
- Select standards-based VPNs (IKE/IPSec preferred over SSL/TLS custom code)
- Implement strong cryptography: TLS 1.3, AES 256-bit, FIPS-validated algorithms
- Configure VPNs with MFA; replace passwords with client digital certificates
- Practice continuous patch management for VPN software
- All VPN traffic should pass through a full security stack (WAF, IDS/IPS)
- Monitor and log VPN usage to detect suspicious activities

4.3 Firewalls

A firewall is a device installed at the point where network connections enter a site. Firewalls apply rules to control traffic flowing in and out. Most organizations follow a deny-all philosophy – access is denied unless a specific business reason is provided.

Firewall types

Firewall Type	Key Characteristics
Packet Filtering	1st generation. Examines packet headers (IP addresses, port numbers). Simple and fast but vulnerable to IP spoofing, source routing, and miniature fragment attacks.
Application-Level Gateway	Uses proxies per service (HTTP, FTP, Telnet). Hides internal network addresses via NAT. More secure but slower and less scalable.
Circuit-Level Gateway	Validates TCP/UDP sessions via a single general-purpose proxy. More efficient than application-level. Commercially rare.
Stateful Inspection	Tracks destination IPs of outbound packets and matches inbound responses. More efficient than application proxies. Complex to administer.
Next Generation Firewall (NGFW)	Combines packet filtering, stateful inspection, DPI, IDS/IPS, application awareness, and threat intelligence. Operates up to OSI Layer 7. Blocks advanced malware.
Web Application Firewall (WAF)	Protects web applications by filtering HTTP traffic. Detects XSS, SQL injection, CSRF, L7 DDoS. Operates at OSI Layer 7. Comes in blocklist, allowlist, network-based, host-based, and cloud-based variants.

Common packet filter attacks

- IP Spoofing: Attacker fakes the IP address of a trusted host to pass through firewall rule base.
- Source Routing Specification: Attacker defines a packet route that bypasses the firewall.
- Miniature Fragment Attack: Attacker fragments IP packets so only the first packet is examined and residual packets pass unreviewed.

Firewall implementation examples

- Screened-Host Firewall: Packet-filtering router + bastion host. Intruder must penetrate two separate systems. Router filters allow traffic only to the bastion host.
- Dual-Homed Firewall: Two or more network interfaces on a bastion host. More restrictive than screened-host. One interface for public servers, another for private network.
- DMZ / Screened-Subnet Firewall: Two packet-filtering routers + bastion host. Most secure: intruder must penetrate three separate devices. Private network addresses not disclosed to Internet.

Firewall issues to watch

- False sense of security – most incidents are caused by insiders not controlled by firewalls
- Circumvention via modems connecting directly to ISPs
- Misconfigured firewalls allowing unknown/dangerous services through
- Most firewalls operate at network layer and cannot stop application-based attacks (SQL injection, buffer overflow)

4.4 Network attached storage (NAS) security

NAS consists of a centralized file server enabling multiple users to store and share files over networks. NAS security helps organizations manage their NAS proactively rather than reactively.

NAS Vulnerabilities

- Unsecure network configurations (open networks, unencrypted sessions)
- Unsecure or shared passwords
- Insufficient authentication allowing unauthorized access
- Leakage from connected IoT devices
- Exposure to malware and ransomware attacks
- Command injection attacks allowing root access

4.5 Network time protocol (NTP)

NTP synchronizes system clocks over packet-switched data networks. Critical when security solutions depend on consistent timekeeping (e.g., Kerberos). NTP is built on UDP and operates at the OSI Application Layer.

- Key Benefits: Improved security, reduced spoofing attacks, improved log accuracy and correlation, improved availability and reliability.
- Key Risks: Inefficient security options (MD5-based symmetric encryption), continued spoofing vulnerability at client level, vulnerability to Kiss-of-Death (KoD) attacks, dependency on time-sensitive security protocols.

4.6 Network segmentation

Network segmentation is splitting a network into smaller parts to improve performance and security. Also known as network partitioning or network isolation. Results in multiple network zones, each with specific security requirements.

Network segmentation VS. micro-segmentation

Feature	Comparison
Level	Network Segmentation = physical (hardware-based); Micro-segmentation = virtual (software-based)
Granularity	Micro-segmentation is more granular; each device/app gets its own virtual segment
Traffic Focus	Network segmentation = north-south traffic (client-server); Micro-segmentation = east-west traffic (lateral)
Similarities	Both reduce network attack surface; treat as related concepts with similar benefits, challenges, best practices

Methods of network segmentation

- VLAN Segmentation: Uses VLANs/subnets to create smaller segments; IP addresses segment the network. Limitation: complex, requires regular re-architecting.
- Firewall Segmentation: Firewalls deployed inside the network create internal zones, separating functional areas.
- SDN Segmentation: Modern approach using SDN-automated network overlays; typically used for micro-segmentation. Challenges: complex, difficult to manage.
- Host-Based Segmentation: Special software installed on endpoints reports to a central location; uses workload telemetry and visualization for multi-cloud environments.

Benefits of network segmentation

- Improves Operational Performance: Reduces network congestion; better load balancing; channels traffic to specific zones.
- Limits Attack Damage: Contains attacks within specific zones; prevents malware from spreading to other zones.
- Protects Vulnerable Devices: Prevents malicious traffic from reaching devices vulnerable to attacks.
- Improves Compliance: Minimizes compliance scope; separates in-scope systems (e.g., payment processing) from others.
- Enhances Security: Creates multi-layer perimeters; implements defense-in-depth; hinders lateral movement.
- Improves Network Monitoring: Greater visibility in segments; easier to detect threats; quicker threat isolation.

Network segmentation best practices

- Avoid under or over segmentation – aim for optimal segmentation
- Perform regular network audits (vulnerability assessments + penetration tests)
- Control third-party access – maintain specific access portals for each third party
- Combine similar network resources into separate zones
- Define access rights clearly to prevent unauthorized revision of segmentation design
- Implement POLP (Principle of Least Privilege)

4.7 Endpoint security

An endpoint is any device enabling an employee to connect to the organizational network. Endpoint security refers to security measures implemented on each endpoint. The growth of BYOD and IoT has dramatically increased potential endpoints.

Common endpoint types

Category	Examples
Computing Devices	Laptops, tablets, servers, mobile phones, smartwatches
IoT/Smart Devices	IoT-enabled smart devices, industrial machines, medical devices
Financial/Other	Automated teller machines (ATMs), printers

Benefits of endpoint security

- Keeps Connected Devices Secure: Organizations can reduce risk and detect suspicious activity regardless of employee location.
- Promotes Data Security: Data is the most valuable asset; losing it can risk insolvency.
- Facilitates Secure Remote Working: Remote work and BYOD policies make perimeter security insufficient; endpoint security fills the gap.

Endpoint detection and response (EDR)

EDR refers to tools and technologies that continuously monitor endpoints to detect suspicious behavior and trigger automatic responses.

5. EDR components

Component	Description
Endpoint Data Collection Agents	Software agents that monitor and collect data about endpoint status. Data (running processes, activity volume, connection status) is transmitted to a central database.
Automated Response	Preconfigured rules that recognize known security attacks or breaches. Triggers automatic responses including alerting personnel and logging off users.
Analysis and Forensics	Real-time analytics for incidents not resolved automatically. Uses sophisticated algorithms for large data correlation and pattern analysis. Includes forensic tools for threat hunting and post-mortem analysis.

EDR implementation approaches

- On-Location (On-Premises): Locally hosted data center acts as hub for management console. Legacy model; creates security silos since administrators can only manage endpoints within their perimeter.
- Cloud: Centralized management console in the cloud; devices connect remotely. Removes silos and enhances administrator reach.
- Hybrid: Mix of on-location and cloud solutions; prevalent with remote working increase.

Key EDR features

- Advanced antimalware and antivirus protection
- ML capabilities to detect zero-day threats in real time
- Proactive web security for safe browsing
- DLP to prevent data loss and exfiltration
- Firewalls to block undesirable network traffic
- Email gateways to block social engineering attacks
- Computer forensics for quickly isolating infections
- Centralized management console for visibility and simplified operations

Extended detection and response (XDR)

XDR takes a broader view than EDR by integrating security across endpoints, cloud computing, email, and other solutions. Provides extended visibility, analysis and response across endpoints, workloads, users and networks.

Three parts of XDR

- Data Analysis: Monitors/collects data across multiple security layers; correlates context from alerts into high-priority alerts; avoids overwhelming security teams.
- Detection: Superior visibility to search alerts requiring immediate response; creates behavioral baselines; detects threats using software, ports, and protocols; investigates threat origins.
- Response: Contains and eliminates threats; updates security policies. Unlike EDR (endpoints/workloads only), XDR addresses all security control points including servers and networks.

XDR benefits

Benefit	Description
Granular Visibility	Full visibility into security environment; shows hidden threats, entry points, victims, origins, and spread
Prioritizes Threats	Groups alerts using MITRE ATT&CK framework; surfaces only the most important ones
Improves Speed	Automation eliminates manual steps; handles large data volumes with complex processes
Improves Operational Efficiency	Holistic view of threats; centralized data collection; detects authorized software used to infiltrate
Sophisticated Responses	Tailors responses to specific systems; incorporates lateral movement, anomalous connections, beacons, data exfiltration
Improves Prevention	Combines threat intelligence with adaptive ML; continuous monitoring with automated response
Improves Control Processes	Allows/denies traffic; fewer false positives; unified platform (not aggregation of endpoint solutions)

5.1 Data loss prevention (DLP)

Definition

DLP is a set of tools and processes implemented to prevent loss, misuse, or unauthorized access to sensitive data. Also called data leakage prevention. DLP software classifies regulated, confidential, and business-critical data, identifies policy violations, and enforces remediation.

Consequences of Data Loss

- Reduced productivity as employees become idle
- Increased costs to replace or regain control of data
- Exposure to legal actions from loss of sensitive data
- Loss of business due to customers losing trust (lower revenue/profitability)
- Risk of business closure if organizations fail to raise funds for data recovery

Types of DLP systems

Type	Description
Network-Based DLP	Scans all outgoing data; if restricted data is sent to unauthorized destination, detects and blocks in real time; sends alert; may quarantine or encrypt data. Uses DPI (Deep Packet Inspection) to read packet payload content.
Endpoint-Based DLP	Scans files stored on systems and files sent to external devices (printers, flash drives). Uses keyword scanning; blocks copy/print jobs. Managed centrally via an agent.
Cloud DLP	Monitors and protects data stored in the cloud. Uses predefined data types to identify sensitive data; blocks exposures. Example: removes sensitive attachments from emails.

Data loss risk

Area of Risk	Key Causes
Technology	Loss/theft of devices, unencrypted storage, software vulnerabilities, failure to patch, insecure remote access, poor system programming
Process	Poor data governance, no data retention policy, no risk assessments, not enforcing POLP, poor data monitoring, failure to close expired accounts
People	Negligence, unintentional transmission, lack of training, data theft, insider threats, misuse of passwords, sharing work devices
Threat Actors	Malware propagation, software corruption, sabotage by malicious insiders
Natural Disasters	Fires, earthquakes, tornadoes, power outages, liquid spillages, overheating

DLP use cases

- Compliance: Identifies, classifies, and tags sensitive data; monitors activities for compliance purposes
- Intellectual Protection: Classifies IP in structured and unstructured forms; protects against unwanted exfiltration
- Data Visibility: Tracks data on endpoints, networks, and cloud; provides visibility into how users interact with data
- Pervasiveness: Spans multiple environments including cloud and complex supply chain networks
- Frequent Data Breaches: Protects against nation states, cybercriminals, and malicious insiders
- Value of Stolen Data: Guards against financial data theft (credit cards, banking info sold on dark web)

DLP solutions and data states

Data State	DLP Mechanism	Key Notes
Data at Rest	Crawlers deployed remotely to scan data stores	Crawlers log location of specific information sets based on DLP management console rules
Data in Transit	Network appliances or embedded technology to capture/analyze traffic	DPI at the core; can alert and block data flows in real/near-real time
Data in Use	Agent software on endpoints monitoring user actions	Monitors copying to flash drives, printing, cutting/pasting between applications

DLP content analysis methods

Method	Description
Regular Expression Matching	Matches specific data patterns (e.g., 16-digit credit card numbers). Good first filter; high false-positives without checksum validation.
Structured Fingerprinting	Algorithms map data to shorter text strings (fingerprints); used for structured data like databases. Also known as Exact Data Matching (EDM).
Exact File Matching (EFM)	File hashes matched against exact fingerprints; determines if file content changed. Low false positives. Not effective for files with different versions.
Indexed Document Matching (IDM)	Fingerprinting applied to unstructured data (Office docs, PDFs, JPEGs). Detects derived content copied from source documents.
Lexicon Matching	Also called conceptual analysis. Analyzes unstructured data using dictionary terms. Requires customization.
Statistical Analysis	Uses ML and Bayesian analysis for obscure sensitive information. Requires large data volumes; yields both false positives and negatives.
Categorization	Sets prebuilt categories with rules for highly sensitive data. Determines compliance violations.

DLP deployment best practices

- Create a DLP policy aligned to the organization's requirements
- Define business and security requirements before deploying
- Involve all employees; adopt a stakeholder approach
- Secure senior management support with all department leaders
- Deploy in appropriate mode: Passive (monitoring only) or Active (blocks leakage)
- Incorporate strong encryption technologies
- Be aware that most threats are launched internally (insider threats)
- Classify data by criticality; start with most valuable/sensitive data
- Conduct risk assessments for data distributed to devices or third parties
- Document controls and changes to the environment
- Provide training and development to reduce accidental data loss

DLP Risk, Limitations and Considerations

- Improperly Tuned Modules: Test in monitor-only mode first; involve business and IT stakeholders; ensure access for critical content during off-hours
- Excessive False Positives: Avoid excessive templates; roll out in phases focusing on highest risk first
- Encryption: DLP combined with encryption provides stronger protection
- Graphics: DLP cannot intelligently interpret graphics files – significant gap in control

6. Data encryption

Encryption converts plaintext into ciphertext using a mathematical function and a key. Decryption reverses the process. Encryption is limited in that it cannot prevent loss or modification of data; key protection is paramount.

Primary Uses of Encryption

- Protect data in transit over networks from unauthorized interception and manipulation
- Protect information stored on computers from unauthorized viewing and manipulation
- Deter and detect accidental or intentional alterations of data
- Verify authenticity of a transaction or document

Elements of Encryption Systems

- Encryption Algorithm: Mathematically based function that encrypts/decrypts data
- Encryption Key: Information used by the algorithm to make the process unique. Wrong key produces unreadable form.
- Key Length: Longer keys are more difficult to compromise in brute force attacks; time required grows exponentially with key length

Encryption Types

Type	Key Details
Symmetric (Secret Key)	Same key for encryption and decryption (bidirectional). Key must be shared out of band. Advantages: shorter keys, less processing power, ideal for bulk encryption. Disadvantage: key distribution problem.
Asymmetric (Public Key)	Different keys for encryption and decryption (unidirectional). Public key encrypts; private key decrypts. Solves key distribution. Disadvantage: longer keys (1024-4096 bits), more complex calculations.

Hash functions

Hash functions transform arbitrary-length text into a fixed-width digest. Must be one-way. Hashing algorithms are accurate integrity check tools – a hash detects even a single-bit change.

Encryption	Hashing
Two-way (reversible)	One-way (irreversible)
Data security during transmission and at rest	Data verification and authentication
Variable length output (ciphertext)	Fixed length output (digest)
Uses asymmetric and symmetric keys	No keys; salt can be added
Algorithms: AES, RC4, DES, RSA	Algorithms: SHA-1, SHA-2, MD5

Common hash algorithms

- MD5: Generates 128-bit digest – being phased out for security concerns
- SHA-1: 160-bit digest – being phased out for security concerns
- SHA-2: 6 hash functions with varying digest lengths – current industry standard
- SHA-3: Announced by NIST as backup if SHA-2 is successfully attacked

Link encryption VS. end-to-end encryption (E2EE)

Feature	Comparison
Link Encryption	Encrypts ALL traffic on a channel including headers, addresses, routing data. Decrypted at each hop; re-encrypted and forwarded. Operates at data link/physical layers. Advantage: simple (users uninvolved). Disadvantage: complex key distribution; vulnerabilities at each hop.
E2EE	Message stays encrypted from origin to destination. Only communicating parties can read messages. No intermediate decryption. More secure than link encryption. Disadvantage: headers/addresses not encrypted (vulnerable). Example: WhatsApp.

Symmetric key systems

- DES (Data Encryption Standard): Withdrawn; replaced by AES in 2001. Triple DES (3DES) extended DES while retaining backward compatibility.
- AES (Advanced Encryption Standard): Public algorithm; supports 128-256 bit keys. Current standard.
- RC4 (Rivest Cipher 4): Stream cipher often used in SSL/TLS protocol sessions

Public (asymmetric) key cryptography

Two inversely related keys based on mathematical integer factorization. One public (encrypts), one private (decrypts). Developed to solve key distribution. RSA was the first practical implementation.

ECC VS. RSA

Parameter	Comparison
Working Algorithm	ECC: mathematical model of elliptic curves vs. RSA: prime factorization approach
Bandwidth Savings	ECC: more bandwidth savings vs. RSA: less bandwidth savings
Encryption Process	ECC: shorter vs. RSA: longer
Decryption Process	ECC: slower vs. RSA: faster
Security	ECC: considered safer, continues to adapt vs. RSA: reaching its maximum lifespan

Quantum cryptography

Uses individual light particles (photons) transmitted over fiber optic cables to secure data. Security based on quantum mechanics: cannot copy whole particle, particles exist in more than one state, cannot observe without changing.

Benefits

- Provides secure communication – any tampering changes the quantum state immediately
- Protects against eavesdropping – detection of unauthorized access attempts
- Provides a variety of security methods – can be combined with conventional encryption
- Simplicity – simple to operate with less resources for ongoing maintenance

Limitations

- Polarization changes may cause errors in the communication channel
- Limited range – maximum approximately 500 km through guided media
- High implementation costs – requires separate infrastructure (repeaters, fiber optic cables)
- Limited destination range – requires dedicated channel; multiplexing not possible

Homomorphic encryption

Allows mathematical operations to be performed on encrypted data without decrypting it. Enables outsourcing data processing without revealing data.

Types

- Partially Homomorphic: Allows infinite amount of one type of operation (e.g., addition OR multiplication). Relatively easy to design. Note: RSA is partially homomorphic.
- Somewhat Homomorphic: Allows finite number of any operation (e.g., up to six additions/multiplications).
- Fully Homomorphic: Allows infinite additions AND multiplications – the desired end goal.

Challenges

- Inefficiency – slow; requirements are extensive
- High storage requirements due to large processing workloads
- Reduced performance – much slower than plaintext operations
- Inability to scale with large user bases
- Large and complex algorithms with high overhead ratios

Digital signatures

Uses public key cryptography for authentication, integrity, and nonrepudiation. Private key encrypts a hash of the document (digest/pre-hash); public key decrypts to verify. Because only the owner has the private key, ownership cannot be denied – this is nonrepudiation.

Digital signature properties

- Data Integrity: Any change to plaintext results in a different hash – mismatch detected
- Authentication: Only the claimed sender has the private key
- Nonrepudiation: Sender cannot later deny generating the document

Note: Replay attacks (intercepting and resending signed documents) can be prevented by signed timestamping or a counter.

Digital envelope

An electronic container protecting data using encryption and data authentication. Message is first encoded using symmetric encryption. The symmetric key is then secured using public key encryption. PGP (Pretty Good Privacy) is a typical example.

Cryptographic applications

Protocol/System	Key Facts
TLS (Transport Layer Security)	Cryptographic protocol for secure Internet communications. Three phases: peer negotiation, public key exchange + authentication, symmetric cipher traffic encryption. Consists of Handshake Protocol + Record Protocol. Replaced SSL (vulnerability found 2014).
IPSec	Secures communications at IP level. Establishes VPNs via transport and tunnel modes. Uses ESP (confidentiality) and AH (nonrepudiation). Security Associations (SAs) define security parameters.
Kerberos	Ticket authentication mechanism using a trusted third party (KDC) in a Distributed Computing Environment. Provides SSO. Version 5 uses AES. Advantage: confidentiality and integrity via end-to-end security. Risk: KDC is a single point of failure.
SSH (Secure Shell)	Client-server program providing secure encrypted command-line remote logon. Replaced Telnet (transmitted passwords in clear). Implemented at application layer. Uses digital certificates.
DNSSEC	Cryptographic technology to resolve DNS security issues. Adds digital signatures to DNS records. Prevents DNS cache poisoning and DNS false zones. Vulnerabilities: DoS risk, increased query responses, slow performance.

Email security

Common email attacks

- Bombing: Repeatedly sending identical email to a particular address
- Spamming: Mass unsolicited email; combined with spoofing makes it harder to identify sender. Managed with SPF, Bayesian filtering, grey listing.
- Spoofing: Email appears to come from one source but came from another; tricks users into revealing sensitive information
- Business Email Compromise (BEC): Targets employees authorizing financial transactions; involves extensive research on executives, employees, and business partners

Email security technologies

Technology	Description
S/MIME	Authentication and confidentiality via public key encryption and digital signatures. Uses X.509 digital certificates. Provides integrity, sender authentication, confidentiality, and nonrepudiation.
MOSS	Protocol using encrypted frameworks signed by multiple parties. Applies digital signatures to MIME objects. Not widely used.
PEM (Privacy Enhanced Mail)	Authentication, integrity, confidentiality, and nonrepudiation. Uses RSA and DES encryption based on X.509 standard.
DKIM	Email authentication via digital signature. Detects forged sender addresses – most common technique in phishing and spam.
PGP (Pretty Good Privacy)	Public-private key system using multiple encryption algorithms. Open-source; provides authentication, integrity, privacy, and nonrepudiation.

Email security controls

- Spam Filters: Detect and prevent spam by examining email contents for abnormal patterns; direct to junk folder
- Email Encryption: Encrypts email in transit so intercepted emails cannot be read without decryption key
- Antivirus Protection: Screens emails and attachments for viruses and malware
- Secure Email Gateway (SEG): Filters potentially unwanted emails; can be deployed on-premises or in cloud
- Email Attachment Control (EAC): Shows file types before opening; helps verify email legitimacy before opening

7. Public key infrastructure (PKI)

PKI is a system for distributing public keys through digital certificates. Comprises policies, procedures, hardware, software, and personnel to create, manage, store, distribute, and revoke public key certificates.

Digital certificates

A PKI system validates that a public key belongs to a specific individual or organization. Individuals obtain certificates through a Certificate Authority (CA) such as VeriSign or Thawte. The CA digitally signs the certificate.

Key PKI components

Component	Role
Certificate Authority (CA)	Issues and signs digital certificates; maintains secret keys for all members; performs key management.
Registration Authority (RA)	Delegated administrative functions from CA; verifies subscriber identity; restricted to submitting details to the CA.
Certificate Policy (CP)	Identifies PKI actors, roles, duties, and responsibilities; specifies certificate use, key generation, and name selection.
Certificate Practice Statement (CPS)	Describes how a CA issues certificates; contains certificate types, policies, cryptographic algorithms, key lengths, lifetimes.
Certificate Revocation List (CRL)	List of compromised/revoked certificates published by CA; browsers use to verify certificate validity.
OCSP (Online Certificate Status Protocol)	Protocol to request revocation status of a certificate; real-time query vs. downloading entire CRL.

Key management

Activity	Description
Key Creation	Also known as key generation; process of generating keys through a key generator device/program.
Key Distribution	Process of securely transferring a key to a user or system.
Key Storage & Custody	Keys stored securely in protected facilities (e.g., Windows certificate store). Methods: dual custody, split knowledge. Some keys placed under key escrow.
Key Rotation	Retiring old keys and implementing new ones to mitigate risk of theft or loss.
Key Recovery & Backup	Critical element; losing a private key leads to data loss. Key escrow enables safe storage for later recovery.
Key Destruction	Key can be suspended, revoked, expired, or destroyed. Monitor destruction process for appropriateness and security.

Certificate revocation

Reasons for revocation

- Changes in affiliation – individual terminated, resigned, died, or changed roles
- Compromise of the private key – key in hands of unauthorized individual
- Cessation of operation – server/workstation decommissioned
- Superseded – new certificate issued; old one revoked
- Unspecified – revoked without specific reason (not recommended – poor audit trail)
- CA compromise – CA itself compromised; certificate may be fraudulently signed

CRL VS. OCSP

- CRL (Certificate Revocation List): Published periodically; applications download and check. Two states: revoked (irreversible) and hold (reversible/temporary).
- OCSP: Real-time query to CA server; more updated information. OCSP Stapling: server caches
- OCSP response and includes it with the certificate – eliminates need for browser to contact CA.

PKI infrastructure risk

Risk	Description
Outdated Protocols	Leave organization prone to security incidents and data breaches
Weak Cryptographic Keys	Keys smaller than 2,048 bits are considered vulnerable and insecure
Infrequent Key Rotation	Keys don't expire by default; infrequent rotation creates opportunities for cybercriminals
Mismanaged Certificates	Failure to manage/renew/revoke certificates; expired certificates cause outages and enable lateral movement
Lack of Automation	Manual monitoring of certificates/locations/owners/expiry dates is error-prone
Insufficient Skills & Resources	Talent gap means organizations hire less-skilled professionals for complex PKI
Unclear Certificate Ownership	Without clear owners/approvers, unauthorized alterations of PKI infrastructure are possible
Poor Private Key Management	Improper management leads to private key compromise and data decryption by attackers
Compromised Root CA	Root CA compromise breaks entire chain of trust; store root CA offline in protected vault
Poor Patch Management	Failure to promptly detect PKI vulnerabilities and reduce response time

8. Cloud and virtualized environments virtualization overview

Virtualization allows multiple OSs (guests) to coexist on the same physical server (host) in isolation. Creates a layer between hardware and guest OSs to manage shared processing and memory resources. Main focus: enable single physical environment to run multiple logical, independent systems.

Virtualization elements

- Server/Hardware: Physical hardware on which virtualization runs
- Virtualization Hypervisor: Software/firmware/hardware that creates and runs virtual machine environment (the 'host')
- Guest Machine: Virtual environment elements (OS, switches, routers, firewalls) residing on the hypervisor host

Types of virtualization deployment

- Bare Metal/Native: Hypervisor runs directly on underlying hardware without a host OS
- Hosted: Hypervisor runs on top of host OS (Windows, Linux, MacOS)

Containerization: Containers include app and dependencies but share kernel with other containers; runs as isolated process in user space

Advantages & disadvantages of virtualization

Advantages	Disadvantages
Decreased server hardware costs	Inadequate host configuration creates vulnerabilities affecting all guests
Multiple OSs share processing capacity – reduced operating costs	DoS attack against host affects all guests
Smaller physical server footprint	Management console compromise grants unapproved access to all guests
Multiple OS versions on single host for application testing	Host OS performance issues impact all guests
Duplicate copies in alternate locations support business continuity	Data can leak between guests if memory not managed properly
Tighter access controls with single host controlling multiple guests	Insecure remote access protocols expose administrative credentials

Cloud service models

Model	Description	Key Consideration
IaaS (Infrastructure as a Service)	Provisions processing, storage, networks; customer deploys/runs arbitrary software including OSs	Complete freedom with OS and applications; IT operations in third-party hands
PaaS (Platform as a Service)	Application development sandbox in the cloud; customer deploys apps using provider-supported languages/tools	Designed for developers; application development environment
SaaS (Software as a Service)	Provider applications running on cloud infrastructure; accessible via browser	Complete applications on demand; changes traditional licensing and asset management

Cloud deployment models

Model	Security Dimensions
Public Cloud	CSP owns/operates data centers and is responsible for security OF the cloud; customer responsible for security IN the cloud. Least protected – accessible to everyone.
Private Cloud	CSP has lesser role. Customer has more visibility and control. Resources can be segmented. Suitable for healthcare, finance.
Hybrid Cloud	CSP has lesser role. Customers control their data; choose different security environments per use case. Data segmented to reduce attack chances.
Community Cloud	Managed and controlled by member organizations. High data security – similar to private cloud.
Multi-Cloud	Combines public clouds. More complex; may have security loopholes; increased attack surface.

Shared responsibility model (SRM)

A security and compliance framework outlining CSP responsibilities in cloud security. Responsibilities are divided between CSP and customer depending on the cloud service type.

- CSP Responsibility: Physical security, infrastructure, virtualization layer, hardware device security, networking, databases, data centers – ALWAYS
- Customer Responsibility: Data security, guest OS, IAM controls, OS configuration, encryption, security policies, firewalls
- Shared: Security training, patch management, configuration management

SRM benefits

- Efficiency: Major security aspects (hardware, infrastructure, virtualization) managed by CSP, not customer
- Reduces IT Staff Costs: Shifts IT focus; reduces staff complement and labor budget
- Enhanced Protection: CSPs dedicate significant resources to cloud security; regular monitoring, patching, testing
- Expertise: CSPs often have higher cloud security knowledge than organizations

Cloud migration security risk

- Multi-tenancy: Tenants unaware of each other; one tenant's migration can affect resource provision for others
- API Vulnerabilities: APIs must be secured at all migration stages; may enable unauthorized network penetration
- Compliance Risk: Data protection/privacy regulations apply; moving to cloud may increase compliance risk
- Uncontrolled Growth: Migration not one-time; new services and apps must be secured continuously
- Data Loss: Data can be lost, incomplete, or corrupt during migration due to technical issues, power outages, human error
- Data Security: Insecure APIs, accidental errors, malware, external attacks while data is in transit
- Incompatible Architecture: Legacy infrastructure may not be supported in cloud; migration may fail
- Reduced Visibility: Responsibilities transfer to CSP; continuous monitoring is essential
- Data Remanence: Simple deletion may not permanently remove data (just changes pointers)
- Talent Gap: Both CSP and organization may lack skilled cloud security personnel

Containerization

A form of virtualization running a single OS instance with multiple user spaces to isolate processes. Packages applications with configuration files, libraries, and dependencies. Lightweight alternative to full virtualization.

Container benefits VS. limitations

Benefits	Limitations
Faster deployment – lightweight, compartmentalized	Well-supported on Linux but not Windows
Platform-agnostic – deployable in any environment	Kernel vulnerabilities affect all containers
Improved security – isolation between containers	Networking is difficult; requires network bridge
Promotes flexibility – works in virtualized and non-virtualized environments	Monitoring is challenging (multiple containers vs. single VM)
Enhanced operational efficiency – uses all available resources	Requires effective management by skilled employees
Cost reductions – fewer physical machines needed	Less isolation than VMs – shared kernel
High scalability – can handle increasing workloads	Incident response and forensics are limited

Software-defined networking (SDN)

Network virtualization approach where users control resource allocation at virtual network level through the control plane. Addresses vendor lock-in limitation of traditional networks.

SDN planes

- Data Plane: Forwards actual user data through applications (TCP/IP) to final destinations
- Control Plane: Dictates which path flows apply; where administrator interacts with SDN; consists of routing protocols
- Management Plane: Performance and fault management; configuration of remotely connected devices; uses SNMP

SDN advantages

- Centralized Control: Virtualizes data and network control planes; single location provisioning; holistic system view
- Abstracts Network: Separates infrastructure from control; eliminates traditional IP addressing, subnets, routing complexities
- Facilitates Scalability: Provisions resources as infrastructure changes; more scalable than traditional manual configuration
- Enhances Security: Centralized security management; clearer network perspective for administrators
- Lower Operating Costs: Automates routine administration; optimizes older hardware; resources easily shared

SDN disadvantages

- Latency – virtualization creates performance delays
- Limited management – can manage services but not physical devices themselves
- Network management complexity – no standards or consensus; multiple independent SDN providers
- Dependency on controller – controller failure brings down the entire network

DevSecOps

Convergence of Development, Security, and Operations. Integrates security from the beginning of the SDLC to the end. Security becomes an automated part of CI/CD pipelines – a shared responsibility.

DevSecOps benefits

- Enhances fast, cost-effective, and secure software delivery
- Addresses security issues proactively throughout the SDLC
- Encourages fast vulnerability remediation – patches applied early in development cycle
- Enhances automation-driven development via CI/CD pipelines
- Simplifies compliance reporting with automated data collection
- Standardizes information security efforts across all development stages

DevSecOps best practices

- Shift Security Left: Move security from end to beginning of delivery process
- Incorporate Compliance: All team members work closely with compliance function
- Invest in Training: All software delivery personnel trained in security principles
- Improve Workplace Culture: Leadership encourages collaborative security practices
- Enhance Observability: Continuous monitoring for visibility, traceability, and auditability

EXAM TIP	SRM: CSP ALWAYS responsible for physical security of the cloud. Customer ALWAYS responsible for their own data. Organization CANNOT transfer responsibility for data security and GRC.

9. Mobile, wireless and internet of things devices

Mobile computing

Mobile computing devices are transported or moved during normal use (tablets, smartphones, laptops, USB storage, digital cameras). Their mobility makes it harder to implement logical and physical access controls.

Mobile device threats

Threat	Impact
Information Interception	Unauthorized access to sensitive data; reputational damage; regulatory/compliance risk
Malware Propagation	Mobile devices allow malware to infect organizational systems via internal networks
Data Leakage	Lost or stolen devices; data not backed up is permanently lost
Open Public Wi-Fi	Less secure; no passwords/encryption; easy to spy on device online activities
Outdated Devices	No security updates from manufacturers; must be replaced
Identity Theft	Attackers steal credentials to open new accounts or add phone lines
Drive-by Downloads	Malware installed without knowledge via suspicious websites or malicious email links

Mobile device controls

- Device Registration: All authorized mobile devices registered in a database; personally owned flagged
- Physical Security: Cable locking; motion detectors; protected cases; cameras covered when not in use
- Bluetooth: Disable Bluetooth when not in use (airplane mode doesn't always disable it)
- Wi-Fi: Don't connect to public Wi-Fi; disconnect when not needed; delete unused networks
- Software Updates: Update device and applications as soon as available
- Passwords: Strong lock screen passwords; set to lock automatically after short intervals
- Applications: Only from official stores; only necessary apps; close when not in use
- Data Storage: Store only necessary content; back up regularly to enterprise file server
- Compliance: All devices must comply with security requirements; require passwords; use MFA
- Secure Transmission: Connect to enterprise network via VPN

Mobile device management (MDM)

MDM is a collective suite of tools to secure and manage mobile devices, applications, data, and access. Objectives: improve security, provide monitoring, enable remote management, support troubleshooting.

MDM key features

- Encryption: Protects data on device and in transit
- Remote Wiping: Deletes all data remotely – but does NOT guarantee permanent data removal (attackers can use data recovery tools)
- Device Lockout: Disables device after repeated failed credential attempts
- Asset Management: GPS tracking of devices and personnel movements
- Application Control: Controls which applications can be installed; enforces security baseline
- Device Troubleshooting: Remote troubleshooting from management console
- Credential Management: Centralized secure storage of credentials using master credential set (preferably MFA)

BYOD (bring your own device)

Policy allowing employees to use personal mobile devices for work. Benefits: increased productivity, improved morale, cost savings. Risks: data protection, network protection, data removal on termination, malware.

BYOD security best practices

- Establish clear data ownership policies
- Obtain user acceptance and consent before onboarding
- Enforce adherence to organizational security policies
- Define patch management processes and responsibilities
- Implement effective antivirus management
- Consider infrastructure requirements (wireless network capacity)
- Have an exit BYOD strategy for when employees leave

Wireless networks

Wireless Network Types by Coverage Range

- WWAN (Wireless Wide Area Networks): Links networks over large geographical areas via radio, satellite, mobile phone technologies. Common: 4G LTE and 5G.
- WLAN (Wireless Local Area Networks): Uses Access Points (APs); AP coverage ~300 feet. Devices: WEP, WPA, WPA2, WPA3.
- WPAN (Wireless Personal Area Networks): Short-range; dominant technology is Bluetooth (up to 49 feet/15 meters). Alternative: ZigBee (slower, cheaper, less energy).
- Wireless Ad Hoc Networks: Dynamic networks with shifting topologies using mobile routers connected by wireless links.

Wi-Fi security standards comparison

Standard	Key Feature	Security Notes
WEP	RC4 encryption, 40-bit key	Weak – easily broken with hacking tools; has fragmentation and DoS vulnerabilities
WPA	TKIP with RC4, 128-bit key	Temporary WEP replacement; PSK attacks, DoS vulnerabilities; attacks made security unreliable
WPA2	CCMP with AES, 128-bit key	Significant improvement; vulnerability allows attacker to obtain keys to attack other devices on same network
WPA3	AES, 128-bit (Personal) / 198-bit (Enterprise)	Newest; addresses WPA2 flaws; SAE for key management; mandatory PMF technology; auto-encrypts public networks

Internet of things (IoT)

A collection of devices communicating over the Internet with each other or with a control console. Physical devices with sensors and software to connect, exchange, and process data. Includes home appliances and embedded systems.

Internet of things (IoT)

A collection of devices communicating over the Internet with each other or with a control console. Physical devices with sensors and software to connect, exchange, and process data. Includes home appliances and embedded systems.

IoT risk areas

- Low Software Quality: Developers unaware of potential security issues; firmware vulnerabilities
- Lack of Encryption: Most IoT devices do not implement encryption; account credentials exposed during transit
- Low Processing Power: Firmware runs on hardware with limited computational power
- Outdated Hardware/Software: May contain exploitable security vulnerabilities
- Backdoor Accounts: Service accounts masquerade as backdoors; attackers bypass access controls
- Poor Device Management: Little visibility into remotely connected IoT devices
- Interconnectedness: Compromised device can spread attack to other devices or entire network
- Absence of Inbuilt Security: No built-in security features; disconnect when not in use

IoT security controls

- Physical Security: Resilient components and specialized hardware; IMEI lock; eSIM technology
- Remote Access Security: Protocols able to lock SIM to specific device; remotely disable connection on breach detection
- Public vs. Private Networks: Use private networks; avoid public Wi-Fi for IoT communication
- Network Isolation: Isolate IoT network connectivity from core functions; disable unneeded functions
- Abnormality Prevention & Detection: Controls for detecting abnormal activity; firewalls to monitor and block suspicious traffic

10. Security awareness, training and education

Effective security depends on people – the weakest link in information security. Success of any security initiative is based on whether people understand the operation of security solutions and know what is expected of them. Security awareness, training, and education programs address this gap.

The information security learning continuum

Category	Focus	Key Differentiator
Security Awareness	Behavior change; creates culture of good security practices. Learning is often passive.	Answers the 'WHAT' of information security policy. Short-term. Self-paced e-learning, videos.
Security Training	Teaches skills to perform jobs more securely. More formal than awareness.	Answers the 'HOW' of security procedures. Intermediate-term. Instructor-led, hands-on activities.
Security Education	Intensive; targets security professionals seeking careers in IS.	Answers the 'WHY'. Long-term. Seminars, research, lectures, examinations.

Benefits of a security awareness, training & education program

- Supports Individual Accountability: Employees cannot be held accountable if unaware of security controls. Training enables management to enforce accountability.
- Serves as a Preventive Control: Security-aware employees maintain best security practices across the organization.
- Serves as a Detective Control: Trained employees identify and report possible security violations in daily activities.
- Lowers Security Risk: Security-trained and aware workforce significantly lowers security risk.
- Serves as Foundation for Other Security Controls: Awareness training is a best practice before deploying any security solution.

Conditions for a successful program

- Develop a security culture encouraging shared mindset and individual vigilance about cybersecurity
- Develop an IS security policy incorporating awareness, training, and education elements
- Inform everyone of IS security roles, responsibilities, and expectations
- Establish processes for monitoring and reviewing the program
- Focus on the entire organization
- Set the tone at the top for proper IS security behavior
- Explain proper rules of behavior in simple terms
- Establish basis for penalties and sanctions for noncompliance

Implementation steps

Step	Description
1. Define Program Scope	Goals, objectives, strategies, and coverage of various employee groups. One master program for large orgs.
2. Select Training Staff	Identify internal or external facilitators with sufficient knowledge of content.
3. Identify Target Audience	Ensure appropriate people are targeted; everyone doesn't need the same training.
4. Motivate Management & Trainees	Gain support and commitment; demonstrate benefits. Critical for resource allocation.
5. Administer the Program	Give visibility; provide adequate timely materials; ensure relevant topics and clear presentation.
6. Maintain the Program	IS field constantly evolves; regularly update to stay relevant.
7. Evaluate the Program	Measure retention, policy compliance, attitudes/behaviors. Methods: questionnaires, observation, testing, incident monitoring.

11. Information system attack methods & techniques

Fraud risk factors – the fraud triangle

Cressey's Fraud Triangle identifies three key elements:

- Motivation: Perceived financial or other need (debt, grudge, gambling, desire for status symbols)
- Rationalization: How fraudsters justify crimes to themselves ('I deserved it', 'I was only borrowing')
- Opportunity: Method by which crime is committed; created by abuse of position, poor controls, poor oversight. THIS IS THE ELEMENT ORGANIZATIONS HAVE MOST CONTROL OVER.

Computer crime perpetrators

Perpetrator	Description
Hackers	Explore programmable systems; test limits of access restrictions; typically seeking personal satisfaction, not destruction
Crackers	Break into systems with malicious intent (stealing/destroying data); targeted by law enforcement
Script Kiddies	Use scripts/programs written by others; often incapable of writing their own tools
Employees	Authorized or unauthorized; significant harm potential; background checks are an important preventive measure
IT Personnel	Easiest access as system custodians; mitigated by logical access controls, SoD, and supervision
Former Employees	May have access if not immediately blocked on termination or if backdoors exist
Nations	State-sponsored attacks on critical infrastructure (SCADA systems, etc.)

Common attack methods and techniques

Attack Method	Key Facts
Alteration Attack	Unauthorized modifications affect data/code integrity. Defense: cryptographic hash.
Botnets	Collection of compromised zombie computers running software (worms, Trojans, back doors). Used for DoS, adware, spyware, spam.
DoS/DDoS Attack	Types: ICMP flood (smurf, ping flood, SYN flood, teardrop), peer-to-peer, PDoS (phlashing – hardware damage), buffer overflow, brute-force, bandwidth saturation, DDoS (multiple compromised systems).
Eavesdropping	Intruder gathers information flowing through network. Can compromise credentials, email, and keystrokes in real time.
Phishing	Fraudulently acquiring sensitive info by masquerading as trustworthy entity. Types: Spear (targeted), Whaling (C-suite), Smishing (SMS), Vishing (voice calls).
Man-in-the-Middle	Attacker establishes connections with two devices, pretending to each to be the other.
Masquerading	Presenting false identity to gain access. Machines: IP spoofing (forged IP addresses to break firewalls).
Social Engineering	Human exploitation; trick employees into revealing passwords, IP addresses. Best defense: ongoing security awareness program.
Pharming	Redirects website traffic to bogus website by changing host file or exploiting DNS server. DNS servers become 'poisoned'.
SQL Injection	SQL query inserted into data input fields; bypasses security; leads to data loss, deletion, or modification.
Zero-Day Exploit	Exploits unknown vulnerability before patch is available. Antivirus not effective. Mitigated by: continuous patching, updated software, sandboxing, updated IRP.
Cryptojacking	Attackers use victim's computer to mine cryptocurrencies without awareness. Monitor CPU usage.
XSS (Cross-Site Scripting)	Scripts inject malicious code into websites or redirect users. Prevention same as SQL injection: input validation and sanitization.
CSRF (Cross-Site Request Forgery)	Forces victim to execute unwanted actions on authenticated web application. Social engineering-based delivery (links via chat).
DNS Tunneling	Inserts malware into DNS queries to create persistent communication channel most firewalls fail to detect.
Ransomware	Encrypts victim's files; demands ransom (often cryptocurrency). Three stages: Infection > Encryption > Ransom Demand. Double extortion: ransom + threat to publish data.

Ransomware deep dive

Three Stages of Ransomware Attack

- Stage 1 – Infection: Gains access principally through phishing email with malicious link/attachment. Ransomware downloaded and executed.
- Stage 2 – Encryption: Attacker encrypts files using asymmetric encryption; replaces originals with encrypted versions. Private key withheld.
- Stage 3 – Ransom Demand: Demands cryptocurrency via ransom note. If paid, operator provides private key.

Ransomware best practices

- Use secure networks – avoid public Wi-Fi; use VPN
- Continuous data backups – automated, protected backups for recovery without paying ransom
- Secure data backups – backup data not accessible for modification or deletion (immutability)
- Effective patch management – apply latest patches to reduce exploitable vulnerabilities
- Strong authentication – MFA makes guessed/stolen passwords harder to use
- Minimal attack surface – use antiransomware solutions

Responding to active ransomware

- Quarantine the machine – disable access to connected drives and other network machines
- Contain the spread – disconnect all suspicious devices; consider disconnecting entire network
- Do NOT switch off the system – preserve volatile memory for higher recovery probability
- Create a backup – copy encrypted files in case free decryptor becomes available
- Check for decryptors – some organizations maintain free decryptors
- Locate patient zero – find the initial point of attack to isolate the source
- Wipe and restore from clean backup – ensures complete ransomware removal
- Report to authorities – ransomware is illegal in many jurisdictions

Antimalware software types

Type	Description
Malware Signatures/Masks	Checks files, sectors, memory for known malware using specific code strings. Works well for known malware.
Heuristic Scanners	Analyzes instructions statistically to detect possible malware presence. High false-positive rate.
Active Monitors	Interprets command line and ROM BIOS calls looking for malware-like actions. Cannot distinguish user vs. malware requests.
Integrity CRC Checkers	Computes binary number on malware-free program; detects changes. Effective but only after infection occurs.
Behavior Blockers	Detects abnormal behavior (writing to boot sector, changing executables). Detects malware at early stage.
Immunizers	Appends sections to files; continuously checks for changes. Impractical to immunize against all known malware.

12. Security testing tools and techniques

Security testing is a process performed to reveal flaws and vulnerabilities in information systems. Results should lead to improvement in security architectures.

Objectives of security testing

- Identification of Assets: Pinpoints assets needing protection (software, computing infrastructure); determines whether protected from malicious actors.
- Identification of Threats and Vulnerabilities: Identifies threats that can damage systems and weaknesses that can be exploited.
- Identification of Risk: Evaluates the risk specific threats/vulnerabilities pose; based on severity, likelihood, and impact of exploitation.
- Performance of Remediation: Proactively provides insights on remediating vulnerabilities; ensures they are addressed.

Key security testing concepts

IS auditors should understand attack types sufficient to recognize business risk and how they should be addressed by appropriate controls. Understanding methods and techniques allows for more thorough evaluations and provides more secure environments.

Security concepts summary table

Concept/Tool	Key Function for Auditors
Vulnerability Assessment	Identifies known vulnerabilities; essential before enabling DLP content blocking
Penetration Testing	Active exploitation of vulnerabilities; part of regular network audits per segmentation best practices
Antimalware Testing	Both a preventive and detective control; must be regularly updated to remain effective
Configuration Auditing	Verifying default settings changed, hardening applied, and management interfaces secured
Encryption Audit	Verify policies, data classification, risk assessments, algorithm effectiveness, key management
PKI Audit	Review CA, RA, certificates, key management, CP, CPS, and CRL/OCSP compliance
Wireless Security Audit	Evaluates all security aspects of wireless network; verifies AP configs, encryption strength, IDS placement
Mobile Device Audit	Governance, patch management, configuration, device management, BYOD controls, disaster recovery
DLP Audit	Assess efficiency/effectiveness of DLP controls; provide assurance and improvement recommendations

Encryption audit procedures

Audit Area	Key Procedures
Encryption Governance	Verify written policies and procedures exist; confirm data classification system; verify encryption risk assessments; verify dual control and SoD; confirm regulatory compliance.
Encryption Design	Verify algorithm selection is effective; confirm management has applied respected standards (TLS); verify key properties (length, composition, management).
Key Management	Verify changes to cryptographic system are controlled; only authorized individuals update; key transmission controlled per written procedure; creation/rotation/destruction per policy.
Digital Signatures	Verify private keys are never backed up (increases exposure); confirm different key pairs for encryption vs. digital certificates.
Encryption Algorithms	Ascertain if management considered complex mathematical equations; verify cost of deciphering does not exceed information value.

Main objectives of security risk assessments

- Identify assets and their value; create risk profiles for each asset.
- Assess asset criticality and sensitivity; rank and prioritize assets.
- Identify vulnerabilities and threats to assets.
- Quantify the probability and business impact of potential threats.
- Provide economic balance between threat impact and countermeasure cost.
- Enable management to make informed decisions on security efforts.
- Indicate areas requiring employee awareness and training.
- Apply mitigating security controls to reduce risk to an acceptable level.

12.1 Vulnerability assessments

A vulnerability assessment (also called vulnerability scanning) is undertaken to identify vulnerabilities in a target system. It is one of the most common techniques used by IS auditors to gauge the overall threat landscape.

Goals of vulnerability assessments

- Evaluate the security posture of the organization.
- Identify, evaluate, and prioritize vulnerabilities.
- Assess the reaction of the information security environment to vulnerabilities and attacks.
- Learn about vulnerabilities currently present.
- Identify ways vulnerabilities can be exploited by attackers.
- Decide on controls to implement to address the vulnerabilities.

: As the environment changes, new vulnerabilities can arise, meaning assessment results may quickly become outdated. IS auditors should consider recency when relying on vulnerability assessment results.

12.2 Penetration testing

Penetration testing (also called intrusion testing or ethical hacking) involves an IS auditor using the same techniques as a hacker to identify the real-time risk to an information processing environment. The tester identifies vulnerabilities and then attempts to exploit them by simulating attacks.

Prior written permission from management must be obtained before undertaking any penetration test. Without permission, the entire test may be considered illegal.

Manual VS. automated penetration testing

Manual Penetration Testing	Automated Penetration Testing
Conducted by	Human information security experts.
Tools	Run manually; results provided at specified points.
Results	Variable each time; combine expert insights and can discover hidden vulnerabilities.
Coverage	Comprehensive – covers the entire attack surface.
Speed	Time-consuming and cumbersome.
Best for	In-depth, comprehensive assessments.
Conducted by	Anyone with knowledge of test configuration – no expert required.
Tools	Fully automated; results provided in report form at end.
Results	Fixed – only predefined tests and associated attack vectors are run.
Coverage	Limited – only a portion of the attack surface is tested.
Speed	Faster and more efficient than manual testing.
Note	Results ordinarily need to be analyzed manually by an IS auditor afterward.

Audit scope considerations for penetration testing

From an audit risk perspective, the scope document should clearly address:

- Precise IP addresses/ranges to be tested
- Restricted hosts (hosts not to be tested)
- Acceptable testing techniques (social engineering, DoS/DDoS, SQL injections, etc.)
- Management acceptance of proposed methodology
- Timing of attack simulation (business hours vs. off hours)
- IP addresses of the source of attack simulation
- Point of contact for both penetration tester/auditor and targeted system owner
- Handling of information collected (NDA or standard rules of engagement)
- Warning notification to avoid false alarms to law enforcement

Phases of penetration testing

Phase	Key Activities	Notes
Planning	Rules of engagement, management approval, methodology, goals, timelines, milestones, deliverables, tool preparation.	Foundation of the test – must be documented thoroughly.
Reconnaissance / Discovery	Network mapping, DNS interrogation, WHOIS, social media/resume searches, packet sniffing (internal only), port scanning, OS detection, website mapping.	Passive and active information gathering about the target.
Attack	SQL injection, cookie/session manipulation, authentication circumvention, privilege escalation, lateral movement, installation of further attack tools.	If successful: escalate privileges, gather internal info, install further tools.
Reporting	Occurs simultaneously with all other phases. Final report includes risk ratings, ease of exploitation, impact, and remediation steps.	Vulnerabilities rated by probability and business impact.

Types of penetration tests

- External testing: Attacks and control circumvention from outside the target's network perimeter (usually the Internet).
- Internal testing: Attacks from within the perimeter to determine the impact of a compromised internal host or malicious insider.
- Blind testing: Penetration tester given limited or no knowledge of the target. Expensive due to research required. Based on publicly available information only.
- Double blind testing: Extension of blind testing – the target's administrator and security staff are also unaware. Effectively tests incident handling and response capability.
- Targeted testing: Both IT team and penetration testers are aware of the testing activities. Testers are given target/network information and possibly a limited-privilege user account.

Risks associated with penetration testing

- Does not provide assurance that all vulnerabilities are discovered.
- Miscommunication may result in test objectives not being achieved.
- Testing may inadvertently trigger escalation procedures not appropriately planned.
- Sensitive information may be disclosed, heightening the target's exposure level.
- Unvetted testers may damage assets or misuse gained information for personal benefit.

Penetration testing VS. vulnerability Assessment – comparison

Dimension	Vulnerability Assessment	Penetration Testing
Goal	Uncover known vulnerabilities	Uncover and exploit vulnerabilities to show criminal leverage
Frequency	More frequent; at least quarterly	Less frequent; once or twice a year
Scope	Wide and broad (surface scanning)	Focused and deep
Performers	Automated tools with human oversight; low skill required	Experienced hackers; typically external experts
Outcome	List of known vulnerabilities	Prioritized list of unknown exploitable vulnerabilities + attack narratives
Value	Basic security posture; detection of compromised systems	Full security posture understanding; vulnerability reduction

Penetration testing VS. ethical hacking

Penetration Testing	Ethical Hacking
Scope	Tests a specific IS aspect per documented scope.
Duration	Once-off engagement of limited duration.
Results	Not very detailed.
Knowledge required	Robust knowledge of domains under test.
Responsibility	No responsibility for client's security configuration or incident handling.
Reporting	Required to be proficient writers of accurate reports.
–	–
Scope	Broader scope; tests an entire system using multiple attack vectors. No restrictions.
Duration	Continuous in nature.
Results	In-depth and comprehensive.
Knowledge required	Tactics, techniques, and procedures (mimics attacker footsteps).
Responsibility	Assists the client's information security teams to improve security posture.
Reporting	Often not mandated to produce reports.

12.3 Threat readiness / information security teams

Characteristic	Blue Team	Red Team	Purple Team
Objective	Detect and mitigate cyberattacks	Test resilience against real attacks	
Scope	Organization-wide	Organization-wide	
Testing method	No specific methods employed	Simulation	
Controls tested	No controls tested	Detective and responsive	
Tools	EDR, SIEM	Sophisticated, stealthy tools	
Positioning	Continuous	Periodic	

12.4 Security testing techniques

Security testing techniques are used to reveal flaws in the security mechanisms of an IS. Common techniques include:

- **SAST (Static Application Security Testing):** White box testing. Analyzes source code without running the application. Tester has full access to code, frameworks, and libraries. Finds vulnerabilities in earlier SDLC phases. CANNOT detect runtime vulnerabilities.
- **DAST (Dynamic Application Security Testing):** Black box testing. Simulates an attacker – no source code access. Application is executed and analyzed. Finds vulnerabilities in later SDLC phases; critical ones fixed in next cycle.
- **IAST (Interactive Application Security Testing):** Grey box testing. Combines SAST and DAST to address their respective drawbacks. Uses information inside the application while running. Covers a broader set of testing rules than either SAST or DAST alone.
- **MAST (Mobile Application Security Testing):** Combination of static, dynamic, and forensic analysis for mobile code. Focuses on mobile-specific issues: device rooting, spoofed Wi-Fi, certificate handling and validation.
- **SCA (Software Composition Analysis):** Identifies open-source components with vulnerabilities and compliance threats. Provides notifications/alerts for affected code areas and suggests security fixes.

12.5 Security operations center (SOC)

A Security Operations Center (SOC) is a team of IT security professionals that continuously monitors the entire IT infrastructure to catch security events in real time. The team can be in-house or outsourced. It unifies, aggregates, and coordinates an organization's security tools, practices, and incident response.

Common SOC activities

- Asset inventory management: Maintains an exhaustive inventory of all assets needing protection: apps, databases, servers, cloud services, endpoints.
- Security research: Stays current on the latest security solutions, technologies, and threat intelligence.
- Events monitoring: Monitors the entire IT infrastructure – apps to servers, cloud workloads – for signs of known exploits and suspicious activity.
- Investigating and triaging incidents: Analyzes alerts to determine real incidents; triages and prioritizes to optimize resource utilization.
- Security infrastructure management: Selects, operates, and maintains security technologies (firewalls, AV/AM tools, monitoring software).
- Information security testing: Periodically performs VA and pen tests to fine-tune security infrastructure and ensure compliance (GDPR, PCI DSS).
- Patch management: Applies software patches and upgrades; updates firewalls, allow/deny lists, security policies and procedures.
- Incident response: Containment (disconnect, isolate, reroute), eradication, and restoration to pre-incident state using backup systems.
- Post-mortem and refinement: Uses intelligence from incidents to update processes, policies, technologies, and the IRP to prevent recurrence.

12.6 Security testing audit procedures

The IS auditor uses specific procedures when undertaking a security testing audit. Key areas include:

Terminal identification

- Work with the network manager to obtain a listing of terminal addresses and locations.
- Inventory the terminals, noting any incorrectly logged, missing, or additional terminals.
- Select a sample of terminals and verify they are identified in the network diagram.

Logon IDs and passwords

- Attempt to guess passwords of sample employee logon IDs (discretely).
- Tour end-user and programmer work areas looking for passwords taped to terminals or inside desk drawers.
- Test encryption by working with the security administrator to attempt to view the internal password table – contents should be unreadable.
- Test periodic change requirements by interviewing users about forced password changes.
- Test for inactive logon ID disabling by matching active IDs to current employees.
- Test for password syntax by attempting to create invalid passwords (too short, too long, repeated).
- Test for automatic logoff of unattended terminals.
- Test for automatic deactivation after unsuccessful access attempts.
- Test for password masking on terminals.

Controls over production resources

- Determine if access to high-level utilities, macro libraries, and system software is on a need-to-know basis.
- Identify users who can access sensitive resources and determine what they can do with that access.

Bypassing security – key features to review

- Bypass Label Processing (BLP): Bypasses computer reading of the file label, circumventing access control programs. Only system software programmers should have access.
- System exits: Permit complex system maintenance often existing outside the security system – use is not restricted or reported by default.
- Special system logon IDs: Often provided by vendors with known/default passwords. Must be changed immediately upon installation.

13. Security monitoring logs tools & techniques

Monitoring, detection, and logging are integral parts of information security. Organizations must monitor data and information flowing into and out of the organization to detect potential problems.

13.1 Information security monitoring

Information security monitoring is the process of reviewing information to detect malicious activities, attempted intrusions, and system failures. Log analysis is a form of monitoring where logged information is systematically analyzed for trends, patterns, and security issues.

Benefits of monitoring

- Enforces accountability: Users can be held accountable for their actions; monitoring audit trail logs enforces this.
- Promotes positive behavior: Users aware of logging are less likely to attempt unauthorized actions.
- Encourages compliance culture: Legislation, regulations, and policies require specific monitoring and accountability practices.
- Supports investigations: Enables investigators to reconstruct events before, during, and after an incident. NTP implementation keeps timestamps consistent.
- Identifies security problems: Reveals system failures, OS bugs, software errors, and malicious attacks.

13.2 Intrusion detection systems (IDS)

An IDS complements firewall implementations by monitoring network use anomalies. It operates continuously in the background, notifying administrators when it detects a perceived threat. It is NOT a substitute for a firewall – it complements firewall function.

IDS categories

- Network-based IDS (NIDS): Placed between the Internet and firewall (detects all attack attempts) or between firewall and corporate network (detects intruders that bypassed the firewall).
- Host-based IDS (HIDS): Configured for a specific environment; monitors internal OS resources. Can detect modification of executable programs, file deletion, and privileged command attempts.

IDS components

- Sensors – responsible for collecting data (network packets, log files, system call traces)
- Analyzers – receive input from sensors and determine intrusive activity
- Administration console
- User interface

IDS types

- Signature-based: Protects against detected intrusion patterns stored as signatures. CANNOT detect all intrusion types due to rule limitations.
- Statistical-based: Requires comprehensive definition of known/expected system behavior. May generate many false positives for unusual but legitimate activity.
- Neural network: Monitors general patterns of activity; creates a database. Similar to statistical model but with self-learning functionality.

IDS features

- Intrusion detection
- Gathering evidence on intrusive activity
- Automated response (termination of connection, alarm messaging)
- Security policy
- Interface with system tools
- Security policy management

IDS limitations (cannot help with)

- Weaknesses in the policy definition
- Application-level vulnerabilities
- Back doors into applications
- Weaknesses in I&A (identification and authentication) schemes

IDS policy – actions when intruder detected

- Terminate the access: Used when there is significant risk to the organization's data or systems.
- Trace the access: Used when risk is low, activity is not immediately threatening, or analysis of the entry point is desirable. Collects evidence that may be used in court.

13.3 Intrusion prevention systems (IPS)

An IPS is designed not only to detect attacks but also to PREVENT the intended victim hosts from being affected. Unlike an IDS (which alerts and requires human action), an IPS actively stops the attack.

IDS	IPS
Scope	Monitoring tool for detection and surveillance; takes minimal action by itself.
Interrelatedness	Cannot do the job of an IPS.
Extent	Detected threats/anomalies flagged and sent to human personnel for action.
Location	Operates across the organizational network, monitoring traffic in real time.
Human intervention	Requires dedicated human resource to deal with detected malicious traffic.
Configuration	Generally set to operate inline.
Scope	Control-based solution; accepts or rejects network packets based on predetermined rulesets.
Interrelatedness	CAN do the job of an IDS.
Extent	Once threat detected, IPS stops the flow, shuts down the threat, and alerts personnel.
Location	Typically operates in the same location as a firewall, at the internal network–Internet juncture.
Human intervention	Highly proactive; leverages threat signatures or ML-powered behavior models.
Configuration	Placed behind the firewall; configured as end host or inline.

IPS types

- Host-based IPS (HIPS): Located on individual clients and servers; monitors events and thwarts attacks at the device level.
- Network-based IPS (NIPS): Deployed within enterprise network infrastructure; monitors all data in the complete network.
- Wireless IPS (WIPS): Monitors radio waves for unauthorized access points; automatically takes countermeasures.

Key Advantage IPS vs IDS: An IPS can block zero-day threats that bypass traditional security measures because it is not reliant on identifying and distributing threat signatures or patches.

13.4 Cont. honeypots and honeynets

A honeypot is a software application that pretends to be a vulnerable server on the Internet. It acts as a decoy system to lure hackers. The more a honeypot is targeted, the more valuable it becomes.

Honeypot Type	Description
High-interaction	Gives hackers a real environment to attack. More valuable but more risky.
Low-interaction	Emulates production environments and provides limited information to attackers.

A honeynet is a set of multiple linked honeypots simulating a larger network installation. All traffic on honeypots/honeynets is assumed to be suspicious since they are not meant for internal use.

13.5 Audit logging in monitoring system access

Access control software can log computer activity initiated through a logon ID or computer terminal, providing management with an audit trail to monitor suspicious activities.

Access rights to system logs

- Access rights to system logs should be strictly controlled.
- Computer security managers and system administrators/managers should have access for review.
- Security/administration personnel maintaining logical access functions may not need access to audit logs.
- Integrity of audit trail data must be protected against modification – use digital signatures, write-once devices, or SIEM.
- Audit trail files must be protected because intruders may try to modify them to cover their tracks.

Tools for audit trail (Log) analysis

- Audit reduction tools: Pre-processors that remove records of little security significance, reducing volume for manual review by up to half.
- Trend/variance-detection tools: Look for anomalies in user or system behavior (e.g., a user logging in at 04:30 instead of their usual 09:00).
- Attack-signature-detection tools: Look for specific sequences of events indicative of an unauthorized access attempt.
- SIEM systems: Capture audit trails from many sources, perform real-time analysis, correlate events, provide alerts, and can execute automated tasks (e.g., launching a vulnerability scan or closing a firewall port).

When a violation IS identified

1. The person who identified the violator refers the problem to the security administrator for investigation.
2. The security administrator and responsible management work together to determine severity. Most violations are accidental.
3. If a violation attempt is serious, EXECUTIVE MANAGEMENT should be notified — not law enforcement directly. Executive management is responsible for notifying law enforcement.

13.6 Protecting log data

If attackers modify log files, they can erase their activity, making the data inaccurate and potentially inadmissible as evidence. Organizations must have appropriate procedures to protect log files.

Methods for protecting log data

- Centralize log storage: Store copies of logs on a central system; even if originals are corrupted, the copy remains usable.
- Implement access controls: Assign permissions to limit access; users should have append-only privileges with no read access if possible.
- Restrict logging of sensitive data: Do not log information not required or that would present substantial risk if accessed (e.g., passwords).
- Establish log policies: Mandate backups of log files and define log retention times.
- Implement secure log transfer: Use secure protocols (IPsec, TLS) to transport log data to centralized log management servers.
- Implement secure storage media: Physically protect storage media; maintain proper environmental controls.
- Protect archived log files: Create/secure message digests, encrypt log files, provide adequate physical protection for archival media.
- Implement log disposal controls: Destroy logs safely when no longer required using methods that completely and permanently destroy data to avoid data remanence.

13.7 Security information and event management (SIEM)

SIEM is an umbrella term for centralized information security software packages that combine Security Information Management (SIM) and Security Event Management (SEM) into a single platform.

SIM Component	SEM Component
Function	Collects data from log files for analysis and reporting on PAST security threats and events.
Mode	Historical – works on stored log data.
Focus	Automating collection of log data from various security tools and systems.
Function	Works in REAL-TIME to identify relevant security events.
Mode	Real-time – conducts real-time system monitoring.
Focus	Notifies security administrators about important issues and establishes correlations as they happen.

SIEM log collection methods

- Agentless aggregation: SIEM server receives data from hosts without requiring special software installation. SIEM authenticates to each host and retrieves logs on a regular basis.
- Agent-based collection: An agent program installed on the log-generating host performs event filtering, aggregation, and log normalization before transmitting to the SIEM server in real time.

Key benefits of SIEM

KEY POINTS: SIEM Benefits
• Enhances analytics – supports data collection, analysis, response, and remediation; ML/AI-powered SIEMs investigate sophisticated attacks.
• Enhances regulatory compliance – centralized compliance auditing and reporting across entire business infrastructure.
• Improves speed in addressing security concerns – SOAR integration allows automated adaptation and faster incident response.
• Supports investigations – allows efficient collection and analysis of log data from all digital assets in one place.
• Improves threat intelligence – incorporates proprietary or open-source intelligence feeds; reduces lead time for threat identification.
• Provides insight into past events – uses log data to show not just that an attack happened, but how and why.
• Provides real-time detection of attacks – distinguishes between legitimate use and malicious attacks.
• Reduces security staffing – streamlines workflow; single SIEM server can generate reports addressing all relevant logged security events.

Core SIEM features

- Policies – default rules, alerts, reports, and dashboards customizable to the organization's requirements.
- Security knowledge base – information about known vulnerabilities, log message interpretation, and technical data.
- Log data management – pools log info from a variety of data sources; analyzed in real time.
- Event correlation and analytics – consolidates, parses, and analyzes log files; groups security events and applies correlation rules.
- Notifications and alerts – recognizes patterns of malicious behavior and raises alerts for IS security analyst review.
- Network visibility – inspects packet captures; enhances visibility into network flows to reveal malicious files or data exfiltration.
- Security incident monitoring – detects and tracks security events in real time with robust workflow features.
- Compliance reporting – generates reports to assist organizations with applicable compliance requirements

14. Security incident response management

Incident management is the management of incidents that are potentially damaging to an organization. Not all incidents are computer-related – a physical burglary is also an incident. A formal incident response capability should be established to minimize damage and enable recovery and learning.

14.1 Incident response process

The four phases of incident response follow the NIST SP 800-61 model:

Phase 1: Preparation

Establishes incident response capability so the organization is ready to respond. Incident prevention is a fundamental component – preventing problems is usually less costly than reacting to them.

- Define an incident – create the organization's own definition to standardize incidents and reduce false positives.
- Create an incident response policy – defines what constitutes incidents, organizational structure, roles/responsibilities, and reporting requirements.
- Develop incident response procedures (SOPs) – specific technical processes, techniques, checklists, and forms for the IR team.
- Establish communication guidelines – determine what information is shared with outside parties (law enforcement, media, vendors).
- Define IR activities – security advisory distribution, vulnerability assessment, intrusion detection, education.
- Select an incident response team – consider organization size, geographic diversity, 24/7 availability, cost, and staff expertise.
- Establish and maintain notification mechanisms – on-hour and off-hour contact mechanisms for CIO, CISO, IT support, BCP, etc.

Phase 2: Detection and Analysis

Critical to detect incidents quickly – they often become more damaging as time passes. Detection tools include IDSs/IPSs, antivirus software, log analyzers, and user reports.

- Automated detection: IDSs/IPSs, antivirus software, log analyzers.
- Manual detection: user reports, observations.
- Most challenging aspect: accurately detecting and assessing the type, extent, and magnitude of the incident.

Phase 3: Containment, Eradication & Recovery

- Containment: Decision-making is essential – shut down a system, disconnect from the network, or disable certain functions. Organizations should create separate containment strategies for each major incident type.
- Eradication: Eliminate incident components such as deleting malicious code and disabling breached user accounts. For some incidents, eradication is performed during recovery.
- Recovery: Restore systems to normal operation and harden to prevent similar incidents. May involve: restoring from clean backups, rebuilding from scratch, replacing compromised files, installing patches, changing passwords, tightening perimeter security.

Phase 4: Post-incident Activity

After handling an incident, the organization should hold a lessons-learned process to review the effectiveness of the incident handling process. Information from all lessons-learned meetings and incident data should be used to:

- Identify systemic security weaknesses and policy/procedure deficiencies.
- Propose improvements to existing security controls and practices.
- Inform handling of future incidents and training and awareness programs.

14.2 Computer security incident response team (CSIRT)

A CSIRT is a team established with clear lines of reporting. It acts as a single point of contact for all information security incidents and issues.

CSIRT primary responsibilities when an incident occurs

- Determine the amount and scope of damage realized.
- Determine whether information was compromised during the incident.
- Implement necessary recovery procedures to restore security.
- Supervise implementation of additional security measures to prevent repeat incidents.

The CSIRT should have a formal, documented plan that contains vulnerability identification, reporting, and IR procedures for common threats including: virus outbreaks, web defacement, abuse notifications, unauthorized access, IPS/IDS alerts, hardware/software theft, system root compromises, physical security breaches, malware, forensic investigations.

14.3 Incident response plan (IRP)

An IRP is put in place to deal with incidents and potential security incidents. Its greatest benefit is allowing the organization to treat a security incident scene systematically and initiate remediation processes.

Best practices for developing an IRP

- Automate repetitive tasks: Combine all IR tools and steps; automation frees information security teams for more strategic work.
- Leverage templates and playbooks: Agile playbooks customized or preconfigured to automate multistep responses in real time.
- Centralize IR initiatives: Gather information from all relevant security tools to create a single accessible resource/data pool.
- Test the plan: Conduct exercises to evaluate IRP effectiveness; test the ability to discover and contain incidents before they spread.
- Invest in IR training and development: Address talent gaps; keep personnel current on advances in security technologies.
- Standardize incident response: Reduces training required and allows new recruits to easily grasp concepts.
- Obtain executive buy-in: Executives approve the IRP and are ultimately responsible for its effective operations.
- Confirm roles and responsibilities: Clearly define roles; ensure reserves are available as backups if critical personnel are unavailable.
- Document critical assets: Rank and document assets in terms of criticality to assess incident impact and adjust response depth.
- Establish a crisis communications plan: Draft core communications in advance and have them approved so they are instantly retrievable during incidents.

14.4 Security orchestration, automation and response (SOAR)

SOAR is a collection of technologies that allows the organization to gather inputs monitored by the security operations team and incorporate automated responses to the resolution of security events. A single centralized console coordinates all security aspects.

SOAR components

- Orchestration: Connects security tools and integrates interdependent and disparate security systems. Forms the connected layer that streamlines security processes and drives automation.
- Automation: Eliminates manual intervention for cumbersome and time-consuming tasks.
- Automates: user access management, query log management, triaging potential threats, containing security issues.
- Response: Enables the organization to manage, plan, and coordinate responses to identified security threats with reduced human error risk.

SIEM VS. SOAR – key differences

SIEM	SOAR
Detection	Detects security issues and sends alerts to IS security analysts.
Aggregation	Collects data from logs/events from typical IT infrastructure components.
Response	Does not add automated response capability beyond alerting.
Detection	Extends SIEM by adding automation and automated response; can predict similar future threats.
Aggregation	Absorbs SIEM data and adds information from other sources: endpoint security, cloud alerts, IoT device alerts.
Response	Adds orchestration and automation to execute automated responses – not just alerting.

Benefits of SOAR

- Promotes security visibility – dashboards, metrics, reporting across the entire IS infrastructure.
- Reduces security costs – streamlines and automates information security, lowering overall costs.
- Improves security efficiency – significant time-saving and enhanced productivity through automation.
- Improves security effectiveness – accurate real-time interventions; fewer errors and less time addressing problems.
- Promotes security flexibility – can be implemented in existing setups without system redesign.
- Enhances collaboration – allows security personnel from different teams to collaborate on the same platform.
- Streamlines security operations – plugin libraries for frequently used technologies; prebuilt workflows for common use cases.

15. Evidence collection and forensics

Computer crimes often go unreported because they are not detected or because organizations fear negative publicity. In the aftermath of a computer crime, proper evidence collection procedures are critical – improper handling can render evidence inadmissible in court.

15.1 Types of investigations

Type	Description	Key Consideration
Administrative	Provides appropriate authorities with all relevant information so they can determine the proper course of action.	Often tied to HR scenarios (e.g., manager accused of improprieties).
Criminal	Undertaken when a crime has been committed. Organization typically works with law enforcement.	Suspect must be proven guilty beyond a reasonable doubt; evidence sharing with defense required.
Civil	One entity sues another (e.g., trademark violation, IP theft). Seeks monetary damages.	Burden of proof is LESS than criminal – preponderance of evidence standard.
Regulatory	Conducted by a regulating body (e.g., SEC) against an organization suspected of infracting regulations.	Organization must comply and provide all relevant evidence.
Industry Standards	Determines whether an organization adheres to a specific industry standard or set of standards.	Many organizations strive to adhere even when not legally required.
Forensic	Scientifically gathers and preserves criminal or potentially criminal evidence in a manner suitable for court.	Must maintain a documented chain of evidence; structured investigation required.

15.2 Types of computer forensics

Computer forensics involves gathering, processing, interpreting, and using digital evidence to substantiate whether an incident occurred. Any electronic document or data can be used as digital evidence provided its contents are in their original state and have not been tampered with.

- Database forensics: Retrieval and examination of data and associated metadata residing in databases. Investigator requires unrestricted database access.
- Email forensics: Retrieval and analysis of email content (messages, contacts, schedules). Requires access to the threat actor's email account and the organization's email.
- Mobile forensics: Retrieval and examination of information from mobile devices (messages, photos, videos, contacts). May require device seizure from the suspect.
- Memory forensics: Retrieval and examination of data stored in a computer's memory/cache (data in process). Technique used: live analysis.
- Network forensics: Uses tools to monitor network traffic to identify abnormal behavior. Captures, records, and analyzes network events to establish the source and trajectory of attacks.
- Malware forensics: Examines programming code to identify malicious programs (viruses, ransomware, Trojan horses). Analyzes program payloads for abnormal behavior.

15.3 Phases of computer forensics

Phase	Description	Key Action
First Response	Computer forensics team gets involved immediately after a security incident is reported.	Actions depend on the nature of the incident.
Search and Seizure	Searches devices involved in suspected crime to collect data for evidentiary purposes.	Seizure ensures suspects cannot continue attacks or extract information.
Evidence Collection	Forensic investigators collect data using forensic methods and specified evidence handling.	Handle evidence carefully per specified methods.
Evidence Security	Store evidence in a safe environment to reduce contamination.	Secure storage enables authentication and proof of accuracy and accessibility.
Data Acquisition	Retrieves electronically stored information (ESI) from seized devices.	Must use proper procedures to avoid altering data or affecting evidence integrity.
Data Analysis	Identify and examine authenticated ESI to obtain evidential data suitable for court.	Apply extraction, processing, modeling, and interpretation techniques.
Evidence Assessment	Assess evidence against the security incident reported.	Relates data gathered directly to the incident case.
Documentation and Reporting	Post-investigation – report and document data and acceptable evidence per legal requirements.	Two types: technical report for IT, non-technical report for management.
Expert Witness Testimony	A professional in the relevant field affirms the data is useful and constitutes evidence.	Verifies the forensic process and evidence interpretation.

Forensic reporting goals – the report must:

- Accurately describe the details of the incident.
- Be understandable to decision-makers.
- Withstand a barrage of legal scrutiny.
- Be unambiguous and not open to misinterpretation.
- Be easily referenced.
- Contain all information required to explain conclusions reached.
- Offer valid conclusions, opinions, or recommendations when needed.
- Be created in a timely manner

15.4 Audit considerations

Data protection

- Establish specific protocols to inform appropriate parties that electronic evidence will be sought.
- Refrain from destroying evidence by any means.
- Infrastructure and processes for incident response/handling must be in place to permit effective forensic investigation.

Data acquisition

- Transfer all required information/data to a controlled location.
- Includes all types of electronic media: fixed disk drives and removable media.
- Each device must be verified as write-protected (use a write-blocker device).
- Volatile data (open ports, open files, active processes, user logons, RAM data) should be examined first – this information is typically lost when the infected computer is shut down.

Imaging

Imaging obtains a bit-for-bit copy of data to avoid damaging original data. The imaging process duplicates the disk surface sector by sector, enabling recovery of residual data such as deleted files and fragments. With appropriate tools, it is sometimes possible to recover information erased even by reformatting.

15.5 Computer forensic techniques

- Deleted file recovery (file carving / data carving): Recovers and restores files deleted by a malicious employee, threat actor, or malware by searching the system and memory for file fragments.
- Reverse steganography: Searches hashes of file contents to identify changes – threat actors often hide important information inside images or other digital files. Changes in underlying hashes reveal manipulation.
- Cross-drive analysis: Analyzes data across multiple system drives through correlation and cross-referencing to compare suspicious events and detect anomalies. Also referred to as anomaly detection.
- Live analysis: Analyzes the computer's volatile data (RAM and cache) while the computer is in process. Can identify causes of abnormal system traffic; often performed in a forensic laboratory to maintain chain of custody.
- Stochastic forensics: Analyzes and reconstructs past digital activity without digital artifacts. Applied in data breaches involving insiders who do not normally leave behind digital artifacts.

15.6 Computer forensics tools

- Acquisition tools: Gather digital evidence by creating mirror-image or bit-stream backup files (e.g., SafeBank). Evidence may later be used in court – trusted tools are essential.
- Digital Evidence Bags (DEBs): Plastic evidence bags that assist in securing physical evidence and maintaining chain of custody. Contains: tag file (metadata, investigation info), index file (data source/format/capture device), bag file (actual evidence bits streams or logical files).
- Analysis tools: Initial tools examine bit-stream images and produce listings of programs and files present on the original device. Tools used to hide/protect/encrypt files (TrueCrypt, Hide and Seek) are also relevant to forensic analysis.
- File recovery tools: Recover deleted files from storage media free space (e.g., Encase). Examines file characteristics, last view time, and deletion time before opening for investigation.

15.7 Chain of custody

Chain of custody refers to documenting, in detail, how evidence is handled and maintained, including its ownership, transfer, and modification. This is necessary to satisfy legal requirements that mandate a high level of confidence regarding the integrity of evidence.

Chain of evidence contains information about:

- Who had access to the evidence (chronological).
- The procedures followed in working with the evidence (disk duplication, virtual memory dump).
- Proof that analysis is based on copies identical to the original evidence (documentation, checksums, timestamps).

! Critical point: Evidence

loses its integrity and value in legal proceedings if it is not preserved and subjected to a documented chain of custody. Any further analysis must be performed on an IMAGE of the system – not the original system.

15.8 Best practices to secure digital evidence

- **Prevent contamination:** Preserve the crime scene; take images of memory and storage; never work on original data.
- **Have a clear chain of custody:** Maintain audit logs proving integrity of evidence; verify transfer of media and digital evidence between every person and agency.
- **Implement tamper detection:** Imaging generates cryptographic hash values – any alteration generates a new hash that does not match the original, revealing tampering.
- **Secure storage devices:** Use password-protected logon; offsite storage if long-term evidence management is required.
- **Keep mobile devices digitally isolated:** Keep in Faraday bags; switch to airplane mode; turn off to preserve cell tower location information and call logs. Use antistatic packaging (NOT plastic).
- **Encrypt the hard drive:** Adds security if there are heightened concerns after password implementation. Full disk encryption is not always the best option.
- **Involve forensic experts:** Know when to stop and let forensic experts take over – preserving and analyzing evidence usually requires increased forensic expertise.
- **Avoid changing device power status:** Leave devices in their current power state as long as possible; for battery devices, remove batteries when turning off.
- **Monitor evidence transactions:** Record employees signing out evidence; essential for maintaining chain of custody.
- **Install write-blocking software:** Prevents changes to data on a device or media under examination; permits read-only access.
- **Incorporate other evidence:** Evidence extends beyond device files to the Internet: chat rooms, instant messaging, websites, email headers, timestamps on messaging.

Professional skills focus – applying judgement as an IS auditor

Anchor to the asset, not the control list. Judgement starts with whether the organisation has correctly identified what it is protecting and how sensitive each class of data really is. Controls reviewed without this anchor produce findings that are technically accurate but strategically irrelevant. If classification is weak, that finding usually outweighs any downstream control gap.

Evaluate controls as a system. Protection works in layers, and the whole is rarely the sum of its parts. Weak passwords matter less with universal MFA; strong encryption matters less when privileged accounts can read data in clear. The auditor's job is to trace how controls reinforce or undermine each other, not to score each one in isolation.

Proportionality, not maximalism. More controls are not always better – they cost money, slow work, and decay when unmaintained. Recommending enterprise-grade tooling for a small team is template-thinking, not judgement. A sustainable posture with fewer well-run controls is almost always safer than an ambitious one that exists only on paper.

Test effect, not intent. Policy describes what should happen; evidence shows what does. A crisp access policy is not proof of access control. Sampling user lists, reperforming privileged-access reviews, and tracing real incidents against stated response procedures convert documented controls into demonstrated ones.

Reason about the perimeter as it is. Cloud services, SaaS platforms, and third-party vendors mean most assets are no longer protected by the organisation alone. Judgement here means understanding the shared-responsibility boundary for each service, and deciding which findings in a vendor's assurance report actually matter for this organisation's risk profile.

Weigh readiness alongside prevention. Preventive controls produce clean evidence; detective and responsive ones require a view on how the organisation would perform under stress. Whether incident plans have been exercised recently, and whether post-incident reviews are candid, often predicts real-world resilience better than any configuration check.

Calibrate to materiality. The final act of judgement is what goes in the report and at what weight. A gap that could cause material loss or regulatory breach is not the same as a missing review signature. Good reporting separates findings by likelihood and impact, explains residual risk in plain business terms, and recommends what the organisation can realistically fix first.

Practice questions and answers with explanations

Question 1

Web application developers sometimes use hidden fields on web pages to save information about a client session. This technique is used, in some cases, to store session variables that enable persistence across web pages, such as maintaining the contents of a shopping cart on a retail web site application. The MOST likely web-based attack due to this practice is:

A. parameter tampering.

B. cross-site scripting.

C. cookie poisoning.

D. stealth commanding.

Correct Answer: A. parameter tampering

Justification / Explanation:

Web application developers sometimes use hidden fields to save information about a client session or to submit hidden parameters, such as the language of the end user, to the underlying application. Because hidden form fields do not display in the browser, developers may feel safe passing unvalidated data in the hidden fields (to be validated later). This practice is NOT safe because an attacker can intercept, modify and submit requests, which can discover information or perform functions that the web developer never intended. The malicious modification of web application parameters is known as parameter tampering.

Question 2

Which control is the BEST way to ensure that the data in a file have not been changed during transmission?

A. Reasonableness check

B. Parity bits

C. Hash values

D. Check digits

Correct Answer: C. Hash values

Justification / Explanation:

Hash values are calculated on the file and are very sensitive to any changes in the data values in the file. Thus, they are the best way to ensure that data has not changed.

Question 3

The PRIMARY purpose of audit trails is to:

A. improve response time for users.

B. establish accountability for processed transactions.

C. improve the operational efficiency of the system.

D. provide information to auditors who wish to track transactions.

Correct Answer: B. establish accountability for processed transactions

Justification / Explanation:

Enabling audit trails helps in establishing the accountability and responsibility of processed transactions by tracing transactions through the system.

Question 4

Which of the following systems or tools can recognize that a credit card transaction is more likely to have resulted from a stolen credit card than from the holder of the credit card?

A. Intrusion detection systems

B. Data mining techniques

C. Stateful inspection firewalls

D. Packet filtering routers

Correct Answer: B. Data mining techniques

Justification / Explanation:

Data mining is a technique used to detect trends or patterns of transactions or data. If the historical pattern of charges against a credit card account is changed, then it is a flag that the transaction may have resulted from a fraudulent use of the card.

Question 5

Which of the following BEST ensures the integrity of a server's operating system?

A. Protecting the server in a secure location

B. Setting a boot password

C. Hardening the server configuration

D. Implementing activity logging

Correct Answer: C. Hardening the server configuration

Justification / Explanation:

Hardening a system means to configure it in the most secure manner (install latest security patches, properly define access authorization for users and administrators, disable insecure options and uninstall unused services) to prevent nonprivileged users from gaining the right to execute privileged instructions and, thus, take control of the entire machine, jeopardizing the integrity of the OS.

Question 6

Which of the following network components is PRIMARILY set up to serve as a security measure by preventing unauthorized traffic between different segments of the network?

A. Firewalls

B. Routers

C. Layer 2 switches

D. Virtual local area networks

Correct Answer: A. Firewalls

Justification / Explanation:

Firewall systems are the primary tool that enables an organization to prevent unauthorized access between networks. An organization may choose to deploy one or more systems that function as firewalls.

Question 7

An IS auditor discovers that the chief information officer (CIO) of an organization is using a wireless broadband modem using global system for mobile communications (GSM) technology. This modem is being used to connect the CIO's laptop to the corporate virtual private network when the CIO travels outside of the office. The IS auditor should:

A. do nothing because the inherent security features of GSM technology are appropriate.

B. recommend that the CIO stop using the laptop computer until encryption is enabled.

C. ensure that media access control address filtering is enabled on the network so unauthorized wireless users cannot connect.

D. suggest that two-factor authentication be used over the wireless link to prevent unauthorized communications.

Correct Answer: A. do nothing because the inherent security features of GSM technology are appropriate

Justification / Explanation:

The inherent security features of global system for mobile communications (GSM) technology combined with the use of a virtual private network (VPN) are appropriate. The confidentiality of the communication on the GSM radio link is ensured by the use of encryption and the use of a VPN signifies that an encrypted session is established between the laptop and the corporate network. GSM is a global standard for cellular telecommunications that can be used for both voice and data. Currently deployed commercial GSM technology has multiple overlapping security features which prevent eavesdropping, session hijacking or unauthorized use of the GSM carrier network.

Question 8

Which of the following is the BEST way to minimize unauthorized access to unattended end-user PC systems?

A. Enforce use of a password-protected screen saver

B. Implement proximity-based authentication system

C. Terminate user session at predefined intervals

D. Adjust power management settings so the monitor screen is blank

Correct Answer: A. Enforce use of a password-protected screen saver

Justification / Explanation:

A password-protected screen saver with a proper time interval is the best measure to prevent unauthorized access to unattended end-user systems. It is important to ensure that users lock the workstation when they step away from the machine, which is something that could be reinforced via awareness training.

Question 9

The implementation of which of the following would MOST effectively prevent unauthorized access to a system administration account on a web server?

A. Host intrusion detection software installed on the server
B. Password expiration and lockout policy
C. Password complexity rules
D. Two-factor authentication

Correct Answer: D. Two-factor authentication

Justification / Explanation:

Two-factor authentication requires a user to use a password in combination with another identification factor that is not easily stolen or guessed by an attacker. Types of two-factor authentication include electronic access tokens that show one-time passwords on their display panels or biometric authentication systems.

Question 10

An organization's IT director has approved the installation of a wireless local area network access point in a conference room for a team of consultants to access the Internet with their laptop computers. The BEST control to protect the corporate servers from unauthorized access is to ensure that:

A. encryption is enabled on the access point.
B. the conference room network is on a separate virtual local area network (VLAN).
C. antivirus signatures and patch levels are current on the consultants' laptops.
D. default user IDs are disabled and strong passwords are set on the corporate servers.

Correct Answer: B. the conference room network is on a separate virtual local area network (VLAN)

Justification / Explanation:

The installation of the wireless network device presents risk to the corporate servers from both authorized and unauthorized users. A separate virtual local area network is the best solution because it ensures that both authorized and unauthorized users are prevented from gaining network access to database servers, while allowing Internet access to authorized users.

Question 11

The IS auditor is reviewing an organization's human resources (HR) database implementation. The IS auditor discovers that the database servers are clustered for high availability, all default database accounts have been removed and database audit logs are kept and reviewed on a weekly basis. What other area should the IS auditor check to ensure that the databases are appropriately secured?

A. Database administrators are restricted from access to HR data.
B. Database logs are encrypted.
C. Database stored procedures are encrypted.
D. Database initialization parameters are appropriate.

Correct Answer: D. Database initialization parameters are appropriate

Justification / Explanation:

When a database is opened, many of its configuration options are governed by initialization parameters. These parameters are usually governed by a file ("init.ora" in the case of Oracle Database Management System), which contains many settings. The system initialization parameters address many "global" database settings, including authentication, remote access and other critical security areas. To effectively audit a database implementation, the IS auditor must examine the database initialization parameters.

Question 12

An IS auditor has been asked by management to review a potentially fraudulent transaction. The PRIMARY focus of an IS auditor while evaluating the transaction should be to:

A. maintain impartiality while evaluating the transaction.

B. ensure that the independence of an IS auditor is maintained.

C. assure that the integrity of the evidence is maintained.

D. assess all relevant evidence for the transaction.

Correct Answer: C. assure that the integrity of the evidence is maintained

Justification / Explanation:

The IS auditor has been requested to perform an investigation to capture evidence which may be used for legal purposes, and therefore, maintaining the integrity of the evidence should be the foremost goal. Improperly handled computer evidence is subject to being ruled inadmissible in a court of law.

Question 13

A new business application has been designed in a large, complex organization and the business owner has requested that the various reports be viewed on a "need to know" basis. Which of the following access control methods would be the BEST method to achieve this requirement?

A. Mandatory

B. Role-based

C. Discretionary

D. Single sign-on

Correct Answer: B. Role-based

Justification / Explanation:

Role-based access control limits access according to job roles and responsibilities and would be the best method to allow only authorized users to view reports on a need-to-know basis.

Question 14

Which of the following is the BEST control to prevent the deletion of audit logs by unauthorized individuals in an organization?

A. Actions performed on log files should be tracked in a separate log.

B. Write access to audit logs should be disabled.

C. Only select personnel should have rights to view or delete audit logs.

D. Backups of audit logs should be performed periodically.

Correct Answer: C. Only select personnel should have rights to view or delete audit logs

Justification / Explanation:

Granting access to audit logs to only system administrators and security administrators would reduce the possibility of these files being deleted.

Question 15

A company is implementing a Dynamic Host Configuration Protocol. Given that the following conditions exist, which represents the GREATEST concern?

A. Most employees use laptops.

B. A packet filtering firewall is used.

C. The IP address space is smaller than the number of PCs.

D. Access to a network port is not restricted.

Correct Answer: D. Access to a network port is not restricted

Justification / Explanation:

Given physical access to a port, anyone can connect to the internal network. This would allow individuals to connect that were not authorized to be on the corporate network.

Chapter 5
Information Systems Auditing

1. IS audit standards, guidelines, functions and code of ethics
2 Types of audits, assessments and reviews
3 Risk-based audit planning
4 Types of controls and considerations
5 Audit project management
6 Audit testing and sampling methodology
7 Audit evidence collection techniques
8 Audit data analytics
9 Reporting and communication techniques

Practice questions and answers with explanations



Section summary

The information system auditing process covers the full lifecycle of an IS audit – from deciding what to examine and how deeply, through evidence gathering and testing, to reporting findings and verifying that they get resolved. It rests on a foundation of audit standards, a risk-based approach to scoping, and documented methodologies for planning, sampling, and evidence evaluation. The process recognizes six connected phases: risk-based scoping to identify what matters, detailed planning to sequence the work and set evidence thresholds, fieldwork to gather sufficient and reliable evidence, testing of both control design and operating effectiveness, reporting findings calibrated by materiality, and follow-up to confirm that remediation has actually occurred. Throughout, the auditor is expected to maintain independence, apply professional skepticism, and document work in a way that would allow another competent reviewer to reach the same conclusion. The process is deliberately non-mechanical – standards set the floor, but the quality of any individual audit depends on how well the auditor exercises judgement within that framework.

1. IS Audit standards, guidelines, functions and code of ethics

1.1 ISACA IS audit and assurance standards

The IS audit profession derives its credibility from the consistent application of commonly accepted standards. ISACA publishes IS Audit and Assurance Standards that define the minimum acceptable performance required for IS auditing work. These standards serve three distinct audiences: they tell IS auditors the minimum level of performance expected of them; they inform management and other interested parties what the profession expects of its practitioners; and they set out the professional performance requirements for holders of the CISA designation.

The framework for ISACA IS Audit and Assurance Standards is built across three tiers of documents:

Document tier	Nature	Obligation on IS auditor
Standards	Define mandatory requirements for IS audit and assurance and reporting. These are binding on all IS auditors and CISA holders.	Mandatory. Non-compliance must be disclosed and justified.
Guidelines	Provide guidance and information on how to comply with the Standards. They explain how the Standards should be implemented in practice.	Strongly recommended. IS auditor must use professional judgment in applying them and be prepared to justify any departure.
Tools and Techniques	Offer examples of processes an IS auditor might follow in an audit engagement. They explain how to meet the Standards but do not themselves set requirements.	Non-mandatory. Provide helpful examples and best-practice models for practical application.

Within the Standards themselves, ISACA draws a further distinction across three categories, each governing a different phase and aspect of the audit function:

Standard category	Scope	Examples of matters covered
General Standards	Establish the guiding principles under which the IS assurance profession operates. They apply to all assignments irrespective of type or subject matter.	Ethics, independence, objectivity, due professional care, knowledge, competency, and skill of the IS auditor.
Performance Standards	Govern the conduct of individual audit assignments, from inception through execution.	Planning and supervision, scope setting, risk and materiality assessment, resource mobilization, collection and assessment of audit evidence, and exercise of professional judgment.
Reporting Standards	Address the outputs of the audit process and how those outputs are communicated to stakeholders.	Types of audit reports, means of communication, information to be communicated, and level of assurance to be expressed.

1.2 ISACA IS audit and assurance guidelines

ISACA IS Audit and Assurance Guidelines provide granular guidance on how IS auditors should implement the mandatory Standards in practice. Where the Standards define what must be done, the Guidelines explain how it should be done. The IS auditor is expected to consider the Guidelines carefully in determining how to implement each Standard, to apply professional judgment in adapting the Guidelines to the specific circumstances of each engagement, and to be able to justify any departure from the approach set out in the Guidelines.

It is important to note that candidates are not expected to memorise the specific numbering of individual ISACA Standards or Guidelines. However, the CISA examination will test a candidate's ability to apply these Standards and Guidelines to practical audit scenarios.

1.3 ISACA code of professional ethics

ISACA's Code of Professional Ethics guides the professional and personal conduct of all ISACA members and certification holders in their capacity as IS audit and assurance professionals. The Code establishes seven obligations that members and certification holders must uphold:

Obligation	Detailed description
1. Support implementation of standards	Support the implementation of, and encourage compliance with, appropriate standards, procedures, and practices for the effective governance and management of enterprise information systems and technology, including audit, control, security, and risk management.
2. Perform duties with objectivity and due diligence	Perform their duties with objectivity, due diligence, and professional care, in accordance with professional standards. This includes maintaining an independent state of mind and avoiding bias, conflicts of interest, and undue influence.
3. Serve stakeholders in a lawful manner	Serve in the interest of stakeholders in a lawful manner, while maintaining high standards of conduct and character, and not discrediting their profession or ISACA. This obligation reflects the primacy of public interest in the conduct of IS audit work.
4. Maintain privacy and confidentiality	Maintain the privacy and confidentiality of information obtained in the course of their activities unless disclosure is required by legal authority. Such information shall not be used for personal benefit or released to inappropriate parties.
5. Maintain competency	Maintain competency in their respective fields and agree to undertake only those activities they can reasonably expect to complete with the necessary skills, knowledge, and competence. IS auditors should not accept engagements beyond their professional capability.
6. Inform appropriate parties of significant results	Inform appropriate parties of the results of work performed, including disclosure of all significant facts known to them that, if not disclosed, may distort the reporting of the results. This obligation reinforces the completeness and accuracy of audit reporting.
7. Support professional education	Support the professional education of stakeholders in enhancing their understanding of the governance and management of enterprise information systems and technology, including audit, control, security, and risk management.

1.4 IS Internal audit function and the audit charter

The IS internal audit function must be formally established and authorised through an audit charter that has been approved by the board of directors and the audit committee, or by senior management where these bodies do not exist. The audit charter is an overarching document that covers the entire scope of audit activities within an entity. It must clearly state management's responsibility for, and objectives of, the IS audit function, together with the delegation of authority necessary to carry out that function. The charter should be amended only when a change is thoroughly justified; it should not be subject to revision as a matter of routine.

The responsibility, authority, and accountability of the IS audit function must be appropriately documented either in the audit charter or, for specific engagements, in an engagement letter. The two documents serve different purposes:

Document	Scope	Approved by
Audit Charter	Overarching document establishing the mandate, authority, responsibility, and accountability of the IS audit function across all audit activities of the entity. Permanent in nature, subject to change only when thoroughly justified.	Highest level of management and the audit committee (or board of directors). Must be approved before the IS audit function can legitimately operate.
Engagement Letter	Focused document specific to a particular audit exercise, setting out the scope, objectives, timing, and approach of a defined audit engagement. Created at the commencement of each individual engagement.	Agreed between the IS audit function and the specific auditee management for that engagement.

Where IS audit services are provided by an external firm, the scope and objectives of the services must be documented in a formal contract or statement of work between the contracting organisation and the service provider. In either case – whether IS audit is internal or outsourced – the IS audit function must remain independent and must report to the audit committee, or to the highest level of management where no audit committee exists.

Management of the IS audit function

The IS audit function must be managed and led in a manner that ensures the diverse tasks performed by the audit team fulfil the audit function's objectives while preserving audit independence and competence. IS technology changes continuously; accordingly, IS auditors must maintain their competency through ongoing training in new audit techniques and emerging technology areas. Skills and knowledge must be taken into consideration when planning audits and assigning staff to specific audit assignments. Where the audit department lacks the specific skills required for a particular engagement, the IS auditor may engage external experts, subject to appropriate oversight and monitoring to ensure objectivity and independence throughout the engagement.

1.5 The IT assurance framework (ITAF)

ITAF is ISACA's comprehensive, best-practice-setting reference model that brings together the full body of IS audit and assurance guidance into a single coherent framework. ITAF serves three functions: it establishes standards that address IS auditor roles and responsibilities, knowledge and skills, and diligence, conduct, and reporting requirements; it defines terms and concepts specific to IS assurance; and it provides guidance and tools on the planning, design, conduct, and reporting of IS audit and assurance assignments.

2. Types of audits, assessments and reviews

An IS auditor must be proficient in recognising which type of audit, assessment, or review is appropriate for a given situation and in understanding the associated procedures, scope, and level of assurance provided. Formal audits provide a higher level of assurance than broader assessments or reviews. Assessments and reviews tend to be perceived with less negative connotation than formal audits and may focus on opportunities for reducing costs, identifying improvement proposals, or gaining employee perceptions on quality.

Audit or review type	Primary purpose	Key characteristics
IS Audit	Collect and evaluate evidence to determine whether IS and related resources are adequately safeguarded, maintain data integrity and availability, achieve organisational goals, consume resources efficiently, and have effective internal controls.	Formal examination and testing. Focuses on information systems and related processes. Provides highest level of assurance.
Compliance Audit	Test controls to demonstrate adherence to specific regulations, laws, or industry-specific standards and practices.	Often overlaps with other audit types. May focus on particular systems or categories of data. Scope driven by regulatory requirements.
Financial Audit	Assess the accuracy of financial reporting and the integrity and reliability of financial information.	Involves detailed substantive testing. IS auditors increasingly apply risk- and control-based approach rather than solely transaction-level testing.
Operational Audit	Evaluate the internal control structure in a given process or operational area, including application controls and logical security.	Examples include audit of application controls or logical security systems. Focused on the effectiveness and efficiency of operations.
Integrated Audit	Assess overall objectives within an organisation relating to financial information, safeguarding of assets, efficiency, and compliance, by combining financial and operational audit steps.	Conducted by external or internal auditors. Includes compliance tests and substantive audit steps. Permits a single audit of an entity with one comprehensive report.
Administrative Audit	Assess issues related to the efficiency of operational productivity within an organisation.	Focused on administrative processes, productivity, and operational effectiveness rather than financial or IT-specific controls.
Fraud Audit	Discover fraudulent activity using specific tools and data analysis techniques.	Specialised audit. Auditors use targeted investigative and data analytics methods to detect fraud schemes and business irregularities.

Forensic Audit	Discover, disclose, and follow up on fraud and crime for the purpose of developing evidence for law enforcement and judicial authorities.	Primary purpose is the creation of legally admissible evidence. Requires specialised forensic skills and chain-of-custody procedures.
Computer Forensic Audit	Analyse electronic computing devices to gather and preserve evidence for forensic investigation.	IS auditor with forensic skills can assist security managers in performing forensic investigations and auditing compliance with evidence collection procedures.
Functional Audit	Provide an independent evaluation of software products, verifying that actual functionality and performance match requirement specifications.	Conducted either before software delivery or after implementation. Evaluates whether configuration items meet stated requirements.
Readiness Assessment	Review an organisation's current state of compliance or adherence to documented standards before a formal audit.	Focuses on control design rather than operating effectiveness. Results in actionable items for remediation prior to formal audit. Less formal than a full audit.
Third-Party Service Audit	Audit outsourced financial and business processes to third-party service providers that may operate in different jurisdictions.	Issues an opinion on the service organisation's description of controls through a service auditor's report, which can be used by the IS auditor of the contracting entity.

2.1 Control self-assessment (CSA)

Control self-assessment is a methodology by which the staff and management of the unit being reviewed assess their own internal controls. It is a management technique used to assure stakeholders, customers, and other parties that the internal control system of the organisation is reliable. CSA also ensures that employees are aware of business risk and conduct periodic, proactive reviews of controls. CSA may be implemented through questionnaires and surveys, facilitated workshops, or informal peer reviews.

Primary objective of CSA

The primary objective of a CSA programme is to leverage the internal audit function by shifting some of the control monitoring responsibilities to the functional areas. It is not intended to replace the audit function but to enhance it. Line managers who are responsible for the controls in their environment should be the ones monitoring those controls. CSA programmes educate management about control design and monitoring, particularly in areas of high risk.

Role of the IS auditor in CSA

In a CSA engagement, the IS auditor acts in the role of a facilitator. The IS auditor is not the auditor in the traditional sense; rather, the management client is the participant and the IS auditor supports the decision-making process. During a CSA workshop, for example, the IS auditor leads and guides the auditees in assessing their own environment by providing insight into the objectives of controls based on risk assessment, rather than performing detailed audit procedures. The IS auditor helps participants explore their own experiences, identify control strengths and weaknesses, and share knowledge and concerns.

Benefits and limitations of CSA

Benefits of CSA	Limitations and disadvantages of CSA
Early detection of risk, allowing the organisation to respond proactively before a formal audit identifies a problem.	CSA could be mistaken by management or staff as a replacement for the formal audit function, reducing the frequency of independent audits.
Stronger and more effective internal controls through continuous monitoring by those closest to the processes.	CSA may be perceived by staff as an additional workload – one more report to be submitted to management – reducing engagement and quality.
Development of a sense of control ownership among employees and process owners, reducing resistance to control improvement initiatives.	Failure by management to act on improvement suggestions raised during CSA can damage employee morale and reduce future participation.
Increased employee knowledge of risk, internal controls, and organisational objectives, contributing to a stronger control culture.	The lack of formal audit knowledge among process owners may limit their effectiveness in detecting weak or missing controls.
Increased communication between operational staff and top management on control-related matters.	Independence and objectivity limitations: self-assessment may not uncover fraud or management override of controls.
Reduction in control cost and improved audit rating through proactive identification and remediation of weaknesses.	

2.2 Integrated auditing

Integrated auditing is a process whereby appropriate audit disciplines are combined to assess key internal controls over an operation, process, or entity with a primary focus on risk. It is driven by the recognition that business processes are deeply dependent on IT, requiring all auditors – regardless of specialism – to develop an understanding of both IT control structures and business control structures. The integrated audit approach enables a single audit of an entity to be conducted, producing one comprehensive report that addresses both operational and IT dimensions.

The integrated audit process typically involves: identification of the risk faced by the organisation in the area being audited; identification of relevant key controls; review and understanding of the design of key controls; testing of IT system support for key controls; testing of the operational effectiveness of management controls; and the production of a combined report or opinion on control risk, control design, and control weaknesses. This approach benefits all stakeholders: employees better understand the linkage between controls and audit procedures; management sees the connection between control effectiveness and IT resource utilisation; and shareholders gain confidence in the financial reporting process.

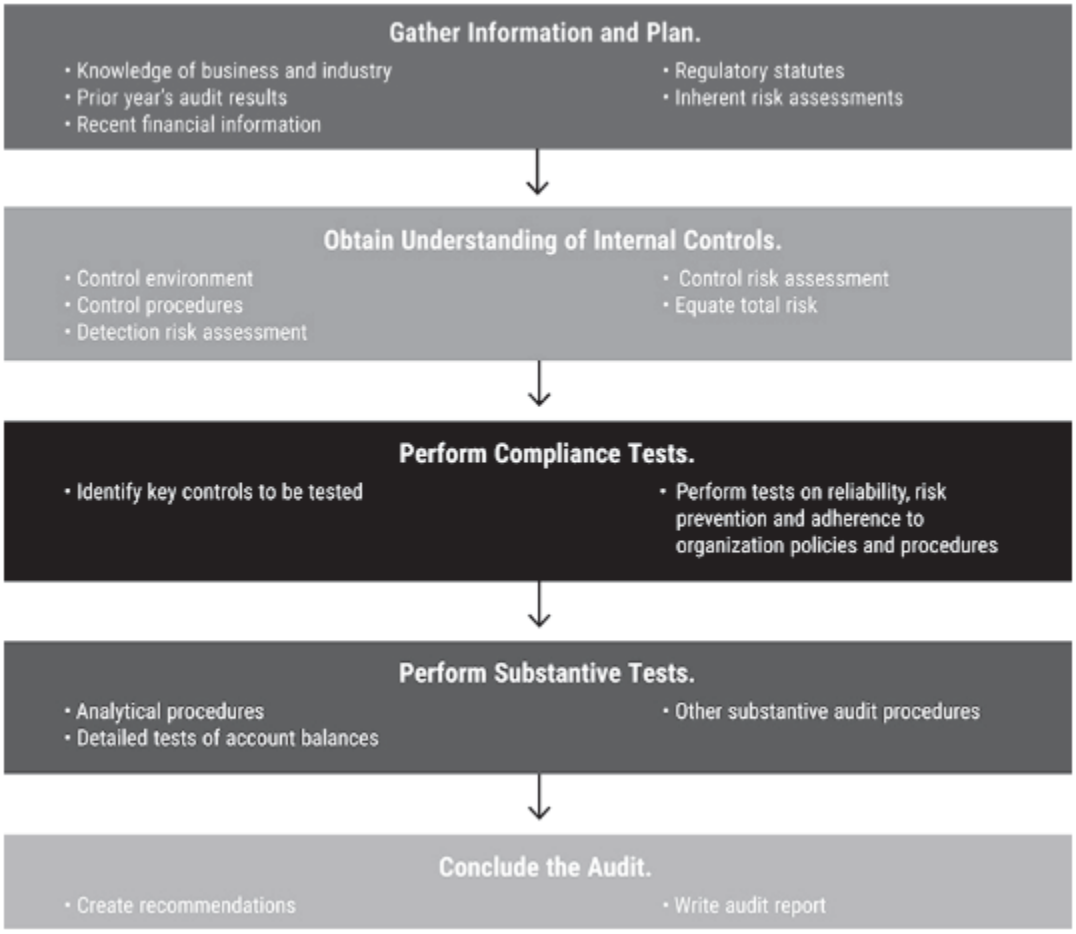
3. Risk-based audit planning

Audit planning is conducted at the beginning of the audit process and encompasses both short-term and long-term planning. Short-term planning considers audit issues that will be covered during the current year. Long-term planning addresses risk-related issues regarding changes in the organisation's IT strategic direction that will affect its IT environment over a multi-year horizon. All relevant processes that form the blueprint of the enterprise's business should be included in the audit universe, which lists all processes that may be considered for audit. Each process undergoes a qualitative or quantitative risk assessment based on defined risk factors.

3.1 Steps in audit planning

When planning an individual IS audit engagement, the IS auditor should perform the following steps in sequence:

Step	Activity	Key considerations
1	Gain an understanding of the organisation's mission, objectives, purpose, and processes, including information and processing requirements such as availability, integrity, security, and confidentiality.	This foundational step ensures the auditor understands what the organisation is trying to achieve and what information systems support those objectives.
2	Gain an understanding of the organisation's governance structure and practices related to the audit objectives.	Includes understanding how authority is delegated, how decisions are made, and how IT is governed within the organisation.
3	Understand changes in the business environment of the auditee since the last audit.	Changes in strategy, technology, regulations, or organisational structure may alter the risk profile and required audit scope.
4	Review prior work papers and audit findings.	Prior findings may indicate persistent control weaknesses or systemic issues that require continued attention.
5	Identify stated contents such as policies, standards, required guidelines, procedures, and organisation structure.	Understanding the documented control environment is essential before testing whether it operates as designed.
6	Perform a risk analysis to help in designing the audit plan.	Identifies and assesses risk relevant to the area under review. Required by ISACA IS Audit and Assurance Standard 1201.
7	Set the audit scope and audit objectives.	Defines the specific systems, functions, or units to be included, and articulates the purpose of the audit in measurable terms.
8	Develop the audit approach or audit strategy.	Determines the balance between compliance testing and substantive testing, and identifies the tools and techniques to be used.
9	Assign personnel resources to the audit.	Ensures that staff with the necessary skills and knowledge are assigned, and that any gaps are addressed through training or use of external experts.
10	Address engagement logistics.	Covers scheduling, access arrangements, points of contact, and communication plans.
11	Identify opportunities for continuous audit or audit automation using CAATs.	Continuous auditing can improve efficiency and provide more timely assurance, particularly in high-volume transaction environments.



3.2 Effect of laws and regulations on is audit planning

Every organisation, regardless of size or industry, must comply with a range of governmental and external requirements related to IS practices and controls, and the manner in which data is used, stored, and secured. Industry-specific regulations may govern how data is processed, transmitted, and stored. IS auditors must identify applicable legal and regulatory requirements and assess whether management has incorporated them into its planning, policies, standards, procedures, and business applications.

The IS auditor would perform the following steps to determine an organisation's level of compliance with external requirements: identify government or other relevant external requirements dealing with electronic data, personal data, copyrights, e-commerce, e-signatures, IS practices and controls, and IS audits; document applicable laws and regulations; assess whether management has considered the requirements in making plans and setting policies; review internal IT documents that address adherence to applicable laws; determine adherence to established procedures; and determine whether contracts with external IT service providers reflect any applicable legal requirements.

3.3 Audit risk and materiality

Audit risk is the risk that information collected during the audit may contain a material error that goes undetected. The IS auditor must understand and manage four components of audit risk throughout the planning and execution process:

Risk component	Definition	Key characteristic
Inherent risk	The risk level or exposure of the process or entity to be audited without regard to the controls management has implemented. Inherent risk exists independent of an audit and arises from the nature of the business, the industry, and the complexity of the transactions involved.	Exists regardless of controls. Cannot be eliminated by auditor action alone. Drives the level of scrutiny applied during planning.
Control risk	The risk that a material error exists that will not be prevented or detected on a timely basis by the system of internal controls. Control risk is high where controls are absent or ineffective, such as in manual review processes where volume may prevent thorough examination.	Reflects the quality of the control environment. IS auditors evaluate control risk during compliance testing. High control risk increases the amount of substantive testing required.
Detection risk	The risk that material errors or misstatements will not be detected by the IS auditor through substantive tests. Detection risk is influenced by the nature, timing, and extent of substantive audit procedures.	Can be managed by the auditor through additional or more rigorous substantive testing. Is the one component of audit risk most directly within the auditor's control.
Overall audit risk	The composite risk that the auditor may fail to detect a material error in information or financial reports. The objective in formulating the audit approach is to limit overall audit risk to a sufficiently low level by the completion of the audit.	Overall audit risk = function of inherent risk, control risk, and detection risk. Cannot be reduced to zero; auditors aim to reduce it to an acceptable level.

Materiality refers to the relative significance or importance of a particular matter in the context of the enterprise as a whole. There is an important inverse relationship between materiality and the level of audit risk acceptable to the IS auditor: the higher the materiality of the area under review, the lower the level of audit risk that can be accepted, and vice versa. An IS auditor must also be careful to distinguish between overall audit risk and sampling risk, which is the specific risk that incorrect conclusions are drawn about a population because the sample selected does not accurately represent the population's characteristics.

3.4 Risk assessment techniques

Risk assessment should identify, quantify, and priorities risk against criteria for risk acceptance and objectives relevant to the organization. Using risk assessment to determine areas to be audited enables audit management to allocate limited audit resources effectively; ensures that information is obtained from all levels of management; establishes a basis for managing the audit department; and provides a summary of how individual audit subjects relate to the overall organization and business plans.

Risk assessment methodologies available to IS auditors range from simple qualitative classifications (high, medium, low, based on the auditor's judgment) to complex quantitative scoring systems that produce numerical risk ratings by weighting variables such as technical complexity, level of control procedures in place, and potential financial loss. A combination of approaches may be used. Risk analysis – a subset of risk assessment – is used during audit planning to identify risk and vulnerabilities so that the IS auditor can determine what controls are needed to mitigate those risks.

4. Types of controls and considerations

4.1 Internal controls

Internal controls operate at all levels within an organisation to mitigate risk exposures that could prevent the achievement of business objectives. The board of directors and senior management are responsible for establishing an appropriate culture that facilitates an effective and efficient internal control system and for continuously monitoring its effectiveness, although every individual within the organisation must participate in the control process.

There are two key aspects that every control must address: what should be achieved (the desired outcomes and business objectives), and what should be avoided (undesired events, errors, irregularities, and fraudulent activities). Control activities occur throughout the enterprise, at all levels and in all functions, including granting approvals and authorisations, implementing verifications and reconciliations, reviewing operating performance, securing assets, and ensuring separation of duties.

4.2 Control objectives and control measures

A control objective is a statement of the desired result or purpose to be achieved by implementing control activities. Control objectives are explicitly related to the company's overall strategy and may relate to effectiveness and efficiency of operations, reliability of financial reporting, compliance with applicable laws and regulations, and the safeguarding of information assets. Control objectives apply equally to manual, automated, or combined controls.

A control measure is an activity that contributes to the fulfilment of a control objective. Together, the control objective and control measure serve to decompose strategic-level goals into lower-level goals and activities that can be assigned as tasks to specific staff members. Specific IS control objectives include: safeguarding information assets; ensuring SDLC processes operate effectively; maintaining the integrity of operating system environments; ensuring the integrity of sensitive and critical application environments; ensuring appropriate identification and authentication of users; ensuring efficiency and effectiveness of operations; ensuring compliance with laws and regulations; ensuring availability of IT services through BCPs and DRPs; and ensuring integrity through effective change management.

4.3 Control classifications

The elements of controls that should be considered when evaluating control strength are classified as follows. It is important to note that preventive controls are generally the strongest because they prevent threat events from occurring; detective controls identify threats without stopping them; and corrective controls reduce impact after a threat event has occurred.

Control classification	Purpose	Examples in IS environment
Preventive	Inhibit or impede attempts to violate security policy and practices. These are the strongest controls because they prevent threat events from occurring in the first place. If a threat event is prevented, there is no impact to address.	Encryption of data at rest and in transit; multi-factor authentication; input validation; separation of duties; security awareness training; access control lists; vault-construction physical doors.
Deterrent	Provide guidance or warnings that may dissuade intentional or unintentional attempts at compromise. Deterrent controls do not prevent the act but reduce the likelihood of an attempt by raising the perceived risk of detection and consequence.	Warning banners on login screens; acceptable use policies; security camera signage; notices of monitoring; published penalties for policy violations; rewards for reporting security incidents.
Detective	Provide warnings of violations or attempted violations of security policy and practices without inhibiting or impeding the questionable actions. Detective controls identify a threat event that has taken place or is in progress, enabling a response.	Audit trails and logs; intrusion detection systems (IDS); checksums and hash verifications; variance analysis; management review of exception reports; continuous monitoring systems.
Corrective	Remediate errors, omissions, unauthorised uses, and intrusions when they are detected. Corrective controls do not prevent or detect the event; they reduce its impact and restore normal operations.	Data backups stored offsite; error correction routines; automated failover to backup systems; incident response procedures; patch management processes; system recovery from clean backups.
Compensating	Offset a deficiency or weakness in the control structure, typically because the baseline control cannot meet a stated requirement due to legitimate technical or business constraints. A compensating control must achieve the same result as the control it replaces.	Placing unsecured systems on isolated network segments with strong perimeter security; adding third-party challenge-response mechanisms to devices that do not support individual login accounts; enhanced monitoring of access to systems where separation of duties cannot be fully implemented.

4.4 General control methods

General control methods apply across all areas of an organisation and must be balanced to meet the organisation's specific needs. An enterprise that implements a technical control – such as a firewall – without corresponding managerial controls such as staff training, configuration procedures, and monitoring schedules may develop a false sense of security, resulting in unidentified vulnerabilities and greater risk than intended.

Control method	Description	Examples
Managerial (Administrative)	Controls related to the oversight, reporting, procedures, and operations of a process. Often encompass operational and administrative controls governing day-to-day functions and activities.	Policies and procedures; accounting controls (e.g., balancing and reconciliation); employee training and development programmes; compliance reporting and management review processes.
Technical (Logical)	Controls provided through the use of technology, equipment, or devices. Technical controls require proper managerial controls to operate correctly – technology alone does not create security.	Firewall rulesets; network-based and host-based intrusion detection systems; passwords and multi-factor authentication; antimalware solutions; encryption and key management systems.
Physical	Controls installed to physically restrict access to a facility or hardware. Physical controls require maintenance, monitoring, and the ability to address and react to alerts.	Physical access badges and electronic locks; closed-circuit television (CCTV) surveillance; biometric access controls; security guards; environmental controls (fire suppression, UPS, temperature control).

4.5 Prescriptive controls and frameworks

In some instances, authoritative sources provide a prescriptive set of controls or control objectives for organisations to implement and assess. These prescriptive control frameworks provide a standard set of controls that an organisation should implement to mitigate applicable risk, either to the organisation as a whole or to a specific business process. Key frameworks include:

- Center for Internet Security (CIS) 18 Critical Security Controls – a prescriptive, prioritised, and simplified set of best practices for strengthening cybersecurity posture.
- OWASP Software Assurance Maturity Model (SAMM) – an open framework to help organisations formulate and implement strategies for software security tailored to their specific risk profile.
- Service Organization Controls (SOC) Reports – a framework developed by the AICPA for organisations processing data related to services they provide.
- Payment Card Industry Data Security Standard (PCI DSS) – mandatory requirements for organisations that store, process, transmit, or affect the security of credit card data.

Cloud Security Alliance (CSA) Cloud Controls Matrix (CCM) – a cybersecurity control framework for cloud computing providing security principles across different cloud models.

5. Audit project management

The IS audit process requires the auditor to gather evidence, evaluate the strengths and weaknesses of controls based on that evidence, and prepare an audit report presenting findings and recommendations to management in an objective manner. Audit management must ensure the availability of adequate resources and a schedule for performing audit procedures and, for internal IS audits, for conducting follow-up reviews on the status of corrective actions.

5.1 The three phases of IS audit

Phase	Key activities	Outputs
Planning Phase	Determine audit subject and area. Define audit objectives. Set audit scope. Perform pre-audit planning (risk assessment, resource identification, communication plan, regulatory compliance review). Determine audit procedures and steps for data gathering, including identification of individuals to interview, test scripts, and evaluation criteria.	Approved audit plan; defined scope and objectives; risk assessment results; resource assignments; audit programme; communication schedule.
Fieldwork and Documentation Phase	Acquire data through an advance request list and secure collection process. Test controls using interviews, observations, inspections, and CAATs. Discover and validate issues – identify deviations from expected outcomes (policy requirements, control objectives). Document results within the audit programme and work papers per applicable documentation standards.	Completed work papers; documented test results and evidence; identified issues and observations; validated findings.
Reporting and Follow-Up Phase	Gather reporting requirements from internal audit standards and external reporting obligations. Draft report for review by IS audit leadership, then by auditee management for response. Issue the final report per retention requirements and present to the oversight function (e.g., audit committee). Establish a follow-up process to monitor management's remediation of identified issues.	Draft and final audit report; management responses and action plans; follow-up schedule; record of management remediation actions.

5.2 Audit objectives and audit programmes

Audit objectives refer to the specific goals that must be accomplished by the audit. In contrast, a control objective refers to how an internal control should function. A key element in planning an IS audit is to translate broad audit objectives into specific IS control objectives. For example, in a financial audit, a control objective might be to ensure transactions are properly posted to the general ledger; in an IS audit, this extends to verifying that editing features are in place to detect coding errors that could affect account-posting activities.

An audit programme is a step-by-step set of audit procedures and instructions that should be performed to complete the audit. It serves as the formal documentation of audit procedures and sequential steps, creates repeatable procedures for internal or external auditors, documents the type of testing to be used, and meets generally accepted audit standards relating to the planning phase.

5.3 Audit work papers

All audit plans, programmes, activities, tests, findings, and incidents must be documented in work papers. Work papers are the bridge between audit objectives and the final audit report, providing seamless traceability from objectives to report and from report to objectives. They provide support for the representations in the auditor's report, demonstrate that the engagement complied with applicable standards, and support the basis for the auditor's conclusions. IS auditors should apply the same security-related considerations to their work papers that they apply to the systems they audit, as audit reports and work papers can contain sensitive information that could be exploited by malicious actors.

5.4 Agile auditing

Agile auditing applies software development concepts – specifically the Agile methodology – to IS audit engagements with the goal of providing faster, more efficient, and more collaborative audits. Traditional IS audits enforce strict temporal separation between planning and fieldwork phases; Agile auditing blurs or removes this separation, allowing tasks to run in parallel. Key benefits of Agile auditing include:

- Reduced end-to-end planning: condensed sprint cycles compress planning from months to weeks or days.
- Streamlined engagements: combining planning, fieldwork, and reporting phases into a single cohesive process eliminates long lead times between phases.
- Direct customer collaboration: involving auditees in daily standup meetings from the start of the engagement facilitates input and increases buy-in for audit outcomes.
- Flexible audit scope: real-time adjustment of scope as new information is discovered, subject to audit management approval.
- Real-time assurance: findings and control weaknesses are communicated to auditees as they are discovered, rather than only at the end of the engagement.

Frequent audit plan updates: Agile audit plans are reviewed quarterly or more frequently rather than annually.

6. Audit testing and sampling methodology

6.1 Compliance testing versus substantive testing

The choice between compliance testing and substantive testing – or a combination of both – is one of the most important judgments an IS auditor makes during the planning phase. The two types of testing serve fundamentally different purposes:

Test type	Purpose	What it answers	Relationship to the other
Compliance testing (tests of controls)	Gather evidence to determine whether controls are operating effectively and in accordance with management's policies and procedures. Tests whether a control WORKS as designed.	Are the controls in place and functioning? Do they consistently prevent or detect the types of errors or irregularities they are designed to address?	If compliance testing reveals strong controls, the IS auditor can justify reducing the extent of substantive testing. Weak controls revealed by compliance testing require more extensive substantive testing.
Substantive testing (tests of details)	Gather evidence to evaluate the integrity of individual transactions, data, or other information. Tests whether the DATA is accurate, complete, and valid.	Is the information in financial statements or system outputs accurate, complete, and reliable? Are balances correctly stated?	If compliance test results are reliable, substantive procedures may be minimised. If control weaknesses raise doubts about completeness or accuracy, substantive testing directly addresses those doubts.

6.2 Audit sampling

Sampling is performed when time and cost considerations prevent total verification of all transactions or events in a predefined population. The population is the entire group of items to be examined; the sample is the subset selected for testing. The two general approaches to audit sampling are:

Sampling approach	Method	Applications
Statistical sampling	Uses mathematical laws of probability to calculate sample size, select sample items, and evaluate sample results. Allows the IS auditor to quantify the probability of error (confidence coefficient) and express results in mathematically rigorous terms. To be a valid statistical sample, each item in the population must have an equal opportunity or known probability of being selected.	Use when drawing conclusions about an entire population with mathematically quantifiable confidence. Required when sampling risk must be expressed numerically. Attribute sampling for compliance testing; variable sampling for substantive testing.
Non-statistical (judgmental) sampling	Uses the IS auditor's professional judgment to determine the method of sampling, sample size, and selection of items. Selection is based on subjective judgment about which items or transactions are most material or most risky.	Use when the auditor has strong knowledge of the population and can apply informed judgment. Faster and less resource-intensive but does not permit mathematical expression of sampling risk.

Within statistical sampling, two primary methods are applied: attribute sampling (generally used in compliance testing, which deals with the presence or absence of a specific characteristic and provides conclusions expressed as rates of incidence), and variable sampling (generally used in substantive testing, which estimates monetary values or other quantitative measures of a population). Key statistical sampling terminology that candidates must understand includes:

Term	Definition
Confidence coefficient	A percentage expression (e.g., 90%, 95%, 99%) of the probability that the characteristics of the sample are a true representation of the population. A 95% confidence coefficient is generally considered a high degree of assurance. The greater the confidence coefficient required, the larger the sample size must be.
Level of risk	Equal to 1 minus the confidence coefficient. For example, a 95% confidence coefficient corresponds to a 5% level of risk. Represents the probability that the sample does not accurately represent the population.
Precision	The acceptable range difference between the sample result and the actual population value. For attribute sampling, precision is expressed as a percentage; for variable sampling, as a monetary amount. Higher precision (tighter tolerance) requires a larger sample size.
Expected error rate	An estimate, expressed as a percentage, of the errors that may exist in the population. The greater the expected error rate, the larger the sample size required. Applied to attribute sampling formulas.
Tolerable error rate	The maximum misstatement or number of errors that can exist without an account being considered materially misstated. Sets the upper limit of the precision range for compliance testing.
Sample mean	The sum of all sample values divided by the sample size. Measures the average value of the sample and is used in variable sampling to project an estimated total for the population.
Sample standard deviation	A measure of the variance of sample values from the sample mean, representing the spread or dispersion of sample values. Applied in variable sampling formulas; greater standard deviation requires a larger sample size.

7. Audit evidence collection techniques

Evidence encompasses any information used by the IS auditor to determine whether the entity or data being audited follows the established criteria or objectives. The rules of evidence and sufficiency, and the competency of evidence, must be considered as required by audit standards. The quality (appropriateness) and quantity (sufficiency) of evidence must both be assessed: evidence is competent when it is both reliable and relevant. Audit judgment is used to determine when sufficiency is achieved.

7.1 Reliability determinants for audit evidence

Determinant	Explanation	Practical implication
Independence of the provider	Evidence obtained from a source outside the organisation is more reliable than evidence obtained from within. External sources have no direct interest in the outcome of the audit and are therefore less susceptible to management bias or manipulation.	Confirmation letters and third-party reports are more reliable than internally produced documents. Signed contracts with external parties, if original documents are made available, can be considered reliable.
Qualifications of the individual providing evidence	Regardless of whether providers are inside or outside the organisation, the IS auditor must consider the qualifications and functional responsibilities of the person providing the information. An auditor who does not fully understand the technical area under review may not reliably interpret the evidence gathered.	Evidence from a qualified system administrator on system configurations is more reliable than evidence from a general user. IS auditors must ensure they have the technical competence to properly evaluate the evidence.
Objectivity of the evidence	Objective evidence – that which can be verified without requiring significant judgment or interpretation – is more reliable than evidence that is inherently subjective. Direct physical observation produces objective evidence; management explanations of efficiency may be subjective.	A physical review of media inventory is direct, objective evidence. An auditor's analysis of application efficiency based purely on discussions with personnel is not objective evidence and must be supplemented with corroborating objective evidence.
Timing of the evidence	The IS auditor must consider when information exists or is available, as the time during which evidence is accessible may affect the nature, timing, and extent of testing procedures.	Audit evidence processed by dynamic systems such as spreadsheets may not be retrievable after a specified period if file changes are not controlled or if files are not backed up. Timing affects the auditor's ability to validate the completeness and currency of the evidence.

7.2 Evidence-gathering techniques

Technique	Description	Strengths and limitations
Reviewing IS organisation structures	An IS auditor reviews the organisational structure to assess whether adequate separation of duties is maintained. Where cooperative distributed processing or end-user computing is prominent, IT functions may be organised differently from the classic IS organisation.	Provides evidence of the overall control framework. Limitation: does not demonstrate that controls operate as intended in practice.
Reviewing IS policies and procedures	The IS auditor reviews whether appropriate policies and procedures are in place, whether personnel understand them, and whether they are being followed. Management must take full responsibility for formulating, documenting, and maintaining policies.	Essential for understanding the documented control environment. Limitation: policies may exist on paper but not be followed in practice; must be combined with other techniques.
Reviewing IS documentation	Reviewing technical and operational documentation including system development initiating documents, SLAs, functional requirements, test plans, program and operations documents, change logs, user manuals, security plans, risk assessments, BCPs, and QA reports.	Provides a comprehensive understanding of the systems under audit. Limitation: documentation may be incomplete, outdated, or not representative of actual system operation.
Interviewing personnel	Structured interviews, organised in advance with clearly communicated objectives and following a fixed outline, documented through interview notes. Interviews should be non-accusatory and designed to help interviewees share information, ideas, concerns, and knowledge.	Effective for gathering qualitative information and understanding processes. Limitation: responses may be biased, incomplete, or inaccurate; should always be verified through other evidence.
Observing processes and employee performance	The IS auditor observes actual functions performed, processes followed, security awareness demonstrated, and reporting relationships in practice. Observations should be unobtrusive and documented in sufficient detail to present as audit evidence if required.	Provides direct evidence of how controls operate in practice. Limitation: the observer effect – employees may change their behaviour when they know they are being observed (Hawthorne effect)..

Reperformance	The IS auditor actually performs the control under assessment in real time, rather than simply reviewing documentation or observing others perform it. This technique generally provides better evidence than inquiry, observation, or inspection alone.	Provides the strongest form of direct evidence of control operation. Used when a combination of inquiry, observation, and examination does not provide sufficient assurance. More resource-intensive.
Walk-throughs	The IS auditor traces a transaction or process from initiation to completion, confirming understanding of controls and identifying evidence needed to validate control effectiveness. Ensures that both the auditor and the control owner clearly understand the controls being assessed.	Effective for confirming process understanding and identifying key control points. Limitation: tests only the process as described during the walk-through; may not reflect all scenarios or exceptions.

8. Audit data analytics

Data analytics is a critical tool for IS auditors, enabling them to select and analyse full data sets to continuously audit or monitor key organisational data for abnormalities or variances that can identify and evaluate organisational risk and achieve compliance with control and regulatory requirements. Data analytics can be applied in both the planning phase (risk assessment) and the fieldwork phase (control testing, fraud detection, exception identification). The data analytics process involves: setting the scope and defining data needs; identifying and obtaining the data; validating the data for sufficiency and reliability; executing tests; documenting and reviewing results; and retaining important test elements.

8.1 Computer-assisted audit techniques (CAATs)

CAATs are important tools that IS auditors use to gather and analyse data during an IS audit or review. When systems have different hardware and software environments, data structures, record formats, or processing functions, it is almost impossible for an IS auditor to collect certain evidence without using software tools. CAATs enable IS auditors to gather information independently, gain access to and analyse data for a predetermined audit objective, and report findings with emphasis on the reliability of the records produced and maintained in the system.

CAAT type	Description	Key functions and applications
Generalised Audit Software (GAS)	Standard software that can directly read and access data from various database platforms, flat-file systems, and ASCII formats. Provides IS auditors with an independent means of accessing and analysing data.	File access (reading different record formats); file reorganisation (indexing, sorting, merging, linking); data selection (filtration and selection criteria); statistical functions (sampling, stratification, frequency analysis); arithmetic functions. Examples: ACL Analytics, IDEA.
Utility Software	A subset of software – including report generators of database management systems – that provides evidence about system control effectiveness.	Used for tests of details of transactions and balances; analytical review procedures; compliance tests of IS general controls and application controls; network and OS vulnerability assessments; penetration testing; and application security testing and source code security scans.
Test Data	IS auditors use a sample set of data to assess whether logic errors exist in a program and whether the program meets its objectives.	Used to test the processing logic of application systems in a controlled manner. Can be used in combination with integrated test facility (ITF) techniques.
Application Software Tracing and Mapping	Tools that trace the execution path of application programs, allowing the auditor to analyse logic, identify processing weaknesses, and map the flow of data through a system.	Useful for reviewing complex application logic and validating that the program performs as documented.
Expert Systems	Query-based systems built on the knowledge base of senior auditors or managers, providing direction and guidance to all levels of auditors during the audit process.	Encodes specialist audit knowledge to support less experienced auditors in making consistent audit judgments across complex audit areas.

When using CAATs on production data, the IS auditor must always request read-only access. Any data manipulation by the IS auditor must be applied to copies of production files in a controlled environment to ensure that production data is not exposed to unauthorised updating. Most CAATs allow production data to be downloaded to a standalone platform and analysed there, thereby insulating production systems from any adverse impact.

8.2 Continuous auditing techniques

Continuous auditing techniques are particularly important in time-sharing environments that process large numbers of transactions but leave a limited paper trail. By permitting IS auditors to evaluate operating controls on a continuous basis without disrupting normal operations, these techniques improve the security of a system and reduce the time lag between the misuse of a system and the detection of that misuse. There are five types of automated evaluation techniques applicable to continuous auditing:

Technique	Description	Complexity	Ideal when
SCARF/EAM (Systems Control Audit Review File and Embedded Audit Modules)	Embeds specially written audit software in the organisation's host application system so that application systems are monitored on a selective basis. The audit software captures data meeting defined criteria for subsequent auditor review.	Very high	Regular processing cannot be interrupted; the auditor needs to monitor transactions continuously without affecting normal operations.
Snapshots	Involves taking 'pictures' of the processing path that a transaction follows, from input to output. Transactions are tagged by applying identifiers to input data, and selected information about what occurs is recorded for IS auditor review.	Medium	An audit trail of the full processing path of specific transactions is required; useful where the auditor needs to understand the transformation of data through the system.
Audit Hooks	Involves embedding hooks – such as logging and monitoring triggers – in application systems to function as red flags and alert IS auditors and security staff to act before an error or irregularity becomes unmanageable.	Low	Only select transactions or processes need to be examined; useful where the auditor can define specific exception conditions that should trigger an alert.
Integrated Test Facility (ITF)	Dummy entities are set up and included in the auditee's production files. The IS auditor makes the system process test transactions alongside live transactions during regular processing runs, updating the dummy entity's records. The auditor then compares output with independently calculated results.	High	It is not beneficial to use test data in a separate test environment; useful where the auditor needs to test the system using realistic transaction volumes and conditions without affecting real data.
Continuous and Intermittent Simulation (CIS)	During a process run, the computer system simulates the instruction execution of the application. As each transaction is entered, the simulator decides whether it meets predetermined criteria; if so, the transaction is audited; if not, the simulator waits for the next qualifying transaction.	Medium	Transactions meeting certain predetermined criteria need to be examined and audited in near-real time without interrupting the normal processing of other transactions.

9. Reporting and communication techniques

9.1 The exit interview and pre-report communication

The exit interview, conducted at the end of the audit fieldwork phase, provides the IS auditor with the opportunity to discuss findings and recommendations with auditee management before a draft report is finalised. During the exit interview, the IS auditor should: ensure that all facts presented in the report are correct and material; ensure that recommendations are realistic and cost-effective, and if not, seek alternatives through negotiation with auditee management; and recommend implementation dates for agreed recommendations.

Before communicating results to senior management, the IS auditor should discuss findings with auditee management to gain agreement on the findings and develop an agreed-upon course of corrective action. In cases of disagreement, the IS auditor should elaborate on the significance of the findings, the risk involved, and the effects of not correcting the control weakness. The IS auditor must remain aware that they are ultimately responsible to senior management and the audit committee, and must not allow lower levels of management to restrict their access to senior management or the audit committee.

9.2 The six objectives of audit reporting

Objective	Explanation
1. Formally present audit results	The audit report formally presents the purpose, scope, findings, and conclusions of the audit to the auditee and, where applicable, to the audit client (who may be different from the auditee).
2. Serve as formal closure of the engagement	The issuance of the final audit report formally concludes the audit engagement and marks the transition to follow-up activities.
3. Provide statements of assurance and recommendations	The report provides a statement of the IS auditor's assurance on the adequacy of controls and, where necessary, identifies areas requiring corrective action with specific, actionable recommendations.
4. Serve as a valued reference	The audit report serves as a reference document for any party researching the auditee or the audit topic, including management, regulators, external auditors, and other stakeholders.
5. Serve as the basis for follow-up	Where findings are presented, the audit report establishes the baseline against which management's remediation of those findings will be assessed in subsequent follow-up activities.
6. Promote audit credibility	A well-developed, well-written, and well-evidenced audit report promotes the credibility and professional standing of the IS audit function within the organisation.

9.3 Audit report structure and contents

An IS audit report should provide unbiased, well-supported responses to the audit's stated objectives. Every audit report should include: an introduction stating the audit objectives, limitations to the audit, scope, period of coverage, an overview of the nature and extent of audit procedures conducted, and a statement regarding the IS audit methodology and guidelines applied; audit findings presented in sections by materiality and/or intended recipient; an overall conclusion and opinion regarding the adequacy of controls and the actual potential risk identified as a consequence of detected deficiencies; reservations or qualifications with respect to the audit; and detailed findings and recommendations.

The materiality of a finding is a critical determinant of what is reported at each level of management. A weakness in physical access controls at a remote site may be significant to local management but immaterial to upper management at headquarters. Conversely, issues relating to separation of duties, access rights, or fraud risk may be material to upper management even if local management considers them minor. An IS auditor should provide a balanced report – addressing not only negative findings but also positive observations regarding effective controls and improved processes.

9.4 Audit documentation

Audit documentation – the written record that supports the representations in the auditor's report – must: demonstrate that the engagement complied with applicable standards; support the basis for the auditor's conclusions; and include, at a minimum, planning and preparation documents, description or walk-throughs of the scoped audit area, the audit programme, audit steps performed and evidence gathered, use of other auditors or experts, findings, conclusions, and recommendations, and documentation identification information and dates. Audit documentation is generally the property of the auditee and should be accessible only to authorised personnel.

9.5 Follow-up activities

Auditing is an ongoing process. An IS auditor is not effective if audits are performed and reports issued without follow-up to determine whether management has taken appropriate corrective actions. IS auditors must have a formal follow-up programme to determine whether agreed-on corrective actions have been implemented. The timing of follow-up depends on the criticality of the findings and is subject to the IS auditor's professional judgment. The results of follow-up must be communicated to appropriate levels of management.

QA component	Responsibility	Key requirements
Audit Committee Oversight	Audit committee (or designated group if no committee exists).	Oversee the IS audit function; interact with the chief audit executive; establish and review continuous performance monitoring through periodic reporting.
Audit Quality Assurance	Audit leadership and assigned project leads.	Ensure documented audit procedures are followed. Establish a formal review process (detail review, engagement quality review, QA) for all audit types based on risk and authoritative guidance.
Audit Team Training and Development	IS audit leadership.	Establish a formal development plan for all IS audit function members including applicable training programmes and certifications by role. Create and maintain a budget for training and development.

Independence Monitoring	IS audit leadership; individual IS auditors.	Establish a process allowing IS auditors to self-report potential independence impairments. Periodically check independence has not been impaired and report changes through the established process.
Continued Professional Education	IS audit leadership and individual IS auditors.	Monitor compliance with continued professional education or training requirements established either by internal development plans or external certifying bodies such as ISACA.
Audit QA Procedures Review	Audit leadership.	Periodically review and summarise the results of audit QA procedures to identify trends and lessons learned. Formally track and remediate actionable items identified during QA.

Professional skills focus – applying judgement as an IS auditor

Scope on risk, not convenience. An auditor can never examine everything. The skill is picking what matters based on inherent risk, materiality, and control reliability – not what is easiest to access. A narrow scope on the right areas beats a broad scope spread thinly.

Plan for what usually goes wrong. Good planning shows at the end of an engagement, not the start. Build contingency for the things that reliably derail fieldwork: delayed access, unavailable personnel, incomplete evidence. Optimism about cooperation produces slipped timelines and walked-back conclusions.

Evidence sufficiency is judgement, not arithmetic. Sufficiency, reliability, and relevance are all context-dependent. A low-risk control may need only a walkthrough; a high-risk one over material data may warrant full-population testing. System logs beat management

representations; independent confirmations beat both. Volume of evidence is not the same as fit to the assertion being tested.

Separate design from operating effectiveness. A control can be well-designed and still fail in practice, or informally run yet consistently effective. Test both – capability and actual operation across the period. Conflating them weakens every finding that follows.

Apply scepticism to strong-sounding controls too. It is easy to challenge thin documentation and accept crisp policies. The harder discipline is treating polished dashboards and management representations as claims to be tested, not evidence in themselves. A confident answer is not a correct one.

Calibrate findings to materiality. Not every observation is a finding, and not every finding is material. Grade by impact and likelihood, separate gaps from failures, and recommend remediation management can realistically deliver. Weighting a missing signature equally with a control failure that could cause material misstatement obscures rather than informs.

Treat follow-up as part of the audit. An audit that identifies issues but never verifies remediation leaves the organisation no better off. Judgement extends to when to re-test, what evidence of remediation is acceptable, and when persistent non-closure is itself a finding worth escalating.

The connecting thread is that standards set the floor, not the ceiling. Judgement is what turns process compliance into an opinion the organisation can actually rely on.

Practice questions and answers with explanations

Question 1

The internal audit department wrote some scripts that are used for continuous auditing of some information systems. The IT department asked for copies of the scripts so that they can use them for setting up a continuous monitoring process on key systems. Does sharing these scripts with IT affect the ability of the IS auditors to independently and objectively audit the IT function?

A. Sharing the scripts is not permitted because it gives IT the ability to pre-audit systems and avoid an accurate, comprehensive audit.

B. Sharing the scripts is required because IT must have the ability to review all programs and software that run on IS systems regardless of audit independence.

C. Sharing the scripts is permissible if IT recognizes that audits may still be conducted in areas not covered in the scripts.

D. Sharing the scripts is not permitted because the IS auditors who wrote the scripts would not be permitted to audit any IS systems where the scripts are being used for monitoring.

C is the correct answer.

Justification:

C. IS audit can still review all aspects of the systems. They may not be able to review the effectiveness of the scripts, but they can still audit the systems.

Question 2

An IS auditor is developing an audit plan for an environment that includes new systems. The organization's management wants the IS auditor to focus on recently implemented systems. How should the IS auditor respond?

A. Audit the new systems as requested by management.

B. Audit systems not included in last year's scope.

C. Determine the highest-risk systems and plan accordingly.

D. Audit both the systems not in last year's scope and the new systems.

C is the correct answer.

Justification:

C. The best action is to conduct a risk assessment and design the audit plan to cover the areas of highest risk. An IS audit and assurance function shall use an appropriate risk assessment approach and supporting methodology to develop the overall IS audit plan and determine priorities for the effective allocation of IS audit resources.

Question 3

Which of the following controls would an IS auditor look for in an environment where duties cannot be appropriately segregated?

A. Overlapping controls

B. Boundary controls

C. Access controls

D. Compensating controls

D is the correct answer.

Justification:

D. Compensating controls are internal controls that are intended to reduce the risk of an existing or potential control weakness that may arise when duties cannot be appropriately segregated.

Question 4

For a retail business with a large volume of transactions, which of the following audit techniques is the MOST appropriate for addressing emerging risk?

A. Use of computer-assisted audit techniques

B. Quarterly risk assessments

C. Sampling of transaction logs

D. Continuous auditing

D is the correct answer.
Justification:

D. The implementation of continuous auditing enables a real-time feed of information to manage ment through automated reporting processes so that management may implement corrective actions more quickly.

Question 5

An IS auditor is reviewing access to an application to determine whether recently added accounts were appropriately authorized. This is an example of:

A. variable sampling.

B. substantive testing.

C. compliance testing.

D. stop-or-go sampling.

C is the correct answer.
Justification:

C. Compliance testing determines whether controls are being applied in compliance with policy. This includes tests to determine whether new accounts were appropriately authorized.

Question 6

The decisions and actions of an IS auditor are MOST likely to affect which of the following types of risk?

A. Inherent

B. Detection

C. Control

D. Business

B is the correct answer.
Justification:

B. Detection risk is directly affected by the IS auditor's selection of audit procedures and techniques. Detection risk is the risk that a review will not detect or notice a material issue.

Question 7

Which of the following is the MOST critical step when planning an IS audit?

A. Review findings from prior audits

B. Executive management's approval of the audit plan

C. Review information security policies and procedures

D. Perform a risk assessment

D is the correct answer.

Justification:

D. Of all the steps listed, performing a risk assessment is the most critical. Risk assessment is required so that IS audit and assurance professionals identify and assess risk relevant to the area under review when planning individual engagements. In addition to the standards requirement, if a risk assessment is not performed, then high-risk areas of the auditee systems or operations may not be identified for evaluation.

Question 8

Which of the following sampling methods is MOST useful when testing for compliance?

A. Attribute sampling

B. Variable sampling

C. Stratified mean-per-unit sampling

D. Difference estimation sampling

A is the correct answer.

Justification:

A. Attribute sampling is the primary sampling method used for compliance testing. Attribute sampling is a sampling model that is used to estimate the rate of occurrence of a specific quality (attribute) in a population and is used in compliance testing to confirm whether the quality exists. For example, an attribute sample may check all transactions over a certain predefined dollar amount for proper approvals.

Question 9

Which of the following situations could impair the independence of an IS auditor? The IS auditor:

A. implemented specific functionality during the development of an application.
B. designed an embedded audit module for auditing an application.
C. participated as a member of an application project team and did not have operational respon sibilities.
D. provided consulting advice concerning application good practices.

A is the correct answer.
Justification:

A. Independence may be impaired if an IS auditor is, or has been, actively involved in the devel opment, acquisition and implementation of the application system.

Question 10

In planning an IS audit, the MOST critical step is the identification of the:

A. areas of significant risk.
B. skill sets of the audit staff.
C. test steps in the audit.
D. time allotted for the audit.

A is the correct answer.
Justification:

A. When designing a risk-based audit plan, it is important to identify the areas of highest risk to determine the areas to be audited.

Question 11

Which of the following would normally be the MOST reliable evidence for an IS auditor?

A. A confirmation letter received from a third party verifying an account balance
B. Assurance from line management that an application is working as designed
C. Trend data obtained from Internet sources
D. Ratio analysis developed by the IS auditor from reports supplied by line management

A is the correct answer.
Justification:

A. Evidence obtained from independent third parties is almost always considered to be more reliable than assurance provided by local management.

Question 12

Which of the following forms of evidence would an IS auditor consider the MOST reliable?

A. An oral statement from the auditee
B. The results of a test that is performed by an external IS auditor
C. An internally generated computer accounting report
D. A confirmation letter that is received from an outside source

B is the correct answer.
Justification:

B. An independent test that is performed by an IS auditor should always be considered a more reliable source of evidence than a confirmation letter from a third party, because the letter is the result of an analysis of the process and may not be based on authoritative audit techniques. An audit should consist of a combination of inspection, observation and inquiry by an IS auditor as determined by risk. This provides a standard methodology and reasonable assurance that the controls and test results are accurate.

Question 13

The internal IS audit team is auditing controls over sales returns and is concerned about fraud. Which of the following sampling methods will BEST assist the IS auditors?

A. Stop-or-go
B. Classical variable
C. Discovery
D. Probability-proportional-to-size

C is the correct answer.
Justification:

C. Discovery sampling is used when an IS auditor is trying to determine whether a type of event has occurred. Therefore, it is suited to assess the risk of fraud and to identify whether a single occurrence has taken place.

Question 14

Which of the following represents the GREATEST potential risk in an electronic data interchange (EDI) environment?

A. Lack of transaction authorizations
B. Loss or duplication of EDI transmissions
C. Transmission delay
D. Deletion or manipulation of transactions prior to, or after, establishment of application controls

A is the correct answer.
Justification:

A. Because the interaction between parties is electronic, there is no inherent authentication occurring; therefore, lack of transaction authorization is the greatest risk.

Question 15

When developing a risk management program, what is the FIRST activity to be performed?

A. Threat assessment
B. Classification of data
C. Inventory of assets
D. Criticality analysis

C is the correct answer.
Justification:

C. Identification of the assets to be protected is the first step in the development of a risk man agement program.

CA BANGLADESH

THE INSTITUTE OF CHARTERED ACCOUNTANTS OF BANGLADESH

CA Bhaban
100 Kazi Nazrul Islam Avenue
Dhaka 1215, Bangladesh

880 2 9115340, 9612612100
9117521, 9137847 (Off.)

880 2 9125266

ceo@icab.org.bd

facebook.com/ca.bangladesh

icab.org.bd